



NERC CIP

Companion Guide for VMware Cloud Foundation 9.1

June 2026

Table of Contents

Disclaimer.....	9
Version.....	10
Introduction.....	10
Third Party Identifiers and Mappings	10
Coverage Levels	10
Controls.....	11
Control CIP-002-5.1a 1.1	11
Control CIP-002-5.1a 1.2	12
Control CIP-002-5.1a 1.3	13
Control CIP-002-5.1a 2.1	14
Control CIP-002-5.1a 2.2	15
Control CIP-003-8 1.1	16
Control CIP-003-8 1.1.1	18
Control CIP-003-8 1.1.2	19
Control CIP-003-8 1.1.3	24
Control CIP-003-8 1.1.4	25
Control CIP-003-8 1.1.5	26
Control CIP-003-8 1.1.6	29
Control CIP-003-8 1.1.7	33
Control CIP-003-8 1.1.8	37
Control CIP-003-8 1.1.9	43
Control CIP-003-8 1.2.1	44
Control CIP-003-8 1.2.2	45
Control CIP-003-8 1.2.3	46
Control CIP-003-8 1.2.4	50
Control CIP-003-8 1.2.5	53
Control CIP-003-8 1.2.6	54
Control CIP-003-8 R1	55
Control CIP-003-8 R2	56
Control CIP-003-8 R3	58
Control CIP-003-8 R4	59
Control CIP-004-7 1.1	60
Control CIP-004-7 2.1.1	61

Control CIP-004-7 2.1.2	62
Control CIP-004-7 2.1.3	63
Control CIP-004-7 2.1.4	64
Control CIP-004-7 2.1.5	65
Control CIP-004-7 2.1.6	66
Control CIP-004-7 2.1.7	67
Control CIP-004-7 2.1.8	68
Control CIP-004-7 2.1.9	69
Control CIP-004-7 2.2	70
Control CIP-004-7 2.3	71
Control CIP-004-7 3.1	72
Control CIP-004-7 3.2	73
Control CIP-004-7 3.2.1	74
Control CIP-004-7 3.2.2	75
Control CIP-004-7 3.3	76
Control CIP-004-7 3.4	77
Control CIP-004-7 3.5	78
Control CIP-004-7 4.1	79
Control CIP-004-7 4.1.1	85
Control CIP-004-7 4.1.2	89
Control CIP-004-7 4.2	90
Control CIP-004-7 4.3	91
Control CIP-004-7 5.1	95
Control CIP-004-7 5.2	100
Control CIP-004-7 5.3	105
Control CIP-004-7 5.4	110
Control CIP-004-7 6.1	111
Control CIP-004-7 6.1.1	113
Control CIP-004-7 6.1.2	117
Control CIP-004-7 6.2	118
Control CIP-004-7 6.2.1	122
Control CIP-004-7 6.2.2	126
Control CIP-004-7 6.3	130
Control CIP-004-7 R2	134

Control CIP-004-7 R3	135
Control CIP-004-7 R4	136
Control CIP-004-7 R5	141
Control CIP-004-7 R6	146
Control CIP-005-7 1.1	151
Control CIP-005-7 1.2	155
Control CIP-005-7 1.3	159
Control CIP-005-7 1.4	162
Control CIP-005-7 1.5	166
Control CIP-005-7 2.1	171
Control CIP-005-7 2.2	174
Control CIP-005-7 2.3	177
Control CIP-005-7 2.4	180
Control CIP-005-7 2.5	183
Control CIP-005-7 3.1	186
Control CIP-005-7 3.2	189
Control CIP-006-6 1.1	192
Control CIP-006-6 1.2	193
Control CIP-006-6 1.3	194
Control CIP-006-6 1.4	195
Control CIP-006-6 1.5	196
Control CIP-006-6 1.6	197
Control CIP-006-6 1.7	198
Control CIP-006-6 1.8	199
Control CIP-006-6 1.9	200
Control CIP-006-6 1.10	204
Control CIP-006-6 2.1	211
Control CIP-006-6 2.2	212
Control CIP-006-6 2.3	213
Control CIP-006-6 3.1	217
Control CIP-006-6 R1	221
Control CIP-006-6 R2	222
Control CIP-006-6 R3	223
Control CIP-007-6 1.1	227

Control CIP-007-6 1.2	231
Control CIP-007-6 1.3	232
Control CIP-007-6 2.1	236
Control CIP-007-6 2.2	240
Control CIP-007-6 2.3	244
Control CIP-007-6 2.4	248
Control CIP-007-6 3.1	252
Control CIP-007-6 3.2	256
Control CIP-007-6 3.3	260
Control CIP-007-6 4.1	264
Control CIP-007-6 4.1.1	270
Control CIP-007-6 4.1.2	276
Control CIP-007-6 4.1.3	282
Control CIP-007-6 4.2	288
Control CIP-007-6 4.2.1	293
Control CIP-007-6 4.2.2	297
Control CIP-007-6 4.3	300
Control CIP-007-6 4.4	304
Control CIP-007-6 5.1	307
Control CIP-007-6 5.2	312
Control CIP-007-6 5.3	316
Control CIP-007-6 5.4	317
Control CIP-007-6 5.5.1	321
Control CIP-007-6 5.5.2	324
Control CIP-007-6 5.6	328
Control CIP-007-6 5.7	333
Control CIP-008-6 1.1	335
Control CIP-008-6 1.2.1	339
Control CIP-008-6 1.2.2	343
Control CIP-008-6 1.3	346
Control CIP-008-6 1.4	347
Control CIP-008-6 2.1	351
Control CIP-008-6 2.2	352
Control CIP-008-6 2.3	353

Control CIP-008-6 3.1	357
Control CIP-008-6 3.1.1	358
Control CIP-008-6 3.1.2	359
Control CIP-008-6 3.1.3	360
Control CIP-008-6 3.2	361
Control CIP-008-6 3.2.1	364
Control CIP-008-6 3.2.2	365
Control CIP-008-6 4.1	366
Control CIP-008-6 4.1.1	367
Control CIP-008-6 4.1.2	368
Control CIP-008-6 4.1.3	369
Control CIP-008-6 4.2	370
Control CIP-008-6 4.3	371
Control CIP-008-6 R1	372
Control CIP-008-6 R2	373
Control CIP-008-6 R3	374
Control CIP-008-6 R4	375
Control CIP-009-6 1.1	376
Control CIP-009-6 1.2	379
Control CIP-009-6 1.3	380
Control CIP-009-6 1.4	386
Control CIP-009-6 1.5	392
Control CIP-009-6 2.1	395
Control CIP-009-6 2.2	397
Control CIP-009-6 2.3	402
Control CIP-009-6 3.1	404
Control CIP-009-6 3.1.1	406
Control CIP-009-6 3.1.2	407
Control CIP-009-6 3.1.3	408
Control CIP-009-6 3.2	409
Control CIP-009-6 3.2.1	412
Control CIP-009-6 3.2.2	413
Control CIP-009-6 R1	414
Control CIP-009-6 R2	418

Control CIP-009-6 R3	422
Control CIP-010-3 R1	426
Control CIP-010-4 1.1	432
Control CIP-010-4 1.1.1	438
Control CIP-010-4 1.1.2	444
Control CIP-010-4 1.1.3	450
Control CIP-010-4 1.1.4	456
Control CIP-010-4 1.1.5	462
Control CIP-010-4 1.2	468
Control CIP-010-4 1.3	472
Control CIP-010-4 1.4	476
Control CIP-010-4 1.4.1	480
Control CIP-010-4 1.4.2	485
Control CIP-010-4 1.4.3	490
Control CIP-010-4 1.5	494
Control CIP-010-4 1.5.1	498
Control CIP-010-4 1.5.2	503
Control CIP-010-4 1.6	508
Control CIP-010-4 1.6.1	512
Control CIP-010-4 1.6.2	517
Control CIP-010-4 2.1	522
Control CIP-010-4 3.1	528
Control CIP-010-4 3.2.1	531
Control CIP-010-4 3.2.2	534
Control CIP-010-4 3.3	537
Control CIP-010-4 3.4	540
Control CIP-011-3 1.1	543
Control CIP-011-3 1.2	547
Control CIP-011-3 2.1	551
Control CIP-011-3 2.2	553
Control CIP-011-3 R1	554
Control CIP-013-2 1.1	556
Control CIP-013-2 1.2.1	557
Control CIP-013-2 1.2.2	558

Control CIP-013-2 1.2.3	559
Control CIP-013-2 1.2.4	564
Control CIP-013-2 1.2.5	565
Control CIP-013-2 1.2.6	566
Control CIP-013-2 R1	567
Control CIP-013-2 R2	568
Control CIP-013-2 R3	569

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260612-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward compliance with NERC Critical Infrastructure Protection (CIP) standards. NERC CIP establishes mandatory cybersecurity requirements for the bulk electric system in North America, covering asset identification, security management, electronic and physical security perimeters, incident reporting, and recovery planning. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for identifying, categorizing, and protecting BES Cyber Assets remains with the responsible entity.

<https://www.nerc.com/standards/reliability-standards/cip>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control CIP-002-5.1a 1.1

> Each Responsible Entity shall implement a process that considers each of the following assets for purposes of parts 1.1 through 1.3: [Violation Risk Factor: High][Time Horizon: Operations Planning] i. Control Centers and backup Control Centers; ii. Transmission stations and substations; iii. Generation resources; iv. Systems and facilities critical to system restoration, including Blackstart Resources and Cranking Paths and initial switching requirements; v. Special Protection Systems that support the reliable operation of the Bulk Electric System; and vi. For Distribution Providers, Protection Systems specified in Applicability section 4.2.1 above. 1.1. Identify each of the high impact BES Cyber Systems according to Attachment 1, Section 1, if any, at each asset;

SCF Controls: RSK-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-002-5.1a 1.2

> Each Responsible Entity shall implement a process that considers each of the following assets for purposes of parts 1.1 through 1.3: [Violation Risk Factor: High][Time Horizon: Operations Planning] i. Control Centers and backup Control Centers; ii. Transmission stations and substations; iii. Generation resources; iv. Systems and facilities critical to system restoration, including Blackstart Resources and Cranking Paths and initial switching requirements; v. Special Protection Systems that support the reliable operation of the Bulk Electric System; and vi. For Distribution Providers, Protection Systems specified in Applicability section 4.2.1 above. 1.2. Identify each of the medium impact BES Cyber Systems according to Attachment 1, Section 2, if any, at each asset; and

SCF Controls: RSK-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-002-5.1a 1.3

> Each Responsible Entity shall implement a process that considers each of the following assets for purposes of parts 1.1 through 1.3: [Violation Risk Factor: High][Time Horizon: Operations Planning] i. Control Centers and backup Control Centers; ii. Transmission stations and substations; iii. Generation resources; iv. Systems and facilities critical to system restoration, including Blackstart Resources and Cranking Paths and initial switching requirements; v. Special Protection Systems that support the reliable operation of the Bulk Electric System; and vi. For Distribution Providers, Protection Systems specified in Applicability section 4.2.1 above. 1.3. Identify each asset that contains a low impact BES Cyber System according to Attachment 1, Section 3, if any (a discrete list of low impact BES Cyber Systems is not required).

SCF Controls: RSK-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-002-5.1a 2.1

> The Responsible Entity shall: [Violation Risk Factor: Lower] [Time Horizon: Operations Planning] 2.2 Have its CIP Senior Manager or delegate approve the identifications required by Requirement R1 at least once every 15 calendar months, even if it has no identified items in Requirement R1.

SCF Controls: GOV-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-002-5.1a 2.2

> The Responsible Entity shall: [Violation Risk Factor: Lower] [Time Horizon: Operations Planning] 2.2 Have its CIP Senior Manager or delegate approve the identifications required by Requirement R1 at least once every 15 calendar months, even if it has no identified items in Requirement R1.

SCF Controls: GOV-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.1

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.1. Personnel and training (CIP-004); 1.1.2. Electronic Security Perimeters (CIP-005) including Interactive Remote Access; 1.1.3. Physical security of BES Cyber Systems (CIP-006); 1.1.4. System security management (CIP-007); 1.1.5. Incident reporting and response planning (CIP-008); 1.1.6. Recovery plans for BES Cyber Systems (CIP-009); 1.1.7. Configuration change management and vulnerability assessments (CIP010); 1.1.8. Information protection (CIP-011); and 1.1.9. Declaring and responding to CIP Exceptional Circumstances.

SCF Controls: AST-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.1.1

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.1. Personnel and training (CIP-004);

SCF Controls: HRS-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.1.2

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.1. Personnel and training (CIP-004); 1.1.2. Electronic Security Perimeters (CIP-005) including Interactive Remote Access; 1.1.3. Physical security of BES Cyber Systems (CIP-006); 1.1.4. System security management (CIP-007); 1.1.5. Incident reporting and response planning (CIP-008); 1.1.6. Recovery plans for BES Cyber Systems (CIP-009); 1.1.7. Configuration change management and vulnerability assessments (CIP010); 1.1.8. Information protection (CIP-011); and 1.1.9. Declaring and responding to CIP Exceptional Circumstances.

SCF Controls: IAC-01, NET-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System

Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with

downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also

supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-003-8 1.1.3

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.2. Electronic Security Perimeters (CIP-005) including Interactive Remote Access;

SCF Controls: PES-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.1.4

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.4. System security management (CIP-007);

SCF Controls: GOV-01, SEA-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.1.5

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.5. Incident reporting and response planning (CIP-008);

SCF Controls: IRO-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VMware Live Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.1.6

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.6. Recovery plans for BES Cyber Systems (CIP-009);

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted

vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-003-8 1.1.7

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.7. Configuration change management and vulnerability assessments (CIP010);

SCF Controls: CFG-01, CHG-01, VPM-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's change management program, though the program itself must be established and governed through organizational policy and process.

VCF Operations is the central lifecycle management engine for the platform. It coordinates updates across the full stack and requires a precheck before applying any update to verify that the environment is ready. Lifecycle management tools within VCF Operations support planning updates so that administrators can schedule maintenance windows and make changes with minimal disruption to services. When updates are available, VCF Operations Fleet Management displays them through its Lifecycle view, where administrators can select a VCF instance and review pending VCF Operations updates.

vSphere Lifecycle Manager (vLCM) provides centralized lifecycle management for ESX hosts, drivers, firmware, and add-on software. vLCM uses desired-state configuration with a single image per cluster to maintain consistency across infrastructure components. Upon remediation, the image is installed on all hosts in the cluster, replacing the older baseline and baseline group approach from Update Manager. vLCM synchronizes to its download sources, including VCF Operations, on a regular and automatic basis. The Update Manager module provides PowerCLI cmdlets for downloading patches, creating and modifying baselines, and scanning and remediating hosts and virtual machines. Together, these components provide a structured, repeatable process for applying changes to the infrastructure.

VCF Operations extends change management support through configuration drift detection and source control integration. The Configuration Drifts feature tracks changes in product configurations over time and compares them against assigned desired values, providing scheduled drift detection for VMware vCenter and cluster objects to proactively detect configuration deviations from the desired state. Configuration Drifts Templates can be integrated with a source control repository (GitHub or GitLab), which enables versioning, auditing, and management of configuration templates. This integration supports change control with reviews and can be incorporated into continuous integration and continuous deployment pipelines for automated testing and validation of configuration changes. VCF Operations orchestrator also supports pushing local change sets to a Git repository, where each change set can consist of one or more modified orchestrator objects, providing a traceable record of automation changes. VCF Operations audit logging tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed it, allowing data center administrators to determine who changed what and when.

VCF Automation includes workflow capabilities with approval policies that require project administrators to review changes to deployed catalog instances before they take effect. This allows organizations to integrate change approval into their operational workflows. For organizations that use ServiceNow for IT service management, the ServiceNow ITSM Plug-in for VCF Automation integrates deployment lifecycle actions (such as power operations, lease changes, ownership transfers, and deployment edits) with ServiceNow change workflows. This allows VCF operational changes to be routed through an organization's existing ITSM change approval processes. Policy management capabilities within VCF Automation allow Organization Administrators to create, update, and manage policy definitions, providing a governance layer for controlling what changes are permitted within the platform.

NSX Global Manager provides change validation by checking proposed configuration changes against both Global Manager and Local Manager configurations before they are applied, reducing the risk of conflicting or disruptive network changes in federated environments.

Role-based access control across VCF components restricts who can make configuration changes. Audit logging across the platform captures change activity for review, including vDefend firewall audit logs that capture both old and new values for modified security policies and VCF Operations audit events that record interactions such as configuration modifications, logins, and capability checks.

VMware vDefend (Contributes)

VMware vDefend provides configuration management mechanisms for its network security policy infrastructure, contributing to an organization's broader configuration management program.

The vDefend distributed firewall (DFW) supports a draft configuration management workflow that separates policy authoring from activation. Administrators prepare and review firewall policy changes in draft form before publishing them to the enforcement plane. Draft configurations can be saved as a new configuration or as an update to an existing one, and can be locked with an optional comment requirement to enforce change control discipline. Auto drafts and manual drafts can be cloned and saved, with the option to edit the name and lock the configuration with a required comment. Export options include the published configuration, an auto-saved draft, or a manually saved draft. The Publish function commits a draft and makes it active; the Revert function returns the environment to the previous published configuration. Auto-drafts and saved manual drafts can be loaded and published at any time, giving administrators the ability to restore a prior policy state after a change.

In federated deployments, a Global Manager provides centralized configuration management across distributed Local Manager sites. IDS/IPS signatures, profiles, Distributed Firewall and Gateway Firewall policies, oversubscription settings, and syslog settings can all be managed centrally from the Global Manager and applied across all Local Managers. This enables consistent security policy baselines across geographically distributed environments.

The vDefend also supports full rollback capability, which deletes newly added policies and reverts the security configuration to its prior state in reverse order. This applies to broader policy migration and transition scenarios, beyond the draft-level Revert function.

Security Services Platform (SSP) extends configuration management to vDefend's detection and prevention services. The SSP deployment wizard conducts validations before implementing configuration changes to confirm that configurations are correct and compatible. The SSP Configuration Database is the storage layer for system settings and configurations. SSP also extracts all IDS policies, rules, and security profiles to support multiple remediations, clean up stale policies, and suggest policies that do not conflict with each other. IDS/IPS remediation policies can be verified by navigating to Security > IDS/IPS & Malware Prevention > Emergency Threat Rules. Security policies defined within SSP are propagated and enforced across Bare Metal servers as well, extending policy management scope beyond virtual workloads.

Administrators can use flow inactivity data and Security Intelligence recommendations to identify and remove unused or outdated DFW policies and rules, supporting configuration lifecycle hygiene. Security Intelligence's segmentation posture assessment stores data in a Configuration Management Database (CMDB) within the Security Services Platform, maintaining application context and workload attributes. Segmentation planning supports importing workload context from flat files containing IP addresses, subnets, virtual machines, logical segments, and organizational roles, allowing administrators to establish a baseline for policy configuration decisions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role

install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports configuration management by providing structured mechanisms for defining, applying, and monitoring the configuration of database infrastructure components. Administrators interact with DSM through two primary interfaces: the Provider UI for system-wide settings and the vSphere Client for infrastructure configuration. The Settings view in the Provider interface is the central location for managing system-wide settings, including LDAPS integration, SMTP configuration, and directory service settings. The Administrator Dashboard displays at-a-glance metrics covering the number of configured users, their assigned roles, and the types and counts of provisioned database services, giving administrators a current view of deployment state.

Infrastructure configuration in DSM is governed by infrastructure policies. These policies define which VM classes are available for database VMs, which storage policies apply, and which vSphere clusters and namespaces are used during provisioning. Infrastructure policy configuration requires that placements, storage policies, VM classes, and IP ranges be correctly configured for valid policy status. Policies that are actively in use by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added; unused policies can be changed at any time. VM classes are configurable resource profiles that specify vCPU cores and memory allocation, and can be defined to match organizational capacity standards. Infrastructure policies also establish guardrails that restrict the quantity and quality of resources DSM users can consume from vSphere clusters. Configuration tasks performed during initial deployment include configuring IP pools, defining VM classes, assigning user permissions, creating infrastructure policies, and selecting storage policies.

Database-level configuration is managed through the database instance settings. DSM allows configuration of database instances using either custom or default configuration profiles, with configuration properties varying by database type (PostgreSQL, MySQL, MinIO, or SQL Server). DSM automates provisioning, backups, and security patch application for managed database instances. After initial provisioning, database VM resource configuration can be adjusted at runtime. Optional database configuration parameters for PostgreSQL and MySQL databases can be added or removed after database creation. Maintenance windows can be configured to control when software updates and database option changes are applied, providing a mechanism for scheduled, controlled configuration changes.

DSM provides a Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, for configuring automatic software updates of the DSM plug-in within defined maintenance windows. The DSM controller manages component and feature dependencies through status monitoring and automated remediation.

When integrated with VCF Automation, DSM supports data service policies that define and enforce configurations for each tenant or organization. These policies can be enforced across different namespaces and namespace labels to maintain a uniform configuration posture. The Consumption Operator automates database deployments based on predefined infrastructure and backup policies, reducing the scope for manual configuration drift.

DSM provides visibility into configuration activity through the Operations tab, which displays the progress of database configuration changes, resource changes, and disk extension tasks. A support bundle can be created and downloaded to collect diagnostic information for troubleshooting system configuration failures. DSM system configuration is also managed through a `dsmsystemconfig` Custom Resource within the gateway, which can be inspected via SSH access to the appliance VM to review directory service status and configuration details.

DSM's contribution to a configuration management program is at the platform level: it provides technical mechanisms for defining baseline configurations through policies and VM classes, enforcing them during provisioning, and tracking changes through operational visibility. The broader configuration management program, including change control processes, configuration baseline documentation and approval, configuration audits against external standards, and periodic review cycles, must be established and maintained by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: `CONFIG_CREATE`, `CONFIG_UPDATE`, and `CONFIG_DELETE`. `CONFIG_UPDATE` events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Control CIP-003-8 1.1.8

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.8. Information protection (CIP-011); and

SCF Controls: DCH-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful

workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl` snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation

issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control CIP-003-8 1.1.9

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning] 1.1. For its high impact and medium impact BES Cyber Systems, if any: 1.1.1. Personnel and training (CIP-004); 1.1.9. Declaring and responding to CIP Exceptional Circumstances.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.2.1

> For its assets identified in CIP-002 containing low impact BES Cyber Systems, if any: 1.2.1. Cyber security awareness;

SCF Controls: SAT-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.2.2

> For its assets identified in CIP-002 containing low impact BES Cyber Systems, if any: 1.2.2. Physical security controls;

SCF Controls: PES-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.2.3

> For its assets identified in CIP-002 containing low impact BES Cyber Systems, if any: 1.2.3. Electronic access controls;

SCF Controls: IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS

supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within

the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-003-8 1.2.4

> For its assets identified in CIP-002 containing low impact BES Cyber Systems, if any: 1.2.4. Cyber Security Incident response;

SCF Controls: IRO-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VMware Live Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.2.5

> For its assets identified in CIP-002 containing low impact BES Cyber Systems, if any: 1.2.5. Transient Cyber Assets and Removable Media malicious code risk mitigation;

SCF Controls: AST-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 1.2.6

> For its assets identified in CIP-002 containing low impact BES Cyber Systems, if any: 1.2.6. Declaring and responding to CIP Exceptional Circumstances.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 R1

> Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: [Violation Risk Factor: Medium]
[Time Horizon: Operations Planning]

SCF Controls: GOV-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 R2

> Each Responsible Entity with at least one asset identified in CIP-002 containing low impact BES Cyber Systems shall implement one or more documented cyber security plan(s) for its low impact BES Cyber Systems that include the sections in Attachment 1. [Violation Risk Factor: Lower] [Time Horizon: Operations Planning]

SCF Controls: AST-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 R3

> Each Responsible Entity shall identify a CIP Senior Manager by name and document any change within 30 calendar days of the change. [Violation Risk Factor: Medium] [Time Horizon: Operations Planning]

SCF Controls: AST-01.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-003-8 R4

> The Responsible Entity shall implement a documented process to delegate authority, unless no delegations are used. Where allowed by the CIP Standards, the CIP Senior Manager may delegate authority for specific actions to a delegate or delegates. These delegations shall be documented, including the name or title of the delegate, the specific actions delegated, and the date of the delegation; approved by the CIP Senior Manager; and updated within 30 days of any change to the delegation. Delegation changes do not need to be reinstated with a change to the delegator. [Violation Risk Factor: Lower] [Time Horizon: Operations Planning]

SCF Controls: GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 1.1

> Security awareness that, at least once each calendar quarter, reinforces cyber security practices (which may include associated physical security practices) for the Responsible Entity's personnel who have authorized electronic or authorized unescorted physical access to BES Cyber Systems.

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.1.1

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. 2.1.1. Cyber security policies;

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.1.2

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. 2.1.2. Physical access controls;

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.1.3

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. 2.1.3. Electronic access controls;

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.1.4

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. 2.1.1. Cyber security policies; 2.1.2. Physical access controls; 2.1.3. Electronic access controls; 2.1.4. The visitor control program; 2.1.5. Handling of BES Cyber System Information and its storage; 2.1.6. Identification of a Cyber Security Incident and initial notifications in accordance with the entity's incident response plan; 2.1.7. Recovery plans for BES Cyber Systems; 2.1.8. Response to Cyber Security Incidents; and 2.1.9. Cyber security risks associated with a BES Cyber System's electronic interconnectivity and interoperability with other Cyber Assets, including

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.1.5

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. 2.1.5. Handling of BES Cyber System Information and its storage;

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.1.6

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. 2.1.6. Identification of a Cyber Security Incident and initial notifications in accordance with the entity's incident response plan;

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.1.7

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. 2.1.7. Recovery plans for BES Cyber Systems;

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.1.8

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. 2.1.8. Response to Cyber Security Incidents; and

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.1.9

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. 2.1.9. Cyber security risks associated with a BES Cyber System’s electronic interconnectivity and interoperability with other Cyber Assets, including

SCF Controls: SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.2

> Require completion of the training specified in Part 2.1 prior to granting authorized electronic access and authorized unescorted physical access to applicable Cyber Assets, except during CIP Exceptional Circumstances.

SCF Controls: HRS-03.1, SAT-02, SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 2.3

> Require completion of the training specified in Part 2.1 at least once every 15 calendar months.

SCF Controls: SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 3.1

> Each Responsible Entity shall implement one or more documented personnel risk assessment program(s) to attain and retain authorized electronic or authorized unescorted physical access to BES Cyber Systems that collectively include each of the applicable requirement parts in CIP-004-7 Table R3 – Personnel Risk Assessment Program.

SCF Controls: HRS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 3.2

> Process to perform a seven year criminal history records check as part of each personnel risk assessment that includes:

SCF Controls: HRS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 3.2.1

> Process to perform a seven year criminal history records check as part of each personnel risk assessment that includes:
3.2.2. other locations where, during the seven years immediately prior to the date of the criminal history records check, the subject has resided

SCF Controls: HRS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 3.2.2

> Process to perform a seven year criminal history records check as part of each personnel risk assessment that includes:
3.2.2. other locations where, during the seven years immediately prior to the date of the criminal history records check, the subject has resided

SCF Controls: HRS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 3.3

> Criteria or process to evaluate criminal history records checks for authorizing access.

SCF Controls: HRS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 3.4

> Criteria or process for verifying that personnel risk assessments performed for contractors or service vendors are conducted according to Parts 3.1 through 3.3.

SCF Controls: HRS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 3.5

> Process to ensure that individuals with authorized electronic or authorized unescorted physical access have had a personnel risk assessment completed according to Parts 3.1 to 3.4 within the last seven years.

SCF Controls: HRS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 4.1

> Process to authorize based on need, as determined by the Responsible Entity, except for CIP Exceptional Circumstances: 4.1.1. Electronic access; and 4.1.2. Unescorted physical access into a Physical Security Perimeter

SCF Controls: IAC-08

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types,

and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration

rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control CIP-004-7 4.1.1

> Process to authorize based on need, as determined by the Responsible Entity, except for CIP Exceptional Circumstances:
4.1.1. Electronic access; and

SCF Controls: IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory.

Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within

the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 4.1.2

> Process to authorize based on need, as determined by the Responsible Entity, except for CIP Exceptional Circumstances:
4.1.2. Unescorted physical access into a Physical Security Perimeter

SCF Controls: PES-02, PES-06.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 4.2

> Verify at least once each calendar quarter that individuals with active electronic access or unescorted physical access have authorization records.

SCF Controls: PES-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 4.3

> For electronic access, verify at least once every 15 calendar months that all user accounts, user account groups, or user role categories, and their specific, associated privileges are correct and are those that the Responsible Entity determines are necessary.

SCF Controls: IAC-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support periodic review of account privileges, though the organizational process of scheduling and conducting those reviews remains a customer responsibility.

VCF's role-based access control model structures privileges as fine-grained access controls that can be grouped into roles and mapped to users or groups. This model applies across VCF components including VMware vCenter, NSX, VCF Automation, and Avi Load Balancer. Administrators can define custom roles containing only the minimum set of required privileges, and VCF documentation recommends that user accounts be given the minimal number of privileges on the system that they require to do their jobs. This least-privilege foundation makes periodic reviews more tractable by providing well-defined privilege boundaries to evaluate against. For VMware ESX hosts specifically, vSphere documentation recommends creating individual accounts for administrative access rather than shared accounts, which provides the per-account audit traceability needed to conduct meaningful privilege reviews at the host level.

VCF Operations generates User Permissions Audit reports that provide traceability of user accounts, their roles, access groups, and access privileges. These reports give reviewers a consolidated view of who has access to what across the environment, directly supporting the periodic review process. VCF Operations Access Control also maintains audit records of the last person to update a user account and the last time the user account was updated, which helps reviewers identify stale accounts or recently changed privilege assignments that warrant closer inspection. System administrators can change account attributes, revoke previously granted access, and delete accounts when reviews determine that privileges are no longer needed.

For deeper analysis of privilege usage, vCenter includes a Privilege Checks Recorder feature that monitors and records the privileges checked during vCenter operations. Administrators can retrieve recorded privilege checks through the vCenter Management API, filtering results by managed object IDs, request operation IDs, privilege names, sessions, and user or group identities. This data allows reviewers to compare assigned privileges against actually exercised privileges, identifying cases where accounts hold more access than they use. The PrivilegeChecks service interface provides operations for retrieving the latest privilege checks along with corresponding sessions, users, managed objects, and operation IDs. The recorded privilege check data can also be used to create scripts that automatically build roles with the minimum privileges required for specific workflows, helping enforce least-privilege assignments as an outcome of periodic reviews. Note that the Privilege Checks Recorder is available only through the API and supports scripted workflows; it does not provide a graphical interface, so organizations should plan for scripted or automated retrieval of privilege check data when incorporating this capability into review processes.

For service accounts specifically, VCF Automation allows system administrators to manage service account attributes, revoke previously granted access, and delete service accounts entirely. Service account creation requires specific administrative privileges (View Service Accounts and Manage Service Accounts), restricting who can provision these accounts. Service accounts are granted access using the Request Service Account Authorization process, which restricts token access so that only the authorized application can use it. During platform upgrades, VCF automatically deletes old service account privileges and replaces them with predefined privileges, providing a form of automated privilege realignment.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and VCF Services, extends the privilege review surface to Kubernetes workloads. Kubernetes RBAC structures permissions through Roles and ClusterRoles that define discrete permission sets, and RoleBindings and ClusterRoleBindings that attach those permissions to users, groups, and ServiceAccounts. This declarative model allows cluster administrators to enumerate all

privilege assignments at any point in time using standard Kubernetes API tools such as `kubectl auth can-i`, `kubectl get rolebindings`, and `kubectl get clusterrolebindings`. Kubernetes documentation specifically recommends periodically reviewing RBAC settings for redundant entries and possible privilege escalation paths, and recommends that cluster administrators avoid using cluster-admin accounts except where specifically required, instead using low-privileged accounts for routine operations and reserving broader access for break-glass emergency scenarios. VKS cluster security guidance calls for scoping IAM role trust policies to specific service accounts and namespaces to enforce least privilege at the workload level.

For Kubernetes service accounts, Kubernetes separates ServiceAccount objects from human user identities, and VCF Consumption documentation notes that auditing considerations for humans and service accounts may differ; this separation makes it easier to apply differentiated audit strategies and to review workload permissions independently of human access reviews. Each in-cluster service should be configured with a dedicated ServiceAccount with only the permissions required for its function, and granting cluster-wide roles to all service accounts should be avoided in favor of per-namespace RoleBindings. The LegacyServiceAccountTokenCleanup feature gate enables automatic cleanup of Secret-based service account tokens that are not used within a configurable period (with a default retention of one year), reducing the risk of stale service account credentials persisting beyond their useful lifetime. Kubernetes audit logging records API server interactions including RBAC-related operations, and organizations can configure the Kubernetes audit policy to capture reads and modifications of Role, ClusterRole, RoleBinding, and ClusterRoleBinding resources, supporting an audit trail for privilege changes between review cycles.

The vSphere Supervisor adds platform-level privilege gates that are subject to periodic review. The Manage Supervisor Services privilege is required to delete or deactivate a Supervisor Service, and the SupervisorServices.Install privilege is required to install, upgrade, or uninstall service instances on the Supervisor; these privileges are managed through VCF SSO and vCenter RBAC, which integrates with Supervisor namespace permissions. VCF Services consumed through the Tenant Portal and Content Hub can surface RBAC controls through Argo CD, where RBAC policy rules control account permissions including the ability to grant admin roles to specific local accounts and assign accounts to role groups through group mappings, supporting review of GitOps-layer access assignments.

VCF Automation also supports an access request approval workflow where access requests require approval before granting OAuth token access. This provides a checkpoint for new privilege grants that complements periodic reviews of existing privileges.

NSX Manager audits any user account change, providing an audit trail that reviewers can use to track privilege modifications over time and verify that changes follow approved processes.

VCF does not include automated recertification workflows or scheduled access review campaigns. Organizations should use external identity governance tools for the scheduling and tracking aspects of periodic privilege reviews, using the audit and reporting data that VCF and its Consumption layer provide as input to those reviews.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) supports periodic review of user privileges within its own management plane by providing an admin interface where role assignments for both local and directory-managed accounts can be reviewed and updated. In 9.1, SSP implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. The Enterprise Admin role grants full access to all platform operations, including User Management, while the Auditor role is scoped to read-only access, allowing holders to view information and track activity without the ability to make changes. The predefined local Auditor account provides API and service access for auditing purposes rather than administrative control. Access to User Management and modification of role assignments requires Admin privileges; administrators can review and adjust which accounts hold each role through the SSP interface. When removing an identity source from SSP, all associated user role assignments must first be deleted, which provides a built-in enforcement point for confirming that access has been cleaned up before the identity source is removed. vDefend's contribution is limited to privilege review within its own management interfaces; periodic review of privileges across the broader organizational environment, including service accounts and other systems, requires organizational governance processes outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to periodic privilege review through its role-based access model, defined database-level privilege baselines, and audit logging capabilities, though the periodic review process itself is an organizational responsibility.

DSM organizes administrative access through two distinct roles: the DSM Admin role and the DSM User role. The Admin role carries broader capabilities across the environment, while the DSM User role is scoped to the user's own objects within their namespace. This role separation allows administrators to identify which users hold elevated access by reviewing the DSM user list and confirming that role assignments remain appropriate. Deleting a user in DSM revokes their access to the system. When access must be suspended while keeping databases running, administrators can reset the user password and delegate database management to a different account instead.

DSM maintains service account rotation logs that can be checked to verify service account management activities, including those for vCenter authentication. Service account expiry triggers an alert, supporting investigations into whether continued access remains needed.

For database-level privilege management, DSM defines and enforces a documented privilege baseline across its supported database engines. The default MySQL database user is not a superuser; DSM grants specific data and schema operation privileges while explicitly revoking create and update privileges on the mysql.system schema. MySQL users authenticated through LDAPS can be granted specific privileges using the GRANT command to restrict access to designated databases. For PostgreSQL, host-based authentication requires database administrators to grant specific privileges to LDAPS users. For SQL Server clusters, DSM restricts the cluster administrator login to read-only privileges and specific ALTER permissions for server management and auditing rather than full administrative access. DSM also deactivates the default sa account and uses a reserved internal management account for its own operations, reducing the number of high-privilege accounts requiring review.

DSM adds configurable audit logging for SQL Server clusters. Administrators can select the level of audit logging for system logins and set the log retention period. Preset server audit configurations support login tracking, providing a record of login activity that can inform periodic access reviews.

To satisfy the full requirements of this control, organizations must establish a periodic review process that formally schedules reviews, documents approvals, and records privilege changes. DSM does not automate the review cycle or generate access certification reports, so an access governance program or external identity management tool is needed to drive the review cadence and produce the evidence that auditors typically require.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a role-based access control (RBAC) framework within the Avi Controller that gives administrators the mechanisms to view, assign, modify, and revoke account privileges for all users and service accounts across all tenants. Access to account management functions is governed by the Accounts section write privilege: any administrator holding that privilege can reactivate or deactivate other user accounts, modify role assignments, and adjust tenant scoping.

Avi enforces RBAC through Tenant and Role assignment, restricting each user account to specific areas of the system at account creation. Accounts can be scoped to specific tenants and granted different roles within each tenant, supporting the granular privilege model needed for periodic access reviews. The system ships with predefined roles. A Super User privilege level grants the same privileges as the admin account and is selectable via a checkbox during user account creation.

Administrators can also create custom user account profiles with configurable security thresholds covering password history, login failure behavior, session limits, and credential timeout policies. Write privilege at the Controller level grants full access to create, read, modify, and delete resources, while more narrowly scoped roles can be assigned per tenant.

For CLI access, the admin account is the standard administrative account and is maintained as a locally authenticated account even in systems configured for remote authentication. Non-admin users access the Avi Load Balancer Linux CLI through an SSH client under distinct privilege boundaries, providing separation between elevated shell access and read-only log inspection.

For service account and API access patterns, the Avi Controller supports temporary token authentication. A system administrator can issue a token with a defined expiration time (the token-expiration setting), after which the token automatically expires without requiring explicit revocation. This bounds the duration of any granted service account access and reduces exposure from stale credentials. In VCF-integrated deployments, Avi manages two user accounts for password updates, admin and vcfops-admin, and the Controller provides a REST API endpoint for service account password rotation via POST to the reverse-proxy/password-update endpoint, requiring the username, old password, and new password. For Avi SaaS Controller deployments, authorization tokens can be generated to enable service account authentication.

The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization. Administrators can suspend and reactivate accounts as needed. The periodic cadence of privilege reviews, the criteria for determining whether a privilege remains necessary, and the organizational decision to reassign or remove access are processes that Avi's account management tooling supports but does not schedule or automate.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 5.1

> A process to initiate removal of an individual's ability for unescorted physical access and Interactive Remote Access upon a termination action, and complete the removals within 24 hours of the termination action (Removal of the ability for access may be different than deletion, disabling, revocation, or removal of all access rights).

SCF Controls: IAC-20.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms for revoking logical access authorizations across its component products, though full compliance with this control also requires organizational processes governing when and how revocation occurs.

VCF Automation includes dedicated access token revocation capabilities. Administrators can revoke access tokens for individual users through the Administration access control settings, navigating to a specific user's access control page to view and revoke their active tokens at any time. When a user's access needs to be suspended rather than permanently removed, VCF Automation supports disabling the user account, which blocks access while preserving the account for potential reactivation later. Provider account access can also be revoked and accounts deleted through administrative controls. Deactivating the provider consumption organization feature flag blocks access to that organization through the UI and the Provider Management API without deleting the underlying organization data.

For service accounts, VCF uses API access tokens that rotate after each use. Access tokens have a default lifetime of one hour and are derived from a refresh token that lasts 90 days. The refresh token can be revoked before its expiration and optionally rotated with each access token request, giving administrators control over the window of valid access for automated integrations.

At the VMware vCenter layer, the AuthorizationManager provides programmatic methods for modifying and removing access authorizations. RemoveAuthorizationRole allows deletion of defined roles, and SetEntityPermissions allows administrators to reassign or clear permissions on specific inventory objects. The ResetEntityPermissions method replaces existing permissions with a new set of permissions on vSphere inventory objects, providing a bulk permission replacement capability. AuthorizationManager enforces role-based access control across vSphere components, restricting access to server objects based on the permissions associated with each object. System administrators with the Manage General ACL right in VCF Automation can also create, modify, and remove specific access control lists through the accessControls API, providing another path for revoking granular permissions.

NSX enforces access restrictions on objects owned by principal identities. Users without the Enterprise Administrator role cannot modify or delete protected objects, while Enterprise Administrators retain the ability to modify or delete those objects when access changes are required. This layered ownership model provides a controlled mechanism for adjusting access to network configuration objects.

Because authentication is centralized through VCF SSO, disabling or removing a user's identity source account effectively revokes access across all VCF components simultaneously. When an authentication source needs to be fully decommissioned, deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes all provisioned users and groups associated with it. When resetting VCF SSO to change the identity provider, provisioned users and groups must be removed and then reassigned required service roles in each component. These mechanisms provide broad revocation capabilities for scenarios such as identity provider migrations or environment decommissioning.

For Kubernetes workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, revocation operates at multiple layers of the access model. At the namespace level, permissions control which users can self-provision namespaces through kubectl, with the Administrator role as the default when permissions are unset. Users with the Namespaces.Edit privilege on a user-created Namespace folder can perform create, patch, update, delete, watch, get, and list operations on Kubernetes API resources.

Within VKS clusters, the primary revocation mechanism for user access is deletion of RBAC binding objects. Removing a RoleBinding takes effect immediately for new API requests within the specific namespace; removing a ClusterRoleBinding revokes access across the entire cluster. Because Kubernetes RBAC authorization is evaluated at request time against the current state of the authorization store, there is no delay between removing a binding and its effect on subsequent requests. Administrators should avoid assigning users to the system:masters group, as membership bypasses all RBAC rights checks and cannot be restricted or revoked through standard RBAC mechanisms; access should instead be granted through named roles and bindings that can be individually removed.

Service account access within VKS clusters is revoked by deleting the ServiceAccount object or its associated token Secrets. ServiceAccount tokens can also be explicitly revoked through the Kubernetes API, and a token's validity can optionally be bound to the lifetime of a specific API object, causing it to become invalid automatically when that object is deleted. Short-lived bound tokens issued via the TokenRequest API expire automatically without requiring explicit revocation; however, TokenRequest API tokens are not suited for user authentication because no revocation method exists for them. Kubernetes RBAC should be used to enforce least-privilege access to Secret objects, limiting the data a service account can reach after credentials are injected into containers running in a namespace.

Authentication for Supervisor namespaces integrates with VCF SSO via OIDC. When a user is removed from the identity provider, new authentication requests fail at the VCF SSO layer. OIDC tokens carry a finite lifetime and the API server may cache authentication state, creating a window between identity provider deprovisioning and complete access termination; administrators should account for this in deprovisioning procedures. Minimizing the number of active authentication mechanisms in a cluster further reduces the paths through which a user might retain access after being deprovisioned from the primary identity source.

Within individual virtual machines, VCF SSO user mappings to guest operating system accounts can be removed, revoking VCF SSO-authenticated access to specific guest accounts without affecting the user's broader platform permissions.

For virtual machine access to physical devices, VMware ESX allows administrators to revoke device access by removing the associated virtual device from the VM configuration. This applies to USB, storage, optical disc drives, virtual GPU, and PCI passthrough devices that have been granted to a guest. ESX also allows administrators to deactivate shell access for individual users. When shell access is deactivated for a user with administrative privileges, that user can no longer grant shell access to other users or modify the passwords of users who have shell access.

Role-based access control across vCenter, ESX, NSX, and VCF Operations supports granular permission removal at each layer. When vCenter permissions change, VCF Operations refreshes those permissions at fixed intervals defined in its auth.properties configuration, or users can log out and back in to pick up changes immediately. This cross-component RBAC model, combined with the centralized VCF SSO revocation path, allows administrators to revoke access at multiple levels of granularity depending on the situation.

VMware Private AI Services (PAIS) gates access to its endpoints through OIDC group-based authorization. The Private AI Services configuration includes an `authorizedGroups` setting that names the OIDC groups permitted to reach PAIS in a given organization namespace, with example group names such as `group-for-pais-access-01` and `group-for-pais-access-02`. Removing a user from a configured group in the external OIDC identity provider revokes that user's access at the next authentication or token refresh, because PAIS validates group membership against the groups claim in the access token. The OIDC integration is configured with an issuer URL, the `pais-authentication-id` client ID, and the `openid`, `groups`, and `offline\_access` scopes. PAIS requires the OIDC provider to be registered as a public client application with Authorization Code and Refresh Token grant types, and it supports configurable Extra Audiences and a configurable groups claim name to align with the OIDC provider's token format. Activation requires coordination with the OIDC provider administrator.

PAIS exposes several revocation surfaces for non-interactive access as well. Model endpoints deployed through PAIS use a `harbor-pull-secret-readonly` credential to pull container images from the private Harbor registry, and rotating or deleting this secret revokes the endpoint's ability to pull new images. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and linked data sources and can be revoked individually. Remote Model Context Protocol (MCP) servers connected to PAIS can optionally use static authentication tokens that can be rotated to revoke access.

Passwords entered through the Private AI Services Quickstart, including the private container registry password and proxy password, are saved as VCF Automation secrets, where they can be rotated or deleted.

Platform identity store management and tenant detachment are handled outside PAIS. VCF SSO governs identity for the surrounding VCF platform, and detaching a VMware vCenter from VCF Automation requires verifying that the associated identity provider has been deleted on the vCenter Identity Providers page. PAIS does not manage identities or group membership directly; primary revocation occurs in the organizational OIDC provider and in the VCF identity layer. The control also covers physical access authorization revocation, which is handled outside the platform.

VMware vDefend (Contributes)

VMware vDefend contributes to access authorization revocation through network-level controls that can immediately restrict or terminate connectivity for users and workloads, complementing the identity and credential revocation mechanisms provided by other VCF components.

vDefend (DFW) and Gateway Firewall (GFW) policies can be updated to deny network access to specific workloads, IP addresses, or network segments. Because firewall rules are enforced at the vNIC level (Distributed Firewall) and at tier-0/tier-1 gateways (Gateway Firewall), changes take effect immediately across the fabric without requiring affected workloads to be restarted or reconfigured. Administrators revoking access can add deny rules or remove allow rules to cut off network connectivity for a user, application, or workload. Security Intelligence supports this by allowing administrators to modify allow actions to deny, effectively enforcing microsegmentation as part of the revocation process. Organization Admin ownership of firewall rules restricts project members from accessing rule modifications, adding a governance layer over the revocation mechanism itself.

vDefend Identity Firewall (IDFW) provides identity-based network access control by integrating with Active Directory. IDFW maps users to IP addresses to enable identity-based filtering and access control, and applies security policies to virtual machines based on dynamic name-based criteria combined with Active Directory group membership of logged-in users. When an AD administrator modifies or removes a user's group membership, AD administrators should force a logout so that Identity Firewall rule changes take effect and reflect current group membership. Identity Firewall rules enforce context-aware access control by matching AD group membership to network traffic, including blocking SSH access for specific user groups. In Remote Desktop Session Host (RDSH) environments, administrators create Active Directory security groups to allow or deny users access to application servers based on their assigned role, making revocation as straightforward as modifying the relevant AD group.

Security Services Platform (SSP) supports deletion of remote user and remote user group role assignments when LDAP is configured as an authentication provider, providing a mechanism for revoking management-plane access to vDefend capabilities. SSP implements Role-Based Access Control (RBAC) to limit system access based on user roles so that only authorized users can perform specific actions within the platform, including the License Hub.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the revocation of logical access to database services. The platform exposes user management capabilities through its administrator interface that allow authorized administrators to remove access at multiple levels.

The primary revocation mechanism for local users is account deletion. Deleting a user from DSM revokes their access to the system. The revocation process involves an additional step before deletion: the administrator must first reset the user's password, which immediately blocks continued access, and then delegate management of any databases owned by that user to a different account. This sequenced process is available through the user management interface, where DSM administrators can edit role assignments and namespace access for existing local users, and delete those users entirely. The initial DSM administrator account created during deployment of the Provider Appliance is mandatory and cannot be deleted, which is a constraint on full access revocation at the administrator tier.

For local user accounts, DSM includes a `force_password_change` flag that administrators can configure. This flag can be used as part of an access review workflow to require immediate credential rotation before full account removal, reducing the window of access for a user whose authorization is being revoked.

When DSM is integrated with a directory service via LDAPS, the directory becomes the authoritative source for user identity. Disabling or removing an account in the connected directory restricts access accordingly. Reconfiguring the LDAPS server or group in DSM may also result in loss of access for users not registered with the new configuration. At the individual database level, DSM supports enabling or disabling directory service authentication per database, which allows administrators to restrict authentication for specific databases independently of the global directory configuration.

At the database privilege layer, DSM manages privilege assignments for provisioned databases. For MySQL, DSM revokes create and update privileges on objects in the `mysql.system` schema for database users, establishing a least-privilege baseline. MySQL users created with LDAPS authentication can also be granted specific privileges using the GRANT command to restrict access to designated databases. For SQL Server, DSM assigns the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative rights, and an internal management login (`dsm_mgmt`) restricts users from accessing or modifying system-level objects. These privilege assignments are managed by the platform rather than requiring manual revocation by administrators.

Physical access revocation is outside the scope of DSM, as it is a software platform that operates on top of the vSphere infrastructure layer. Full compliance with this control requires organizational processes for managing the lifecycle of access authorizations, including timely removal of directory accounts when users leave or change roles, and procedural enforcement of the multi-step local user deletion workflow.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports logical access revocation through several mechanisms within its management and data planes.

For local administrator accounts, access can be revoked by deleting the account or removing the user's role assignments through the Avi Controller UI or REST API. The Controller can also be configured to restrict access for any user who does not have a defined role, so that removing a user's role assignment is sufficient to revoke access without deleting the account. The superuser flag on Controller accounts can be disabled to immediately reduce a user's privileges across all tenants and roles. For administrators using password-less SSH-based login, a dedicated REST API endpoint allows targeted deletion of individual SSH public keys, supporting revocation of specific credentials without affecting the account as a whole.

The Avi Controller system administrator can create temporary tokens for users that grant access for a limited duration. These tokens automatically expire at the configured time, revoking access without requiring explicit deletion. This provides a time-bounded access mechanism suitable for temporary or delegated access scenarios.

Granular role-based access control allows app owners to remove specific object labels from a resource, discontinuing access for other users scoped to that object. The Avi License Hub provides an additional administrative path for access revocation: it allows deletion of all current user role assignments to remove an identity source.

When Avi is integrated with an external identity provider via LDAP, SAML, or OAuth/OIDC, access is governed through Auth Mapping Profiles that bind user group memberships to Avi roles and tenants. Revoking access in these configurations requires removing the user from the relevant group in the external directory; the Auth Mapping Profile then rejects their access on the next authentication attempt. Auth Mapping rules can also be updated directly to deny privileges to specific users, preventing them from obtaining any roles or tenants upon login. The Controller Access Policy provides configurable authentication and authorization fields to define and enforce these mappings. Basic Authentication can be deactivated when no longer required, narrowing available authentication pathways.

At the data-plane level, the Controller automatically revokes secure channel credentials for all Service Engines when the Controller cluster enters manual recovery state. This provides a mechanism to invalidate data-plane trust relationships as part of incident response or planned recovery operations.

One architectural consideration applies to client-facing JWT authentication. JWTs used in OAuth/OIDC flows are designed as portable, decoupled identities that cannot be revoked at the authorization server level once issued. Organizations using JWT-based client authentication should configure short token expiry windows to limit exposure from tokens that cannot be individually recalled. Avi provides a configuration API for defining JWT authorization policies under the `ssopolicy:authorization_policy:authz_rules` path, allowing fine-grained control over which tokens can access specific resources.

Physical access revocation is outside Avi's scope; that capability rests with VCF platform controls and organizational physical security processes.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 5.2

> For reassignments or transfers, revoke the individual's authorized electronic access to individual accounts and authorized unescorted physical access that the Responsible Entity determines are not necessary by the end of the next calendar day following the date that the Responsible Entity determines that the individual no longer requires retention of that access.

SCF Controls: IAC-20.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms for revoking logical access authorizations across its component products, though full compliance with this control also requires organizational processes governing when and how revocation occurs.

VCF Automation includes dedicated access token revocation capabilities. Administrators can revoke access tokens for individual users through the Administration access control settings, navigating to a specific user's access control page to view and revoke their active tokens at any time. When a user's access needs to be suspended rather than permanently removed, VCF Automation supports disabling the user account, which blocks access while preserving the account for potential reactivation later. Provider account access can also be revoked and accounts deleted through administrative controls. Deactivating the provider consumption organization feature flag blocks access to that organization through the UI and the Provider Management API without deleting the underlying organization data.

For service accounts, VCF uses API access tokens that rotate after each use. Access tokens have a default lifetime of one hour and are derived from a refresh token that lasts 90 days. The refresh token can be revoked before its expiration and optionally rotated with each access token request, giving administrators control over the window of valid access for automated integrations.

At the VMware vCenter layer, the AuthorizationManager provides programmatic methods for modifying and removing access authorizations. RemoveAuthorizationRole allows deletion of defined roles, and SetEntityPermissions allows administrators to reassign or clear permissions on specific inventory objects. The ResetEntityPermissions method replaces existing permissions with a new set of permissions on vSphere inventory objects, providing a bulk permission replacement capability. AuthorizationManager enforces role-based access control across vSphere components, restricting access to server objects based on the permissions associated with each object. System administrators with the Manage General ACL right in VCF Automation can also create, modify, and remove specific access control lists through the accessControls API, providing another path for revoking granular permissions.

NSX enforces access restrictions on objects owned by principal identities. Users without the Enterprise Administrator role cannot modify or delete protected objects, while Enterprise Administrators retain the ability to modify or delete those objects when access changes are required. This layered ownership model provides a controlled mechanism for adjusting access to network configuration objects.

Because authentication is centralized through VCF SSO, disabling or removing a user's identity source account effectively revokes access across all VCF components simultaneously. When an authentication source needs to be fully decommissioned, deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes all provisioned users and groups associated with it. When resetting VCF SSO to change the identity provider, provisioned users and groups must be removed and then reassigned required service roles in each component. These mechanisms provide broad revocation capabilities for scenarios such as identity provider migrations or environment decommissioning.

For Kubernetes workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, revocation operates at multiple layers of the access model. At the namespace level, permissions control which users can self-provision namespaces through kubectl, with the Administrator role as the default when permissions are unset. Users with the Namespaces.Edit privilege on a user-created Namespace folder can perform create, patch, update, delete, watch, get, and list operations on Kubernetes API resources.

Within VKS clusters, the primary revocation mechanism for user access is deletion of RBAC binding objects. Removing a RoleBinding takes effect immediately for new API requests within the specific namespace; removing a ClusterRoleBinding revokes access across the entire cluster. Because Kubernetes RBAC authorization is evaluated at request time against the current state of the authorization store, there is no delay between removing a binding and its effect on subsequent requests. Administrators should avoid assigning users to the system:masters group, as membership bypasses all RBAC rights checks and cannot be restricted or revoked through standard RBAC mechanisms; access should instead be granted through named roles and bindings that can be individually removed.

Service account access within VKS clusters is revoked by deleting the ServiceAccount object or its associated token Secrets. ServiceAccount tokens can also be explicitly revoked through the Kubernetes API, and a token's validity can optionally be bound to the lifetime of a specific API object, causing it to become invalid automatically when that object is deleted. Short-lived bound tokens issued via the TokenRequest API expire automatically without requiring explicit revocation; however, TokenRequest API tokens are not suited for user authentication because no revocation method exists for them. Kubernetes RBAC should be used to enforce least-privilege access to Secret objects, limiting the data a service account can reach after credentials are injected into containers running in a namespace.

Authentication for Supervisor namespaces integrates with VCF SSO via OIDC. When a user is removed from the identity provider, new authentication requests fail at the VCF SSO layer. OIDC tokens carry a finite lifetime and the API server may cache authentication state, creating a window between identity provider deprovisioning and complete access termination; administrators should account for this in deprovisioning procedures. Minimizing the number of active authentication mechanisms in a cluster further reduces the paths through which a user might retain access after being deprovisioned from the primary identity source.

Within individual virtual machines, VCF SSO user mappings to guest operating system accounts can be removed, revoking VCF SSO-authenticated access to specific guest accounts without affecting the user's broader platform permissions.

For virtual machine access to physical devices, VMware ESX allows administrators to revoke device access by removing the associated virtual device from the VM configuration. This applies to USB, storage, optical disc drives, virtual GPU, and PCI passthrough devices that have been granted to a guest. ESX also allows administrators to deactivate shell access for individual users. When shell access is deactivated for a user with administrative privileges, that user can no longer grant shell access to other users or modify the passwords of users who have shell access.

Role-based access control across vCenter, ESX, NSX, and VCF Operations supports granular permission removal at each layer. When vCenter permissions change, VCF Operations refreshes those permissions at fixed intervals defined in its auth.properties configuration, or users can log out and back in to pick up changes immediately. This cross-component RBAC model, combined with the centralized VCF SSO revocation path, allows administrators to revoke access at multiple levels of granularity depending on the situation.

VMware Private AI Services (PAIS) gates access to its endpoints through OIDC group-based authorization. The Private AI Services configuration includes an `authorizedGroups` setting that names the OIDC groups permitted to reach PAIS in a given organization namespace, with example group names such as `group-for-pais-access-01` and `group-for-pais-access-02`. Removing a user from a configured group in the external OIDC identity provider revokes that user's access at the next authentication or token refresh, because PAIS validates group membership against the groups claim in the access token. The OIDC integration is configured with an issuer URL, the `pais-authentication-id` client ID, and the `openid`, `groups`, and `offline\_access` scopes. PAIS requires the OIDC provider to be registered as a public client application with Authorization Code and Refresh Token grant types, and it supports configurable Extra Audiences and a configurable groups claim name to align with the OIDC provider's token format. Activation requires coordination with the OIDC provider administrator.

PAIS exposes several revocation surfaces for non-interactive access as well. Model endpoints deployed through PAIS use a `harbor-pull-secret-readonly` credential to pull container images from the private Harbor registry, and rotating or deleting this secret revokes the endpoint's ability to pull new images. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and linked data sources and can be revoked individually. Remote Model Context Protocol (MCP) servers connected to PAIS can optionally use static authentication tokens that can be rotated to revoke access.

Passwords entered through the Private AI Services Quickstart, including the private container registry password and proxy password, are saved as VCF Automation secrets, where they can be rotated or deleted.

Platform identity store management and tenant detachment are handled outside PAIS. VCF SSO governs identity for the surrounding VCF platform, and detaching a VMware vCenter from VCF Automation requires verifying that the associated identity provider has been deleted on the vCenter Identity Providers page. PAIS does not manage identities or group membership directly; primary revocation occurs in the organizational OIDC provider and in the VCF identity layer. The control also covers physical access authorization revocation, which is handled outside the platform.

VMware vDefend (Contributes)

VMware vDefend contributes to access authorization revocation through network-level controls that can immediately restrict or terminate connectivity for users and workloads, complementing the identity and credential revocation mechanisms provided by other VCF components.

vDefend (DFW) and Gateway Firewall (GFW) policies can be updated to deny network access to specific workloads, IP addresses, or network segments. Because firewall rules are enforced at the vNIC level (Distributed Firewall) and at tier-0/tier-1 gateways (Gateway Firewall), changes take effect immediately across the fabric without requiring affected workloads to be restarted or reconfigured. Administrators revoking access can add deny rules or remove allow rules to cut off network connectivity for a user, application, or workload. Security Intelligence supports this by allowing administrators to modify allow actions to deny, effectively enforcing microsegmentation as part of the revocation process. Organization Admin ownership of firewall rules restricts project members from accessing rule modifications, adding a governance layer over the revocation mechanism itself.

vDefend Identity Firewall (IDFW) provides identity-based network access control by integrating with Active Directory. IDFW maps users to IP addresses to enable identity-based filtering and access control, and applies security policies to virtual machines based on dynamic name-based criteria combined with Active Directory group membership of logged-in users. When an AD administrator modifies or removes a user's group membership, AD administrators should force a logout so that Identity Firewall rule changes take effect and reflect current group membership. Identity Firewall rules enforce context-aware access control by matching AD group membership to network traffic, including blocking SSH access for specific user groups. In Remote Desktop Session Host (RDSH) environments, administrators create Active Directory security groups to allow or deny users access to application servers based on their assigned role, making revocation as straightforward as modifying the relevant AD group.

Security Services Platform (SSP) supports deletion of remote user and remote user group role assignments when LDAP is configured as an authentication provider, providing a mechanism for revoking management-plane access to vDefend capabilities. SSP implements Role-Based Access Control (RBAC) to limit system access based on user roles so that only authorized users can perform specific actions within the platform, including the License Hub.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the revocation of logical access to database services. The platform exposes user management capabilities through its administrator interface that allow authorized administrators to remove access at multiple levels.

The primary revocation mechanism for local users is account deletion. Deleting a user from DSM revokes their access to the system. The revocation process involves an additional step before deletion: the administrator must first reset the user's password, which immediately blocks continued access, and then delegate management of any databases owned by that user to a different account. This sequenced process is available through the user management interface, where DSM administrators can edit role assignments and namespace access for existing local users, and delete those users entirely. The initial DSM administrator account created during deployment of the Provider Appliance is mandatory and cannot be deleted, which is a constraint on full access revocation at the administrator tier.

For local user accounts, DSM includes a `force_password_change` flag that administrators can configure. This flag can be used as part of an access review workflow to require immediate credential rotation before full account removal, reducing the window of access for a user whose authorization is being revoked.

When DSM is integrated with a directory service via LDAPS, the directory becomes the authoritative source for user identity. Disabling or removing an account in the connected directory restricts access accordingly. Reconfiguring the LDAPS server or group in DSM may also result in loss of access for users not registered with the new configuration. At the individual database level, DSM supports enabling or disabling directory service authentication per database, which allows administrators to restrict authentication for specific databases independently of the global directory configuration.

At the database privilege layer, DSM manages privilege assignments for provisioned databases. For MySQL, DSM revokes create and update privileges on objects in the `mysql.system` schema for database users, establishing a least-privilege baseline. MySQL users created with LDAPS authentication can also be granted specific privileges using the GRANT command to restrict access to designated databases. For SQL Server, DSM assigns the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative rights, and an internal management login (`dsm_mgmt`) restricts users from accessing or modifying system-level objects. These privilege assignments are managed by the platform rather than requiring manual revocation by administrators.

Physical access revocation is outside the scope of DSM, as it is a software platform that operates on top of the vSphere infrastructure layer. Full compliance with this control requires organizational processes for managing the lifecycle of access authorizations, including timely removal of directory accounts when users leave or change roles, and procedural enforcement of the multi-step local user deletion workflow.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports logical access revocation through several mechanisms within its management and data planes.

For local administrator accounts, access can be revoked by deleting the account or removing the user's role assignments through the Avi Controller UI or REST API. The Controller can also be configured to restrict access for any user who does not have a defined role, so that removing a user's role assignment is sufficient to revoke access without deleting the account. The superuser flag on Controller accounts can be disabled to immediately reduce a user's privileges across all tenants and roles. For administrators using password-less SSH-based login, a dedicated REST API endpoint allows targeted deletion of individual SSH public keys, supporting revocation of specific credentials without affecting the account as a whole.

The Avi Controller system administrator can create temporary tokens for users that grant access for a limited duration. These tokens automatically expire at the configured time, revoking access without requiring explicit deletion. This provides a time-bounded access mechanism suitable for temporary or delegated access scenarios.

Granular role-based access control allows app owners to remove specific object labels from a resource, discontinuing access for other users scoped to that object. The Avi License Hub provides an additional administrative path for access revocation: it allows deletion of all current user role assignments to remove an identity source.

When Avi is integrated with an external identity provider via LDAP, SAML, or OAuth/OIDC, access is governed through Auth Mapping Profiles that bind user group memberships to Avi roles and tenants. Revoking access in these configurations requires removing the user from the relevant group in the external directory; the Auth Mapping Profile then rejects their access on the next authentication attempt. Auth Mapping rules can also be updated directly to deny privileges to specific users, preventing them from obtaining any roles or tenants upon login. The Controller Access Policy provides configurable authentication and authorization fields to define and enforce these mappings. Basic Authentication can be deactivated when no longer required, narrowing available authentication pathways.

At the data-plane level, the Controller automatically revokes secure channel credentials for all Service Engines when the Controller cluster enters manual recovery state. This provides a mechanism to invalidate data-plane trust relationships as part of incident response or planned recovery operations.

One architectural consideration applies to client-facing JWT authentication. JWTs used in OAuth/OIDC flows are designed as portable, decoupled identities that cannot be revoked at the authorization server level once issued. Organizations using JWT-based client authentication should configure short token expiry windows to limit exposure from tokens that cannot be individually recalled. Avi provides a configuration API for defining JWT authorization policies under the `ssopolicy:authorization_policy:authz_rules` path, allowing fine-grained control over which tokens can access specific resources.

Physical access revocation is outside Avi's scope; that capability rests with VCF platform controls and organizational physical security processes.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 5.3

> For termination actions, revoke the individual's non-shared user accounts (unless already revoked according to Part 5.1) within 30 calendar days of the effective date of the termination action.

SCF Controls: HRS-01.1, IAC-20.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms for revoking logical access authorizations across its component products, though full compliance with this control also requires organizational processes governing when and how revocation occurs.

VCF Automation includes dedicated access token revocation capabilities. Administrators can revoke access tokens for individual users through the Administration access control settings, navigating to a specific user's access control page to view and revoke their active tokens at any time. When a user's access needs to be suspended rather than permanently removed, VCF Automation supports disabling the user account, which blocks access while preserving the account for potential reactivation later. Provider account access can also be revoked and accounts deleted through administrative controls. Deactivating the provider consumption organization feature flag blocks access to that organization through the UI and the Provider Management API without deleting the underlying organization data.

For service accounts, VCF uses API access tokens that rotate after each use. Access tokens have a default lifetime of one hour and are derived from a refresh token that lasts 90 days. The refresh token can be revoked before its expiration and optionally rotated with each access token request, giving administrators control over the window of valid access for automated integrations.

At the VMware vCenter layer, the AuthorizationManager provides programmatic methods for modifying and removing access authorizations. RemoveAuthorizationRole allows deletion of defined roles, and SetEntityPermissions allows administrators to reassign or clear permissions on specific inventory objects. The ResetEntityPermissions method replaces existing permissions with a new set of permissions on vSphere inventory objects, providing a bulk permission replacement capability. AuthorizationManager enforces role-based access control across vSphere components, restricting access to server objects based on the permissions associated with each object. System administrators with the Manage General ACL right in VCF Automation can also create, modify, and remove specific access control lists through the accessControls API, providing another path for revoking granular permissions.

NSX enforces access restrictions on objects owned by principal identities. Users without the Enterprise Administrator role cannot modify or delete protected objects, while Enterprise Administrators retain the ability to modify or delete those objects when access changes are required. This layered ownership model provides a controlled mechanism for adjusting access to network configuration objects.

Because authentication is centralized through VCF SSO, disabling or removing a user's identity source account effectively revokes access across all VCF components simultaneously. When an authentication source needs to be fully decommissioned, deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes all provisioned users and groups associated with it. When resetting VCF SSO to change the identity provider, provisioned users and groups must be removed and then reassigned required service roles in each component. These mechanisms provide broad revocation capabilities for scenarios such as identity provider migrations or environment decommissioning.

For Kubernetes workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, revocation operates at multiple layers of the access model. At the namespace level, permissions control which users can self-provision namespaces through kubectl, with the Administrator role as the default when permissions are unset. Users with the Namespaces.Edit privilege on a user-created Namespace folder can perform create, patch, update, delete, watch, get, and list operations on Kubernetes API resources.

Within VKS clusters, the primary revocation mechanism for user access is deletion of RBAC binding objects. Removing a RoleBinding takes effect immediately for new API requests within the specific namespace; removing a ClusterRoleBinding

revokes access across the entire cluster. Because Kubernetes RBAC authorization is evaluated at request time against the current state of the authorization store, there is no delay between removing a binding and its effect on subsequent requests. Administrators should avoid assigning users to the `system:masters` group, as membership bypasses all RBAC rights checks and cannot be restricted or revoked through standard RBAC mechanisms; access should instead be granted through named roles and bindings that can be individually removed.

Service account access within VKS clusters is revoked by deleting the `ServiceAccount` object or its associated token `Secrets`. `ServiceAccount` tokens can also be explicitly revoked through the Kubernetes API, and a token's validity can optionally be bound to the lifetime of a specific API object, causing it to become invalid automatically when that object is deleted. Short-lived bound tokens issued via the `TokenRequest` API expire automatically without requiring explicit revocation; however, `TokenRequest` API tokens are not suited for user authentication because no revocation method exists for them. Kubernetes RBAC should be used to enforce least-privilege access to `Secret` objects, limiting the data a service account can reach after credentials are injected into containers running in a namespace.

Authentication for Supervisor namespaces integrates with VCF SSO via OIDC. When a user is removed from the identity provider, new authentication requests fail at the VCF SSO layer. OIDC tokens carry a finite lifetime and the API server may cache authentication state, creating a window between identity provider deprovisioning and complete access termination; administrators should account for this in deprovisioning procedures. Minimizing the number of active authentication mechanisms in a cluster further reduces the paths through which a user might retain access after being deprovisioned from the primary identity source.

Within individual virtual machines, VCF SSO user mappings to guest operating system accounts can be removed, revoking VCF SSO-authenticated access to specific guest accounts without affecting the user's broader platform permissions.

For virtual machine access to physical devices, VMware ESX allows administrators to revoke device access by removing the associated virtual device from the VM configuration. This applies to USB, storage, optical disc drives, virtual GPU, and PCI passthrough devices that have been granted to a guest. ESX also allows administrators to deactivate shell access for individual users. When shell access is deactivated for a user with administrative privileges, that user can no longer grant shell access to other users or modify the passwords of users who have shell access.

Role-based access control across vCenter, ESX, NSX, and VCF Operations supports granular permission removal at each layer. When vCenter permissions change, VCF Operations refreshes those permissions at fixed intervals defined in its `auth.properties` configuration, or users can log out and back in to pick up changes immediately. This cross-component RBAC model, combined with the centralized VCF SSO revocation path, allows administrators to revoke access at multiple levels of granularity depending on the situation.

VMware Private AI Services (PAIS) gates access to its endpoints through OIDC group-based authorization. The Private AI Services configuration includes an `authorizedGroups` setting that names the OIDC groups permitted to reach PAIS in a given organization namespace, with example group names such as `group-for-pais-access-01` and `group-for-pais-access-02`. Removing a user from a configured group in the external OIDC identity provider revokes that user's access at the next authentication or token refresh, because PAIS validates group membership against the groups claim in the access token. The OIDC integration is configured with an issuer URL, the `pais-authentication-id` client ID, and the `openid`, `groups`, and `offline_access` scopes. PAIS requires the OIDC provider to be registered as a public client application with Authorization Code and Refresh Token grant types, and it supports configurable Extra Audiences and a configurable groups claim name to align with the OIDC provider's token format. Activation requires coordination with the OIDC provider administrator.

PAIS exposes several revocation surfaces for non-interactive access as well. Model endpoints deployed through PAIS use a `harbor-pull-secret-readonly` credential to pull container images from the private Harbor registry, and rotating or deleting this secret revokes the endpoint's ability to pull new images. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and linked data sources and can be revoked individually. Remote Model Context Protocol (MCP) servers connected to PAIS can optionally use static authentication tokens that can be rotated to revoke access. Passwords entered through the Private AI Services Quickstart, including the private container registry password and proxy password, are saved as VCF Automation secrets, where they can be rotated or deleted.

Platform identity store management and tenant detachment are handled outside PAIS. VCF SSO governs identity for the surrounding VCF platform, and detaching a VMware vCenter from VCF Automation requires verifying that the associated identity provider has been deleted on the vCenter Identity Providers page. PAIS does not manage identities or group membership directly; primary revocation occurs in the organizational OIDC provider and in the VCF identity layer. The control also covers physical access authorization revocation, which is handled outside the platform.

VMware vDefend (Contributes)

VMware vDefend contributes to access authorization revocation through network-level controls that can immediately restrict or terminate connectivity for users and workloads, complementing the identity and credential revocation mechanisms provided by other VCF components.

vDefend (DFW) and Gateway Firewall (GFW) policies can be updated to deny network access to specific workloads, IP addresses, or network segments. Because firewall rules are enforced at the vNIC level (Distributed Firewall) and at tier-0/tier-1 gateways (Gateway Firewall), changes take effect immediately across the fabric without requiring affected workloads to be restarted or reconfigured. Administrators revoking access can add deny rules or remove allow rules to cut off network connectivity for a user, application, or workload. Security Intelligence supports this by allowing administrators to modify allow actions to deny, effectively enforcing microsegmentation as part of the revocation process. Organization Admin ownership of firewall rules restricts project members from accessing rule modifications, adding a governance layer over the revocation mechanism itself.

vDefend Identity Firewall (IDFW) provides identity-based network access control by integrating with Active Directory. IDFW maps users to IP addresses to enable identity-based filtering and access control, and applies security policies to virtual machines based on dynamic name-based criteria combined with Active Directory group membership of logged-in users. When an AD administrator modifies or removes a user's group membership, AD administrators should force a logout so that Identity Firewall rule changes take effect and reflect current group membership. Identity Firewall rules enforce context-aware access control by matching AD group membership to network traffic, including blocking SSH access for specific user groups. In Remote Desktop Session Host (RDSH) environments, administrators create Active Directory security groups to allow or deny users access to application servers based on their assigned role, making revocation as straightforward as modifying the relevant AD group.

Security Services Platform (SSP) supports deletion of remote user and remote user group role assignments when LDAP is configured as an authentication provider, providing a mechanism for revoking management-plane access to vDefend capabilities. SSP implements Role-Based Access Control (RBAC) to limit system access based on user roles so that only authorized users can perform specific actions within the platform, including the License Hub.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the revocation of logical access to database services. The platform exposes user management capabilities through its administrator interface that allow authorized administrators to remove access at multiple levels.

The primary revocation mechanism for local users is account deletion. Deleting a user from DSM revokes their access to the system. The revocation process involves an additional step before deletion: the administrator must first reset the user's password, which immediately blocks continued access, and then delegate management of any databases owned by that user to a different account. This sequenced process is available through the user management interface, where DSM administrators can edit role assignments and namespace access for existing local users, and delete those users entirely. The initial DSM administrator account created during deployment of the Provider Appliance is mandatory and cannot be deleted, which is a constraint on full access revocation at the administrator tier.

For local user accounts, DSM includes a `force\_password\_change` flag that administrators can configure. This flag can be used as part of an access review workflow to require immediate credential rotation before full account removal, reducing the window of access for a user whose authorization is being revoked.

When DSM is integrated with a directory service via LDAPS, the directory becomes the authoritative source for user identity. Disabling or removing an account in the connected directory restricts access accordingly. Reconfiguring the LDAPS server or group in DSM may also result in loss of access for users not registered with the new configuration. At the individual database level, DSM supports enabling or disabling directory service authentication per database, which allows administrators to restrict authentication for specific databases independently of the global directory configuration.

At the database privilege layer, DSM manages privilege assignments for provisioned databases. For MySQL, DSM revokes create and update privileges on objects in the ``mysql.system`` schema for database users, establishing a least-privilege baseline. MySQL users created with LDAPS authentication can also be granted specific privileges using the GRANT command to restrict access to designated databases. For SQL Server, DSM assigns the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative rights, and an internal management login (`dsm_mgmt`) restricts users from accessing or modifying system-level objects. These privilege assignments are managed by the platform rather than requiring manual revocation by administrators.

Physical access revocation is outside the scope of DSM, as it is a software platform that operates on top of the vSphere infrastructure layer. Full compliance with this control requires organizational processes for managing the lifecycle of access authorizations, including timely removal of directory accounts when users leave or change roles, and procedural enforcement of the multi-step local user deletion workflow.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports logical access revocation through several mechanisms within its management and data planes.

For local administrator accounts, access can be revoked by deleting the account or removing the user's role assignments through the Avi Controller UI or REST API. The Controller can also be configured to restrict access for any user who does not have a defined role, so that removing a user's role assignment is sufficient to revoke access without deleting the account. The superuser flag on Controller accounts can be disabled to immediately reduce a user's privileges across all tenants and roles. For administrators using password-less SSH-based login, a dedicated REST API endpoint allows targeted deletion of individual SSH public keys, supporting revocation of specific credentials without affecting the account as a whole.

The Avi Controller system administrator can create temporary tokens for users that grant access for a limited duration. These tokens automatically expire at the configured time, revoking access without requiring explicit deletion. This provides a time-bounded access mechanism suitable for temporary or delegated access scenarios.

Granular role-based access control allows app owners to remove specific object labels from a resource, discontinuing access for other users scoped to that object. The Avi License Hub provides an additional administrative path for access revocation: it allows deletion of all current user role assignments to remove an identity source.

When Avi is integrated with an external identity provider via LDAP, SAML, or OAuth/OIDC, access is governed through Auth Mapping Profiles that bind user group memberships to Avi roles and tenants. Revoking access in these configurations requires removing the user from the relevant group in the external directory; the Auth Mapping Profile then rejects their access on the next authentication attempt. Auth Mapping rules can also be updated directly to deny privileges to specific users, preventing them from obtaining any roles or tenants upon login. The Controller Access Policy provides configurable authentication and authorization fields to define and enforce these mappings. Basic Authentication can be deactivated when no longer required, narrowing available authentication pathways.

At the data-plane level, the Controller automatically revokes secure channel credentials for all Service Engines when the Controller cluster enters manual recovery state. This provides a mechanism to invalidate data-plane trust relationships as part of incident response or planned recovery operations.

One architectural consideration applies to client-facing JWT authentication. JWTs used in OAuth/OIDC flows are designed as portable, decoupled identities that cannot be revoked at the authorization server level once issued. Organizations using JWT-based client authentication should configure short token expiry windows to limit exposure from tokens that cannot be individually recalled. Avi provides a configuration API for defining JWT authorization policies under the

ssopolicy:authorization_policy:authz_rules path, allowing fine-grained control over which tokens can access specific resources.

Physical access revocation is outside Avi's scope; that capability rests with VCF platform controls and organizational physical security processes.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 5.4

> For termination actions, change passwords for shared account(s) known to the user within 30 calendar days of the termination action. For reassignments or transfers, change passwords for shared account(s) known to the user within 30 calendar days following the date that the Responsible Entity determines that the individual no longer requires retention of that access. If the Responsible Entity determines and documents that extenuating operating circumstances require a longer time period, change the password(s) within 10 calendar days following the end of the operating circumstances.

SCF Controls: HRS-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 6.1

> Prior to provisioning, authorize (unless already authorized according to Part 4.1.) based on need, as determined by the Responsible Entity, except for CIP Exceptional Circumstances: 6.1.1. Provisioned electronic access to electronic BCSI; and 6.1.2. Provisioned physical access to physical BCSI.

SCF Controls: IAC-28.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical controls that support management approval workflows for new accounts and permission changes, though the formal approval process itself requires organizational procedures and may benefit from integration with external identity governance or ITSM tools.

Account creation across VCF components is restricted to highly privileged administrators. In NSX Manager, only users with the Enterprise Admin role can create new local user accounts or guest user accounts. In VCF Automation, only a System Administrator can create other system administrator and user accounts in the provider organization. Provider management service accounts are created by administrators who hold specific "View Service Accounts" and "Manage Service Accounts" privileges. Service accounts authenticate using API access tokens that rotate after each use per RFC 6749 section 6, with access tokens normally lasting one hour and based on a refresh token that normally lasts 90 days but can be revoked earlier. When authenticating with a service account, applications cannot perform user management tasks, create API refresh tokens, or manage other service accounts, limiting the blast radius of programmatic access. For user group management in VCF Operations for Networks, the user performing management operations must have admin-level permissions. User accounts must be created and activated in the system before role assignments can be made, establishing a clear two-step process where account provisioning and privilege assignment are distinct actions. These restrictions concentrate account creation authority in a small number of administrators, supporting a controlled process where account requests flow through authorized personnel.

VCF Automation includes a configurable approval policy framework that organizations can use for account-related workflows. Approval policies can be scoped at the organization level with configurable criteria and approval types, such as user-based approval with specific approver assignment by email address. When multiple valid approval policies apply, all designated approvers are added to the approval chain, creating a multi-level review process. The approval mode can be set to require all designated approvers to approve before an action executes. Approvers must hold at least the Organization User role, and the Organization Administrator role can create and manage policies. The Manage Association permission controls who can update policy associations for objects, allowing granular delegation of administrative responsibilities. Organizations can also create custom user roles that include the ability to review and respond to approval requests, allowing designated managers to participate in the approval workflow without granting broader administrative access.

Service accounts in VCF Automation are granted access using the Request Service Account Authorization process, which restricts token access so that only the application that must use the token has sole access and no other actor can retrieve it. After access is granted, the authenticated client application receives an OAuth refresh token and an access token representing its first VCF Automation session for immediate use.

VCF Automation integrates with ServiceNow ITSM through a plug-in that supports sub-workflows containing approval group activities. The system administrator creates a sub-workflow with approval group activity and approval group information, and by default three approval activities are added to the sub-workflow. Custom workflows in ServiceNow can route approval requests to different approval groups based on user entitlement membership, enabling organizations to route account and permission change requests through their standard change management process.

NSX Manager provides audit logging for account lifecycle events. Any user account change in NSX Manager is audited, and the audit trail captures the username, operation type, operation status, and new values for changes including role assignments. Changes to local user accounts are logged separately, providing visibility into both account creation and

permission modifications. This audit capability allows organizations to verify after the fact that proper approvals were obtained before accounts were created or permissions changed.

Organizations should apply the principle of least privilege when granting account permissions. User accounts should be given the minimal number of privileges on the system required for their job functions. While VCF provides the technical enforcement layer, approval workflow tooling, and audit trail, organizations need to define and document the formal management approval process, designate approvers for different account types, and periodically review that account provisioning follows the established workflow. Organizations that require a dedicated identity governance console typically integrate VCF's identity infrastructure with external IAM or ITSM platforms to implement the full management approval lifecycle.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) structures account and permission management through an administrative role model that requires a privileged administrator to create accounts and assign roles, providing a technical control point where organizational approval workflows can be enforced.

DSM supports two identity sources for user accounts: a local user database and a centrally managed LDAPS directory. Local user creation is an administrative action performed by a DSM Admin, who must specify each user's role (Admin or User), email address, and namespace-level access controls at the time of account creation. No new DSM account can be created without explicit action from an authorized administrator. When LDAPS is configured as the identity source, DSM relies on the organization's directory service for user identity, delegating account lifecycle management to the central identity infrastructure where directory-level approval and provisioning processes apply. When the LDAPS server or directory service groups are changed for an existing configuration, all users must be registered with the new server or group to maintain access, requiring administrator action to complete the transition.

Permission changes within DSM are similarly gated. Database ownership transfers require explicit confirmation through the UI before the change takes effect. Admin password changes for managed databases are restricted to database owners, who must act through the DSM interface to complete the operation. Data service policies can be tailored to specific requirements and enforced across different tenants before assignment to one or more organizations; DSM requires review of policy violations before policies are applied to databases. Integration with VCF Automation as a provider requires a user account with the DSM_ADMIN role, making the provisioning of integration access an explicit administrator action.

For SQL Server databases managed by DSM, the default sa account is deactivated at provisioning time and replaced by a reserved internal account, dsm_mgmt, with sysadmin privileges for management operations. SQL Server integration with Active Directory requires a Privileged Account configured in Active Directory to enable automated identity management and Windows Authentication. The password for the account assigned the db_owner role can be changed through the Change Owner Password operation, restricting that action to authorized database owners.

DSM generates service account rotation logs that can be checked to verify service account management activities, providing an audit record of service account lifecycle events. PostgreSQL databases managed by DSM support the insert_username extension, which tracks who changed a table and provides a database-level audit trail for data modifications.

This control requires organizational processes beyond what DSM provides. DSM does not include a built-in approval workflow, ticketing integration, or manager sign-off mechanism. Organizations must establish and document processes outside DSM, such as change management systems or identity governance platforms, to require management approval before a DSM Admin acts on an account request.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 6.1.1

> Prior to provisioning, authorize (unless already authorized according to Part 4.1.) based on need, as determined by the Responsible Entity, except for CIP Exceptional Circumstances: 6.1.1. Provisioned electronic access to electronic BCSI; and

SCF Controls: IAC-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support formal user registration and de-registration processes, though the organizational policies, approval workflows, and periodic entitlement reviews that govern these processes must be established separately.

VCF SSO is the centralized authentication and identity service, supporting multiple user provisioning methods. Organizations can choose between Just-In-Time (JIT) provisioning, where user accounts are dynamically created upon first login from a configured identity provider, and Groups Pre-provisioning, where users and groups are synchronized from a directory source in advance. JIT provisioning requires no additional configuration beyond the identity provider setup, and can also handle group membership with options for either pre-provisioned groups or just-in-time group creation. For directory-based provisioning, VCF supports syncing users directly from groups, including nested group synchronization that imports all users from a selected group and its child groups. Active Directory or LDAP integration provisions users and groups from the enterprise directory. VMware vCenter Identity Provider Federation also supports external OIDC providers, including Okta and PingFederate. When configured with PingFederate, the integration requires a SCIM 2 application and supports User Create, User Update, and User Disable/Delete operations by default, providing a direct mapping to the provisioning and de-provisioning lifecycle this control describes. After initial identity provider configuration, administrators log in to each component with the local admin account and assign the necessary service roles to provisioned users and groups. This two-step process, where accounts are first provisioned through VCF SSO and then granted specific roles, enforces a structured approach to access rights assignment.

VCF Operations provides centralized management of identity provider configuration and user and group provisioning across VCF instances. It supports importing user accounts from external authorization sources such as LDAP databases or SSO servers through the Access Control interface. Imported users and groups receive role-based access control permissions that govern what objects and interface areas they can access. Access groups define granular rights including the ability to add, edit, or delete dashboards, or to view, configure, or manage objects. User groups can be created manually, imported from a single sign-on server, or imported from an LDAP database. VCF Operations user accounts can also be disabled through the Access Control interface to deactivate a user.

VCF Automation includes an Access Control service that supports identity operations for managing groups and users. System Administrators can create other system administrator and user accounts in the provider organization. Organization Administrators can view role rights or create roles local to their organization. VCF Automation supports cloning of rights bundles and global roles, with the ability to modify selected rights for the cloned role. This allows administrators to build custom access configurations tailored to specific provisioning requirements. User accounts in VCF Automation can have their name, password, and role assignments edited through the Access Control interface. Provider administrators can create projects, assign users and groups, and allocate quotas to restrict available configurations. When OIDC is configured as the identity provider, imported users authenticate with the credentials established in the external identity provider.

For de-provisioning, VCF provides several mechanisms across its components. VCF Automation supports explicit user account deactivation: disabling a user does not remove them from the organization, allowing reactivation if needed later. Before a user can be deleted in VCF Automation, their access must be disabled first, enforcing a controlled removal process. VCF Operations user accounts can similarly be disabled through the Access Control interface. When the identity provider configuration is reset or deregistered in VCF SSO, the provisioned users and groups are removed, and service roles must be reassigned after reconfiguration. Deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes the provisioned users and groups.

In NSX, user accounts must be created and activated before any role assignments can be made. VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

At the Consumption layer, VMware Kubernetes Service (VKS) clusters within vSphere Supervisor enforce a Kubernetes-native access control model that ties permission assignment to explicitly defined RBAC objects and an authoritative identity source. DevOps users and groups to whom Kubernetes permissions are assigned must exist in the configured identity source integrated with VCF SSO, so that removing a user from the identity source revokes their ability to authenticate to VKS clusters. VKS cluster provisioning requires that cluster users and roles be defined as part of the cluster lifecycle, establishing a registration step before access rights can be granted. Access rights are assigned by creating RoleBindings or ClusterRoleBindings that associate a Role or ClusterRole with a specific user or group identity. These bindings name specific identity source principals and can be audited against the identity source to detect orphaned bindings where the referenced identity has been removed but the binding remains. Kubernetes documentation requires that user account creation prevent reuse of deleted user names, so that a newly provisioned account with the same name does not silently inherit the RoleBindings of its predecessor. VKS separates ServiceAccounts used by workloads from human user accounts, allowing different provisioning and de-provisioning procedures to be applied to each class of identity. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level. For administrators, the Kubernetes documentation recommends creating a least-privilege kubeconfig for routine work and reserving elevated permissions for break-glass access only.

The Argo CD Supervisor Service, when deployed, enforces its own RBAC layer through policy rules and group mappings. Local accounts can be defined in the localAccounts configuration and granted roles through RBAC policy rules and group assignments. Argo CD also supports OIDC authentication with global RBAC policies for federated identity scenarios. Cluster registration for Argo CD creates ClusterRole and ClusterRoleBinding objects that explicitly associate service account identities with their permitted cluster-wide scope. The Secret Store Supervisor Service similarly enforces RBAC for administrators, DevOps engineers, and application tenants, maintaining role-based separation within the Supervisor Services layer.

Across all components, VCF enforces a privilege model where fine-grained access controls are grouped into roles, which are then mapped to users or groups. Each VCF component, including VMware vCenter, VCF Operations, and VCF Automation, enforces permissions based on assigned roles, so provisioning a user account is distinct from granting specific access rights. Administrative operations in VCF Operations require a user with the ADMIN role, maintaining role-based separation.

VCF contributes the technical enforcement layer for user provisioning and de-provisioning. The formal registration process, approval workflows, and periodic entitlement reviews that this control requires are organizational responsibilities outside VCF's scope.

VMware Private AI Services (PAIS) integrates with an external OIDC provider for user authentication, configured through the PAIS activation process on an organization namespace with the issuer URL, client ID, and OIDC scopes. Identity and access management for PAIS is set up in coordination with the OIDC provider administrator, making the external OIDC directory the authoritative source of user identities for PAIS. The oidc-authorized-groups, oidc-groups-claim, and oidc-extra-audiences settings on the organization namespace configure which OIDC groups are accepted, which claim carries group membership, and which additional OAuth 2.0 audiences PAIS will accept when validating the Access Token.

Access to PAIS is gated on OIDC group membership through the authorizedGroups configuration. Only user accounts that belong to one or more of the specified authorized groups (such as group-for-pais-access-01 or group-for-pais-access-02) can access the service. The OIDC configuration includes a groups scope that surfaces group membership in the Access Token, so PAIS enforces the authorization decision at service access time based on current group membership in the external directory. Removing a user from an authorized OIDC group at the provider revokes that user's access to PAIS at the next token issuance.

Within the PAIS platform, organization administrators control which users can perform privileged operations. An organization administrator account is required to activate PAIS in an organization namespace in VCF Automation. A user must be added to a project and namespace in the VCF Automation All Apps organization before that user can provision GPU-accelerated VMware Kubernetes Service (VKS) clusters or request Deep Learning VM and AI catalog items. Catalog item visibility in VCF

Automation is scoped to project membership, restricting which users can request AI workloads from the Private AI Services Quickstart blueprints.

For the model gallery and image registry, a Harbor robot account is created for the project allocated to the model gallery, providing a non-interactive credential that is separate from end-user identities and can be rotated or removed independently. Personal access tokens generated from a user's account settings provide programmatic access to PAIS Knowledge Bases and linked data sources, allowing tokens to be issued, scoped, and revoked separately from the user's interactive sessions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) 9.1 provides structured user provisioning and de-provisioning capabilities that support a formal access rights lifecycle for both local accounts and directory-integrated users.

User accounts in DSM are managed through two identity sources: local users created and managed within the DSM platform itself, and LDAP/LDAPS users authenticated through an enterprise directory service such as Active Directory. DSM can be configured to use one or both identity sources independently. The first local user account is the DSM administrator, created during deployment of the DSM Provider Appliance. That account is mandatory and cannot be deleted. All subsequent local user creation requires administrator credentials, meaning only authorized personnel can add new accounts to the system.

When provisioning a local user, an administrator must specify the user's role, email address, and password through the DSM user creation workflow, accessible in the vSphere Client or the DSM UI. DSM's two built-in roles define the access scope: the Administrator role manages the platform, namespaces, and other users, while the User role creates and maintains individual databases. Namespace access is assigned at user creation. Administrators can modify both role assignments and namespace access for existing local users through the user management interface. Administrators can delete local user accounts when removal is the appropriate de-provisioning action. Alternatively, to prohibit a user's access to DSM while keeping databases running, an administrator can reset the user's password and delegate database management to a different user.

For directory-integrated environments, DSM supports LDAPS authentication and allows assignment of roles to Directory Service Groups, enabling group-based access control for LDAP users. When a user's directory group membership changes, their effective access within DSM reflects the group role assignment.

For SQL Server databases provisioned within VCF Automation, DSM data service policies define the allowed user types for databases created under the policy. Administrators can configure policies to permit Windows Principal authentication using Active Directory credentials, SQL User authentication using standard SQL Server login credentials, or both. For automated Active Directory integration, DSM requires a privileged Active Directory account with permissions to write service principal names (SPNs) and perform dynamic DNS updates. SQL Server databases map the dbo user, the database object owner, to administrator-controlled identities.

The Permissions view in the DSM dashboard provides a consolidated interface for creating, monitoring, and managing all configured user accounts and directory service groups. Because user login precedence between local and LDAPS accounts must be managed deliberately to avoid authentication conflicts, organizations should establish clear provisioning procedures that address the ordering and priority rules DSM applies.

DSM's mechanisms support the technical registration and de-registration workflow but do not themselves constitute a formal process. The control's requirement for governance-level procedures governing access rights assignment extends to organizational approval workflows, access review cycles, and documented registration practices that operate outside the platform. Organizations must establish these processes independently, using DSM's user management capabilities as the technical enforcement layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a native user management system accessible through Administration > Accounts > Users on the Avi Controller. Administrators can create local user accounts, assign each account a specific role and tenant scope, and remove accounts when access is no longer required. Each user account stores role and tenant assignments directly, supporting granular scoping of permissions per deployment.

Avi's RBAC model supports both local user accounts validated against an internal database and remote authentication through LDAP or SAML. Auth Mapping Profiles extend the RBAC model by binding external directory group membership to specific Avi roles and tenants at login time. When a user's group membership changes in the directory, the Auth Mapping Profile applies the updated role and tenant assignments on the next login, without requiring manual changes inside Avi. Multiple Auth Mapping Profile rules can be configured so that a single user's LDAP or SAML group memberships determine distinct roles across multiple tenants simultaneously. SAML integration with Microsoft Active Directory Federation Services (ADFS) is also supported, with configurable issuance authorization rules that control which users may access the relying party.

Avi Controller allows creation of custom roles according to specific access requirements when predefined roles do not fit an account's needs. The Tenant-Admin role can be scoped so that tenant administrators can create, update, and delete cloud infrastructure within their tenant boundary without affecting other tenants. Avi GSLB extends user provisioning to global load balancing by supporting the creation of non-admin users with assigned roles for granular access control across GSLB deployments. The Avi License Hub also supports role-based access control by assigning roles to individual users or groups defined in an external identity provider.

User accounts are attached by default to the Default-User-Account-Profile, and administrators can create new user account profiles with different concurrent session thresholds to meet organizational security requirements.

Organizations should establish and document formal procedures for user registration, access approval, and de-registration to govern how and when accounts are created or removed in Avi. The technical mechanisms Avi provides, including account creation and deletion, role assignment, and directory integration via Auth Mapping Profiles, support a formal lifecycle process but do not replace the organizational procedures the control requires.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 6.1.2

> Prior to provisioning, authorize (unless already authorized according to Part 4.1.) based on need, as determined by the Responsible Entity, except for CIP Exceptional Circumstances: 6.1.2. Provisioned physical access to physical BCSI.

SCF Controls: IAC-07, PES-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 6.2

> Verify at least once every 15 calendar months that all individuals with provisioned access to BCSI: 6.2.1. have an authorization record; and 6.2.2. still need the provisioned access to perform their current work functions, as determined by the Responsible Entity.

SCF Controls: IAC-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support periodic review of account privileges, though the organizational process of scheduling and conducting those reviews remains a customer responsibility.

VCF's role-based access control model structures privileges as fine-grained access controls that can be grouped into roles and mapped to users or groups. This model applies across VCF components including VMware vCenter, NSX, VCF Automation, and Avi Load Balancer. Administrators can define custom roles containing only the minimum set of required privileges, and VCF documentation recommends that user accounts be given the minimal number of privileges on the system that they require to do their jobs. This least-privilege foundation makes periodic reviews more tractable by providing well-defined privilege boundaries to evaluate against. For VMware ESX hosts specifically, vSphere documentation recommends creating individual accounts for administrative access rather than shared accounts, which provides the per-account audit traceability needed to conduct meaningful privilege reviews at the host level.

VCF Operations generates User Permissions Audit reports that provide traceability of user accounts, their roles, access groups, and access privileges. These reports give reviewers a consolidated view of who has access to what across the environment, directly supporting the periodic review process. VCF Operations Access Control also maintains audit records of the last person to update a user account and the last time the user account was updated, which helps reviewers identify stale accounts or recently changed privilege assignments that warrant closer inspection. System administrators can change account attributes, revoke previously granted access, and delete accounts when reviews determine that privileges are no longer needed.

For deeper analysis of privilege usage, vCenter includes a Privilege Checks Recorder feature that monitors and records the privileges checked during vCenter operations. Administrators can retrieve recorded privilege checks through the vCenter Management API, filtering results by managed object IDs, request operation IDs, privilege names, sessions, and user or group identities. This data allows reviewers to compare assigned privileges against actually exercised privileges, identifying cases where accounts hold more access than they use. The PrivilegeChecks service interface provides operations for retrieving the latest privilege checks along with corresponding sessions, users, managed objects, and operation IDs. The recorded privilege check data can also be used to create scripts that automatically build roles with the minimum privileges required for specific workflows, helping enforce least-privilege assignments as an outcome of periodic reviews. Note that the Privilege Checks Recorder is available only through the API and supports scripted workflows; it does not provide a graphical interface, so organizations should plan for scripted or automated retrieval of privilege check data when incorporating this capability into review processes.

For service accounts specifically, VCF Automation allows system administrators to manage service account attributes, revoke previously granted access, and delete service accounts entirely. Service account creation requires specific administrative privileges (View Service Accounts and Manage Service Accounts), restricting who can provision these accounts. Service accounts are granted access using the Request Service Account Authorization process, which restricts token access so that only the authorized application can use it. During platform upgrades, VCF automatically deletes old service account privileges and replaces them with predefined privileges, providing a form of automated privilege realignment.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and VCF Services, extends the privilege review surface to Kubernetes workloads. Kubernetes RBAC structures permissions through Roles and ClusterRoles that define discrete permission sets, and RoleBindings and ClusterRoleBindings that attach those permissions to users, groups, and ServiceAccounts. This declarative model allows cluster administrators to enumerate all

privilege assignments at any point in time using standard Kubernetes API tools such as `kubectl auth can-i`, `kubectl get rolebindings`, and `kubectl get clusterrolebindings`. Kubernetes documentation specifically recommends periodically reviewing RBAC settings for redundant entries and possible privilege escalation paths, and recommends that cluster administrators avoid using cluster-admin accounts except where specifically required, instead using low-privileged accounts for routine operations and reserving broader access for break-glass emergency scenarios. VKS cluster security guidance calls for scoping IAM role trust policies to specific service accounts and namespaces to enforce least privilege at the workload level.

For Kubernetes service accounts, Kubernetes separates ServiceAccount objects from human user identities, and VCF Consumption documentation notes that auditing considerations for humans and service accounts may differ; this separation makes it easier to apply differentiated audit strategies and to review workload permissions independently of human access reviews. Each in-cluster service should be configured with a dedicated ServiceAccount with only the permissions required for its function, and granting cluster-wide roles to all service accounts should be avoided in favor of per-namespace RoleBindings. The LegacyServiceAccountTokenCleanup feature gate enables automatic cleanup of Secret-based service account tokens that are not used within a configurable period (with a default retention of one year), reducing the risk of stale service account credentials persisting beyond their useful lifetime. Kubernetes audit logging records API server interactions including RBAC-related operations, and organizations can configure the Kubernetes audit policy to capture reads and modifications of Role, ClusterRole, RoleBinding, and ClusterRoleBinding resources, supporting an audit trail for privilege changes between review cycles.

The vSphere Supervisor adds platform-level privilege gates that are subject to periodic review. The Manage Supervisor Services privilege is required to delete or deactivate a Supervisor Service, and the SupervisorServices.Install privilege is required to install, upgrade, or uninstall service instances on the Supervisor; these privileges are managed through VCF SSO and vCenter RBAC, which integrates with Supervisor namespace permissions. VCF Services consumed through the Tenant Portal and Content Hub can surface RBAC controls through Argo CD, where RBAC policy rules control account permissions including the ability to grant admin roles to specific local accounts and assign accounts to role groups through group mappings, supporting review of GitOps-layer access assignments.

VCF Automation also supports an access request approval workflow where access requests require approval before granting OAuth token access. This provides a checkpoint for new privilege grants that complements periodic reviews of existing privileges.

NSX Manager audits any user account change, providing an audit trail that reviewers can use to track privilege modifications over time and verify that changes follow approved processes.

VCF does not include automated recertification workflows or scheduled access review campaigns. Organizations should use external identity governance tools for the scheduling and tracking aspects of periodic privilege reviews, using the audit and reporting data that VCF and its Consumption layer provide as input to those reviews.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) supports periodic review of user privileges within its own management plane by providing an admin interface where role assignments for both local and directory-managed accounts can be reviewed and updated. In 9.1, SSP implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. The Enterprise Admin role grants full access to all platform operations, including User Management, while the Auditor role is scoped to read-only access, allowing holders to view information and track activity without the ability to make changes. The predefined local Auditor account provides API and service access for auditing purposes rather than administrative control. Access to User Management and modification of role assignments requires Admin privileges; administrators can review and adjust which accounts hold each role through the SSP interface. When removing an identity source from SSP, all associated user role assignments must first be deleted, which provides a built-in enforcement point for confirming that access has been cleaned up before the identity source is removed. vDefend's contribution is limited to privilege review within its own management interfaces; periodic review of privileges across the broader organizational environment, including service accounts and other systems, requires organizational governance processes outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to periodic privilege review through its role-based access model, defined database-level privilege baselines, and audit logging capabilities, though the periodic review process itself is an organizational responsibility.

DSM organizes administrative access through two distinct roles: the DSM Admin role and the DSM User role. The Admin role carries broader capabilities across the environment, while the DSM User role is scoped to the user's own objects within their namespace. This role separation allows administrators to identify which users hold elevated access by reviewing the DSM user list and confirming that role assignments remain appropriate. Deleting a user in DSM revokes their access to the system. When access must be suspended while keeping databases running, administrators can reset the user password and delegate database management to a different account instead.

DSM maintains service account rotation logs that can be checked to verify service account management activities, including those for vCenter authentication. Service account expiry triggers an alert, supporting investigations into whether continued access remains needed.

For database-level privilege management, DSM defines and enforces a documented privilege baseline across its supported database engines. The default MySQL database user is not a superuser; DSM grants specific data and schema operation privileges while explicitly revoking create and update privileges on the mysql.system schema. MySQL users authenticated through LDAPS can be granted specific privileges using the GRANT command to restrict access to designated databases. For PostgreSQL, host-based authentication requires database administrators to grant specific privileges to LDAPS users. For SQL Server clusters, DSM restricts the cluster administrator login to read-only privileges and specific ALTER permissions for server management and auditing rather than full administrative access. DSM also deactivates the default sa account and uses a reserved internal management account for its own operations, reducing the number of high-privilege accounts requiring review.

DSM adds configurable audit logging for SQL Server clusters. Administrators can select the level of audit logging for system logins and set the log retention period. Preset server audit configurations support login tracking, providing a record of login activity that can inform periodic access reviews.

To satisfy the full requirements of this control, organizations must establish a periodic review process that formally schedules reviews, documents approvals, and records privilege changes. DSM does not automate the review cycle or generate access certification reports, so an access governance program or external identity management tool is needed to drive the review cadence and produce the evidence that auditors typically require.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a role-based access control (RBAC) framework within the Avi Controller that gives administrators the mechanisms to view, assign, modify, and revoke account privileges for all users and service accounts across all tenants. Access to account management functions is governed by the Accounts section write privilege: any administrator holding that privilege can reactivate or deactivate other user accounts, modify role assignments, and adjust tenant scoping.

Avi enforces RBAC through Tenant and Role assignment, restricting each user account to specific areas of the system at account creation. Accounts can be scoped to specific tenants and granted different roles within each tenant, supporting the granular privilege model needed for periodic access reviews. The system ships with predefined roles. A Super User privilege level grants the same privileges as the admin account and is selectable via a checkbox during user account creation.

Administrators can also create custom user account profiles with configurable security thresholds covering password history, login failure behavior, session limits, and credential timeout policies. Write privilege at the Controller level grants full access to create, read, modify, and delete resources, while more narrowly scoped roles can be assigned per tenant.

For CLI access, the admin account is the standard administrative account and is maintained as a locally authenticated account even in systems configured for remote authentication. Non-admin users access the Avi Load Balancer Linux CLI through an SSH client under distinct privilege boundaries, providing separation between elevated shell access and read-only log inspection.

For service account and API access patterns, the Avi Controller supports temporary token authentication. A system administrator can issue a token with a defined expiration time (the token-expiration setting), after which the token automatically expires without requiring explicit revocation. This bounds the duration of any granted service account access and reduces exposure from stale credentials. In VCF-integrated deployments, Avi manages two user accounts for password updates, admin and vcfops-admin, and the Controller provides a REST API endpoint for service account password rotation via POST to the reverse-proxy/password-update endpoint, requiring the username, old password, and new password. For Avi SaaS Controller deployments, authorization tokens can be generated to enable service account authentication.

The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization. Administrators can suspend and reactivate accounts as needed. The periodic cadence of privilege reviews, the criteria for determining whether a privilege remains necessary, and the organizational decision to reassign or remove access are processes that Avi's account management tooling supports but does not schedule or automate.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 6.2.1

> Verify at least once every 15 calendar months that all individuals with provisioned access to BCSI: 6.2.1. have an authorization record;

SCF Controls: IAC-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support periodic review of account privileges, though the organizational process of scheduling and conducting those reviews remains a customer responsibility.

VCF's role-based access control model structures privileges as fine-grained access controls that can be grouped into roles and mapped to users or groups. This model applies across VCF components including VMware vCenter, NSX, VCF Automation, and Avi Load Balancer. Administrators can define custom roles containing only the minimum set of required privileges, and VCF documentation recommends that user accounts be given the minimal number of privileges on the system that they require to do their jobs. This least-privilege foundation makes periodic reviews more tractable by providing well-defined privilege boundaries to evaluate against. For VMware ESX hosts specifically, vSphere documentation recommends creating individual accounts for administrative access rather than shared accounts, which provides the per-account audit traceability needed to conduct meaningful privilege reviews at the host level.

VCF Operations generates User Permissions Audit reports that provide traceability of user accounts, their roles, access groups, and access privileges. These reports give reviewers a consolidated view of who has access to what across the environment, directly supporting the periodic review process. VCF Operations Access Control also maintains audit records of the last person to update a user account and the last time the user account was updated, which helps reviewers identify stale accounts or recently changed privilege assignments that warrant closer inspection. System administrators can change account attributes, revoke previously granted access, and delete accounts when reviews determine that privileges are no longer needed.

For deeper analysis of privilege usage, vCenter includes a Privilege Checks Recorder feature that monitors and records the privileges checked during vCenter operations. Administrators can retrieve recorded privilege checks through the vCenter Management API, filtering results by managed object IDs, request operation IDs, privilege names, sessions, and user or group identities. This data allows reviewers to compare assigned privileges against actually exercised privileges, identifying cases where accounts hold more access than they use. The PrivilegeChecks service interface provides operations for retrieving the latest privilege checks along with corresponding sessions, users, managed objects, and operation IDs. The recorded privilege check data can also be used to create scripts that automatically build roles with the minimum privileges required for specific workflows, helping enforce least-privilege assignments as an outcome of periodic reviews. Note that the Privilege Checks Recorder is available only through the API and supports scripted workflows; it does not provide a graphical interface, so organizations should plan for scripted or automated retrieval of privilege check data when incorporating this capability into review processes.

For service accounts specifically, VCF Automation allows system administrators to manage service account attributes, revoke previously granted access, and delete service accounts entirely. Service account creation requires specific administrative privileges (View Service Accounts and Manage Service Accounts), restricting who can provision these accounts. Service accounts are granted access using the Request Service Account Authorization process, which restricts token access so that only the authorized application can use it. During platform upgrades, VCF automatically deletes old service account privileges and replaces them with predefined privileges, providing a form of automated privilege realignment.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and VCF Services, extends the privilege review surface to Kubernetes workloads. Kubernetes RBAC structures permissions through Roles and ClusterRoles that define discrete permission sets, and RoleBindings and ClusterRoleBindings that attach those permissions to users, groups, and ServiceAccounts. This declarative model allows cluster administrators to enumerate all privilege assignments at any point in time using standard Kubernetes API tools such as `kubectl auth can-i`, `kubectl get`

rolebindings, and `kubectl get clusterrolebindings`. Kubernetes documentation specifically recommends periodically reviewing RBAC settings for redundant entries and possible privilege escalation paths, and recommends that cluster administrators avoid using cluster-admin accounts except where specifically required, instead using low-privileged accounts for routine operations and reserving broader access for break-glass emergency scenarios. VKS cluster security guidance calls for scoping IAM role trust policies to specific service accounts and namespaces to enforce least privilege at the workload level.

For Kubernetes service accounts, Kubernetes separates `ServiceAccount` objects from human user identities, and VCF Consumption documentation notes that auditing considerations for humans and service accounts may differ; this separation makes it easier to apply differentiated audit strategies and to review workload permissions independently of human access reviews. Each in-cluster service should be configured with a dedicated `ServiceAccount` with only the permissions required for its function, and granting cluster-wide roles to all service accounts should be avoided in favor of per-namespace `RoleBindings`. The `LegacyServiceAccountTokenCleanup` feature gate enables automatic cleanup of Secret-based service account tokens that are not used within a configurable period (with a default retention of one year), reducing the risk of stale service account credentials persisting beyond their useful lifetime. Kubernetes audit logging records API server interactions including RBAC-related operations, and organizations can configure the Kubernetes audit policy to capture reads and modifications of `Role`, `ClusterRole`, `RoleBinding`, and `ClusterRoleBinding` resources, supporting an audit trail for privilege changes between review cycles.

The vSphere Supervisor adds platform-level privilege gates that are subject to periodic review. The `Manage Supervisor Services` privilege is required to delete or deactivate a Supervisor Service, and the `SupervisorServices.Install` privilege is required to install, upgrade, or uninstall service instances on the Supervisor; these privileges are managed through VCF SSO and vCenter RBAC, which integrates with Supervisor namespace permissions. VCF Services consumed through the Tenant Portal and Content Hub can surface RBAC controls through Argo CD, where RBAC policy rules control account permissions including the ability to grant admin roles to specific local accounts and assign accounts to role groups through group mappings, supporting review of GitOps-layer access assignments.

VCF Automation also supports an access request approval workflow where access requests require approval before granting OAuth token access. This provides a checkpoint for new privilege grants that complements periodic reviews of existing privileges.

NSX Manager audits any user account change, providing an audit trail that reviewers can use to track privilege modifications over time and verify that changes follow approved processes.

VCF does not include automated recertification workflows or scheduled access review campaigns. Organizations should use external identity governance tools for the scheduling and tracking aspects of periodic privilege reviews, using the audit and reporting data that VCF and its Consumption layer provide as input to those reviews.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) supports periodic review of user privileges within its own management plane by providing an admin interface where role assignments for both local and directory-managed accounts can be reviewed and updated. In 9.1, SSP implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. The Enterprise Admin role grants full access to all platform operations, including User Management, while the Auditor role is scoped to read-only access, allowing holders to view information and track activity without the ability to make changes. The predefined local Auditor account provides API and service access for auditing purposes rather than administrative control. Access to User Management and modification of role assignments requires Admin privileges; administrators can review and adjust which accounts hold each role through the SSP interface. When removing an identity source from SSP, all associated user role assignments must first be deleted, which provides a built-in enforcement point for confirming that access has been cleaned up before the identity source is removed. vDefend's contribution is limited to privilege review within its own management interfaces; periodic review of privileges across the broader organizational environment, including service accounts and other systems, requires organizational governance processes outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to periodic privilege review through its role-based access model, defined database-level privilege baselines, and audit logging capabilities, though the periodic review process itself is an organizational responsibility.

DSM organizes administrative access through two distinct roles: the DSM Admin role and the DSM User role. The Admin role carries broader capabilities across the environment, while the DSM User role is scoped to the user's own objects within their namespace. This role separation allows administrators to identify which users hold elevated access by reviewing the DSM user list and confirming that role assignments remain appropriate. Deleting a user in DSM revokes their access to the system. When access must be suspended while keeping databases running, administrators can reset the user password and delegate database management to a different account instead.

DSM maintains service account rotation logs that can be checked to verify service account management activities, including those for vCenter authentication. Service account expiry triggers an alert, supporting investigations into whether continued access remains needed.

For database-level privilege management, DSM defines and enforces a documented privilege baseline across its supported database engines. The default MySQL database user is not a superuser; DSM grants specific data and schema operation privileges while explicitly revoking create and update privileges on the mysql.system schema. MySQL users authenticated through LDAPS can be granted specific privileges using the GRANT command to restrict access to designated databases. For PostgreSQL, host-based authentication requires database administrators to grant specific privileges to LDAPS users. For SQL Server clusters, DSM restricts the cluster administrator login to read-only privileges and specific ALTER permissions for server management and auditing rather than full administrative access. DSM also deactivates the default sa account and uses a reserved internal management account for its own operations, reducing the number of high-privilege accounts requiring review.

DSM adds configurable audit logging for SQL Server clusters. Administrators can select the level of audit logging for system logins and set the log retention period. Preset server audit configurations support login tracking, providing a record of login activity that can inform periodic access reviews.

To satisfy the full requirements of this control, organizations must establish a periodic review process that formally schedules reviews, documents approvals, and records privilege changes. DSM does not automate the review cycle or generate access certification reports, so an access governance program or external identity management tool is needed to drive the review cadence and produce the evidence that auditors typically require.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a role-based access control (RBAC) framework within the Avi Controller that gives administrators the mechanisms to view, assign, modify, and revoke account privileges for all users and service accounts across all tenants. Access to account management functions is governed by the Accounts section write privilege: any administrator holding that privilege can reactivate or deactivate other user accounts, modify role assignments, and adjust tenant scoping.

Avi enforces RBAC through Tenant and Role assignment, restricting each user account to specific areas of the system at account creation. Accounts can be scoped to specific tenants and granted different roles within each tenant, supporting the granular privilege model needed for periodic access reviews. The system ships with predefined roles. A Super User privilege level grants the same privileges as the admin account and is selectable via a checkbox during user account creation. Administrators can also create custom user account profiles with configurable security thresholds covering password history, login failure behavior, session limits, and credential timeout policies. Write privilege at the Controller level grants full access to create, read, modify, and delete resources, while more narrowly scoped roles can be assigned per tenant.

For CLI access, the admin account is the standard administrative account and is maintained as a locally authenticated account even in systems configured for remote authentication. Non-admin users access the Avi Load Balancer Linux CLI through an SSH client under distinct privilege boundaries, providing separation between elevated shell access and read-only log inspection.

For service account and API access patterns, the Avi Controller supports temporary token authentication. A system administrator can issue a token with a defined expiration time (the token-expiration setting), after which the token automatically expires without requiring explicit revocation. This bounds the duration of any granted service account access and reduces exposure from stale credentials. In VCF-integrated deployments, Avi manages two user accounts for password updates, admin and vcfops-admin, and the Controller provides a REST API endpoint for service account password rotation via POST to the reverse-proxy/password-update endpoint, requiring the username, old password, and new password. For Avi SaaS Controller deployments, authorization tokens can be generated to enable service account authentication.

The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization. Administrators can suspend and reactivate accounts as needed. The periodic cadence of privilege reviews, the criteria for determining whether a privilege remains necessary, and the organizational decision to reassign or remove access are processes that Avi's account management tooling supports but does not schedule or automate.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 6.2.2

> Verify at least once every 15 calendar months that all individuals with provisioned access to BCSI: 6.2.2. still need the provisioned access to perform their current work functions, as determined by the Responsible Entity.

SCF Controls: IAC-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support periodic review of account privileges, though the organizational process of scheduling and conducting those reviews remains a customer responsibility.

VCF's role-based access control model structures privileges as fine-grained access controls that can be grouped into roles and mapped to users or groups. This model applies across VCF components including VMware vCenter, NSX, VCF Automation, and Avi Load Balancer. Administrators can define custom roles containing only the minimum set of required privileges, and VCF documentation recommends that user accounts be given the minimal number of privileges on the system that they require to do their jobs. This least-privilege foundation makes periodic reviews more tractable by providing well-defined privilege boundaries to evaluate against. For VMware ESX hosts specifically, vSphere documentation recommends creating individual accounts for administrative access rather than shared accounts, which provides the per-account audit traceability needed to conduct meaningful privilege reviews at the host level.

VCF Operations generates User Permissions Audit reports that provide traceability of user accounts, their roles, access groups, and access privileges. These reports give reviewers a consolidated view of who has access to what across the environment, directly supporting the periodic review process. VCF Operations Access Control also maintains audit records of the last person to update a user account and the last time the user account was updated, which helps reviewers identify stale accounts or recently changed privilege assignments that warrant closer inspection. System administrators can change account attributes, revoke previously granted access, and delete accounts when reviews determine that privileges are no longer needed.

For deeper analysis of privilege usage, vCenter includes a Privilege Checks Recorder feature that monitors and records the privileges checked during vCenter operations. Administrators can retrieve recorded privilege checks through the vCenter Management API, filtering results by managed object IDs, request operation IDs, privilege names, sessions, and user or group identities. This data allows reviewers to compare assigned privileges against actually exercised privileges, identifying cases where accounts hold more access than they use. The PrivilegeChecks service interface provides operations for retrieving the latest privilege checks along with corresponding sessions, users, managed objects, and operation IDs. The recorded privilege check data can also be used to create scripts that automatically build roles with the minimum privileges required for specific workflows, helping enforce least-privilege assignments as an outcome of periodic reviews. Note that the Privilege Checks Recorder is available only through the API and supports scripted workflows; it does not provide a graphical interface, so organizations should plan for scripted or automated retrieval of privilege check data when incorporating this capability into review processes.

For service accounts specifically, VCF Automation allows system administrators to manage service account attributes, revoke previously granted access, and delete service accounts entirely. Service account creation requires specific administrative privileges (View Service Accounts and Manage Service Accounts), restricting who can provision these accounts. Service accounts are granted access using the Request Service Account Authorization process, which restricts token access so that only the authorized application can use it. During platform upgrades, VCF automatically deletes old service account privileges and replaces them with predefined privileges, providing a form of automated privilege realignment.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and VCF Services, extends the privilege review surface to Kubernetes workloads. Kubernetes RBAC structures permissions through Roles and ClusterRoles that define discrete permission sets, and RoleBindings and ClusterRoleBindings that attach those permissions to users, groups, and ServiceAccounts. This declarative model allows cluster administrators to enumerate all privilege assignments at any point in time using standard Kubernetes API tools such as `kubectl auth can-i`, `kubectl get`

rolebindings, and `kubectl get clusterrolebindings`. Kubernetes documentation specifically recommends periodically reviewing RBAC settings for redundant entries and possible privilege escalation paths, and recommends that cluster administrators avoid using cluster-admin accounts except where specifically required, instead using low-privileged accounts for routine operations and reserving broader access for break-glass emergency scenarios. VKS cluster security guidance calls for scoping IAM role trust policies to specific service accounts and namespaces to enforce least privilege at the workload level.

For Kubernetes service accounts, Kubernetes separates `ServiceAccount` objects from human user identities, and VCF Consumption documentation notes that auditing considerations for humans and service accounts may differ; this separation makes it easier to apply differentiated audit strategies and to review workload permissions independently of human access reviews. Each in-cluster service should be configured with a dedicated `ServiceAccount` with only the permissions required for its function, and granting cluster-wide roles to all service accounts should be avoided in favor of per-namespace `RoleBindings`. The `LegacyServiceAccountTokenCleanup` feature gate enables automatic cleanup of Secret-based service account tokens that are not used within a configurable period (with a default retention of one year), reducing the risk of stale service account credentials persisting beyond their useful lifetime. Kubernetes audit logging records API server interactions including RBAC-related operations, and organizations can configure the Kubernetes audit policy to capture reads and modifications of `Role`, `ClusterRole`, `RoleBinding`, and `ClusterRoleBinding` resources, supporting an audit trail for privilege changes between review cycles.

The vSphere Supervisor adds platform-level privilege gates that are subject to periodic review. The `Manage Supervisor Services` privilege is required to delete or deactivate a Supervisor Service, and the `SupervisorServices.Install` privilege is required to install, upgrade, or uninstall service instances on the Supervisor; these privileges are managed through VCF SSO and vCenter RBAC, which integrates with Supervisor namespace permissions. VCF Services consumed through the Tenant Portal and Content Hub can surface RBAC controls through Argo CD, where RBAC policy rules control account permissions including the ability to grant admin roles to specific local accounts and assign accounts to role groups through group mappings, supporting review of GitOps-layer access assignments.

VCF Automation also supports an access request approval workflow where access requests require approval before granting OAuth token access. This provides a checkpoint for new privilege grants that complements periodic reviews of existing privileges.

NSX Manager audits any user account change, providing an audit trail that reviewers can use to track privilege modifications over time and verify that changes follow approved processes.

VCF does not include automated recertification workflows or scheduled access review campaigns. Organizations should use external identity governance tools for the scheduling and tracking aspects of periodic privilege reviews, using the audit and reporting data that VCF and its Consumption layer provide as input to those reviews.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) supports periodic review of user privileges within its own management plane by providing an admin interface where role assignments for both local and directory-managed accounts can be reviewed and updated. In 9.1, SSP implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. The Enterprise Admin role grants full access to all platform operations, including User Management, while the Auditor role is scoped to read-only access, allowing holders to view information and track activity without the ability to make changes. The predefined local Auditor account provides API and service access for auditing purposes rather than administrative control. Access to User Management and modification of role assignments requires Admin privileges; administrators can review and adjust which accounts hold each role through the SSP interface. When removing an identity source from SSP, all associated user role assignments must first be deleted, which provides a built-in enforcement point for confirming that access has been cleaned up before the identity source is removed. vDefend's contribution is limited to privilege review within its own management interfaces; periodic review of privileges across the broader organizational environment, including service accounts and other systems, requires organizational governance processes outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to periodic privilege review through its role-based access model, defined database-level privilege baselines, and audit logging capabilities, though the periodic review process itself is an organizational responsibility.

DSM organizes administrative access through two distinct roles: the DSM Admin role and the DSM User role. The Admin role carries broader capabilities across the environment, while the DSM User role is scoped to the user's own objects within their namespace. This role separation allows administrators to identify which users hold elevated access by reviewing the DSM user list and confirming that role assignments remain appropriate. Deleting a user in DSM revokes their access to the system. When access must be suspended while keeping databases running, administrators can reset the user password and delegate database management to a different account instead.

DSM maintains service account rotation logs that can be checked to verify service account management activities, including those for vCenter authentication. Service account expiry triggers an alert, supporting investigations into whether continued access remains needed.

For database-level privilege management, DSM defines and enforces a documented privilege baseline across its supported database engines. The default MySQL database user is not a superuser; DSM grants specific data and schema operation privileges while explicitly revoking create and update privileges on the mysql.system schema. MySQL users authenticated through LDAPS can be granted specific privileges using the GRANT command to restrict access to designated databases. For PostgreSQL, host-based authentication requires database administrators to grant specific privileges to LDAPS users. For SQL Server clusters, DSM restricts the cluster administrator login to read-only privileges and specific ALTER permissions for server management and auditing rather than full administrative access. DSM also deactivates the default sa account and uses a reserved internal management account for its own operations, reducing the number of high-privilege accounts requiring review.

DSM adds configurable audit logging for SQL Server clusters. Administrators can select the level of audit logging for system logins and set the log retention period. Preset server audit configurations support login tracking, providing a record of login activity that can inform periodic access reviews.

To satisfy the full requirements of this control, organizations must establish a periodic review process that formally schedules reviews, documents approvals, and records privilege changes. DSM does not automate the review cycle or generate access certification reports, so an access governance program or external identity management tool is needed to drive the review cadence and produce the evidence that auditors typically require.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a role-based access control (RBAC) framework within the Avi Controller that gives administrators the mechanisms to view, assign, modify, and revoke account privileges for all users and service accounts across all tenants. Access to account management functions is governed by the Accounts section write privilege: any administrator holding that privilege can reactivate or deactivate other user accounts, modify role assignments, and adjust tenant scoping.

Avi enforces RBAC through Tenant and Role assignment, restricting each user account to specific areas of the system at account creation. Accounts can be scoped to specific tenants and granted different roles within each tenant, supporting the granular privilege model needed for periodic access reviews. The system ships with predefined roles. A Super User privilege level grants the same privileges as the admin account and is selectable via a checkbox during user account creation. Administrators can also create custom user account profiles with configurable security thresholds covering password history, login failure behavior, session limits, and credential timeout policies. Write privilege at the Controller level grants full access to create, read, modify, and delete resources, while more narrowly scoped roles can be assigned per tenant.

For CLI access, the admin account is the standard administrative account and is maintained as a locally authenticated account even in systems configured for remote authentication. Non-admin users access the Avi Load Balancer Linux CLI through an SSH client under distinct privilege boundaries, providing separation between elevated shell access and read-only log inspection.

For service account and API access patterns, the Avi Controller supports temporary token authentication. A system administrator can issue a token with a defined expiration time (the token-expiration setting), after which the token automatically expires without requiring explicit revocation. This bounds the duration of any granted service account access and reduces exposure from stale credentials. In VCF-integrated deployments, Avi manages two user accounts for password updates, admin and vcfops-admin, and the Controller provides a REST API endpoint for service account password rotation via POST to the reverse-proxy/password-update endpoint, requiring the username, old password, and new password. For Avi SaaS Controller deployments, authorization tokens can be generated to enable service account authentication.

The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization. Administrators can suspend and reactivate accounts as needed. The periodic cadence of privilege reviews, the criteria for determining whether a privilege remains necessary, and the organizational decision to reassign or remove access are processes that Avi's account management tooling supports but does not schedule or automate.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 6.3

> For termination actions, remove the individual's ability to use provisioned access to BCSI (unless already revoked according to Part 5.1) by the end of the next calendar day following the effective date of the termination action.

SCF Controls: HRS-01.1, IAC-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support formal user registration and de-registration processes, though the organizational policies, approval workflows, and periodic entitlement reviews that govern these processes must be established separately.

VCF SSO is the centralized authentication and identity service, supporting multiple user provisioning methods. Organizations can choose between Just-In-Time (JIT) provisioning, where user accounts are dynamically created upon first login from a configured identity provider, and Groups Pre-provisioning, where users and groups are synchronized from a directory source in advance. JIT provisioning requires no additional configuration beyond the identity provider setup, and can also handle group membership with options for either pre-provisioned groups or just-in-time group creation. For directory-based provisioning, VCF supports syncing users directly from groups, including nested group synchronization that imports all users from a selected group and its child groups. Active Directory or LDAP integration provisions users and groups from the enterprise directory. VMware vCenter Identity Provider Federation also supports external OIDC providers, including Okta and PingFederate. When configured with PingFederate, the integration requires a SCIM 2 application and supports User Create, User Update, and User Disable/Delete operations by default, providing a direct mapping to the provisioning and de-provisioning lifecycle this control describes. After initial identity provider configuration, administrators log in to each component with the local admin account and assign the necessary service roles to provisioned users and groups. This two-step process, where accounts are first provisioned through VCF SSO and then granted specific roles, enforces a structured approach to access rights assignment.

VCF Operations provides centralized management of identity provider configuration and user and group provisioning across VCF instances. It supports importing user accounts from external authorization sources such as LDAP databases or SSO servers through the Access Control interface. Imported users and groups receive role-based access control permissions that govern what objects and interface areas they can access. Access groups define granular rights including the ability to add, edit, or delete dashboards, or to view, configure, or manage objects. User groups can be created manually, imported from a single sign-on server, or imported from an LDAP database. VCF Operations user accounts can also be disabled through the Access Control interface to deactivate a user.

VCF Automation includes an Access Control service that supports identity operations for managing groups and users. System Administrators can create other system administrator and user accounts in the provider organization. Organization Administrators can view role rights or create roles local to their organization. VCF Automation supports cloning of rights bundles and global roles, with the ability to modify selected rights for the cloned role. This allows administrators to build custom access configurations tailored to specific provisioning requirements. User accounts in VCF Automation can have their name, password, and role assignments edited through the Access Control interface. Provider administrators can create projects, assign users and groups, and allocate quotas to restrict available configurations. When OIDC is configured as the identity provider, imported users authenticate with the credentials established in the external identity provider.

For de-provisioning, VCF provides several mechanisms across its components. VCF Automation supports explicit user account deactivation: disabling a user does not remove them from the organization, allowing reactivation if needed later. Before a user can be deleted in VCF Automation, their access must be disabled first, enforcing a controlled removal process. VCF Operations user accounts can similarly be disabled through the Access Control interface. When the identity provider configuration is reset or deregistered in VCF SSO, the provisioned users and groups are removed, and service roles must be reassigned after reconfiguration. Deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes the provisioned users and groups.

In NSX, user accounts must be created and activated before any role assignments can be made. VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

At the Consumption layer, VMware Kubernetes Service (VKS) clusters within vSphere Supervisor enforce a Kubernetes-native access control model that ties permission assignment to explicitly defined RBAC objects and an authoritative identity source. DevOps users and groups to whom Kubernetes permissions are assigned must exist in the configured identity source integrated with VCF SSO, so that removing a user from the identity source revokes their ability to authenticate to VKS clusters. VKS cluster provisioning requires that cluster users and roles be defined as part of the cluster lifecycle, establishing a registration step before access rights can be granted. Access rights are assigned by creating RoleBindings or ClusterRoleBindings that associate a Role or ClusterRole with a specific user or group identity. These bindings name specific identity source principals and can be audited against the identity source to detect orphaned bindings where the referenced identity has been removed but the binding remains. Kubernetes documentation requires that user account creation prevent reuse of deleted user names, so that a newly provisioned account with the same name does not silently inherit the RoleBindings of its predecessor. VKS separates ServiceAccounts used by workloads from human user accounts, allowing different provisioning and de-provisioning procedures to be applied to each class of identity. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level. For administrators, the Kubernetes documentation recommends creating a least-privilege kubeconfig for routine work and reserving elevated permissions for break-glass access only.

The Argo CD Supervisor Service, when deployed, enforces its own RBAC layer through policy rules and group mappings. Local accounts can be defined in the localAccounts configuration and granted roles through RBAC policy rules and group assignments. Argo CD also supports OIDC authentication with global RBAC policies for federated identity scenarios. Cluster registration for Argo CD creates ClusterRole and ClusterRoleBinding objects that explicitly associate service account identities with their permitted cluster-wide scope. The Secret Store Supervisor Service similarly enforces RBAC for administrators, DevOps engineers, and application tenants, maintaining role-based separation within the Supervisor Services layer.

Across all components, VCF enforces a privilege model where fine-grained access controls are grouped into roles, which are then mapped to users or groups. Each VCF component, including VMware vCenter, VCF Operations, and VCF Automation, enforces permissions based on assigned roles, so provisioning a user account is distinct from granting specific access rights. Administrative operations in VCF Operations require a user with the ADMIN role, maintaining role-based separation.

VCF contributes the technical enforcement layer for user provisioning and de-provisioning. The formal registration process, approval workflows, and periodic entitlement reviews that this control requires are organizational responsibilities outside VCF's scope.

VMware Private AI Services (PAIS) integrates with an external OIDC provider for user authentication, configured through the PAIS activation process on an organization namespace with the issuer URL, client ID, and OIDC scopes. Identity and access management for PAIS is set up in coordination with the OIDC provider administrator, making the external OIDC directory the authoritative source of user identities for PAIS. The oidc-authorized-groups, oidc-groups-claim, and oidc-extra-audiences settings on the organization namespace configure which OIDC groups are accepted, which claim carries group membership, and which additional OAuth 2.0 audiences PAIS will accept when validating the Access Token.

Access to PAIS is gated on OIDC group membership through the authorizedGroups configuration. Only user accounts that belong to one or more of the specified authorized groups (such as group-for-pais-access-01 or group-for-pais-access-02) can access the service. The OIDC configuration includes a groups scope that surfaces group membership in the Access Token, so PAIS enforces the authorization decision at service access time based on current group membership in the external directory. Removing a user from an authorized OIDC group at the provider revokes that user's access to PAIS at the next token issuance.

Within the PAIS platform, organization administrators control which users can perform privileged operations. An organization administrator account is required to activate PAIS in an organization namespace in VCF Automation. A user must be added to a project and namespace in the VCF Automation All Apps organization before that user can provision GPU-accelerated VMware Kubernetes Service (VKS) clusters or request Deep Learning VM and AI catalog items. Catalog item visibility in VCF

Automation is scoped to project membership, restricting which users can request AI workloads from the Private AI Services Quickstart blueprints.

For the model gallery and image registry, a Harbor robot account is created for the project allocated to the model gallery, providing a non-interactive credential that is separate from end-user identities and can be rotated or removed independently. Personal access tokens generated from a user's account settings provide programmatic access to PAIS Knowledge Bases and linked data sources, allowing tokens to be issued, scoped, and revoked separately from the user's interactive sessions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) 9.1 provides structured user provisioning and de-provisioning capabilities that support a formal access rights lifecycle for both local accounts and directory-integrated users.

User accounts in DSM are managed through two identity sources: local users created and managed within the DSM platform itself, and LDAP/LDAPS users authenticated through an enterprise directory service such as Active Directory. DSM can be configured to use one or both identity sources independently. The first local user account is the DSM administrator, created during deployment of the DSM Provider Appliance. That account is mandatory and cannot be deleted. All subsequent local user creation requires administrator credentials, meaning only authorized personnel can add new accounts to the system.

When provisioning a local user, an administrator must specify the user's role, email address, and password through the DSM user creation workflow, accessible in the vSphere Client or the DSM UI. DSM's two built-in roles define the access scope: the Administrator role manages the platform, namespaces, and other users, while the User role creates and maintains individual databases. Namespace access is assigned at user creation. Administrators can modify both role assignments and namespace access for existing local users through the user management interface. Administrators can delete local user accounts when removal is the appropriate de-provisioning action. Alternatively, to prohibit a user's access to DSM while keeping databases running, an administrator can reset the user's password and delegate database management to a different user.

For directory-integrated environments, DSM supports LDAPS authentication and allows assignment of roles to Directory Service Groups, enabling group-based access control for LDAP users. When a user's directory group membership changes, their effective access within DSM reflects the group role assignment.

For SQL Server databases provisioned within VCF Automation, DSM data service policies define the allowed user types for databases created under the policy. Administrators can configure policies to permit Windows Principal authentication using Active Directory credentials, SQL User authentication using standard SQL Server login credentials, or both. For automated Active Directory integration, DSM requires a privileged Active Directory account with permissions to write service principal names (SPNs) and perform dynamic DNS updates. SQL Server databases map the dbo user, the database object owner, to administrator-controlled identities.

The Permissions view in the DSM dashboard provides a consolidated interface for creating, monitoring, and managing all configured user accounts and directory service groups. Because user login precedence between local and LDAPS accounts must be managed deliberately to avoid authentication conflicts, organizations should establish clear provisioning procedures that address the ordering and priority rules DSM applies.

DSM's mechanisms support the technical registration and de-registration workflow but do not themselves constitute a formal process. The control's requirement for governance-level procedures governing access rights assignment extends to organizational approval workflows, access review cycles, and documented registration practices that operate outside the platform. Organizations must establish these processes independently, using DSM's user management capabilities as the technical enforcement layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a native user management system accessible through Administration > Accounts > Users on the Avi Controller. Administrators can create local user accounts, assign each account a specific role and tenant scope, and remove accounts when access is no longer required. Each user account stores role and tenant assignments directly, supporting granular scoping of permissions per deployment.

Avi's RBAC model supports both local user accounts validated against an internal database and remote authentication through LDAP or SAML. Auth Mapping Profiles extend the RBAC model by binding external directory group membership to specific Avi roles and tenants at login time. When a user's group membership changes in the directory, the Auth Mapping Profile applies the updated role and tenant assignments on the next login, without requiring manual changes inside Avi. Multiple Auth Mapping Profile rules can be configured so that a single user's LDAP or SAML group memberships determine distinct roles across multiple tenants simultaneously. SAML integration with Microsoft Active Directory Federation Services (ADFS) is also supported, with configurable issuance authorization rules that control which users may access the relying party.

Avi Controller allows creation of custom roles according to specific access requirements when predefined roles do not fit an account's needs. The Tenant-Admin role can be scoped so that tenant administrators can create, update, and delete cloud infrastructure within their tenant boundary without affecting other tenants. Avi GSLB extends user provisioning to global load balancing by supporting the creation of non-admin users with assigned roles for granular access control across GSLB deployments. The Avi License Hub also supports role-based access control by assigning roles to individual users or groups defined in an external identity provider.

User accounts are attached by default to the Default-User-Account-Profile, and administrators can create new user account profiles with different concurrent session thresholds to meet organizational security requirements.

Organizations should establish and document formal procedures for user registration, access approval, and de-registration to govern how and when accounts are created or removed in Avi. The technical mechanisms Avi provides, including account creation and deletion, role assignment, and directory integration via Auth Mapping Profiles, support a formal lifecycle process but do not replace the organizational procedures the control requires.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 R2

> Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in CIP-004-7 Table R2 – Cyber Security Training Program. [Violation Risk Factor: Lower] [Time Horizon: Operations Planning]

SCF Controls: HRS-03.1, SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 R3

> Each Responsible Entity shall implement one or more documented personnel risk assessment program(s) to attain and retain authorized electronic or authorized unescorted physical access to BES Cyber Systems that collectively include each of the applicable requirement parts in CIP-004-7 Table R3 – Personnel Risk Assessment Program. [Violation Risk Factor: Medium] [Time Horizon: Operations Planning].

SCF Controls: HRS-01, RSK-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-004-7 R4

> Each Responsible Entity shall implement one or more documented access management program(s) that collectively include each of the applicable requirement parts in CIP-004-7 Table R4 – Access Management Program. [Violation Risk Factor: Medium] [Time Horizon: Operations Planning and Same Day Operations].

SCF Controls: IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 R5

> Each Responsible Entity shall implement one or more documented access revocation program(s) that collectively include each of the applicable requirement parts in CIP-004-7 Table

SCF Controls: IAC-20.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms for revoking logical access authorizations across its component products, though full compliance with this control also requires organizational processes governing when and how revocation occurs.

VCF Automation includes dedicated access token revocation capabilities. Administrators can revoke access tokens for individual users through the Administration access control settings, navigating to a specific user's access control page to view and revoke their active tokens at any time. When a user's access needs to be suspended rather than permanently removed, VCF Automation supports disabling the user account, which blocks access while preserving the account for potential reactivation later. Provider account access can also be revoked and accounts deleted through administrative controls. Deactivating the provider consumption organization feature flag blocks access to that organization through the UI and the Provider Management API without deleting the underlying organization data.

For service accounts, VCF uses API access tokens that rotate after each use. Access tokens have a default lifetime of one hour and are derived from a refresh token that lasts 90 days. The refresh token can be revoked before its expiration and optionally rotated with each access token request, giving administrators control over the window of valid access for automated integrations.

At the VMware vCenter layer, the AuthorizationManager provides programmatic methods for modifying and removing access authorizations. RemoveAuthorizationRole allows deletion of defined roles, and SetEntityPermissions allows administrators to reassign or clear permissions on specific inventory objects. The ResetEntityPermissions method replaces existing permissions with a new set of permissions on vSphere inventory objects, providing a bulk permission replacement capability.

AuthorizationManager enforces role-based access control across vSphere components, restricting access to server objects based on the permissions associated with each object. System administrators with the Manage General ACL right in VCF Automation can also create, modify, and remove specific access control lists through the accessControls API, providing another path for revoking granular permissions.

NSX enforces access restrictions on objects owned by principal identities. Users without the Enterprise Administrator role cannot modify or delete protected objects, while Enterprise Administrators retain the ability to modify or delete those objects when access changes are required. This layered ownership model provides a controlled mechanism for adjusting access to network configuration objects.

Because authentication is centralized through VCF SSO, disabling or removing a user's identity source account effectively revokes access across all VCF components simultaneously. When an authentication source needs to be fully decommissioned, deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes all provisioned users and groups associated with it. When resetting VCF SSO to change the identity provider, provisioned users and groups must be removed and then reassigned required service roles in each component. These mechanisms provide broad revocation capabilities for scenarios such as identity provider migrations or environment decommissioning.

For Kubernetes workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, revocation operates at multiple layers of the access model. At the namespace level, permissions control which users can self-provision namespaces through kubectl, with the Administrator role as the default when permissions are unset. Users with the Namespaces.Edit privilege on a user-created Namespace folder can perform create, patch, update, delete, watch, get, and list operations on Kubernetes API resources.

Within VKS clusters, the primary revocation mechanism for user access is deletion of RBAC binding objects. Removing a RoleBinding takes effect immediately for new API requests within the specific namespace; removing a ClusterRoleBinding

revokes access across the entire cluster. Because Kubernetes RBAC authorization is evaluated at request time against the current state of the authorization store, there is no delay between removing a binding and its effect on subsequent requests. Administrators should avoid assigning users to the `system:masters` group, as membership bypasses all RBAC rights checks and cannot be restricted or revoked through standard RBAC mechanisms; access should instead be granted through named roles and bindings that can be individually removed.

Service account access within VKS clusters is revoked by deleting the `ServiceAccount` object or its associated token `Secrets`. `ServiceAccount` tokens can also be explicitly revoked through the Kubernetes API, and a token's validity can optionally be bound to the lifetime of a specific API object, causing it to become invalid automatically when that object is deleted. Short-lived bound tokens issued via the `TokenRequest` API expire automatically without requiring explicit revocation; however, `TokenRequest` API tokens are not suited for user authentication because no revocation method exists for them. Kubernetes RBAC should be used to enforce least-privilege access to `Secret` objects, limiting the data a service account can reach after credentials are injected into containers running in a namespace.

Authentication for Supervisor namespaces integrates with VCF SSO via OIDC. When a user is removed from the identity provider, new authentication requests fail at the VCF SSO layer. OIDC tokens carry a finite lifetime and the API server may cache authentication state, creating a window between identity provider deprovisioning and complete access termination; administrators should account for this in deprovisioning procedures. Minimizing the number of active authentication mechanisms in a cluster further reduces the paths through which a user might retain access after being deprovisioned from the primary identity source.

Within individual virtual machines, VCF SSO user mappings to guest operating system accounts can be removed, revoking VCF SSO-authenticated access to specific guest accounts without affecting the user's broader platform permissions.

For virtual machine access to physical devices, VMware ESX allows administrators to revoke device access by removing the associated virtual device from the VM configuration. This applies to USB, storage, optical disc drives, virtual GPU, and PCI passthrough devices that have been granted to a guest. ESX also allows administrators to deactivate shell access for individual users. When shell access is deactivated for a user with administrative privileges, that user can no longer grant shell access to other users or modify the passwords of users who have shell access.

Role-based access control across vCenter, ESX, NSX, and VCF Operations supports granular permission removal at each layer. When vCenter permissions change, VCF Operations refreshes those permissions at fixed intervals defined in its `auth.properties` configuration, or users can log out and back in to pick up changes immediately. This cross-component RBAC model, combined with the centralized VCF SSO revocation path, allows administrators to revoke access at multiple levels of granularity depending on the situation.

VMware Private AI Services (PAIS) gates access to its endpoints through OIDC group-based authorization. The Private AI Services configuration includes an `authorizedGroups` setting that names the OIDC groups permitted to reach PAIS in a given organization namespace, with example group names such as `group-for-pais-access-01` and `group-for-pais-access-02`. Removing a user from a configured group in the external OIDC identity provider revokes that user's access at the next authentication or token refresh, because PAIS validates group membership against the groups claim in the access token. The OIDC integration is configured with an issuer URL, the `pais-authentication-id` client ID, and the `openid`, `groups`, and `offline_access` scopes. PAIS requires the OIDC provider to be registered as a public client application with Authorization Code and Refresh Token grant types, and it supports configurable Extra Audiences and a configurable groups claim name to align with the OIDC provider's token format. Activation requires coordination with the OIDC provider administrator.

PAIS exposes several revocation surfaces for non-interactive access as well. Model endpoints deployed through PAIS use a `harbor-pull-secret-readonly` credential to pull container images from the private Harbor registry, and rotating or deleting this secret revokes the endpoint's ability to pull new images. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and linked data sources and can be revoked individually. Remote Model Context Protocol (MCP) servers connected to PAIS can optionally use static authentication tokens that can be rotated to revoke access. Passwords entered through the Private AI Services Quickstart, including the private container registry password and proxy password, are saved as VCF Automation secrets, where they can be rotated or deleted.

Platform identity store management and tenant detachment are handled outside PAIS. VCF SSO governs identity for the surrounding VCF platform, and detaching a VMware vCenter from VCF Automation requires verifying that the associated identity provider has been deleted on the vCenter Identity Providers page. PAIS does not manage identities or group membership directly; primary revocation occurs in the organizational OIDC provider and in the VCF identity layer. The control also covers physical access authorization revocation, which is handled outside the platform.

VMware vDefend (Contributes)

VMware vDefend contributes to access authorization revocation through network-level controls that can immediately restrict or terminate connectivity for users and workloads, complementing the identity and credential revocation mechanisms provided by other VCF components.

vDefend (DFW) and Gateway Firewall (GFW) policies can be updated to deny network access to specific workloads, IP addresses, or network segments. Because firewall rules are enforced at the vNIC level (Distributed Firewall) and at tier-0/tier-1 gateways (Gateway Firewall), changes take effect immediately across the fabric without requiring affected workloads to be restarted or reconfigured. Administrators revoking access can add deny rules or remove allow rules to cut off network connectivity for a user, application, or workload. Security Intelligence supports this by allowing administrators to modify allow actions to deny, effectively enforcing microsegmentation as part of the revocation process. Organization Admin ownership of firewall rules restricts project members from accessing rule modifications, adding a governance layer over the revocation mechanism itself.

vDefend Identity Firewall (IDFW) provides identity-based network access control by integrating with Active Directory. IDFW maps users to IP addresses to enable identity-based filtering and access control, and applies security policies to virtual machines based on dynamic name-based criteria combined with Active Directory group membership of logged-in users. When an AD administrator modifies or removes a user's group membership, AD administrators should force a logout so that Identity Firewall rule changes take effect and reflect current group membership. Identity Firewall rules enforce context-aware access control by matching AD group membership to network traffic, including blocking SSH access for specific user groups. In Remote Desktop Session Host (RDSH) environments, administrators create Active Directory security groups to allow or deny users access to application servers based on their assigned role, making revocation as straightforward as modifying the relevant AD group.

Security Services Platform (SSP) supports deletion of remote user and remote user group role assignments when LDAP is configured as an authentication provider, providing a mechanism for revoking management-plane access to vDefend capabilities. SSP implements Role-Based Access Control (RBAC) to limit system access based on user roles so that only authorized users can perform specific actions within the platform, including the License Hub.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the revocation of logical access to database services. The platform exposes user management capabilities through its administrator interface that allow authorized administrators to remove access at multiple levels.

The primary revocation mechanism for local users is account deletion. Deleting a user from DSM revokes their access to the system. The revocation process involves an additional step before deletion: the administrator must first reset the user's password, which immediately blocks continued access, and then delegate management of any databases owned by that user to a different account. This sequenced process is available through the user management interface, where DSM administrators can edit role assignments and namespace access for existing local users, and delete those users entirely. The initial DSM administrator account created during deployment of the Provider Appliance is mandatory and cannot be deleted, which is a constraint on full access revocation at the administrator tier.

For local user accounts, DSM includes a `force\_password\_change` flag that administrators can configure. This flag can be used as part of an access review workflow to require immediate credential rotation before full account removal, reducing the window of access for a user whose authorization is being revoked.

When DSM is integrated with a directory service via LDAPS, the directory becomes the authoritative source for user identity. Disabling or removing an account in the connected directory restricts access accordingly. Reconfiguring the LDAPS server or group in DSM may also result in loss of access for users not registered with the new configuration. At the individual database level, DSM supports enabling or disabling directory service authentication per database, which allows administrators to restrict authentication for specific databases independently of the global directory configuration.

At the database privilege layer, DSM manages privilege assignments for provisioned databases. For MySQL, DSM revokes create and update privileges on objects in the ``mysql.system`` schema for database users, establishing a least-privilege baseline. MySQL users created with LDAPS authentication can also be granted specific privileges using the GRANT command to restrict access to designated databases. For SQL Server, DSM assigns the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative rights, and an internal management login (`dsm_mgmt`) restricts users from accessing or modifying system-level objects. These privilege assignments are managed by the platform rather than requiring manual revocation by administrators.

Physical access revocation is outside the scope of DSM, as it is a software platform that operates on top of the vSphere infrastructure layer. Full compliance with this control requires organizational processes for managing the lifecycle of access authorizations, including timely removal of directory accounts when users leave or change roles, and procedural enforcement of the multi-step local user deletion workflow.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports logical access revocation through several mechanisms within its management and data planes.

For local administrator accounts, access can be revoked by deleting the account or removing the user's role assignments through the Avi Controller UI or REST API. The Controller can also be configured to restrict access for any user who does not have a defined role, so that removing a user's role assignment is sufficient to revoke access without deleting the account. The superuser flag on Controller accounts can be disabled to immediately reduce a user's privileges across all tenants and roles. For administrators using password-less SSH-based login, a dedicated REST API endpoint allows targeted deletion of individual SSH public keys, supporting revocation of specific credentials without affecting the account as a whole.

The Avi Controller system administrator can create temporary tokens for users that grant access for a limited duration. These tokens automatically expire at the configured time, revoking access without requiring explicit deletion. This provides a time-bounded access mechanism suitable for temporary or delegated access scenarios.

Granular role-based access control allows app owners to remove specific object labels from a resource, discontinuing access for other users scoped to that object. The Avi License Hub provides an additional administrative path for access revocation: it allows deletion of all current user role assignments to remove an identity source.

When Avi is integrated with an external identity provider via LDAP, SAML, or OAuth/OIDC, access is governed through Auth Mapping Profiles that bind user group memberships to Avi roles and tenants. Revoking access in these configurations requires removing the user from the relevant group in the external directory; the Auth Mapping Profile then rejects their access on the next authentication attempt. Auth Mapping rules can also be updated directly to deny privileges to specific users, preventing them from obtaining any roles or tenants upon login. The Controller Access Policy provides configurable authentication and authorization fields to define and enforce these mappings. Basic Authentication can be deactivated when no longer required, narrowing available authentication pathways.

At the data-plane level, the Controller automatically revokes secure channel credentials for all Service Engines when the Controller cluster enters manual recovery state. This provides a mechanism to invalidate data-plane trust relationships as part of incident response or planned recovery operations.

One architectural consideration applies to client-facing JWT authentication. JWTs used in OAuth/OIDC flows are designed as portable, decoupled identities that cannot be revoked at the authorization server level once issued. Organizations using JWT-based client authentication should configure short token expiry windows to limit exposure from tokens that cannot be individually recalled. Avi provides a configuration API for defining JWT authorization policies under the

ssopolicy:authorization_policy:authz_rules path, allowing fine-grained control over which tokens can access specific resources.

Physical access revocation is outside Avi's scope; that capability rests with VCF platform controls and organizational physical security processes.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-004-7 R6

> Each Responsible Entity shall implement one or more documented access management program(s) to authorize, verify, and revoke provisioned access to BCSI pertaining to the “Applicable Systems” identified in CIP-004-7 Table R6 – Access Management for BES Cyber System Information that collectively include each of the applicable requirement parts in CIP- 004-7 Table R6 – Access Management for BES Cyber System Information. To be considered access to BCSI in the context of this requirement, an individual has both the ability to obtain and use BCSI. Provisioned access is to be considered the result of the specific actions taken to provide an individual(s) the means to access BCSI (e.g., may include physical keys or access cards, user accounts and associated rights and privileges, encryption keys). [Violation Risk Factor: Medium] [Time Horizon: Same Day Operations and Operations Planning].

SCF Controls: IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System

Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with

downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also

supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-005-7 1.1

> All applicable Cyber Assets connected to a network via a routable protocol shall reside within a defined ESP.

SCF Controls: NET-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network

Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Contributes)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-005-7 1.2

> All External Routable Connectivity must be through an identified Electronic Access Point (EAP).

SCF Controls: NET-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network

Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Contributes)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-005-7 1.3

> Require inbound and outbound access permissions, including the reason for granting access, and deny all other access by default.

SCF Controls: NET-04

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides multiple layers of access control list (ACL) mechanisms and network traffic restriction capabilities that contribute to data flow enforcement, though full ACL governance across physical and virtual infrastructure requires organizational processes and may benefit from VMware vDefend for advanced stateful firewall rule sets.

At the network infrastructure layer, VCF uses vSphere Distributed Switches to centrally manage VLAN assignments, port group policies, and traffic shaping rules across all hosts in a workload domain. Distributed switches support traffic shaping policies that limit the bandwidth of incoming traffic, helping restrict which traffic types and volumes can traverse each network segment. Distributed port groups and uplink port groups also support a Traffic Filtering and Marking Policy, where per-rule actions can be set to Allow, Drop, or Tag traffic based on defined match criteria, providing rule-based traffic enforcement at the virtual switch level. Traffic segmentation is built into VCF's architecture: management, vMotion, vSAN, and NFS traffic each run on dedicated VLANs and VMkernel ports, and the vMotion network must be distinct from the vSAN network. This separation restricts which traffic types can traverse each segment by design. Private VLANs (PVLANs) provide additional Layer 2 isolation within a single VLAN through virtual network segmentation on distributed virtual switches, limiting communication between VMs even on the same segment. Distributed switches also support VLAN-based SPAN (VSPAN) for virtual distributed port mirroring, which aids in monitoring and validating traffic flows. At the ESX host level, a built-in firewall operates on a deny-by-default basis, closing all ports except those an administrator explicitly designates as authorized, giving each host an independent network access control point.

NSX extends these capabilities with software-defined networking constructs including segments, Tier-0 and Tier-1 gateways, and Virtual Private Clouds (VPCs). NSX Tier-0 gateways can be configured with linked Tier-1 gateways to create multi-tier topologies, enabling route-based traffic restrictions between network tiers. NSX edge gateways handle north-south routing. With vDefend deployed, North-South Firewall Rules on these gateways provide traffic protection, and an NSX project's default gateway firewall and distributed firewall rules (a vDefend capability) govern the default behavior of north-south and east-west traffic for workloads in that project. VPCs are self-contained virtual network environments that provide an abstraction layer for setting up isolated virtual private cloud networks with their own topology, IP address management, and permission models, allocatable to discrete projects in a self-service consumption model. NSX Manager enforces approved authorizations for controlling the flow of management information within network devices based on information flow control policies.

NSX also provides data flow enforcement at the load balancer tier through its Access List Control (ALC) feature. The NSX load balancer compares all traffic flowing through it with ACL statements, which either drop or allow the traffic based on configured rules. This gives administrators another enforcement point for restricting network traffic to only what is authorized.

At the Consumption layer, VMware Kubernetes Service (VKS) and the Supervisor extend ACL enforcement to containerized workloads through Kubernetes NetworkPolicy resources, which function as Layer 3/4 ACLs for pod-level traffic. NetworkPolicy objects specify allowed ingress and egress traffic by pod selector, namespace selector, IP block, port, and protocol; pods not selected by any NetworkPolicy receive no restriction by default, making explicit policy deployment necessary to enforce a default-deny posture across a cluster. VKS clusters run Antrea as the default CNI plugin, which implements NetworkPolicy enforcement through the AntreaPolicy feature gate and provides per-policy and per-rule packet and byte count statistics through the NetworkPolicyStats capability, giving administrators visibility into which policies are actively restricting traffic. For VKS clusters using NSX VPC networking, NSX-backed network policies apply distributed ACLs at the hypervisor level, extending enforcement beyond the CNI layer. The ovn-kubernetes Transparent network mode similarly supports distributed ACLs applied via Kubernetes NetworkPolicy resources. For Layer 7 traffic control within VKS clusters, the Istio service mesh standard package provides a pluggable policy layer and configuration API supporting access controls, rate

limits, and quotas based on workload identity; when deployed in ambient mode with strict mutual TLS, all service-to-service traffic within the mesh is subject to authentication before authorization checks apply, restricting lateral movement to explicitly permitted paths.

For file-level and storage data flow isolation, the Supervisor uses ACLs to isolate file share access within supervisor namespaces, restricting data access between workloads running in different namespaces. vSAN file services support managing ACLs on SMB shares using the MMC tool, giving administrators granular control over which users and systems can access shared storage resources. Administrators should be aware that ACL-based file share isolation in the Supervisor carries a risk of IP spoofing, which should be addressed through complementary network controls when deploying file shares in multi-tenant environments. Argo CD deployments on the Supervisor implement network segmentation and firewall rules to control communication between Argo CD components, following the principle of restricting inter-component traffic to only what each component requires. The Harbor container registry standard package enforces role-based access control over artifact access, complementing network-layer ACLs with image-level access restrictions.

For object-level access control, VCF Automation maintains an ACL table that defines which users can access specific defined entities. System administrators with the Manage General ACL right can create, modify, and remove ACL entries through the accessControls API. Those with the View General ACL right can audit ACL assignments on specific entities. Access to runtime defined entities is controlled through rights bundles and ACL entries. This ACL mechanism works alongside role-based access controls so that rights determine what actions a user can perform while ACLs determine which objects those actions apply to.

VCF Operations for Networks supports ACL visibility through its network assurance and verification capabilities, which allow administrators to validate that ACL configurations are applied as intended across the managed environment. This includes the ability to verify ACL configurations on supported physical network equipment such as Cisco ASR routers, helping validate that physical and virtual network access controls are consistent.

For workload-level traffic enforcement with stateful firewall rules, microsegmentation, and deep packet inspection, VMware vDefend and Gateway Firewall extend VCF's networking foundation with fine-grained Layer 2-7 policy enforcement. Organizations that require ACL governance beyond what VCF provides natively should establish processes for ACL review cycles, change management for firewall rules, and regular validation of both physical and virtual network access controls.

VMware vDefend (Meets)

VMware vDefend provides the primary data flow enforcement mechanism within VCF through its Distributed Firewall, Gateway Firewall, and Security Intelligence capabilities. These capabilities function as software-defined access control lists governing traffic between workloads, segments, and external networks.

The vDefend distributed firewall enforces Layer 2-7 access policies at the vNIC level on every workload. Administrators define firewall rules that explicitly permit or deny traffic based on source and destination groups, ports, protocols, application identity, user identity via Active Directory integration through Identity Firewall, and fully qualified domain names (FQDN filtering). Because enforcement happens at the workload's virtual network interface, traffic is filtered before it reaches the physical network, and policies follow the workload as it moves between hosts. The Application Connectivity Strategy's "Allow Intra, Deny Other Traffic" mode automatically generates an intra-group ALLOW rule with optional logging plus a default ANY/ANY/DROP rule to isolate the group, providing a structured default-deny posture that restricts traffic to only what is explicitly authorized.

URL filtering provides an additional access control layer, enabling rule-based restrictions based on URL categories, URL reputation scores, and custom URL lists applied to both HTTP and HTTPS traffic. Identity Firewall rules can specify source users or groups, destination resources, services, and context profiles to allow or deny traffic based on Active Directory group membership. These rules support Allow and Reject actions and can be applied to physical devices where users log in, as well as to tier-0 and tier-1 gateways. Role-based access control within the Distributed Firewall governs who can create or modify firewall rules, restricting policy changes to authorized personnel.

The vDefend gateway firewall provides stateful North-South traffic inspection at Tier-0 and Tier-1 gateways, enforcing ACL-equivalent rules on traffic entering or leaving network segments. The Gateway Firewall supports Identity Firewall integration

with Active Directory for identity-based access control at the perimeter. Together, the Distributed and Gateway Firewalls address both East-West (inter-workload) and North-South (perimeter) data flow enforcement.

Security Intelligence, hosted on the Security Services Platform, supports ACL governance by observing traffic flows between applications and environments. Security Intelligence classifies flows as allowed, blocked, or unprotected and generates policy recommendations with segmentation strategy actions of Allow (creates a default traffic flow allow rule) or Drop (creates a default traffic flow drop rule). When a security policy is published, a rule is automatically generated to allow intra-application traffic. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, helping administrators identify unauthorized communication patterns and tighten ACL governance over time.

The Security Services Platform governs access to Security Intelligence operations through role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Three permission levels apply across operations: Full Access (Create, Read, Update, and Delete), Read, and None. This restricts policy recommendation and enforcement actions to authorized security personnel.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides network-layer access control list (ACL) enforcement at the application delivery layer through Network Security Policies attached to virtual services. These policies evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. Rules reference named IP Groups, which are reusable collections of IP addresses, IP ranges, and IP network prefixes. A Network Security Policy that denies traffic stops further policy evaluation, so ACL denials take effect before any downstream HTTP Security, Request, or Response policies execute.

Administrators configure Network Security Policies on individual virtual services through the Avi Controller. IP Groups are managed centrally and can be referenced across multiple virtual services, providing a scalable method for applying consistent ACL rules across the environment. The Avi Controller API supports programmatic creation and modification of Network Security rules that match on IP address and apply IP Groups to control access, enabling automated ACL governance through scripts or orchestration systems.

At Layer 7, Avi WAF rule actions support pass (allow) and deny (block) options for controlling traffic based on policy matches, extending data-flow enforcement to the application layer. Avi Load Balancer also supports OAuth/OIDC authorization policies that can match token scope attributes and request paths using CONTAINS and BEGINS_WITH match criteria, enabling granular, path-based access control for API endpoints.

The Avi Controller enforces IP Access Lists on its own management interfaces by programming Linux IP tables on the Controller host, restricting network-layer access to specified management endpoints. These lists, configured under Administration > Controller Access Settings, limit which client IP addresses may reach the Controller API and UI.

These mechanisms scope Avi's ACL enforcement to traffic transiting its virtual services and to Controller management-plane access. ACL governance for east-west and other network traffic not flowing through Avi virtual services relies on VMware vDefend and VCF network controls.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-005-7 1.4

> Where technically feasible, perform authentication when establishing Dial-up Connectivity with applicable Cyber Assets.

SCF Controls: IAC-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms for uniquely identifying and authenticating devices, services, and infrastructure components before establishing connections, using cryptographically-based bidirectional authentication.

VCF SSO is the centralized authentication, authorization, and auditing backbone across the platform. VCF SSO supports both SAML and OIDC authentication protocols, which incorporate replay resistance through nonces, timestamps, and token expiration. Organizations can integrate external identity providers such as Microsoft Entra ID or Ping Identity through these protocols, enabling centralized identity management for both users and service accounts. VCF Operations, VCF Log Management, and other platform components integrate with VCF SSO, providing a single point of AAA policy enforcement across the environment. VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor support both VCF SSO and OIDC-compliant external identity providers for cluster authentication. Supervisor uses Pinnipd to broker OAuth 2.0-based user authentication and group membership resolution with external providers, and cluster access is distributed via kubeconfig files that carry the federated identity configuration. The Kubernetes JWT authenticator verifies that tokens presented to the API server have been signed by the configured issuer and resolves the public signing key from the issuer's OIDC discovery endpoint; multiple JWT issuers can be configured to support multiple identity providers simultaneously.

VMware ESX hosts authenticate to VMware vCenter using cryptographic credentials during the host addition process. Each ESX host has a unique machine SSL certificate issued by a Certificate Authority, and the CommonName in the certificate must match the host's FQDN or IP address used to add it to the vCenter system. vCenter validates this certificate before accepting the host into the managed inventory, and the root certificate of the CA must be present in the trusted root store of both vCenter and connected ESX hosts. This mutual TLS authentication is bidirectional: the host verifies it is communicating with a legitimate vCenter, and vCenter verifies the host's identity through its certificate.

For machine-to-machine communication, NSX supports Principal Identity certificates as the preferred approach for authenticating automated clients and service integrations. Any NSX Manager client can create and use a Principal Identity certificate, providing certificate-based mutual authentication that is inherently bidirectional and cryptographically-based. NSX requires authentication prior to establishing any management connection for administrative access. For network-layer device authentication, NSX BGP neighbor communication can be configured with password-based authentication to verify the identity of routing peers before establishing sessions.

VCF enforces TLS as the transport security protocol for inter-component communication. Components such as Telegraf are configured with a minimum TLS version that provides bidirectional authentication through the TLS handshake, cryptographic key exchange, and built-in replay protection. vCenter supports holder-of-key security token authentication through the LoginByToken method, which binds the authentication token to a specific cryptographic key held by the client, providing proof of possession that is resistant to token replay. Valid session identifiers in vSphere verify the identity of principals and establish trust with API endpoints.

Within the Consumption layer of the VCF platform, VKS clusters on vSphere Supervisor implement bidirectional cryptographic authentication between all Kubernetes cluster components. Each kubelet presents an X.509 client certificate to the Kubernetes API server during connection establishment, and the API server presents its own certificate in return, forming a mutual TLS handshake that is cryptographically based and replay resistant. Operators can restrict the cipher suites accepted for API server connections using the kube-apiserver `--tls-cipher-suites` parameter, set a minimum protocol version using `--tls-min-version`, and apply equivalent constraints at the node level via the KubeletConfiguration `tlsCipherSuites` and `tlsMinVersion` fields. The Kubernetes Scheduler exposes an equivalent `--tls-cipher-suites` parameter for its own API surface. VKS clusters include TLS certificates supporting cryptographic authentication among all cluster components, and the guidance recommends configuring short certificate lifetimes and automating rotation to reduce the exposure window for any

compromised credential. For ingress, the Contour ingress controller available as a standard VKS package supports a configurable `tls.minimum-protocol-version` parameter. For service-to-service authentication within VKS workload clusters, Istio is available as a standard package and enforces mutual TLS between services using X.509 certificates issued by Istio's built-in certificate authority; the minimum TLS protocol version for the mesh is configurable via `meshConfig.meshMTLS.minProtocolVersion`, which defaults to TLS 1.2 and supports TLS 1.3. Antrea, the default CNI for Supervisor, supports configurable TLS cipher suites for its own control-plane communication. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates. For environments subject to strict cryptographic requirements, VKS ClusterClass variables support enabling FIPS mode via the `fips.enabled` setting, which restricts the cluster to FIPS-validated cryptographic modules for all component communication. Harbor, available as a Supervisor service, presents a TLS certificate to clients before any image pull or push operation, providing cryptographic authentication for the container registry endpoint.

Network devices discovered and managed through VCF Operations are authenticated using credentials appropriate to their connection type. VCF Operations supports SSH, SNMP v2, SNMPv3, and API-based access credential types for device discovery and ongoing management. SNMPv3 includes authentication and privacy parameters that provide cryptographic verification of device identity. VCF Operations also supports detection and remediation of default manufacturer passwords on network devices, helping to ensure that devices are uniquely authenticated rather than relying on shared default credentials.

For storage devices, VCF supports mutual CHAP authentication, which provides bidirectional cryptographic verification between initiators and storage targets before establishing a connection. The vSAN iSCSI target service supports both CHAP and Mutual CHAP authentication, and the vSphere API provides the `UpdateInternetScsiAuthenticationProperties` method for configuring iSCSI authentication parameters.

The cryptographic foundation underpinning these authentication mechanisms uses FIPS 140-3 validated modules. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, with validation performed through the NIST Cryptographic Module Validation Program. VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3. This validated cryptographic foundation supports the integrity of all certificate-based and token-based authentication operations across the platform. The vCenter appliance uses VMware's Boring Crypto Module version 6.0 and the OpenSSL FIPS Object Module version 3.0, both FIPS-validated, supporting algorithms including AES, ECDSA, HMAC, RSA, and SHA variants for cryptographic operations. Starting in vSphere 9.0, all TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. For VKS clusters, FIPS mode can be enabled via the `fips.enabled` ClusterClass variable, which restricts the cluster to FIPS-validated cryptographic modules for all component communication.

VCF Automation also provides a device authorization OAuth endpoint that implements the OAuth 2.0 Device Authorization Grant flow. This endpoint accepts a client identifier and returns a device code, user code, verification URI, expiration time, and polling interval, enabling devices with limited input capability to authenticate through a secure, time-bounded authorization process.

VMware vDefend (Contributes)

VMware vDefend contributes to device authentication through its NDR Sensor onboarding process and ongoing sensor-to-platform communication. NDR Sensors connect to Security Services Platform using Mutual TLS (mTLS), providing bidirectional, cryptographically-based authentication before establishing the management connection. During initial registration, Security Services Platform generates a unique registration token that is valid for 30 minutes; the sensor presents this time-limited token as part of the mTLS-secured registration sequence, providing replay resistance for the onboarding step. Security Services Platform and NDR Sensor components implement FIPS 140-2 and FIPS 140-3 validated cryptographic modules for the underlying cryptographic operations, including the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861).

Beyond this sensor authentication, vDefend does not provide centralized AAA for general network devices. vDefend enforces policy on traffic flows based on identity, application, and network context, but it does not issue device certificates or manage a

device identity registry for arbitrary network endpoints. That capability falls outside vDefend's scope and would be addressed by network infrastructure and PKI controls at the platform level.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to device identification and authentication at the application delivery layer through configurable SSL/TLS profiles, FIPS 140-3 mode cryptographic enforcement, Hardware Security Module (HSM) integration for hardware-rooted key protection, and support for federated client authentication protocols including SAML, OAuth, and OpenID Connect (OIDC).

Avi's SSL/TLS Profile mechanism, configured under **Templates > Security > SSL/TLS Profile**, defines accepted protocol versions and cipher suites for each virtual service. Administrators can restrict accepted options to those meeting organizational policy for strong, replay-resistant authentication. In 9.1, the SSL Profile includes post-quantum cryptography options for TLS 1.3, providing a path to quantum-resistant authentication at the application delivery boundary. The same profile mechanism applies to the Controller's own management-plane connections, giving administrators a consistent control point for the cryptographic posture of both the data plane and the management interface.

When FIPS mode is enabled on the Avi Controller, all cryptographic operations are restricted to FIPS 140-3 approved algorithms. The Avi Controller uses an OpenSSL FIPS Object Module validated at FIPS 140-3 Security Level 1 (CMVP Certificate #4985). FIPS mode is enabled at the Controller cluster level and scopes cipher suite choices for all Service Engine connections, satisfying the cryptographically-based and replay-resistant dimension of the control for traffic processed at the Avi layer.

For hardware-backed device authentication, Avi Service Engines support integration with Hardware Security Modules, including Thales Luna HSM, through HSM Groups configured under **Templates > Security > HSM Groups**. The Avi Controller performs mutual authentication with HSM devices using client certificate registration and verification, providing hardware-rooted key storage for SSL certificates and supporting the bidirectional authentication requirement.

At the application delivery layer, Avi supports client authentication through SAML 2.0 (with identity providers such as Okta and PingFederate), OAuth 2.0, and OIDC, configured through SSO Policies referencing authentication profiles. These mechanisms allow Avi virtual services to enforce identity verification before forwarding connections, supporting the

Authenticate and Authorize dimensions of the control for workloads behind Avi. LDAP-based federated authentication is also available for environments using directory-integrated identity.

Avi's audit logging infrastructure records authentication failures for SSH and TLS sessions, logging and persisting those records for auditing purposes, covering the Audit dimension of the AAA requirement for authentication events that pass through Avi.

The central device identity infrastructure, including the PKI, certificate authority, and device enrollment and management functions, is provided by VCF rather than by Avi itself. Avi validates certificates at the application proxy boundary but does not operate the device identity registry or provide the central AAA framework for the broader infrastructure. Organizations must ensure that the PKI and device identity management components in VCF are configured to issue and manage certificates for devices connecting through Avi virtual services.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-005-7 1.5

> Have one or more methods for detecting known or suspected malicious communications for both inbound and outbound communications.

SCF Controls: NET-03, NET-08

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides networking infrastructure and monitoring capabilities that support boundary protection at both external network boundaries and key internal boundaries within the virtual environment.

At the external boundary, NSX Edge nodes serve as the communication gateway for inter-location and northbound traffic, establishing a defined perimeter through which external communications traverse. NSX Edge supports policy-based and route-based IPsec VPN services on Tier-0, Tier-0 VRF, and Tier-1 gateways, enabling secure connectivity between sites and to external networks. NAT rules can be configured at the VPC level to perform IP translation between internal and external networks, controlling which workloads are reachable from outside the environment. External IP configurations allow outside connectivity for virtual machines on private networks by performing address translation through 1:1 NAT, granting access to specific workloads rather than exposing entire network segments.

For internal boundary control, VCF provides several layers of network segmentation. NSX segments, VLANs, and Private VLANs (PVLANS) allow administrators to create logical network boundaries that separate traffic at Layer 2. VMware distributed virtual switches support Private VLAN and VLAN-based SPAN for virtual distributed port mirroring. ESX port groups function as communication boundaries and can be configured with security policies to segment traffic between different groups of virtual machines. vSphere Distributed Switch port groups also support a Traffic Filtering and Marking Policy, which can permit or stop traffic on a per-port-group or per-port basis; port blocking policies provide a complementary mechanism to selectively prevent individual distributed ports from sending or receiving data. vSphere Distributed Switches provide centralized management of these boundaries across all hosts in a workload domain, applying consistent VLAN configurations and traffic shaping rules.

VCF supports multiple distributed switch models that isolate traffic at the physical layer. The Storage Separation Distributed Switch model isolates storage traffic onto a separate vSphere Distributed Switch from management and virtual networking traffic. The Workload Separation Distributed Switch model isolates VM Management traffic onto a separate switch from ESX Management, vMotion, Storage, and Virtual Networking traffic. In secure environments, these separation models can provide physical air-gapped separation of network traffic.

NSX Virtual Private Clouds (VPCs) provide isolated network environments within a shared infrastructure. VPCs support on-demand logical networks that can be advertised as public subnets or exposed through networking services like External IPs or NAT, providing project-level boundary isolation with their own topology, IP address management, and permission models. VCF Automation maintains secure organizational boundaries that isolate tenants from one another, providing additional logical separation within the environment.

Network I/O Control (NIOC) determines the bandwidth that different network traffic types are given on a vSphere distributed switch. When NIOC is enabled, distributed switch traffic is divided into predefined network resource pools covering Fault Tolerance, iSCSI, vMotion, management, vSphere Replication, NFS, and virtual machine traffic. Bandwidth reservation and shares allocation enforce performance boundaries between traffic types under contention. Avi Load Balancer provides Layer 4 load balancing for services, distributing traffic across server pools with configurable load balancing algorithms and health monitoring.

VCF provides network monitoring through multiple components. NSX supports IPFIX profile configuration on segments to enable flow-based network monitoring, giving administrators visibility into traffic traversing the network. At the vSphere layer, NetFlow can be enabled on individual distributed port groups or ports through the vSphere Distributed Switch monitoring policy, providing IP packet flow data independent of NSX. The pktcap-uw command-line utility on ESX hosts supports packet capture at specific points in the network stack, including at physical adapters and at the boundary between the distributed

switch and physical adapters, enabling packet-level traffic inspection without additional tools. NSX Manager monitors control plane connections between transport nodes and manager nodes, providing awareness of the network infrastructure state.

VCF Operations extends monitoring capabilities with network metrics including inbound and outbound connection tracking (net|allInboundTotal and net|allOutboundTotal). The Management Pack for Network Devices provides alerts and notifications for key network events including throughput totals and packet counts, and monitors outgoing errors on network interfaces. VCF Operations can detect protected flows, identifying traffic that has a specific firewall rule associated with it beyond a default allow-all policy, which helps administrators understand which communications are governed by explicit security policies. Outbound flow limits serve as a protection mechanism, with TCP flows limited to 1,000 allowed and 50 denied outbound, and UDP flows limited to 500 allowed and 50 denied outbound. VCF Operations also supports firewall hardening that restricts network access to its own internal services, demonstrating boundary protection for management interfaces.

VCF Operations for Networks adds flow analysis and troubleshooting capabilities, including application discovery based on flows, network topology visualization through the Topology Graph Widget, and traffic flow visualization between applications, application tiers, shared services, and the Internet. VCF Operations for Networks provides intents for network design and verification, helping validate that the network configuration matches the intended design. Distributed virtual switches support health check operations for NIC teaming and VLAN/MTU verification, while vSAN network partition health checks detect VLAN misconfigurations and uplink losses. VCF Operations for Networks also provides visibility into vDefend distributed firewall rule activity, including identification of inactive rules that have had no matching flows.

VMware Kubernetes Service (VKS) clusters and the vSphere Supervisor control plane extend boundary protection to the workload consumption layer. Within VKS clusters, Kubernetes NetworkPolicy objects provide declarative packet-filtering rules at OSI Layer 3 and Layer 4, defining permitted ingress and egress traffic based on pod label selectors, namespace selectors, and CIDR blocks. By default, pods accept all traffic; NetworkPolicy objects restrict communication to only the flows required for each workload or namespace, establishing internal boundaries between application tiers. Antrea, the CNI plugin integrated with Supervisor in NSX VPC deployments, enforces these NetworkPolicy rules and exposes NetworkPolicyStats, giving administrators measurable visibility into how boundary controls are applied across cluster-internal traffic. At the cluster perimeter, distributed firewall isolation rules on cluster nodes block external networks from reaching VKS cluster pods by default; Supervisor control plane nodes can reach cluster pods, but traffic originating outside the Supervisor control plane is dropped. Connections from worker nodes and pods to the Kubernetes API server use the API server's secure port by default, and SSH tunnels restrict control plane-to-node communications from exposure outside the cluster network. Kubernetes Ingress resources backed by ingress controllers perform TLS termination and route external requests to backend services, establishing a defined and controlled entry point at each cluster's external-facing edge. Network segmentation and firewall rules are applied to secure inter-component communication within Supervisor Service deployments such as Argo CD.

For stateful firewall inspection, microsegmentation, IDS/IPS, and deep packet inspection at network boundaries, organizations can deploy VMware vDefend, which extends VCF's networking foundation with Layer 2 through Layer 7 firewall capabilities and advanced threat prevention. VCF's networking layer provides the segmentation, routing, and monitoring infrastructure on which boundary enforcement policies operate, but the active enforcement of traffic at those boundaries requires either vDefend or integration with external security tools. Organizational processes for defining boundary policies, reviewing traffic logs, managing firewall rule sets, and maintaining network diagrams are also required.

VMware Private AI Services (PAIS) contributes to boundary protection through AI-infrastructure-specific network isolation patterns for both connected and air-gapped deployments. The core boundary enforcement capabilities, including distributed firewall rules, IDS/IPS inspection, and traffic analysis, are provided by VCF and VMware vDefend.

PAIS setup is configured according to environment Internet connectivity, supporting either connected or disconnected air-gapped deployment models. In a disconnected air-gapped environment, files are downloaded from the Internet to a bastion host VM and then transferred to an admin host VM that has no Internet access, from which VI administrators interact with the environment. This pattern removes direct Internet exposure from the AI infrastructure components and constrains the path by which external content enters the trusted enclave.

In air-gapped deployments, PAIS configures components to pull container images from a local internal registry rather than from public sources. The NVIDIA GPU Operator deploys validator, operator, driver, manager, toolkit, and devicePlugin components as separate container images pulled from the local registry. PAIS model endpoints authenticate to private registries through harbor-pull-secret-readonly to control access to container images.

PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, providing an internal boundary between AI workload data stores and other platform consumers. PAIS uses a CA trust bundle for secure communication with external services and databases.

The NSX Edge cluster or Virtual Network Appliance (VNA) cluster provides two-tier north-south routing for the Supervisor instance and the workloads it runs, while the Workload Domain NSX Manager provides VPC networking services to private AI workloads. VPC networking for the VCF Automation organization is configured with a Public IP range, a transit gateway IP range, and a VPC private IP range to delineate external, transit, and internal address space for AI tenants.

Organizations should refer to the VCF and vDefend Coverages for the underlying boundary monitoring and enforcement infrastructure.

VMware vDefend (Meets)

VMware vDefend provides monitoring and control of communications at both external and internal network boundaries within the virtual infrastructure through stateful firewall inspection, microsegmentation, and behavioral traffic analysis.

At the external boundary, vDefend enforces zone boundaries and provides stateful North-South traffic inspection at the network perimeter. Gateway Firewall policies apply to traffic entering and leaving edge gateways, and Gateway Firewall IDS/IPS events can be monitored on nodes, providing inspection-layer visibility at the external boundary.

At internal boundaries, vDefend enforces East-West traffic policies between virtual machines, containers, and workloads regardless of their physical location. Distributed Firewall rules operate at the vNIC level, creating per-workload enforcement points that function as internal boundary controls. Distributed Firewall manages East-West traffic control for both inter-VPC and intra-VPC communication within Organizations, and Distributed Firewall rules protect traffic between objects within a VPC, enforcing boundaries within project-scoped network environments. This microsegmentation approach allows organizations to define fine-grained internal boundaries beyond traditional VLAN-based segmentation. The policy-level Applied-To field defines a clear boundary around a set of VMs, such as an entire application, allowing targeted policies for specific zones, tenants, or applications without interfering with policies defined for other applications, tenants, or zones. Distributed Firewall policies can explicitly block unsecure protocols such as Telnet, FTP, and TFTP across the data center, supporting protocol-level boundary enforcement. Distributed Firewall also supports targeted deny rules scoped to infrastructure groups via the Applied-To field to protect critical services, facilitating phased Zero Trust adoption. Distributed Firewall governance implements least-privilege security by preventing overly permissive rules such as any-to-any-allow configurations. Distributed Firewall policies manage security for Bare Metal servers through traffic-control rules, extending boundary enforcement beyond virtual workloads. For federated environments, Distributed Firewall policies applied globally allow sources or destinations to be any object without span restrictions, supporting multi-site boundary enforcement.

Security Services Platform adds environment-level boundary enforcement through Protection Rules, which define how traffic flows between environment pairs such as production, development, and test. Protection Rule actions can be set to Drop or Reject to block all traffic between specified environment pairs, or Allow for more selective enforcement. Security Services Platform Environment Protection evaluates whether workloads are protected by environment-specific segmentation policies and measures coverage including the percentage of environment pairs in blocked mode. Application Protection in Strict Mode enforces application-level firewall rules on all application workloads except infrastructure, with scoring based on workload coverage, traffic coverage, and lock-down policies. Security Intelligence, a capability within Security Services Platform, defines private IP ranges as the boundary for internal workloads, treating traffic that crosses this boundary as external. The Secure External Communications project identifies workloads with inbound or outbound connections to external IP addresses to mitigate vulnerability to attacks. Security Intelligence recommends identifying all inter-environment flows and securing them with specific policies before enforcing strict block rules, supporting a methodical approach to boundary hardening.

Network Detection and Response (NDR) monitors traffic across boundaries and collects detection events representing security-relevant activity that has occurred in the network. NDR can be integrated with SIEMs to send security event logs about network infrastructure for centralized boundary monitoring. In sensitive or classified environments, NDR can be configured for air-gapped networks, executing all detection, correlation, and response activities entirely within closed networks using local storage and processing without requiring external connectivity. NDR remediations for events detected on the Gateway Firewall are applied on the Distributed Firewall, providing a unified enforcement response across both the internal and external boundary layers.

vDefend does not define which boundaries an organization should establish or set the policies governing boundary placement decisions. Those are organizational architecture and governance responsibilities. The underlying networking infrastructure of VCF, comprising NSX segments, VLANs, and edge gateways, provides the segmentation and routing fabric on which vDefend's boundary enforcement operates.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides boundary protection mechanisms at the application delivery layer for traffic it proxies. Network Security Policies in Avi evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. These policies apply IP-based traffic filtering at the virtual service level; a deny rule stops further policy evaluation, preventing downstream HTTP Security, Request, or Response policies from executing for that traffic. Network security policies are configurable per virtual service and per Virtual IP address, giving administrators auditable and consistent access controls across the deployment.

Avi's Web Application Firewall (WAF) inspects application-layer traffic at the proxy boundary using positive and negative security models. Positive Security rules define what constitutes allowed application behavior and enforce restrictions on traffic that does not conform to that model. WAF Application Rules provide protection against known attack patterns, including rules targeting specific CVEs; rules are automatically updated through the Controller Cloud Services connection, and existing rules continue to protect applications when that connection is unavailable. WAF rule actions support pass and deny options for controlling traffic based on policy matches. Administrators can also enable the Application Rules service through the Avi Cloud Console, which delivers automatically updated CVE-targeted rules directly to Avi Controllers.

For DDoS mitigation, Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework. This includes protection against DNS Reflection Ingress attacks, which involve sending DNS queries with spoofed IP addresses to flood a victim with unsolicited DNS server responses.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) extends boundary controls to Kubernetes ingress traffic. The L4 Rule custom resource definition (CRD) in AKO allows administrators to express custom Security Policies applied to virtual service traffic, including configuration for DDoS attack detection and mitigation. The `'insecureEdgeTerminationPolicy'` setting in AKO controls handling of insecure traffic, with a redirect option that enforces secure traffic routing through HTTP Request policies applied per FQDN.

Avi Service Engines implement traffic isolation between the data plane and the management and control plane using a dedicated management vNIC bound to the default Linux network namespace, with health monitor traffic further isolated through Linux network namespace features in the kernel. Service Engine IP addresses egressing the Data Plane vNIC are routed through the external network and subjected to routing isolation and ACL/firewalling controls present in that external network. A dedicated management network is required for communication between Avi Controllers and Service Engines. In isolated network deployments, each Avi Controller supports a second management IP address or DNS-resolvable FQDN for Service Engines connecting from an isolated segment, configured via the `'isolated-network-management-address'` setting.

In VCF deployments using the Avi-for-VCF integration, the Management Network hosts the Avi Controller and provides connectivity to vCenter, ESX hosts, and Supervisor control plane nodes, maintaining a defined boundary between management and workload traffic.

Incoming HTTP(S) traffic can be replicated to logging and sideband servers at the protocol level via the Virtual Service Sideband Profile, enabling deep traffic inspection by external appliances such as web application firewalls and supporting compliance and auditing requirements.

Avi also supports a Firewall Sandwich Topology, where virtual services and firewall pool members are chained so that application traffic traverses configured firewall members on its path from the Internet to internal servers. In this topology, a sample of traffic is inspected by the firewall while remaining traffic considered trusted is directly routed to the internal network.

Boundary protection for segments and layers outside Avi's application delivery scope, including network-level perimeter controls, east-west enforcement between application tiers, and internal boundary protection across the broader VCF environment, requires the VCF networking infrastructure and VMware vDefend, which is a separate product.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-005-7 2.1

> For all Interactive Remote Access, utilize an Intermediate System such that the Cyber Asset initiating Interactive Remote Access does not directly access an applicable Cyber Asset.

SCF Controls: NET-14

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in mechanisms for controlling and securing remote access to infrastructure components across the platform.

Centralized identity and authentication. All administrative access to VCF components flows through authenticated interfaces with centralized identity management via VCF SSO. VCF SSO supports identity provider federation, allowing vCenter to replace its built-in identity source with an external identity provider such as AD FS, Azure AD, or Okta. This integration enables organizations to enforce their existing authentication policies, including multi-factor authentication, across VCF management interfaces. VCF SSO provides centralized authentication that reduces the need for direct ESX host login with local credentials.

SSH access controls. ESX hosts include the TSM-SSH service, which can be started and stopped to enable or disable SSH access on a per-host basis. SSH access is also available for NSX Manager, VCF Operations appliances, and cloud proxy instances. VCF Operations Cloud Proxy disables SSH by default, requiring initial access through the vCenter console before SSH can be enabled. When SSH is active on VCF Operations nodes, a restricted access banner is displayed to users upon connection. ESX host advanced options allow administrators to configure shell timeouts and host client session timeouts, limiting the duration of interactive remote sessions. For VCF Automation deployments, remote access supports both password and public-private key authentication via SSH, providing a stronger alternative to password-based login. VCF Operations orchestrator can also register a public key on an SSH host to enable key-based authentication.

DCUI and lockdown mode. ESX supports configuration of the DCUI.Access setting, which specifies which users can override lockdown mode and access the Direct Console User Interface. When lockdown mode is enabled, this restricts the set of accounts that can interact with the host locally or through the DCUI, reducing the available remote management surface. ESX hosts support an Exception Users list for lockdown mode, providing granular control over which accounts retain access during restricted operation. ESX supports two lockdown mode levels: Normal mode keeps the DCUI service running and allows local console access alongside vCenter management, while Strict mode stops the DCUI service entirely and restricts access to vCenter only. ESX Shell and SSH services operate independently of lockdown mode and must be separately deactivated, since lockdown mode itself does not restrict those services.

Console and management access. Access to ESX hosts requires login at the host's HTTPS URL as a user with the Administrator role. Virtual machine console access via the VNC protocol can be individually enabled or disabled through the RemoteDisplay.vnc.enabled setting in vCenter, giving administrators control over which remote console methods are available. The virtual serial port proxy can act as a gateway to enforce security policies for remote serial port connections. Management port access on network devices within the VCF environment must be password protected, and console port access must require authentication.

Role-based access control for remote sessions. Role-based access control governs what authenticated users can do once connected. vCenter allows creation of custom roles with granular privilege assignment and permission propagation to vSphere objects. The CloudAdmin role model in VCF Automation restricts administrative scope. NSX implements RBAC to restrict system access to authorized users by assigning roles with specific permissions, including the ability to create custom roles that suit operational requirements. NSX Federation also supports RBAC across federated environments. These layered RBAC controls enforce granular permissions on remote sessions across the platform.

Remote access to provisioned workloads. Remote sessions to provisioned machines in VCF Automation for VM Apps require connecting to the machine's IP address or FQDN and authenticating with a username and password. VCF Automation cloud templates also support remoteAccess authentication using public-private key pairs with SSH key input parameters.

These controls give administrators granular ability to enable, disable, and restrict specific remote access methods across VCF infrastructure. However, defining which remote access methods are organization-approved, establishing policies governing their use, and conducting periodic reviews of remote access configurations are organizational responsibilities that fall outside VCF's scope.

VMware Private AI Services (PAIS) provides mechanisms for controlling remote access to its AI workload components, supporting the organizational processes for defining and reviewing approved access methods.

PAIS enforces user access through OIDC group-based authorization. Access is granted only to user accounts belonging to groups listed in the `authorizedGroups` configuration (and the `oidc-authorized-groups` setting when activation is performed through the VCF Automation UI). Group names such as `group-for-pais-access-01` are specified on the OIDC provider, and HTTPS-based communication to the OIDC provider is required. PAIS also uses a CA trust bundle (`ca-trust-bundle`) for secure communication with external services and databases, including Harbor registries and MCP servers. When PAIS is consumed under VMware vCenter 8.x, VCF SSO must be configured to access Private AI Services namespaces and their resources from VCF Automation; under vCenter 9.x or later this SSO step is not required.

Deep Learning VMs (DL VMs) deployed through VCF Automation require user password configuration and support optional SSH public key authentication for remote administrator access. DL VMs are exposed through LoadBalancer services that provide public IP addresses and mapped ports for SSH on port 22 and JupyterLab notebook access on port 8888. DL VMs that include the NVIDIA Triton Inference Server use the same password and SSH public key authentication pattern, and are accessed over SSH as the `vmware` user. The PyTorch profile for DL VMs restricts JupyterLab to the local machine only by default, listening on port 9400, which reduces the remote attack surface for development notebooks.

API access to PAIS administrative endpoints goes through authenticated channels. The VCF Consumption CLI authenticates to VCF Automation endpoints using an API token, the FQDN or IP address of the endpoint, and an optional CA certificate for TLS verification. The `vcf context create` command issued through this CLI requires the same credentials, and VCF Automation Provider Management exposes an API Token endpoint that allows provider administrators to create and manage API tokens. VCF Automation organization administrator access tokens are obtained through a POST request to a sessions endpoint using Basic authentication. PAIS provides a dedicated VCF Automation API endpoint for registering vCenter instances using Bearer token authentication, and Broadcom recommends using the FQDN of the vCenter instance rather than its IP address when registering it.

For AI agent and knowledge base integrations, PAIS adds review controls on remote endpoints. Remote MCP servers connected to PAIS must be accessible over HTTP or HTTPS using the Streamable HTTP or Server-Sent Events transport, can optionally use static authentication tokens, and require examination and approval of their tools and capabilities before use in agents. The PAIS Agent Builder maintains a list of approved tools for use in AI agents when connecting to MCP servers, giving administrators a control point over which remote services agents are allowed to call. Microsoft SharePoint data sources used as PAIS Knowledge Bases require username and password authentication and are limited to SharePoint On-Premises deployments.

For model artifact distribution, the PAIS Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, and the `oras login` command authenticates to a private Harbor registry using username and password credentials before any push operations.

VMware vDefend (Contributes)

VMware vDefend contributes to remote access governance through network-level enforcement and behavioral detection. The Distributed Firewall (DFW) can enforce policies controlling which sources and protocols, such as SSH and RDP, may reach management interfaces, while Identity Firewall (IDFW) adds user-aware policy enforcement for remote user groups. IDFW supports Virtual Desktop Infrastructure (VDI) environments, Remote Desktop Session Hosts (RDSH), and physical machines, where multiple users may log in simultaneously; in RDSH deployments, administrators create Active Directory security groups to allow or deny user access to application servers through DFW rules based on the user's assigned role. IDFW supports the multi-user RDSH use case for both TCP and UDP protocols.

The Security Services Platform (SSP) includes Security Intelligence, which detects suspicious behavior for remote connections such as telnet, SSH, and VNC, providing visibility into remote access activity. SSP also correlates lateral movement events with subsequent infection-type activity, such as detecting RDP connections from one workload to another followed by command-and-control activity originating from the destination.

SSH access to Malware Prevention Service virtual machines is disabled by default and must be explicitly activated by the vCenter administrator. SSH to these service VMs uses key-based authentication with a public-private key pair; a public key is required at deployment time and a private key is required to initiate an SSH session. Administrators should deactivate SSH access once troubleshooting or debugging tasks are complete.

Role-based access control within SSP limits which users can administer vDefend components remotely. SSP defines five built-in roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles can be assigned to individual remote users or remote user groups, including Active Directory groups, integrating with existing enterprise directory services for remote administrator management. CLI commands for Distributed IDS/IPS must be run on ESX hosts, with available commands and viewable modes differing based on the user's assigned role.

Defining organization-approved remote access methods, VPN provisioning, and centralized remote access governance remain outside vDefend's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several native mechanisms for controlling remote administrative access to the Controller and Service Engines. Administrators reach the Avi Controller through SSH for command-line management or through the HTTPS-based web UI and REST API. SSH is also the secure channel used between the Controller and Service Engines for management communication.

To restrict which hosts may initiate remote access sessions, the Client Management Access feature allows configuration of separate IP allowlists for SSH clients, CLI shell clients, external HTTP(S) clients, and external SNMP clients. Each allowlist accepts individual IP addresses, ranges, or IP groups. Separate IP access lists must be configured per management interface to restrict access through each channel individually. The web interface, SSH daemon, CLI Shell, and SNMP each require their own access list configuration.

SSH management sessions also support configuration of allowed HMAC algorithms. Administrators can restrict which HMAC algorithms are accepted for SSH clients rather than relying on the default of allowing all standard HMACs. This capability restricts the set of cryptographic options available during SSH session establishment.

For Service Engine remote access, Avi supports SSH key-based authentication. By default, Service Engines allow direct SSH access using the system's admin credentials; this default should be reviewed and restricted through allowlists and key-based authentication to align with site access policies.

For identity binding, Avi supports remote authentication through LDAP, TACACS+, and SAML. Administrators configure an Authentication Profile and, optionally, a Mapping Profile that binds enterprise directory group membership to Avi roles. When remote authentication is active, local user login can be retained as a fallback for emergency access or deactivated entirely to enforce remote authentication for all administrator logins.

In Kubernetes deployments, Avi Kubernetes Operator (AKO) Custom Resource Definitions (CRDs) can be governed through Kubernetes Role-Based Access Control (RBAC) policies to restrict which users and groups may configure ingress routing rules and load balancing resources.

The organization must designate approved remote access methods in policy, document them, and conduct periodic reviews to verify that allowlists, HMAC algorithm restrictions, and authentication profiles remain consistent with current access requirements.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-005-7 2.2

> For all Interactive Remote Access sessions, utilize encryption that terminates at an Intermediate System.

SCF Controls: NET-14.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in cryptographic mechanisms that protect the confidentiality and integrity of remote access sessions across its networking, management, and workload migration layers.

All VCF management communications are encrypted in transit using TLS. VCF components support TLS, and FIPS-validated cryptographic modules are used across the platform. VCF Automation runs in FIPS-compliant mode by default, using the BouncyCastle FIPS 2.0.0 cryptographic module. VCF Operations for Networks uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, validated by the NIST Cryptographic Module Validation Program (CMVP), and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. The VMware vCenter appliance uses VMware's Boring Crypto Module version 6.0, a FIPS 140-2 validated module supporting AES, ECDSA, HMAC, RSA, and SHA2 variants. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant. VCF Operations supports a FIPS Security Mode that applies additional algorithm and cipher prerequisites across the platform when enabled. Administrators should be aware that self-signed certificates and private keys generated using OpenSSL are not FIPS-compatible, so organizations operating in FIPS-enforced environments should use certificates from a FIPS-compliant certificate authority or key generation process. These protections apply to all remote management sessions, including browser-based access to vCenter, VCF Operations, and other VCF component consoles. Access to VMware ESX hosts is available through HTTPS, and SSH access to infrastructure components such as VCF Operations Cloud Proxy is disabled by default, with the first login required through the vCenter console.

The VMware Kubernetes Service (VKS) and vSphere Supervisor, which form the consumption layer of the VCF platform, apply cryptographic protections to all remote access paths reaching Kubernetes infrastructure. All client connections to the Kubernetes API server use TLS, and the `--tls-cipher-suites` and --tls-min-version` parameters allow administrators to restrict connections to the cipher suites and protocol versions that meet organizational requirements. Each Supervisor node runs a kubelet that exposes HTTPS endpoints; the tlsCipherSuites` and tlsMinVersion` fields in the KubeletConfiguration similarly control the permitted cipher suites and minimum protocol version for kubelet connections. The kube-scheduler also supports cipher suite restriction through the --tls-cipher-suites` parameter, and Kubernetes hardening guidance recommends providing an explicit preferred cipher suite list to prevent negotiation of weaker algorithms. When Contour is deployed as a standard package on VKS clusters, it provides TLS termination for inbound application traffic, and the tls.minimum-protocol-version` and tls.maximum-protocol-version` parameters in the Contour configuration file bound the protocol versions accepted from remote clients. When Istio is deployed as a standard package, it enforces mutual TLS between services within the mesh; the meshMTLS.minProtocolVersion` setting establishes a floor on the protocol version for inter-service encrypted communication and defaults to TLS 1.2, with TLS 1.3 available as an option. VKS on Supervisor maintains TLS certificates that underpin the cryptographic infrastructure for secure cluster communications. Direct administrative access to Supervisor control plane nodes requires authenticating through VMware vCenter as the root user, constraining that access path to an encrypted channel and tying it to vCenter's authentication controls. Secure login configuration for vSphere Supervisor requires either distributing the vCenter root CA certificate to client machines or replacing the Supervisor VIP certificate with one signed by a CA that client machines already trust.`

For site-to-site and remote access VPN, NSX provides IPSec VPN capabilities with configurable cryptographic schemes. The IPSec VPN service is available on both Tier-0 and Tier-1 gateways, allowing organizations to establish encrypted tunnels for traffic between VCF environments and external locations. Configuration of L2 VPN and IPSec VPN tunnels between Tier-1 gateways within the same project or across different projects in the same NSX deployment is also supported, providing flexibility for multi-site and multi-tenant architectures. Both route-based and policy-based IPSec VPN configurations are available. IPSec VPN sessions support pre-shared key (PSK) or certificate-based authentication, and administrators can select a security compliance suite that applies predefined, non-modifiable IKE and IPSec profiles. When a compliance suite is

selected, the authentication mode is automatically set to certificate-based, and the associated IKE and IPsec security profiles cannot be manually edited, reducing the risk of misconfiguration. For certificate-based authentication, the certificate details for the IPsec session must be configured in the associated local endpoint.

NSX Layer 2 VPN connections are secured with route-based IPsec tunnels between the L2 VPN server and L2 VPN client. The IPsec VPN Phase 2 encapsulation mode is configured to tunnel mode, which encrypts the entire original IP packet including the header. When configuring IPsec between two sites, the two VPN endpoints must be set up with matching attributes, and L2 VPN Client sessions require configuration of a remote IP address for the IPsec tunnel along with a peer code generated from the L2 VPN Server service. For L2 VPN, the FIPS compliance suite applies pre-configured cryptographic parameters with Perfect Forward Secrecy enabled.

VCF provides flexible PKI options for certificate management underpinning these encrypted sessions. Certificate options range from fully automated issuance within VCF to integration with enterprise PKI infrastructure using Certificate Signing Requests (CSRs) or direct certificate uploads. The vCenter certificate management API allows programmatic generation of CSRs and replacement of TLS certificates. VCF Operations certificate management supports replacing default certificates with enterprise CA certificates, CA configuration, and CSR generation, with auto-renewal available for VMCA, MSCA, and OpenSSL CA. The Fleet Management interface provides a centralized Certificates screen for renewing, importing, replacing certificates, or activating auto-renewal. VCF Operations also monitors the status and expiration of Platform, Root, STS, and TLS certificates. Before using the Microsoft Certificate Authority with a pre-configured template, it is recommended to configure least privilege access to Microsoft Active Directory Certificate Services using a restricted service account.

Encrypted vSphere vMotion protects VM migration traffic. For virtual machines that are not encrypted, encrypted vMotion can be set to Disabled, Opportunistic (use encryption when supported, the default), or Required (do not migrate if encryption is unsupported). vSphere vMotion always attempts to use encryption when migrating encrypted virtual machines. Encrypted vMotion can migrate either encrypted or unencrypted virtual machines within a disk cluster or between disk clusters using Storage vMotion.

VMware Private AI Services (PAIS) on VCF provides cryptographic protections across its AI service endpoints, VMware Kubernetes Service (VKS) clusters, and Deep Learning VM access channels.

PAIS instances expose their APIs over TLS using a self-signed certificate whose CA certificate is stored in the `pais-ingress-default` Kubernetes Secret in the PAIS namespace. Clients retrieve this certificate using `kubectl get secrets/pais-ingress-default -o yaml` and configure it before connecting. The PAISConfiguration custom resource supports configurable CA bundle references through the `spec.clientTls.caBundleRefs` field, allowing operators to pin trust anchors for OIDC provider and Harbor registry authentication, with separate trust bundles recommended per application and periodic refresh required before certificate expiration. The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication, and the PAIS Prometheus observability endpoint uses self-signed certificate authentication with TLS sourced from the same `pais-ingress-default` Secret.

When connecting remote MCP servers to PAIS over HTTPS, PAIS requires that the issuer certificate be added as a CA trust bundle, restricting connections to endpoints with verified certificates. Remote MCP servers may optionally present static authentication tokens. PAIS also uses CA trust bundles for secure connections to external services and to the pgvector database server provided by VMware Data Services Manager (DSM).

VKS clusters provisioned by PAIS use the FIPS-compliant cluster topology version `v1.33.1-vmware.1-fips-vkr.2`, which engages FIPS-validated cryptographic modules for control plane and worker communications. This requirement applies to both connected and disconnected PAIS deployments.

Deep Learning VMs and Triton Inference Server workloads support SSH public key authentication. Keys can be supplied during VM deployment through the `public-keys` OVF property, which populates the default user's `~/.ssh/authorized_keys` file and removes reliance on password-based access for remote VM login. The VCF Consumption CLI used to manage PAIS namespaces authenticates to VCF Automation endpoints using an API token, FQDN, and an optional CA certificate for TLS verification. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and linked data sources over the same TLS-protected endpoints.

Platform-level network encryption for remote access, including VPN and segment-level encryption, is provided by the underlying VCF platform. See VCF Coverage for those capabilities.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) applies cryptographic protection to the channels through which it manages paired sites and moves data between them. PNR uses TLS certificates and private keys to protect network communication and to authenticate with peer servers. The Protection and Recovery Appliance terminates TLS through an envoy proxy, and the minimum TLS protocol version is configurable by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file. Replication of virtual machine data between sites supports optional network-level encryption, and PNR can protect and recover virtual machines that are themselves encrypted, applying that protection through both array-based protection groups and vSphere Replication protection groups.

Authentication to vCenter and to remote PNR sites is brokered through VCF SSO. PNR acquires a holder-of-key SAML token from VCF SSO and presents it in cryptographically signed requests to remote services. The Configure Remote Site workflow imports certificates of the remote vCenter to establish trust for the cross-site connection, and the appliance prompts for VCF SSO credentials when an operator initiates operations that affect both sites.

PNR does not provide the network-layer VPN that connects paired sites. The product documentation requires that the connection between the local and remote sites of a Protection and Recovery pair be private, such as a VPN provisioned outside PNR. For isolated recovery environments used during cyber recovery operations, VMware recommends that workload user access be performed through VPN or a Remote Desktop Client rather than direct public internet exposure of recovered services.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-005-7 2.3

> Require multi-factor authentication for all Interactive Remote Access sessions.

SCF Controls: IAC-06, NET-14

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in mechanisms for controlling and securing remote access to infrastructure components across the platform.

Centralized identity and authentication. All administrative access to VCF components flows through authenticated interfaces with centralized identity management via VCF SSO. VCF SSO supports identity provider federation, allowing vCenter to replace its built-in identity source with an external identity provider such as AD FS, Azure AD, or Okta. This integration enables organizations to enforce their existing authentication policies, including multi-factor authentication, across VCF management interfaces. VCF SSO provides centralized authentication that reduces the need for direct ESX host login with local credentials.

SSH access controls. ESX hosts include the TSM-SSH service, which can be started and stopped to enable or disable SSH access on a per-host basis. SSH access is also available for NSX Manager, VCF Operations appliances, and cloud proxy instances. VCF Operations Cloud Proxy disables SSH by default, requiring initial access through the vCenter console before SSH can be enabled. When SSH is active on VCF Operations nodes, a restricted access banner is displayed to users upon connection. ESX host advanced options allow administrators to configure shell timeouts and host client session timeouts, limiting the duration of interactive remote sessions. For VCF Automation deployments, remote access supports both password and public-private key authentication via SSH, providing a stronger alternative to password-based login. VCF Operations orchestrator can also register a public key on an SSH host to enable key-based authentication.

DCUI and lockdown mode. ESX supports configuration of the DCUI.Access setting, which specifies which users can override lockdown mode and access the Direct Console User Interface. When lockdown mode is enabled, this restricts the set of accounts that can interact with the host locally or through the DCUI, reducing the available remote management surface. ESX hosts support an Exception Users list for lockdown mode, providing granular control over which accounts retain access during restricted operation. ESX supports two lockdown mode levels: Normal mode keeps the DCUI service running and allows local console access alongside vCenter management, while Strict mode stops the DCUI service entirely and restricts access to vCenter only. ESX Shell and SSH services operate independently of lockdown mode and must be separately deactivated, since lockdown mode itself does not restrict those services.

Console and management access. Access to ESX hosts requires login at the host's HTTPS URL as a user with the Administrator role. Virtual machine console access via the VNC protocol can be individually enabled or disabled through the RemoteDisplay.vnc.enabled setting in vCenter, giving administrators control over which remote console methods are available. The virtual serial port proxy can act as a gateway to enforce security policies for remote serial port connections. Management port access on network devices within the VCF environment must be password protected, and console port access must require authentication.

Role-based access control for remote sessions. Role-based access control governs what authenticated users can do once connected. vCenter allows creation of custom roles with granular privilege assignment and permission propagation to vSphere objects. The CloudAdmin role model in VCF Automation restricts administrative scope. NSX implements RBAC to restrict system access to authorized users by assigning roles with specific permissions, including the ability to create custom roles that suit operational requirements. NSX Federation also supports RBAC across federated environments. These layered RBAC controls enforce granular permissions on remote sessions across the platform.

Remote access to provisioned workloads. Remote sessions to provisioned machines in VCF Automation for VM Apps require connecting to the machine's IP address or FQDN and authenticating with a username and password. VCF Automation cloud templates also support remoteAccess authentication using public-private key pairs with SSH key input parameters.

These controls give administrators granular ability to enable, disable, and restrict specific remote access methods across VCF infrastructure. However, defining which remote access methods are organization-approved, establishing policies governing their use, and conducting periodic reviews of remote access configurations are organizational responsibilities that fall outside VCF's scope.

VMware Private AI Services (PAIS) provides mechanisms for controlling remote access to its AI workload components, supporting the organizational processes for defining and reviewing approved access methods.

PAIS enforces user access through OIDC group-based authorization. Access is granted only to user accounts belonging to groups listed in the `authorizedGroups` configuration (and the `oidc-authorized-groups` setting when activation is performed through the VCF Automation UI). Group names such as `group-for-pais-access-01` are specified on the OIDC provider, and HTTPS-based communication to the OIDC provider is required. PAIS also uses a CA trust bundle (`ca-trust-bundle`) for secure communication with external services and databases, including Harbor registries and MCP servers. When PAIS is consumed under VMware vCenter 8.x, VCF SSO must be configured to access Private AI Services namespaces and their resources from VCF Automation; under vCenter 9.x or later this SSO step is not required.

Deep Learning VMs (DL VMs) deployed through VCF Automation require user password configuration and support optional SSH public key authentication for remote administrator access. DL VMs are exposed through LoadBalancer services that provide public IP addresses and mapped ports for SSH on port 22 and JupyterLab notebook access on port 8888. DL VMs that include the NVIDIA Triton Inference Server use the same password and SSH public key authentication pattern, and are accessed over SSH as the `vmware` user. The PyTorch profile for DL VMs restricts JupyterLab to the local machine only by default, listening on port 9400, which reduces the remote attack surface for development notebooks.

API access to PAIS administrative endpoints goes through authenticated channels. The VCF Consumption CLI authenticates to VCF Automation endpoints using an API token, the FQDN or IP address of the endpoint, and an optional CA certificate for TLS verification. The `vcf context create` command issued through this CLI requires the same credentials, and VCF Automation Provider Management exposes an API Token endpoint that allows provider administrators to create and manage API tokens. VCF Automation organization administrator access tokens are obtained through a POST request to a sessions endpoint using Basic authentication. PAIS provides a dedicated VCF Automation API endpoint for registering vCenter instances using Bearer token authentication, and Broadcom recommends using the FQDN of the vCenter instance rather than its IP address when registering it.

For AI agent and knowledge base integrations, PAIS adds review controls on remote endpoints. Remote MCP servers connected to PAIS must be accessible over HTTP or HTTPS using the Streamable HTTP or Server-Sent Events transport, can optionally use static authentication tokens, and require examination and approval of their tools and capabilities before use in agents. The PAIS Agent Builder maintains a list of approved tools for use in AI agents when connecting to MCP servers, giving administrators a control point over which remote services agents are allowed to call. Microsoft SharePoint data sources used as PAIS Knowledge Bases require username and password authentication and are limited to SharePoint On-Premises deployments.

For model artifact distribution, the PAIS Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, and the `oras login` command authenticates to a private Harbor registry using username and password credentials before any push operations.

VMware vDefend (Contributes)

VMware vDefend contributes to remote access governance through network-level enforcement and behavioral detection. The Distributed Firewall (DFW) can enforce policies controlling which sources and protocols, such as SSH and RDP, may reach management interfaces, while Identity Firewall (IDFW) adds user-aware policy enforcement for remote user groups. IDFW supports Virtual Desktop Infrastructure (VDI) environments, Remote Desktop Session Hosts (RDSH), and physical machines, where multiple users may log in simultaneously; in RDSH deployments, administrators create Active Directory security groups to allow or deny user access to application servers through DFW rules based on the user's assigned role. IDFW supports the multi-user RDSH use case for both TCP and UDP protocols.

The Security Services Platform (SSP) includes Security Intelligence, which detects suspicious behavior for remote connections such as telnet, SSH, and VNC, providing visibility into remote access activity. SSP also correlates lateral movement events with subsequent infection-type activity, such as detecting RDP connections from one workload to another followed by command-and-control activity originating from the destination.

SSH access to Malware Prevention Service virtual machines is disabled by default and must be explicitly activated by the vCenter administrator. SSH to these service VMs uses key-based authentication with a public-private key pair; a public key is required at deployment time and a private key is required to initiate an SSH session. Administrators should deactivate SSH access once troubleshooting or debugging tasks are complete.

Role-based access control within SSP limits which users can administer vDefend components remotely. SSP defines five built-in roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles can be assigned to individual remote users or remote user groups, including Active Directory groups, integrating with existing enterprise directory services for remote administrator management. CLI commands for Distributed IDS/IPS must be run on ESX hosts, with available commands and viewable modes differing based on the user's assigned role.

Defining organization-approved remote access methods, VPN provisioning, and centralized remote access governance remain outside vDefend's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several native mechanisms for controlling remote administrative access to the Controller and Service Engines. Administrators reach the Avi Controller through SSH for command-line management or through the HTTPS-based web UI and REST API. SSH is also the secure channel used between the Controller and Service Engines for management communication.

To restrict which hosts may initiate remote access sessions, the Client Management Access feature allows configuration of separate IP allowlists for SSH clients, CLI shell clients, external HTTP(S) clients, and external SNMP clients. Each allowlist accepts individual IP addresses, ranges, or IP groups. Separate IP access lists must be configured per management interface to restrict access through each channel individually. The web interface, SSH daemon, CLI Shell, and SNMP each require their own access list configuration.

SSH management sessions also support configuration of allowed HMAC algorithms. Administrators can restrict which HMAC algorithms are accepted for SSH clients rather than relying on the default of allowing all standard HMACs. This capability restricts the set of cryptographic options available during SSH session establishment.

For Service Engine remote access, Avi supports SSH key-based authentication. By default, Service Engines allow direct SSH access using the system's admin credentials; this default should be reviewed and restricted through allowlists and key-based authentication to align with site access policies.

For identity binding, Avi supports remote authentication through LDAP, TACACS+, and SAML. Administrators configure an Authentication Profile and, optionally, a Mapping Profile that binds enterprise directory group membership to Avi roles. When remote authentication is active, local user login can be retained as a fallback for emergency access or deactivated entirely to enforce remote authentication for all administrator logins.

In Kubernetes deployments, Avi Kubernetes Operator (AKO) Custom Resource Definitions (CRDs) can be governed through Kubernetes Role-Based Access Control (RBAC) policies to restrict which users and groups may configure ingress routing rules and load balancing resources.

The organization must designate approved remote access methods in policy, document them, and conduct periodic reviews to verify that allowlists, HMAC algorithm restrictions, and authentication profiles remain consistent with current access requirements.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-005-7 2.4

> Have one or more methods for determining active vendor remote access sessions (including Interactive Remote Access and system-to-system remote access).

SCF Controls: NET-14, NET-14.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in mechanisms for controlling and securing remote access to infrastructure components across the platform.

Centralized identity and authentication. All administrative access to VCF components flows through authenticated interfaces with centralized identity management via VCF SSO. VCF SSO supports identity provider federation, allowing vCenter to replace its built-in identity source with an external identity provider such as AD FS, Azure AD, or Okta. This integration enables organizations to enforce their existing authentication policies, including multi-factor authentication, across VCF management interfaces. VCF SSO provides centralized authentication that reduces the need for direct ESX host login with local credentials.

SSH access controls. ESX hosts include the TSM-SSH service, which can be started and stopped to enable or disable SSH access on a per-host basis. SSH access is also available for NSX Manager, VCF Operations appliances, and cloud proxy instances. VCF Operations Cloud Proxy disables SSH by default, requiring initial access through the vCenter console before SSH can be enabled. When SSH is active on VCF Operations nodes, a restricted access banner is displayed to users upon connection. ESX host advanced options allow administrators to configure shell timeouts and host client session timeouts, limiting the duration of interactive remote sessions. For VCF Automation deployments, remote access supports both password and public-private key authentication via SSH, providing a stronger alternative to password-based login. VCF Operations orchestrator can also register a public key on an SSH host to enable key-based authentication.

DCUI and lockdown mode. ESX supports configuration of the DCUI.Access setting, which specifies which users can override lockdown mode and access the Direct Console User Interface. When lockdown mode is enabled, this restricts the set of accounts that can interact with the host locally or through the DCUI, reducing the available remote management surface. ESX hosts support an Exception Users list for lockdown mode, providing granular control over which accounts retain access during restricted operation. ESX supports two lockdown mode levels: Normal mode keeps the DCUI service running and allows local console access alongside vCenter management, while Strict mode stops the DCUI service entirely and restricts access to vCenter only. ESX Shell and SSH services operate independently of lockdown mode and must be separately deactivated, since lockdown mode itself does not restrict those services.

Console and management access. Access to ESX hosts requires login at the host's HTTPS URL as a user with the Administrator role. Virtual machine console access via the VNC protocol can be individually enabled or disabled through the RemoteDisplay.vnc.enabled setting in vCenter, giving administrators control over which remote console methods are available. The virtual serial port proxy can act as a gateway to enforce security policies for remote serial port connections. Management port access on network devices within the VCF environment must be password protected, and console port access must require authentication.

Role-based access control for remote sessions. Role-based access control governs what authenticated users can do once connected. vCenter allows creation of custom roles with granular privilege assignment and permission propagation to vSphere objects. The CloudAdmin role model in VCF Automation restricts administrative scope. NSX implements RBAC to restrict system access to authorized users by assigning roles with specific permissions, including the ability to create custom roles that suit operational requirements. NSX Federation also supports RBAC across federated environments. These layered RBAC controls enforce granular permissions on remote sessions across the platform.

Remote access to provisioned workloads. Remote sessions to provisioned machines in VCF Automation for VM Apps require connecting to the machine's IP address or FQDN and authenticating with a username and password. VCF Automation cloud templates also support remoteAccess authentication using public-private key pairs with SSH key input parameters.

These controls give administrators granular ability to enable, disable, and restrict specific remote access methods across VCF infrastructure. However, defining which remote access methods are organization-approved, establishing policies governing their use, and conducting periodic reviews of remote access configurations are organizational responsibilities that fall outside VCF's scope.

VMware Private AI Services (PAIS) provides mechanisms for controlling remote access to its AI workload components, supporting the organizational processes for defining and reviewing approved access methods.

PAIS enforces user access through OIDC group-based authorization. Access is granted only to user accounts belonging to groups listed in the `authorizedGroups` configuration (and the `oidc-authorized-groups` setting when activation is performed through the VCF Automation UI). Group names such as `group-for-pais-access-01` are specified on the OIDC provider, and HTTPS-based communication to the OIDC provider is required. PAIS also uses a CA trust bundle (`ca-trust-bundle`) for secure communication with external services and databases, including Harbor registries and MCP servers. When PAIS is consumed under VMware vCenter 8.x, VCF SSO must be configured to access Private AI Services namespaces and their resources from VCF Automation; under vCenter 9.x or later this SSO step is not required.

Deep Learning VMs (DL VMs) deployed through VCF Automation require user password configuration and support optional SSH public key authentication for remote administrator access. DL VMs are exposed through LoadBalancer services that provide public IP addresses and mapped ports for SSH on port 22 and JupyterLab notebook access on port 8888. DL VMs that include the NVIDIA Triton Inference Server use the same password and SSH public key authentication pattern, and are accessed over SSH as the `vmware` user. The PyTorch profile for DL VMs restricts JupyterLab to the local machine only by default, listening on port 9400, which reduces the remote attack surface for development notebooks.

API access to PAIS administrative endpoints goes through authenticated channels. The VCF Consumption CLI authenticates to VCF Automation endpoints using an API token, the FQDN or IP address of the endpoint, and an optional CA certificate for TLS verification. The `vcf context create` command issued through this CLI requires the same credentials, and VCF Automation Provider Management exposes an API Token endpoint that allows provider administrators to create and manage API tokens. VCF Automation organization administrator access tokens are obtained through a POST request to a sessions endpoint using Basic authentication. PAIS provides a dedicated VCF Automation API endpoint for registering vCenter instances using Bearer token authentication, and Broadcom recommends using the FQDN of the vCenter instance rather than its IP address when registering it.

For AI agent and knowledge base integrations, PAIS adds review controls on remote endpoints. Remote MCP servers connected to PAIS must be accessible over HTTP or HTTPS using the Streamable HTTP or Server-Sent Events transport, can optionally use static authentication tokens, and require examination and approval of their tools and capabilities before use in agents. The PAIS Agent Builder maintains a list of approved tools for use in AI agents when connecting to MCP servers, giving administrators a control point over which remote services agents are allowed to call. Microsoft SharePoint data sources used as PAIS Knowledge Bases require username and password authentication and are limited to SharePoint On-Premises deployments.

For model artifact distribution, the PAIS Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, and the `oras login` command authenticates to a private Harbor registry using username and password credentials before any push operations.

VMware vDefend (Contributes)

VMware vDefend contributes to remote access governance through network-level enforcement and behavioral detection. The Distributed Firewall (DFW) can enforce policies controlling which sources and protocols, such as SSH and RDP, may reach management interfaces, while Identity Firewall (IDFW) adds user-aware policy enforcement for remote user groups. IDFW supports Virtual Desktop Infrastructure (VDI) environments, Remote Desktop Session Hosts (RDSH), and physical machines, where multiple users may log in simultaneously; in RDSH deployments, administrators create Active Directory security groups to allow or deny user access to application servers through DFW rules based on the user's assigned role. IDFW supports the multi-user RDSH use case for both TCP and UDP protocols.

The Security Services Platform (SSP) includes Security Intelligence, which detects suspicious behavior for remote connections such as telnet, SSH, and VNC, providing visibility into remote access activity. SSP also correlates lateral movement events with subsequent infection-type activity, such as detecting RDP connections from one workload to another followed by command-and-control activity originating from the destination.

SSH access to Malware Prevention Service virtual machines is disabled by default and must be explicitly activated by the vCenter administrator. SSH to these service VMs uses key-based authentication with a public-private key pair; a public key is required at deployment time and a private key is required to initiate an SSH session. Administrators should deactivate SSH access once troubleshooting or debugging tasks are complete.

Role-based access control within SSP limits which users can administer vDefend components remotely. SSP defines five built-in roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles can be assigned to individual remote users or remote user groups, including Active Directory groups, integrating with existing enterprise directory services for remote administrator management. CLI commands for Distributed IDS/IPS must be run on ESX hosts, with available commands and viewable modes differing based on the user's assigned role.

Defining organization-approved remote access methods, VPN provisioning, and centralized remote access governance remain outside vDefend's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several native mechanisms for controlling remote administrative access to the Controller and Service Engines. Administrators reach the Avi Controller through SSH for command-line management or through the HTTPS-based web UI and REST API. SSH is also the secure channel used between the Controller and Service Engines for management communication.

To restrict which hosts may initiate remote access sessions, the Client Management Access feature allows configuration of separate IP allowlists for SSH clients, CLI shell clients, external HTTP(S) clients, and external SNMP clients. Each allowlist accepts individual IP addresses, ranges, or IP groups. Separate IP access lists must be configured per management interface to restrict access through each channel individually. The web interface, SSH daemon, CLI Shell, and SNMP each require their own access list configuration.

SSH management sessions also support configuration of allowed HMAC algorithms. Administrators can restrict which HMAC algorithms are accepted for SSH clients rather than relying on the default of allowing all standard HMACs. This capability restricts the set of cryptographic options available during SSH session establishment.

For Service Engine remote access, Avi supports SSH key-based authentication. By default, Service Engines allow direct SSH access using the system's admin credentials; this default should be reviewed and restricted through allowlists and key-based authentication to align with site access policies.

For identity binding, Avi supports remote authentication through LDAP, TACACS+, and SAML. Administrators configure an Authentication Profile and, optionally, a Mapping Profile that binds enterprise directory group membership to Avi roles. When remote authentication is active, local user login can be retained as a fallback for emergency access or deactivated entirely to enforce remote authentication for all administrator logins.

In Kubernetes deployments, Avi Kubernetes Operator (AKO) Custom Resource Definitions (CRDs) can be governed through Kubernetes Role-Based Access Control (RBAC) policies to restrict which users and groups may configure ingress routing rules and load balancing resources.

The organization must designate approved remote access methods in policy, document them, and conduct periodic reviews to verify that allowlists, HMAC algorithm restrictions, and authentication profiles remain consistent with current access requirements.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-005-7 2.5

> Have one or more method(s) to disable active vendor remote access (including Interactive Remote Access and system-to-system remote access).

SCF Controls: IAC-25, NET-14.6, NET-14.8

Aggregate Coverage: Meets

VCF (Meets)

VCF provides automated session termination and inactivity timeout mechanisms across its management interfaces, APIs, and component products. These controls operate at multiple layers of the platform to log out users after configurable periods of inactivity or at session end.

At the hypervisor layer, VMware ESX includes a Host Client Session Timeout setting that controls the duration before an inactive Host Client session is terminated. Administrators can configure this value through the ESX security configuration to align with organizational inactivity policies. The ESX Shell, used for console and SSH administrative access, has a separate idle timeout controlled by the ESX-Shell-idle-timeout advanced system setting (UserVars.ESXShellInteractiveTimeOut), which independently terminates inactive shell sessions.

VMware vCenter uses token-based session management through VCF SSO. Security tokens have a default expiration interval of 30 minutes, after which the session is no longer valid and the user must re-authenticate. The vCenter SessionManager managed object controls user access to the server through methods for logging in, obtaining a session, and logging out, providing both automatic expiration and programmatic session termination capabilities. When any session ends, the associated authentication token is invalidated. The vCenter Appliance Management Interface also enforces a session timeout, expiring idle login sessions after 10 minutes by default. The vSphere Client enforces its own session timeout that defaults to 120 minutes of inactivity and is configurable through the session.timeout parameter.

NSX Manager supports session timeout and automatic user logout. Idle sessions time out automatically, and upon session termination or user logout, users are redirected to the login page. The idle session timeout is configurable, and administrators can also delete idle sessions using the /api/session/destroy API command. When a user logs out, NSX Manager immediately destroys the session identifier and removes the session cookie from the reverse-proxy, limiting session identifier reuse. Session IDs and tokens for each session are unique and expire after the user logs out or after a period of inactivity.

VCF Operations enforces a user session timeout that defaults to 15 minutes and can be modified to match organizational requirements. VCF Operations for Networks allows configuration of the user session timeout with a value range from 15 minutes to 24 hours, giving administrators flexibility to set inactivity thresholds appropriate for their environment. VCF Operations also recommends defining a Release Session Request when using session authentication to log out sessions and reduce session leaks.

The VCF Automation Provider Management Portal automatically logs out users after more than 25 minutes of inactivity. VCF Automation also supports API token expiration, with access tokens expiring after 30 days and API tokens expiring after 90 days by default. At the organization level, deactivating a VCF Automation organization terminates the sessions of all users currently logged in to that organization, providing an administrative mechanism for bulk session termination.

At the Kubernetes consumption layer, the VMware Kubernetes Service (VKS) and vSphere Supervisor enforce bounded session lifetimes through multiple token expiration mechanisms. The Kubernetes API server enforces a maximum validity duration for all service account tokens through the --service-account-max-token-expiration parameter, which caps token lifetimes server-side regardless of what a requesting client specifies. Tokens generated via the TokenRequest API accept an expirationSeconds parameter, and the TokenRequestStatus includes an expirationTimestamp confirming when the credential expires. Projected service account tokens mounted into pods default to one hour of validity, with a minimum enforced duration of 600 seconds, and are automatically rotated by the kubelet before expiry; when rotation is not possible, the token expires and subsequent requests from the workload are rejected. User access to vSphere namespaces and VKS clusters is authenticated through VCF SSO, which provides the OIDC token that kubectl and other API clients use; when that token expires, the user must re-authenticate without administrator intervention.

Streaming sessions opened through the Kubernetes API, including `kubectl exec`, `kubectl attach`, and `port-forward` connections, are governed by the kubelet's `streamingConnectionIdleTimeout` parameter, which automatically closes any streaming connection that has been idle for the configured duration. In VKS clusters provisioned through the ClusterClass API, `streamingConnectionIdleTimeout` is exposed as a configurable variable in the `kubeletConfiguration` ClusterClass variable block, with a default of 10 minutes. For ingress traffic routed through the Contour package, idle HTTP connections are terminated when they exceed the `timeouts.connection-idle-timeout` value, and idle HTTP streams are closed when they exceed `timeouts.stream-idle-timeout`; both are configurable in the Contour package configuration and apply to all traffic passing through the ingress layer.

At the API layer, the vSphere Web Services API provides a `SessionManager` with explicit logout methods to close authenticated sessions. The VCF Operations PowerShell plug-in offers a `closeSession` method to terminate sessions by session ID. These programmatic interfaces allow automated tools and scripts to enforce session cleanup as part of operational workflows.

Across all components, VCF provides both configurable inactivity timeouts for interactive sessions and explicit session termination capabilities through management interfaces and APIs. The default timeout values vary by component but are set to enforce session termination within reasonable inactivity windows, and all are adjustable to meet organization-defined policies. Auditors evaluating a VCF deployment should verify the timeout values configured for each management component as well as the Kubernetes API server `--service-account-max-token-expiration` parameter and the kubelet `streamingConnectionIdleTimeout` for VKS clusters.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to third-party remote access governance through network-layer controls that restrict which sources can reach internal systems via firewall policy. The vDefend distributed firewall (DFW) enforces granular east-west segmentation rules that limit the network paths available to third-party remote accounts, reducing exposure from overly broad access grants. The Identity Firewall (IDFW) associates DFW rule enforcement with user identities sourced from Active Directory, using Guest Introspection or Event Log Scraping to detect logon events and apply user- or group-based network restrictions at the hypervisor layer. Event Log Scraping monitors login events from domain controller event log servers and applies to both virtual machines and physical devices. In 9.1, IDFW also supports Multi-User (RDSH) scenarios, enabling identity-aware enforcement for shared terminal server environments commonly used for remote access.

The Security Services Platform (SSP) provides a complementary monitoring layer through campaign correlation rules that detect lateral movement sequences, including RDP activity from one workload to another followed by command-and-control indicators, which can surface anomalous behavior associated with third-party remote access paths. SSP implements role-based access control with three defined roles (Enterprise Admin, Auditor, and Support Bundle Collector) and supports assignment of those roles to remote users and remote user groups, applying access governance to vDefend administration itself. SSP also supports LDAP as an authentication provider for integrating directory services with remote user and user group management.

Provisioning, lifecycle management, and direct account governance for third-party remote access identities fall outside vDefend's scope and require a dedicated identity and access management solution.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides session termination through two distinct planes: the management plane (Avi Controller) and the data plane (Service Engines handling application traffic).

For management sessions, the Avi Controller enforces a configurable Session Timeout that specifies the maximum number of minutes an administrative session can remain idle before the Controller terminates it automatically (Administration > System > Access Settings). When a UI session expires due to timeout or logout, the Controller displays a login screen requiring reauthentication. When an API session ends due to timeout or logout, the next API call fails validation. CLI sessions are terminated silently on expiration; the next command typed triggers re-validation of a new CLI session. The Controller also enforces the `api_force_timeout` setting, which bounds the maximum duration of portal API sessions (24 hours by default). The Avi Controller generates `USER_LOGOUT` events in the audit event log, providing a record of session termination activity for

administrative users. When the maximum concurrent session count is reached, administrators can also forcibly invalidate existing sessions using the shell `-clear-sessions` command.

For application sessions proxied through Avi virtual services, the TCP Fast Path Profile includes a configurable Session Idle Timeout parameter. When an application-layer flow is idle for the configured period, the Service Engine terminates it and sends a TCP reset to both the client and the server.

For applications using OAuth 2.0 and OpenID Connect (OIDC) for client authentication, Avi supports Relying Party (RP)-initiated logout. When a user logs out, Avi, acting as the OAuth client, redirects the user agent to the Identity Provider's end session endpoint (configured via the `end_session_endpoint` parameter in the `oauth_profile`) to terminate the session at the Identity Provider level. The logout URI is configurable via the `logout-uri` parameter, and a `post_logout_redirect_uri` can be configured to direct users to a defined location after logout. Upon logout, Avi clears the user's session details from the session database. After RP-initiated logout completes, the user must provide credentials again to access resources.

In Kubernetes environments using the Avi Kubernetes Operator (AKO), the SSORule CRD provides OAuth/OIDC session cookie timeout configuration via the `cookieTimeout` property in `oauthVsConfig` (specified in minutes, with a default of 120 seconds). The `/oauth/logout` endpoint is available for OAuth session termination through the SSORule CRD configuration.

When Avi is deployed with Avi Cloud Console, session logout from the Cloud Console is separate from Broadcom IDP session logout. Users who log out of the Cloud Console must also log out from the Broadcom support portal to fully terminate their Broadcom IDP session. Auditors evaluating organizations using Avi Cloud Console should verify that users understand this distinction and that operational procedures account for it.

Auditors should verify the Session Timeout setting in the Avi Controller under Administration > System > Access Settings and confirm that the `api_force_timeout` value aligns with organizational policy. For virtual services using OIDC client authentication, auditors should review the OAuth Profile configuration to confirm that the `end_session_endpoint` and `logout-uri` parameters are set.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Not supported directly for this control: VMware Data Services Manager. This product does not currently provide the capability this control requires.

Control CIP-005-7 3.1

> Have one or more method(s) to determine authenticated vendorinitiated remote connections.

SCF Controls: MNT-05.5, NET-14.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical controls that support governance of third-party remote access to system components, though the organizational policies and monitoring processes that govern how third parties are granted, reviewed, and revoked access fall outside the platform itself.

VCF restricts remote access to infrastructure components through multiple mechanisms. ESX hosts support the TSM-SSH service, which can be started and stopped to enable or disable SSH access on a per-host basis. SSH access is disabled by default on components such as VCF Operations Cloud Proxy, where the first login must be performed via the vCenter console. The DCUI.Access setting on ESX hosts controls which users can override lockdown mode and access the Direct Console User Interface, providing an additional layer of access restriction for management interfaces. ESX Lockdown Mode provides a more restrictive posture by limiting direct host access through the DCUI, ESX Shell, and SSH to users with administrator privileges who are designated as Exception Users, while requiring all other operations to flow through VMware vCenter. ESX Shell and SSH services operate independently of Lockdown Mode and must be explicitly deactivated, since Lockdown Mode itself does not restrict those services. VNC-based remote console access to virtual machines can be enabled or disabled through the RemoteDisplay.vnc.enabled setting in vCenter.

For session and authentication management, ESX host advanced options include configurable settings for login attempts before lockout, delay after lockout, session timeouts for SOAP connections, shell access, and host client sessions. The vCenter SessionManager provides an interface to the authentication infrastructure, and local sessions can be configured to control how users with host credentials authenticate. These settings allow administrators to enforce session controls on any account, including those used by third-party support personnel.

VCF integrates with external identity providers through VCF SSO, which supports identity federation with enterprise authentication systems including Active Directory and LDAP. User accounts can be imported from authorization sources through the VCF Operations Access Control interface and assigned roles appropriate to their access needs. Centralizing third-party account management through directory services rather than local accounts gives organizations a single place to provision, review, and revoke access.

Role-based access control is enforced across all VCF components to limit third-party accounts to only the permissions they require. VCF Automation Access Control supports Global Roles with granular rights assignments across categories including Access Control, Administration, Compute, Content Hubs, Extensions, and Infrastructure. Rights bundles allow administrators to group permissions logically and assign them consistently. vSphere controls permissions through role assignments that determine which objects a user can view and which operations they can invoke. vSAN supports its own RBAC and permissions management. In multi-tenant NSX environments, Project Admin and VPC Admin roles automatically scope access to the relevant project or VPC, limiting what third-party users can reach within the infrastructure. VCF Automation supports service accounts for automated access by third-party applications, giving administrators a way to provision and scope machine-to-machine credentials separately from interactive user accounts. System administrators can create custom roles in VCF Automation that scope permissions appropriately for each service account.

VCF Automation Organizations provide a multi-tenancy framework where IT teams can control permissions and monitor resource usage, with network isolation between organizational boundaries. Organization administrators can view role assignments, create organization-local roles, and manage user access within their scope. This is relevant for environments where third-party vendors operate within a dedicated tenant boundary.

Audit logging captures administrative actions performed across the environment. VCF Operations for Networks records CRUD operations and login/logout events in its audit logs, capturing actions from the API, the user interface, and the CLI. NSX Manager generates audit logs for events such as logon, logoff, and resource access, with each entry containing the timestamp,

source, result, and a description of the event. VCF Operations records audit events for interactions including searches, logins, logouts, capability checks, and configuration modifications. Administrators should continuously monitor user security aspects to detect risks early and verify that users have the appropriate level of access.

Proactive lifecycle management of third-party accounts, including onboarding, periodic access reviews, and timely deprovisioning, requires organizational processes and potentially a Privileged Access Management (PAM) solution outside of VCF. VCF provides the RBAC framework, identity integration, session controls, and audit trail that support those processes, but the governance policies themselves must be defined and enforced at the organizational level.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to third-party remote access governance through network-layer controls that restrict which sources can reach internal systems via firewall policy. The vDefend distributed firewall (DFW) enforces granular east-west segmentation rules that limit the network paths available to third-party remote accounts, reducing exposure from overly broad access grants. The Identity Firewall (IDFW) associates DFW rule enforcement with user identities sourced from Active Directory, using Guest Introspection or Event Log Scraping to detect logon events and apply user- or group-based network restrictions at the hypervisor layer. Event Log Scraping monitors login events from domain controller event log servers and applies to both virtual machines and physical devices. In 9.1, IDFW also supports Multi-User (RDSH) scenarios, enabling identity-aware enforcement for shared terminal server environments commonly used for remote access.

The Security Services Platform (SSP) provides a complementary monitoring layer through campaign correlation rules that detect lateral movement sequences, including RDP activity from one workload to another followed by command-and-control indicators, which can surface anomalous behavior associated with third-party remote access paths. SSP implements role-based access control with three defined roles (Enterprise Admin, Auditor, and Support Bundle Collector) and supports assignment of those roles to remote users and remote user groups, applying access governance to vDefend administration itself. SSP also supports LDAP as an authentication provider for integrating directory services with remote user and user group management.

Provisioning, lifecycle management, and direct account governance for third-party remote access identities fall outside vDefend's scope and require a dedicated identity and access management solution.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides account management and access control mechanisms that support governance of third-party remote access to the Avi management plane.

Avi Load Balancer maintains user accounts in two categories: local users and remote users. Remote users are authenticated through an external authentication, authorization, and accounting (AAA) server, with support for LDAP, TACACS+, and SAML. This separation is important for third-party access governance because it allows an organization to route third-party support accounts through the same identity infrastructure used for other administrative access, applying centralized account lifecycle controls such as account disabling when a support engagement ends.

For remotely authenticated users, Avi supports tenant and role mapping through Auth Mapping Profiles. When a third-party account authenticates via LDAP or TACACS+, its access is scoped to the tenants and roles defined in the mapping configuration. When a remote user with the All or Admin role authenticates, any user-specified tenant is applied; in the absence of user-defined tenants, the admin tenant is selected as the default. This limits what any given third-party account can see and do within the Avi Controller. The Auth Mapping Profile configuration is available under User Authentication and Authorization in the Avi Controller.

Avi Controller also supports extended granular role-based access control (RBAC) through label groups that can be associated with tenants, allowing label-based access policies to further constrain what resources a given role can access within a tenant. This provides additional scoping for third-party accounts that need access to specific virtual services or resource groups rather than an entire tenant.

Role-based access control is applied through the Avi admin console, which provides controls to restrict user permissions across the platform. Administrators should define a minimal-privilege role for third-party accounts rather than granting full administrative access.

One configuration point requires attention: the admin account is maintained as a locally authenticated account even when the system is otherwise configured for remote authentication. Third-party access should not rely on this account, as it is not subject to external identity provider controls. Organizations should provision dedicated named accounts for any third party requiring access, so that account activity is attributable and accounts can be individually disabled.

Avi Controller supports SSH access for remote administration using local or remote authentication for Admin and CLI users. When remote authentication is in use, SSH access for third-party accounts is governed by the same external AAA authentication controls that apply to UI access.

Meeting the control's requirement for proactive governance requires organizational process beyond these mechanisms: the organization must define who can grant third-party access, under what conditions, and on what schedule access is reviewed and revoked. Avi provides the access control infrastructure; the governance itself is an organizational responsibility.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-005-7 3.2

> Have one or more method(s) to terminate authenticated vendor-initiated remote connections and control the ability to reconnect.

SCF Controls: IAC-25, NET-14.6, NET-14.8

Aggregate Coverage: Meets

VCF (Meets)

VCF provides automated session termination and inactivity timeout mechanisms across its management interfaces, APIs, and component products. These controls operate at multiple layers of the platform to log out users after configurable periods of inactivity or at session end.

At the hypervisor layer, VMware ESX includes a Host Client Session Timeout setting that controls the duration before an inactive Host Client session is terminated. Administrators can configure this value through the ESX security configuration to align with organizational inactivity policies. The ESX Shell, used for console and SSH administrative access, has a separate idle timeout controlled by the ESX-Shell-idle-timeout advanced system setting (UserVars.ESXShellInteractiveTimeOut), which independently terminates inactive shell sessions.

VMware vCenter uses token-based session management through VCF SSO. Security tokens have a default expiration interval of 30 minutes, after which the session is no longer valid and the user must re-authenticate. The vCenter SessionManager managed object controls user access to the server through methods for logging in, obtaining a session, and logging out, providing both automatic expiration and programmatic session termination capabilities. When any session ends, the associated authentication token is invalidated. The vCenter Appliance Management Interface also enforces a session timeout, expiring idle login sessions after 10 minutes by default. The vSphere Client enforces its own session timeout that defaults to 120 minutes of inactivity and is configurable through the session.timeout parameter.

NSX Manager supports session timeout and automatic user logout. Idle sessions time out automatically, and upon session termination or user logout, users are redirected to the login page. The idle session timeout is configurable, and administrators can also delete idle sessions using the /api/session/destroy API command. When a user logs out, NSX Manager immediately destroys the session identifier and removes the session cookie from the reverse-proxy, limiting session identifier reuse. Session IDs and tokens for each session are unique and expire after the user logs out or after a period of inactivity.

VCF Operations enforces a user session timeout that defaults to 15 minutes and can be modified to match organizational requirements. VCF Operations for Networks allows configuration of the user session timeout with a value range from 15 minutes to 24 hours, giving administrators flexibility to set inactivity thresholds appropriate for their environment. VCF Operations also recommends defining a Release Session Request when using session authentication to log out sessions and reduce session leaks.

The VCF Automation Provider Management Portal automatically logs out users after more than 25 minutes of inactivity. VCF Automation also supports API token expiration, with access tokens expiring after 30 days and API tokens expiring after 90 days by default. At the organization level, deactivating a VCF Automation organization terminates the sessions of all users currently logged in to that organization, providing an administrative mechanism for bulk session termination.

At the Kubernetes consumption layer, the VMware Kubernetes Service (VKS) and vSphere Supervisor enforce bounded session lifetimes through multiple token expiration mechanisms. The Kubernetes API server enforces a maximum validity duration for all service account tokens through the --service-account-max-token-expiration parameter, which caps token lifetimes server-side regardless of what a requesting client specifies. Tokens generated via the TokenRequest API accept an expirationSeconds parameter, and the TokenRequestStatus includes an expirationTimestamp confirming when the credential expires. Projected service account tokens mounted into pods default to one hour of validity, with a minimum enforced duration of 600 seconds, and are automatically rotated by the kubelet before expiry; when rotation is not possible, the token expires and subsequent requests from the workload are rejected. User access to vSphere namespaces and VKS clusters is authenticated through VCF SSO, which provides the OIDC token that kubectl and other API clients use; when that token expires, the user must re-authenticate without administrator intervention.

Streaming sessions opened through the Kubernetes API, including `kubectl exec`, `kubectl attach`, and `port-forward` connections, are governed by the kubelet's `streamingConnectionIdleTimeout` parameter, which automatically closes any streaming connection that has been idle for the configured duration. In VKS clusters provisioned through the ClusterClass API, `streamingConnectionIdleTimeout` is exposed as a configurable variable in the `kubeletConfiguration` ClusterClass variable block, with a default of 10 minutes. For ingress traffic routed through the Contour package, idle HTTP connections are terminated when they exceed the `timeouts.connection-idle-timeout` value, and idle HTTP streams are closed when they exceed `timeouts.stream-idle-timeout`; both are configurable in the Contour package configuration and apply to all traffic passing through the ingress layer.

At the API layer, the vSphere Web Services API provides a `SessionManager` with explicit logout methods to close authenticated sessions. The VCF Operations PowerShell plug-in offers a `closeSession` method to terminate sessions by session ID. These programmatic interfaces allow automated tools and scripts to enforce session cleanup as part of operational workflows.

Across all components, VCF provides both configurable inactivity timeouts for interactive sessions and explicit session termination capabilities through management interfaces and APIs. The default timeout values vary by component but are set to enforce session termination within reasonable inactivity windows, and all are adjustable to meet organization-defined policies. Auditors evaluating a VCF deployment should verify the timeout values configured for each management component as well as the Kubernetes API server `--service-account-max-token-expiration` parameter and the kubelet `streamingConnectionIdleTimeout` for VKS clusters.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to third-party remote access governance through network-layer controls that restrict which sources can reach internal systems via firewall policy. The vDefend distributed firewall (DFW) enforces granular east-west segmentation rules that limit the network paths available to third-party remote accounts, reducing exposure from overly broad access grants. The Identity Firewall (IDFW) associates DFW rule enforcement with user identities sourced from Active Directory, using Guest Introspection or Event Log Scraping to detect logon events and apply user- or group-based network restrictions at the hypervisor layer. Event Log Scraping monitors login events from domain controller event log servers and applies to both virtual machines and physical devices. In 9.1, IDFW also supports Multi-User (RDSH) scenarios, enabling identity-aware enforcement for shared terminal server environments commonly used for remote access.

The Security Services Platform (SSP) provides a complementary monitoring layer through campaign correlation rules that detect lateral movement sequences, including RDP activity from one workload to another followed by command-and-control indicators, which can surface anomalous behavior associated with third-party remote access paths. SSP implements role-based access control with three defined roles (Enterprise Admin, Auditor, and Support Bundle Collector) and supports assignment of those roles to remote users and remote user groups, applying access governance to vDefend administration itself. SSP also supports LDAP as an authentication provider for integrating directory services with remote user and user group management.

Provisioning, lifecycle management, and direct account governance for third-party remote access identities fall outside vDefend's scope and require a dedicated identity and access management solution.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides session termination through two distinct planes: the management plane (Avi Controller) and the data plane (Service Engines handling application traffic).

For management sessions, the Avi Controller enforces a configurable Session Timeout that specifies the maximum number of minutes an administrative session can remain idle before the Controller terminates it automatically (Administration > System > Access Settings). When a UI session expires due to timeout or logout, the Controller displays a login screen requiring reauthentication. When an API session ends due to timeout or logout, the next API call fails validation. CLI sessions are terminated silently on expiration; the next command typed triggers re-validation of a new CLI session. The Controller also enforces the `api_force_timeout` setting, which bounds the maximum duration of portal API sessions (24 hours by default). The Avi Controller generates `USER_LOGOUT` events in the audit event log, providing a record of session termination activity for

administrative users. When the maximum concurrent session count is reached, administrators can also forcibly invalidate existing sessions using the shell `-clear-sessions` command.

For application sessions proxied through Avi virtual services, the TCP Fast Path Profile includes a configurable Session Idle Timeout parameter. When an application-layer flow is idle for the configured period, the Service Engine terminates it and sends a TCP reset to both the client and the server.

For applications using OAuth 2.0 and OpenID Connect (OIDC) for client authentication, Avi supports Relying Party (RP)-initiated logout. When a user logs out, Avi, acting as the OAuth client, redirects the user agent to the Identity Provider's end session endpoint (configured via the `end_session_endpoint` parameter in the `oauth_profile`) to terminate the session at the Identity Provider level. The logout URI is configurable via the `logout-uri` parameter, and a `post_logout_redirect_uri` can be configured to direct users to a defined location after logout. Upon logout, Avi clears the user's session details from the session database. After RP-initiated logout completes, the user must provide credentials again to access resources.

In Kubernetes environments using the Avi Kubernetes Operator (AKO), the SSORule CRD provides OAuth/OIDC session cookie timeout configuration via the `cookieTimeout` property in `oauthVsConfig` (specified in minutes, with a default of 120 seconds). The `/oauth/logout` endpoint is available for OAuth session termination through the SSORule CRD configuration.

When Avi is deployed with Avi Cloud Console, session logout from the Cloud Console is separate from Broadcom IDP session logout. Users who log out of the Cloud Console must also log out from the Broadcom support portal to fully terminate their Broadcom IDP session. Auditors evaluating organizations using Avi Cloud Console should verify that users understand this distinction and that operational procedures account for it.

Auditors should verify the Session Timeout setting in the Avi Controller under Administration > System > Access Settings and confirm that the `api_force_timeout` value aligns with organizational policy. For virtual services using OIDC client authentication, auditors should review the OAuth Profile configuration to confirm that the `end_session_endpoint` and `logout-uri` parameters are set.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Not supported directly for this control: VMware Data Services Manager. This product does not currently provide the capability this control requires.

Control CIP-006-6 1.1

> Define operational or procedural controls to restrict physical access

SCF Controls: OPS-01.1, PES-01.1, PES-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 1.2

> utilize at least one physical access control to allow unescorted physical access into each applicable Physical Security Perimeter to only those individuals who have authorized unescorted physical access.

SCF Controls: PES-01.2, PES-02.1, PES-06, PES-06.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 1.3

> Where technically feasible, utilize two or more different physical access controls (this does not require two completely independent physical access control systems) to collectively allow unescorted physical access into Physical Security Perimeters to only those individuals who have authorized unescorted physical access.

SCF Controls: PES-03, PES-06, PES-06.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 1.4

> Monitor for unauthorized access through a physical access point into a Physical Security Perimeter.

SCF Controls: MON-16.3, PES-03.3, PES-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 1.5

> Issue an alarm or alert in response to detected unauthorized access through a physical access point into a Physical Security Perimeter to the personnel identified in the BES Cyber Security Incident response plan within 15 minutes of detection.

SCF Controls: PES-03, PES-03.1, PES-05.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 1.6

> Monitor each Physical Access Control System for unauthorized physical access to a Physical Access Control System.

SCF Controls: PES-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 1.7

> Issue an alarm or alert in response to detected unauthorized physical access to a Physical Access Control System to the personnel identified in the BES Cyber Security Incident response plan within 15 minutes of the detection.

SCF Controls: PES-05, PES-05.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 1.8

> Log (through automated means or by personnel who control entry) entry of each individual with authorized unescorted physical access into each Physical Security Perimeter, with information to identify the individual and date and time of entry.

SCF Controls: PES-03.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 1.9

> Retain physical access logs of entry of individuals with authorized unescorted physical access into each Physical Security Perimeter for at least ninety calendar days.

SCF Controls: DCH-18, MON-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable event log retention across its component products, allowing organizations to align retention periods with their records retention requirements and support after-the-fact investigations of security incidents.

VCF Automation offers direct control over log history retention through its Activity Log configuration. Administrators can specify the number of days of log history to keep before automatic deletion, or set the value to zero to retain logs indefinitely. This flexibility allows organizations to match retention to their specific statutory, regulatory, or contractual obligations without external tooling.

VCF Log Management is the centralized log aggregation platform and provides configurable data retention periods that govern how long collected audit events remain available for query and analysis. Within VCF Log Management, administrators define log partitions that segregate collected logs by criteria such as source or category, each with its own retention period measured in days, so that security audit records can be retained longer than routine operational logs to match differing records-retention obligations. VCF Log Management removes logs from disk once a partition's retention period is met, and partitions can be archived to external NFS or S3 storage for retention beyond the active log store. VCF Operations surfaces audit events with selectable time ranges of 1, 6, 12, 24, and 48 hours for immediate review, with longer-term availability determined by the retention policy configured in the VCF Log Management instance. When the retention period is set to zero, logs are kept indefinitely and are not automatically removed based on time. VCF Operations for Networks adds its own retention controls, with entity metrics retention configurable from one month to six months. Administrators should back up log files before reducing any retention period, as the change deletes all data older than the newly specified window. Audit logs in VCF Operations for Networks capture administrative actions carried out in the system, including regular CRUD operations and login/logout alerts.

At the host layer, VMware ESX (ESX) provides log file rotation controls that govern how many log files the system maintains locally. When the configured limit is reached, the oldest file is removed. The local syslog directory location is configurable through the Syslog.global.logDir parameter, allowing administrators to point log storage to a volume sized for their retention needs. ESX audit records can be directed to a remote syslog host separately from general syslog messages by enabling the Syslog.global.auditRecord.remote parameter, which works in conjunction with Syslog.global.logHost to specify the destination. ESX and vCenter services maintain separate log files, each with their own rotation and retention behavior.

The Consumption layer of VCF, encompassing VMware Kubernetes Service (VKS) clusters, vSphere Supervisor, and vSphere Namespaces, produces structured audit and operational log data and includes built-in forwarding infrastructure so that organizational retention policies can be applied at external receivers. The Kubernetes API server (kube-apiserver) running on VKS clusters generates audit events conforming to the audit.k8s.io API group. Each event captures the requesting user, timestamp, resource accessed, and the audit level at which it was generated. The --audit-log-path flag directs these events to a file on the node, and the --audit-log-maxage parameter defines the maximum number of days to retain old audit log files based on the timestamp encoded in the filename, providing a direct file-level retention control that can be aligned to statutory or regulatory requirements. Audit policy rules govern which events are recorded at four levels: None (not recorded), Metadata, Request, or RequestResponse. Organizations should note that standard Kubernetes cluster Event objects in the core API group have limited in-cluster retention and should not be relied upon as a compliance log source; the kube-apiserver audit logging subsystem, written to files or forwarded via webhook, is the appropriate mechanism for compliance-relevant event data.

VKS clusters include Fluent Bit logging agents deployed in the vmware-system-logging namespace. These agents collect container logs, Linux daemon logs, Linux authentication logs, and Kubernetes API server audit logs, tagging each category

separately to support targeted routing and retention policies at the receiving system. Fluent Bit can forward logs to Syslog servers, HTTP endpoints, Elasticsearch, Kafka, Splunk, and VCF Log Management; a sample configuration for forwarding to VCF Log Management is included in the Fluent Bit standard package available on VKS clusters. For workloads running as vSphere Pods in a vSphere Namespace, applying a LogAgentConfiguration Custom Resource to the namespace directs syslog messages to a remote Syslog server; each message carries metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, supporting forensic traceability after a security incident. Kubernetes handles log rotation for applications writing to standard output to prevent uncontrolled growth on local node storage. VKS clusters generate additional component logs from CAPI, CAPV, VM Operator, and the VKS Controller Manager, which are accessible via kubectl and gathered in support bundles along with containerd journal logs for incident investigation.

The vSphere Supervisor control plane collects its own kube-apiserver audit logs through Fluent Bit, tagging them with the audit.apiserver.* prefix and reading from /var/log/vmware/audit/kube-apiserver.log on the Supervisor nodes. The Supervisor can also be configured to preserve the source IP addresses of authentication and Kubernetes API Server requests, making them available for inspection in audit logs and supporting forensic reconstruction of access events.

For long-term and centralized retention, VCF supports forwarding event logs from all major components to remote syslog infrastructure. ESX hosts can be configured to send syslog messages to a remote log server using the esxcli system syslog config set command. VMware vCenter can also stream events to a remote syslog server by enabling the vpxd.event.syslog.enabled parameter in the vCenter Management Interface. The vCenter local database is not intended for long-term archival retention: events are deleted at the end of the configured retention period, and extending retention beyond the default requires corresponding database capacity increases. NSX sends audit logs directly to the configured remote syslog server, with NSX Manager audit logging enabled by default and recording security policy changes with request identifiers and timestamps for traceability. VCF Operations integrates its audit log with syslog and supports configuring a syslog collector to gather all audit records. VCF Log Management can also pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. Log collection from vCenter can be activated directly from VCF Operations when vCenter is integrated. This centralized collection architecture enables organizations to apply retention policies at the aggregation layer that match their compliance requirements, independent of local component retention limits.

The audit events captured across VCF components include administrative actions such as login, logout, object creation and deletion, configuration modifications, capability checks, and security policy changes. NSX audit logs include structured fields for audit flag, component, log level, request ID, and subcomponent, providing the detail needed for forensic analysis. NSX supports logging and auditing capabilities that can be integrated with external logging and monitoring solutions to monitor for security events and anomalies. VCF Operations audit events are designed to facilitate security and compliance audits and provide the detail needed for security forensics investigations.

Defining the retention period required by statute, regulation, contract, and internal policy is an organizational data-governance decision.

VMware vDefend (Contributes)

VMware vDefend retains security event data generated by its own features across defined periods. Network Detection and Response (NDR) collects and retains detection events and campaign data for 12 months. For active subscriptions, IDS events, network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year, and for 90 days following subscription expiration. Security Services Platform (SSP) stores intrusion events and flow data for 30 days each. The IDS/IPS monitoring view retains detailed logs for the last 14 days. SSP provides the ssp_flow_storage.avg_flow_storage_ratio metric, which gives operators visibility into the ratio of current retention days to predicted full days for flow storage.

For forwarding events to external systems, vDefend Distributed IDS/IPS can be configured to send IDS events to external syslog consumers; this setting is disabled by default and must be explicitly enabled. Syslog messages from vDefend appliances conform to RFC 5424, and messages from ESX hosts conform to RFC 3164. SSP can be configured to collect and

transmit log messages to a remote syslog server. Identity Firewall Event Log Sources can be integrated with VCF Log Management for centralized logging and monitoring.

VMware vDefend is not an organization-wide log retention or SIEM solution. Meeting statutory, regulatory, and contractual retention periods requires organizations to forward vDefend events to a dedicated log management or SIEM platform, where custom retention policies can be applied.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates and preserves multiple categories of operational and security-specific logs that support after-the-fact investigation of recovery-related events.

PNR records operational information into log files that exclude sensitive data such as private keys and passwords. vSphere Replication maintains dedicated security audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the appliance and at `/var/run/log` on ESX hosts. Security-relevant events captured in these logs include authorization error messages, certificate verification failures, and session activity such as logout events with timestamps, user identity, source IP address, and operation IDs.

PNR records structured event data across its components, with each event carrying a corresponding alarm that PNR can trigger for health tracking and issue resolution. Protection group activity is logged as typed events: consistency group additions, datastore membership changes, and protection group errors are recorded as Info- or Error-level events, respectively. vSphere Replication generates typed audit events for replication lifecycle transitions, including when virtual machines and hosts are configured or unconfigured for replication. Recovery operations are preserved in a per-plan history log; reprotect operations are included in this log and can be exported as a report, providing a record for post-recovery verification.

The Clean Room Orchestrator records events with a structured schema that includes timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Snapshot task events are captured upon completion and are accessible through the Snapshot log interface in the event details panel.

For forwarding and long-term retention, the PNR Appliance natively supports forwarding log files to remote syslog servers for log analysis and centralized monitoring. PNR supports forwarding events to VCF Log Management (version 9.0 and above), enabling log data to flow into centralized log management infrastructure. PNR also integrates with Microsoft Azure Log Analytics Workspace for custom log collection using Data Collection Rules (DCR) and Data Collection Endpoints (DCE), providing a cloud-native retention path.

Per-component logging levels can be adjusted through the advanced configuration interface. The `logManager.Persistence` setting controls the logging verbosity for persistence-related events, with a default value of verbose, allowing administrators to tune log volume to match available storage and retention requirements.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides configurable backup retention controls that support an organization's data retention requirements for its managed databases. These controls do not define retention obligations, which come from the organization's legal and compliance functions, but they provide the technical means to implement those obligations for PostgreSQL, MySQL, SQL Server, and MinIO data.

Retention periods are configured through Data Service Policies in the DSM administration interface. Each policy supports a backup-retention-period setting that defines the duration for which backups are kept. When multiple policies apply to a namespace, DSM aggregates the retention constraints by selecting the more restrictive minimum and maximum retention day values, producing a resultant retention window that reflects all applicable policies. Data service policies can also be tailored to specific requirements and enforced across different tenants, giving administrators a consistent mechanism for applying retention standards in multi-tenant deployments.

For deleted databases, DSM retains automated backups according to the configured retention period and exposes an Archives tab in the administration interface where administrators can access and adjust the retention period of retained

backups. This allows organizations to maintain access to backup data even after a database instance has been removed, supporting retention obligations that outlast the operational lifetime of a specific database. When a database is deleted, automated backups continue to be retained until the retention policy is met.

DSM also supports point-in-time restore within the backup retention period, enabling recovery to any point within the retained window. On-demand backups behave differently from automated backups: they are permanent and do not expire automatically. On-demand backups remain in the backup storage location until an administrator manually deletes them, which means they can consume storage quota indefinitely and require separate tracking for retention compliance.

Data service policies also define backup storage locations (S3-compatible targets) alongside retention duration. If a data service policy that is in use is deleted, the data services associated with that policy become non-compliant, alerting administrators to a configuration gap.

Meeting this control fully requires the organization to determine the applicable retention periods, communicate those requirements to DSM administrators, and configure policies accordingly. DSM does not automatically derive retention obligations from regulatory or contractual sources. Its retention controls also cover only the database data it manages and do not address retention of all media and data types that may fall within an organization's broader retention obligations.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains an event log system that records system activities, configuration changes, and operational events, with an audit trail that tracks who made configuration changes and when. The Avi Controller preserves a permanent log of the underlying events and metrics that triggered alerts, retaining those records beyond the alert expiry period.

The 9.1 documentation specifies that events raised by Avi Load Balancer components must persist in a secure manner for a minimum of 90 days for audit compliance. The retention policy is configurable: administrators can adjust the periodic interval and the threshold that triggers policy enforcement based on system and infrastructure requirements. The Avi Controller analytics API supports querying event logs for periods of up to one year, and the documentation recommends reviewing event logs over a one-year window to maintain audit trails of configuration changes.

For compliance-grade long-term retention beyond the on-appliance minimum, Avi provides the Syslog-Audit-Persistence feature, configured through the Controller's Alert Actions settings. This feature streams audit compliance events to external syslog servers. The Avi Controller and Service Engine also log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk destinations. The documentation recommends streaming all logs directly to an external server such as Splunk for assured retention; Avi's Controller Settings allow specification of syslog server destination details.

There are retention constraints that organizations should account for when designing their log retention architecture. Configuring syslog notifications in the Avi Controller forwards alert events to syslog servers but does not directly export virtual service logs; those must be pulled from an external logging system through the API or scripted to be pushed from the Controller to a remote destination. In the absence of active queries, application logs do not leave the Service Engines that collected them. For retention periods beyond the built-in minimum, administrators must configure Syslog-Audit-Persistence or an equivalent export mechanism to an external destination and maintain that destination's storage capacity and retention settings independently.

Control CIP-006-6 1.10

> Restrict physical access to cabling and other nonprogrammable communication components used for connection between applicable Cyber Assets within the same Electronic Security Perimeter in those instances when such cabling and components are located outside of a Physical Security Perimeter. Where physical access restrictions to such cabling and components are not implemented, the Responsible Entity shall document and implement one or more of the following: ☐ encryption of data that transits such cabling and components; or ☐ monitoring the status of the communication link composed of such cabling and components and issuing an alarm or alert in response to detected communication failures to the personnel identified in the BES Cyber Security Incident response plan within 15 minutes of detection; or ☐ an equally effective logical protection.

SCF Controls: CRY-01, PES-03, PES-12, PES-12.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import

of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor

endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be

configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the `PGCRYPTO_PASSWORD` and `PGCRYPTO_ALGORITHM` keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal

communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control CIP-006-6 2.1

> Require continuous escorted access of visitors (individuals who are provided access but are not authorized for unescorted physical access) within each Physical Security Perimeter, except during CIP Exceptional Circumstances.

SCF Controls: PES-06.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 2.2

> Require manual or automated logging of visitor entry into and exit from the Physical Security Perimeter that includes date and time of the initial entry and last exit, the visitor's name, and the name of an individual point of contact responsible for the visitor, except during CIP Exceptional Circumstances.

SCF Controls: PES-06, PES-06.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 2.3

> Retain visitor logs for at least ninety calendar days.

SCF Controls: MON-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable event log retention across its component products, allowing organizations to align retention periods with their records retention requirements and support after-the-fact investigations of security incidents.

VCF Automation offers direct control over log history retention through its Activity Log configuration. Administrators can specify the number of days of log history to keep before automatic deletion, or set the value to zero to retain logs indefinitely. This flexibility allows organizations to match retention to their specific statutory, regulatory, or contractual obligations without external tooling.

VCF Log Management is the centralized log aggregation platform and provides configurable data retention periods that govern how long collected audit events remain available for query and analysis. Within VCF Log Management, administrators define log partitions that segregate collected logs by criteria such as source or category, each with its own retention period measured in days, so that security audit records can be retained longer than routine operational logs to match differing records-retention obligations. VCF Log Management removes logs from disk once a partition's retention period is met, and partitions can be archived to external NFS or S3 storage for retention beyond the active log store. VCF Operations surfaces audit events with selectable time ranges of 1, 6, 12, 24, and 48 hours for immediate review, with longer-term availability determined by the retention policy configured in the VCF Log Management instance. When the retention period is set to zero, logs are kept indefinitely and are not automatically removed based on time. VCF Operations for Networks adds its own retention controls, with entity metrics retention configurable from one month to six months. Administrators should back up log files before reducing any retention period, as the change deletes all data older than the newly specified window. Audit logs in VCF Operations for Networks capture administrative actions carried out in the system, including regular CRUD operations and login/logout alerts.

At the host layer, VMware ESX (ESX) provides log file rotation controls that govern how many log files the system maintains locally. When the configured limit is reached, the oldest file is removed. The local syslog directory location is configurable through the Syslog.global.logDir parameter, allowing administrators to point log storage to a volume sized for their retention needs. ESX audit records can be directed to a remote syslog host separately from general syslog messages by enabling the Syslog.global.auditRecord.remote parameter, which works in conjunction with Syslog.global.logHost to specify the destination. ESX and vCenter services maintain separate log files, each with their own rotation and retention behavior.

The Consumption layer of VCF, encompassing VMware Kubernetes Service (VKS) clusters, vSphere Supervisor, and vSphere Namespaces, produces structured audit and operational log data and includes built-in forwarding infrastructure so that organizational retention policies can be applied at external receivers. The Kubernetes API server (kube-apiserver) running on VKS clusters generates audit events conforming to the audit.k8s.io API group. Each event captures the requesting user, timestamp, resource accessed, and the audit level at which it was generated. The --audit-log-path flag directs these events to a file on the node, and the --audit-log-maxage parameter defines the maximum number of days to retain old audit log files based on the timestamp encoded in the filename, providing a direct file-level retention control that can be aligned to statutory or regulatory requirements. Audit policy rules govern which events are recorded at four levels: None (not recorded), Metadata, Request, or RequestResponse. Organizations should note that standard Kubernetes cluster Event objects in the core API group have limited in-cluster retention and should not be relied upon as a compliance log source; the kube-apiserver audit logging subsystem, written to files or forwarded via webhook, is the appropriate mechanism for compliance-relevant event data.

VKS clusters include Fluent Bit logging agents deployed in the vmware-system-logging namespace. These agents collect container logs, Linux daemon logs, Linux authentication logs, and Kubernetes API server audit logs, tagging each category separately to support targeted routing and retention policies at the receiving system. Fluent Bit can forward logs to Syslog

servers, HTTP endpoints, Elasticsearch, Kafka, Splunk, and VCF Log Management; a sample configuration for forwarding to VCF Log Management is included in the Fluent Bit standard package available on VKS clusters. For workloads running as vSphere Pods in a vSphere Namespace, applying a LogAgentConfiguration Custom Resource to the namespace directs syslog messages to a remote Syslog server; each message carries metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, supporting forensic traceability after a security incident. Kubernetes handles log rotation for applications writing to standard output to prevent uncontrolled growth on local node storage. VKS clusters generate additional component logs from CAPI, CAPV, VM Operator, and the VKS Controller Manager, which are accessible via kubectl and gathered in support bundles along with containerd journal logs for incident investigation.

The vSphere Supervisor control plane collects its own kube-apiserver audit logs through Fluent Bit, tagging them with the audit.apiserver.* prefix and reading from /var/log/vmware/audit/kube-apiserver.log on the Supervisor nodes. The Supervisor can also be configured to preserve the source IP addresses of authentication and Kubernetes API Server requests, making them available for inspection in audit logs and supporting forensic reconstruction of access events.

For long-term and centralized retention, VCF supports forwarding event logs from all major components to remote syslog infrastructure. ESX hosts can be configured to send syslog messages to a remote log server using the esxcli system syslog config set command. VMware vCenter can also stream events to a remote syslog server by enabling the vpxd.event.syslog.enabled parameter in the vCenter Management Interface. The vCenter local database is not intended for long-term archival retention: events are deleted at the end of the configured retention period, and extending retention beyond the default requires corresponding database capacity increases. NSX sends audit logs directly to the configured remote syslog server, with NSX Manager audit logging enabled by default and recording security policy changes with request identifiers and timestamps for traceability. VCF Operations integrates its audit log with syslog and supports configuring a syslog collector to gather all audit records. VCF Log Management can also pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. Log collection from vCenter can be activated directly from VCF Operations when vCenter is integrated. This centralized collection architecture enables organizations to apply retention policies at the aggregation layer that match their compliance requirements, independent of local component retention limits.

The audit events captured across VCF components include administrative actions such as login, logout, object creation and deletion, configuration modifications, capability checks, and security policy changes. NSX audit logs include structured fields for audit flag, component, log level, request ID, and subcomponent, providing the detail needed for forensic analysis. NSX supports logging and auditing capabilities that can be integrated with external logging and monitoring solutions to monitor for security events and anomalies. VCF Operations audit events are designed to facilitate security and compliance audits and provide the detail needed for security forensics investigations.

Defining the retention period required by statute, regulation, contract, and internal policy is an organizational data-governance decision.

VMware vDefend (Contributes)

VMware vDefend retains security event data generated by its own features across defined periods. Network Detection and Response (NDR) collects and retains detection events and campaign data for 12 months. For active subscriptions, IDS events, network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year, and for 90 days following subscription expiration. Security Services Platform (SSP) stores intrusion events and flow data for 30 days each. The IDS/IPS monitoring view retains detailed logs for the last 14 days. SSP provides the ssp_flow_storage.avg_flow_storage_ratio metric, which gives operators visibility into the ratio of current retention days to predicted full days for flow storage.

For forwarding events to external systems, vDefend Distributed IDS/IPS can be configured to send IDS events to external syslog consumers; this setting is disabled by default and must be explicitly enabled. Syslog messages from vDefend appliances conform to RFC 5424, and messages from ESX hosts conform to RFC 3164. SSP can be configured to collect and transmit log messages to a remote syslog server. Identity Firewall Event Log Sources can be integrated with VCF Log Management for centralized logging and monitoring.

VMware vDefend is not an organization-wide log retention or SIEM solution. Meeting statutory, regulatory, and contractual retention periods requires organizations to forward vDefend events to a dedicated log management or SIEM platform, where custom retention policies can be applied.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates and preserves multiple categories of operational and security-specific logs that support after-the-fact investigation of recovery-related events.

PNR records operational information into log files that exclude sensitive data such as private keys and passwords. vSphere Replication maintains dedicated security audit logs at `/opt/vmware/support/logs/hms/hms-audit.log`` and broker logs at `/opt/vmware/support/logs/hbr`` on the appliance and at `/var/run/log`` on ESX hosts. Security-relevant events captured in these logs include authorization error messages, certificate verification failures, and session activity such as logout events with timestamps, user identity, source IP address, and operation IDs.

PNR records structured event data across its components, with each event carrying a corresponding alarm that PNR can trigger for health tracking and issue resolution. Protection group activity is logged as typed events: consistency group additions, datastore membership changes, and protection group errors are recorded as Info- or Error-level events, respectively. vSphere Replication generates typed audit events for replication lifecycle transitions, including when virtual machines and hosts are configured or unconfigured for replication. Recovery operations are preserved in a per-plan history log; reprotect operations are included in this log and can be exported as a report, providing a record for post-recovery verification.

The Clean Room Orchestrator records events with a structured schema that includes timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Snapshot task events are captured upon completion and are accessible through the Snapshot log interface in the event details panel.

For forwarding and long-term retention, the PNR Appliance natively supports forwarding log files to remote syslog servers for log analysis and centralized monitoring. PNR supports forwarding events to VCF Log Management (version 9.0 and above), enabling log data to flow into centralized log management infrastructure. PNR also integrates with Microsoft Azure Log Analytics Workspace for custom log collection using Data Collection Rules (DCR) and Data Collection Endpoints (DCE), providing a cloud-native retention path.

Per-component logging levels can be adjusted through the advanced configuration interface. The `'logManager.Persistence`` setting controls the logging verbosity for persistence-related events, with a default value of verbose, allowing administrators to tune log volume to match available storage and retention requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains an event log system that records system activities, configuration changes, and operational events, with an audit trail that tracks who made configuration changes and when. The Avi Controller preserves a permanent log of the underlying events and metrics that triggered alerts, retaining those records beyond the alert expiry period.

The 9.1 documentation specifies that events raised by Avi Load Balancer components must persist in a secure manner for a minimum of 90 days for audit compliance. The retention policy is configurable: administrators can adjust the periodic interval and the threshold that triggers policy enforcement based on system and infrastructure requirements. The Avi Controller analytics API supports querying event logs for periods of up to one year, and the documentation recommends reviewing event logs over a one-year window to maintain audit trails of configuration changes.

For compliance-grade long-term retention beyond the on-appliance minimum, Avi provides the Syslog-Audit-Persistence feature, configured through the Controller's Alert Actions settings. This feature streams audit compliance events to external syslog servers. The Avi Controller and Service Engine also log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk destinations. The documentation recommends streaming all logs directly to an external server such as Splunk for assured retention; Avi's Controller Settings allow specification of syslog server destination details.

There are retention constraints that organizations should account for when designing their log retention architecture. Configuring syslog notifications in the Avi Controller forwards alert events to syslog servers but does not directly export virtual service logs; those must be pulled from an external logging system through the API or scripted to be pushed from the Controller to a remote destination. In the absence of active queries, application logs do not leave the Service Engines that collected them. For retention periods beyond the built-in minimum, administrators must configure Syslog-Audit-Persistence or an equivalent export mechanism to an external destination and maintain that destination's storage capacity and retention settings independently.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-006-6 3.1

> Maintenance and testing of each Physical Access Control System and locally mounted hardware or devices at the Physical Security Perimeter at least once every 24 calendar months to ensure they function properly.

SCF Controls: CPL-03.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID,

and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled

test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-006-6 R1

> Each Responsible Entity shall implement one or more documented physical security plan(s) that collectively include all of the applicable requirement parts in CIP-006-6 Table R1 – Physical Security Plan. [Violation Risk Factor: Medium] [Time Horizon: Long Term Planning and Same Day Operations]

SCF Controls: PES-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 R2

> Each Responsible Entity shall implement one or more documented visitor control program(s) that include each of the applicable requirement parts in CIP-006-6 Table R2 – Visitor Control Program. [Violation Risk Factor: Medium] [Time Horizon: Same Day Operations.]

SCF Controls: PES-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-006-6 R3

> Each Responsible Entity shall implement one or more documented Physical Access Control System maintenance and testing program(s) that collectively include each of the applicable requirement parts in CIP-006-6 Table R3 – Maintenance and Testing Program. [Violation Risk Factor: Medium] [Time Horizon: Long Term Planning].

SCF Controls: CPL-03.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID,

and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled

test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 1.1

> Where technically feasible, enable only logical network accessible ports that have been determined to be needed by the Responsible Entity, including port ranges or services where needed to handle dynamic ports. If a device has no provision for disabling or restricting logical ports on the device then those ports that are open are deemed needed.

SCF Controls: CFG-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of configuration controls that restrict systems to only essential capabilities by controlling ports, protocols, and services across the platform stack.

At the hypervisor layer, VMware ESX hosts include a built-in host firewall that controls which ports and services are accessible. The firewall supports specification of allowed hosts through the `allowedHosts` parameter, so administrators can limit which IP addresses may connect to specific services. Services such as SSH (TSM-SSH) can be individually started or stopped through the VMware Host Client, giving administrators direct control over which management services are running. ESX lockdown mode restricts host access so that all management is performed through VMware vCenter, with an Exception Users list for controlled overrides when direct host access is needed. ESX also supports disabling unexposed features through isolation configuration parameters, removing functionality that is not needed in the environment.

Port groups on distributed switches are communication boundaries where security policies can be configured. Each port group carries its own security policy settings, including controls over promiscuous mode, MAC address changes, and forged transmits. Administrators can modify these policies to restrict which types of network traffic virtual machines are permitted to generate or receive. Each port group can also be assigned a VLAN ID to restrict traffic to a logical Ethernet segment. SpoofGuard and switch security profiles can be applied to distributed port groups to prevent traffic spoofing and enforce network security policies at the virtual switch layer. Distributed port groups also support Port Blocking Policies, which allow administrators to selectively block ports from sending or receiving data, including blocking all ports within a group simultaneously. Traffic Filtering and Marking Policy can be applied at the individual distributed port or uplink port level to permit or stop traffic flows through virtual machines, VMkernel adapters, and physical adapters. Port-level configuration overrides on distributed virtual switches are deactivated by default, so permitting per-port policy exceptions requires deliberate administrator action. The virtual serial port proxy provides an additional gateway that enforces security for remote serial port connections, restricting access to only authorized communication paths.

Management traffic is isolated on dedicated networks. The Fleet Level Components on Dedicated Management Network model uses VLAN-backed distributed port groups to provide isolation from other networks. NSX allows configuration of services with port and protocol pairing, and these services can be referenced in firewall rules to allow or block specific types of traffic.

The platform documents explicit port requirements for each component. When vSAN is enabled on a cluster, required ports are added to ESX firewall rules and configured automatically, keeping firewall configuration aligned with actual service requirements rather than leaving unnecessary ports open. VCF Operations Cloud Proxy requires only ports 4505, 4506, and 8443 via TCP for application monitoring, establishing a minimal set of allowed network communication paths. These defined port lists give administrators a clear baseline of what must be open rather than relying on permissive defaults.

VCF Operations supports firewall hardening, which when activated restricts network access to internal services, limiting exposure to only the ports and protocols required for operation. A service discovery policy setting controls whether the system actively discovers services on the network; disabling this policy reduces the attack surface by preventing unnecessary service enumeration, though administrators should be aware that turning it off changes the security posture of the operating system. For orchestration functions, VCF Operations enforces privilege requirements where ports below 1024 can only be opened with superuser privileges on Linux systems, providing an inherent restriction on which processes can bind to well-known service ports. VCF Operations also collects ESX security properties including service running status, firewall rulesets,

service policies, and disabled protocols when the vSphere Hardening Guide policy is applied, giving administrators visibility into the least-functionality posture of each host.

The Security Configuration Guide provides recommendations for disabling unnecessary services and enabling security features on ESX hosts as a baseline for least-functionality configuration.

At the workload consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor enforce least functionality across compute, kernel, and network dimensions for containerized workloads. Pod Security Admission (PSA), enabled by default in Supervisor clusters running VKS 1.25 and later, enforces Kubernetes Pod Security Standards at the namespace level. Administrators configure each namespace with an enforcement profile from three options: Privileged (no restrictions), Baseline (blocks known privilege escalation paths), and Restricted (heavily restricted, following pod hardening practices). Each profile supports three independent modes: enforce (rejects non-compliant pods at admission), audit (records violations in the audit log without blocking), and warn (surfaces policy warnings to the requesting user without blocking), allowing operators to gain visibility into policy gaps before tightening enforcement. The Restricted PSA level requires containers to drop all Linux capabilities, blocks host networking, host PID, and host IPC namespaces, restricts volume types to a safe subset, disallows privilege escalation by setting `allowPrivilegeEscalation` to false, and requires a defined Seccomp profile. Supervisor applies the `vmware-system-restricted` Pod Security Policy by default to VKS clusters, which blocks privileged container access, helps prevent root escalation, and restricts permitted volume types; standard packages such as Contour also reference this policy so that system components operate under the same restricted constraints. VKS Cluster Management Security Policies provide an additional management layer for pod security within VKS clusters; when creating a security policy, the Restricted pod security policy template offers a preconfigured tight security context that constrains pod privileges and capabilities across the cluster.

Kubernetes pod and container security context configuration allows administrators to add or drop specific POSIX kernel capabilities through the `securityContext.capabilities` field, restricting which kernel operations individual containers may exercise. Pods can be configured with Seccomp profiles that filter the system calls available to containers; the `RuntimeDefault` profile applies the container runtime's default system call filter and blocks calls not required by typical applications, while custom profiles allow more precise control. The Restricted Pod Security Standard makes a defined Seccomp profile mandatory for compliant workloads. Supervisor also supports SELinux, which restricts access to files, applications, ports, and processes through labels and security policies enforced on tagged processes, and AppArmor profiles that restrict a container's abilities by enforcing a defined set of rules and restrictions on process behavior at the kernel level. On Ubuntu and Photon nodes in VKS clusters, AppArmor additionally controls file system access and network access, extending mandatory access control across multiple resource dimensions beyond process behavior alone. These mechanisms operate independently of Kubernetes admission controls and provide a defense-in-depth layer for workload capability restriction. Kubernetes ephemeral containers disallow ports, `livenessProbe`, and `readinessProbe` fields, further restricting their capabilities relative to standard containers.

Network-level least functionality for VKS workloads is enforced through Kubernetes `NetworkPolicy` objects, implemented by Antrea or NSX-based CNI plugins in Supervisor, which restrict ingress and egress traffic at the pod and namespace level by port, protocol, and peer selector. Cluster administrators can restrict the IP address ranges allowed for Kubernetes Services through centralized management of `ServiceCIDR` resources, reducing the scope of reachable service endpoints across the cluster. Access to control plane ports such as the etcd API port should be restricted at the network level to only specified and trusted IP address ranges. VKS control plane nodes enforce a set of default inbound firewall rules that administrators cannot override, covering only the ports required for control plane operation, including TCP 6443 for the kube-apiserver, TCP 2379-2380 for etcd, TCP 22 for SSH, TCP 179 for BGP, and TCP 10100 for the kapp-controller, among others. The kubelet `allow-privileged` flag controls whether privileged containers are permitted on cluster nodes. The Istio CNI plugin, configurable through the `istioCNI.enabled` setting, manages pod network interfaces and enforces network policies without requiring privileged containers, reducing the need for elevated privileges in service mesh deployments. Kubernetes guidance documented in Supervisor materials states that access control components operating with high privileges should be isolated from general workloads using namespace boundaries, so that privilege is scoped to where it is operationally required.

VCF Automation provides security groups that define isolation settings for on-demand private or outbound networks, allowing administrators to restrict which services and ports are accessible within network segments. Network profiles support isolation

policies defined as either on-demand or existing security groups, enabling granular control over network communication boundaries.

For ongoing compliance verification, VCF Network Operations provides a search query capability to identify firewall rules that permit any port, querying for rules where the action is set to allow and the service is configured as "any." This allows administrators to systematically find and remediate overly permissive rules that violate least-functionality principles, restricting access to only the ports and protocols that are explicitly required.

VMware vDefend (Meets)

VMware vDefend provides the primary enforcement mechanism for least functionality at the network layer, allowing administrators to configure systems so that only essential ports, protocols, and services are permitted.

vDefend (DFW) operates per workload and supports Allow, Drop, or Reject actions on traffic matching defined services with specific port and protocol pairings. Administrators build policies that permit only the traffic required for a workload's function while denying everything else. DFW policies can explicitly block insecure protocols such as Telnet, FTP, and TFTP across the data center, actively blocking protocols that should not be present in the environment. DFW governance implements a least-privilege posture by preventing overly permissive rules such as "ANY/ANY/ANY ALLOW," guiding administrators toward specific port and protocol restrictions rather than broad allow policies. Rules are processed in precedence order across multiple policy sections, giving administrators fine-grained control over which traffic categories are evaluated first.

vDefend extends least-functionality enforcement to inter-project and perimeter boundaries. Gateway Firewall rules support configurable service selection, allowing administrators to specify a blanket block on all protocols or access restricted to specific ports for selective inter-project communication. Enterprise administrators can configure inter-project isolation policies that allow only essential infrastructure protocols while denying all other inter-project communication, defining perimeter-level traffic boundaries based on what each segment actually requires.

Security Intelligence, part of the Security Services Platform, provides traffic flow analysis with protocol and port filtering. Administrators can analyze observed flows using Exclude or Match criteria, supporting up to 15 entries of single ports, port ranges, or protocols. This visibility helps administrators verify that only essential ports and protocols carry traffic and identify unexpected communication patterns that may indicate unnecessary services remain enabled. Security Intelligence also provides guidance on restricting risky application protocols that transport data in clear text, flagging these for restriction or replacement as part of the overall least-functionality posture.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the Least Functionality control through its infrastructure policy framework and data service policy allowlists, which restrict what network resources, compute configurations, and service parameters are available to database consumers.

Infrastructure policies are the primary mechanism. Each infrastructure policy requires the selection of specific network port groups for each compute resource (network-port-group setting), and at least one IP pool must be defined for each selected port group (ip-pools setting). This constrains which network segments database instances can attach to, restricting consumers from selecting arbitrary network endpoints. Infrastructure policies must be explicitly enabled before they become available for database provisioning; policies that are not yet ready for use can be kept deactivated (infrastructure-policy-enabled setting), which limits which network configurations are offered to consumers at any given time. DSM also validates infrastructure policy IP ranges against system configuration networks, detecting and rejecting overlapping configurations before they take effect.

Data service policies build on infrastructure policies to create a tiered allowlisting mechanism. Each data service policy requires the selection of at least one infrastructure policy, and in the self-service consumption model, the DataServicePolicy custom resource's allowedInfrastructurePolicies field enumerates precisely which infrastructure policies authorized consumers may use. Database users cannot select infrastructure configurations outside the approved set defined by administrators. Infrastructure policies also filter storage policies to display only those compatible with the designated compute resources, further narrowing the options available at provisioning time.

Infrastructure policies create broader resource guardrails as well: the overall policy framework restricts the quality and quantity of resources DSM users can consume from vSphere clusters, and database clusters are deployed with infrastructure and storage policies that enforce isolation and resource constraints from the moment they are provisioned.

Data service policies support an "Allow with a List" option, which creates a specific allowlist of approved parameters that users can select from during provisioning. SQL Server data service policies extend this pattern: they require selection of at least one infrastructure policy and restrict instance provisioning and server-level configuration, including Active Directory integration and high availability settings, to administrators only.

For PostgreSQL databases, DSM provides an additional connection control capability. The Block Database Connections operation can stop existing client connections and block new ones from being established, with exemptions only for monitoring, replication, and internal service traffic. This allows administrators to restrict access to a database instance to only the services required for continued operation.

DSM's contribution to this control is scoped to the database-as-a-service layer. Restrictions on ports, protocols, and services at the network perimeter, host, or hypervisor level depend on the underlying VCF platform, NSX networking configuration, and vDefend firewall policies outside DSM's direct control. Organizations should complement DSM's policy framework with platform-level network security controls to fully address the Least Functionality requirement.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides mechanisms for restricting ports, protocols, and services at the application delivery layer, supporting least-functionality configurations for application traffic and management access.

At the application traffic layer, each virtual service accepts traffic only on explicitly configured service ports. The per-Service-Port profile configuration (ApplicationProfile or NetworkProfile) can be overridden on a per-service-port basis for advanced use cases. Virtual Service Network Security Policies can match on service port to filter traffic based on TCP service ports on which the virtual service is listening, allowing administrators to explicitly permit or block traffic by protocol and port on a per-virtual-service basis.

For Controller management access, Avi provides several mechanisms to restrict access to management channels. The Client Management Access configuration allows administrators to define allowed SSH clients, allowed CLI shell clients, allowed external HTTP(S) clients, and allowed external SNMP clients separately, each scoped to specific IP addresses, ranges, subnets, or IP groups. Management channels not included in the configured allowlist are blocked. This configuration is accessible through the Securing Management IP Access workflow in the Controller UI under System settings. Trusted host profiles can be configured to restrict which hosts are permitted to access the Controller, providing an additional layer of host-identity-based access restriction. The Controller also limits the allowed ciphers and HMACs for management sessions, reducing the cryptographic surface exposed on each management channel.

Security groups for Avi Controller and Service Engines specify the protocol ports for which traffic is permitted between components, providing a defined port inventory that administrators use to scope surrounding network controls.

These capabilities apply at the application delivery boundary. Least-functionality controls for the underlying compute, storage, and network virtualization layers are provided by VCF, which is rated Meets for this control.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 1.2

> Protect against the use of unnecessary physical input/output ports used for network connectivity, console commands, or Removable Media.

SCF Controls: END-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 1.3

> A patch management process for tracking, evaluating, and installing cyber security patches for applicable Cyber Assets. The tracking portion shall include the identification of a source or sources that the Responsible Entity tracks for the release of cyber security patches for applicable Cyber Assets that are updateable and for which a patching source exists.

SCF Controls: VPM-01, VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized software and firmware patching across the entire infrastructure stack through VCF Operations and vSphere Lifecycle Manager, which together form a unified lifecycle management plane. VCF Operations is the central orchestration point for patching and update operations, coordinating patch releases (such as 9.0.1.0100) that deliver time-sensitive fixes to security and operational issues between major, minor, and maintenance releases.

VCF uses a desired-state model for host remediation through vSphere Lifecycle Manager (vLCM). Administrators define a software specification for each cluster, and vLCM brings all hosts into compliance with that specification during remediation. This approach applies uniformly to VMware-supplied components and third-party solutions alike. To make a third-party solution available on a cluster, administrators create a software specification containing the solution and remediate all hosts with that image. vLCM manages software updates for VMware ESX hosts, including patches of the ESX base image, OEM additions, components from different software vendors, and VMware Tools updates. Dynamic patch baselines automatically adjust their contents based on specified criteria each time Update Manager downloads new patches, keeping remediation current without manual baseline maintenance. Fixed baselines are also available for environments that require explicit control over which patches are applied. Hardware Support Manager (HSM) plugins extend vLCM to manage vendor-specific firmware and driver updates alongside software patches, providing unified lifecycle management for both software and firmware from within the same interface. Firmware updates through Hardware Support Manager are only available for clusters and hosts managed with vSphere Lifecycle Manager images; hosts managed with baselines do not support firmware updates through this mechanism.

The remediation workflow is coordinated through multiple layers. Coordinator Manager runs pre-checks before remediation begins to evaluate how each host in the cluster is affected and whether additional steps are needed. Pre-checks verify component connectivity, version compatibility, and component status. The ESX Updater Manager then handles the actual remediation on each host. Coordinator Manager also allows administrators to query the status of the remediation operation for the cluster and for each individual host, providing centralized visibility into remediation progress. The VCF Operations cluster transition specification includes a remediationOptionsSpec with a configurable remediationFailureAction that supports automatic retry with adjustable retryCount and retryDelay parameters, allowing administrators to define consistent remediation behavior.

VCF Operations extends lifecycle management with patch planner functionality for VCF core components, including the ability to download and manage upgrade, patch, and install binaries. Pre-update validation performs health checks and compatibility verification before patches are applied, and component interdependency management helps maintain compatibility and stability across the infrastructure during updates. All dependent elements related to package objects are added to packages automatically to help maintain compatibility between versions. VCF Operations also provides compliance management capabilities that detect violations, highlight risk areas, and provide actionable remediation recommendations, with out-of-the-box workflows mapped to recommendations and associated with specific alerts for automated remediation.

VCF supports programmatic management of the patching process through multiple interfaces. The VMware vCenter patching API supports discovery of all available and applicable updates for vCenter instances in the environment, including minor in-place updates and major migration-based updates. REST API endpoints provide operations for checking pending updates, requirements checking, staging, and installation. The life cycle management API provides operations for listing all available updates and upgrades and generating a pre-check compatibility report before applying updates. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, and the Update-Entity operation remediates hosts by applying baselines with configurable failure handling and

retry behavior. PowerCLI provides the Update Manager module with cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating hosts, including a Test-Compliance command to verify entities against downloaded patches. The vCenter Appliance itself can be patched via the vCenter Appliance Management Interface (VAMI) or the appliance shell; VMware distributes vCenter patches in two forms, ISO-based and URL-based, and the `software-packages` utility in the appliance shell supports both methods, including staging patches from a repository URL, installing directly from a URL without staging, or installing from an attached ISO image. These interfaces enable integration with external change management and orchestration systems for automated remediation workflows.

VCF includes several capabilities to reduce patching risk and support continuity during updates. Live Patching updates and restarts discrete components without requiring host evacuation or reboot, as vSphere Lifecycle Manager does not place hosts into maintenance mode when a Live Patch is enforced. Snapshots should be created before patching VCF Operations fleet management to provide a rollback path. VCF supports Ensure Accessibility maintenance mode for vSAN storage clusters, which evacuates data to maintain object accessibility during updates through durability components. The VCF Download Tool supports a patches-only option and offline depot configuration for managing patch binaries in air-gapped environments.

VCF Operations complements patch application with patch-gap detection for server firmware. It monitors hardware properties across the fleet, including BIOS version and BIOS release date, and provides dashboards that flag hosts running outdated server BIOS. This detection capability helps administrators identify hosts that require firmware patching before they become a compliance or security gap.

The VCF Consumption layer, implemented through vSphere Supervisor and VMware Kubernetes Service (VKS), extends this patching coverage to Kubernetes control plane components and cluster add-ons. VKS clusters use a rolling update model where updates are initiated by changing the cluster specification; the Supervisor reconciler applies changes node by node to maintain cluster availability during the process. This model covers control plane components including kube-apiserver, kube-controller-manager, kube-scheduler, etcd, kubelet configuration, and CoreDNS, all updated through the kubectl upgrade mechanism. Kubectl supports targeted patching of individual components through a patches directory; files named with the pattern `target[suffix][+patchtype].extension` (for example, `kube-apiserverO+merge.yaml` or `etcd.json`) apply strategic merge patches, merge patches, or JSON patches to the specified component. The patches mechanism is available through the InitConfiguration, JoinConfiguration, and UpgradeConfiguration APIs, providing consistent patching behavior across cluster initialization, node join, and upgrade operations. Instance-specific patches can also be applied over the base KubeletConfiguration through kubectl customization.

VKS clusters support add-on management that enables installation and updates of standard packages through versioned add-on repositories. Administrators can track and update packages such as istio, harbor, sriov-network-device-plugin, windows-gmsa-webhook, and vsphere-pv-csi-webhook as new versions become available. For container image currency, Harbor is available as a Supervisor service and provides vulnerability scanning and content trust capabilities to help identify images that require patching. Admission controllers, including validating webhooks and image pull policies, can be configured to restrict deployment of images that have not passed vulnerability scanning or that contain known vulnerabilities, integrating image patch compliance into the workload deployment workflow. Content library VM images deployed in the vSphere Supervisor environment should be created with the latest patches and required security settings aligned with organizational security policies. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS node releases (VKRs), providing prescriptive hardening guidance that defines what patches and configurations constitute a compliant deployment for the Kubernetes consumption layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability management through network-layer detection, virtual patching, and security posture monitoring capabilities that complement traditional patch management workflows.

vDefend Distributed IDS/IPS provides signature-based detection of vulnerability exploitation attempts across east-west traffic within the data center. When a new vulnerability is disclosed, administrators can deploy custom IDS/IPS signatures to detect and block exploitation attempts before official patches are available, a practice commonly referred to as virtual patching. In 9.1, IDS/IPS event monitoring displays Common Vulnerability Scoring System (CVSS) scores and CVE reference information

for vulnerabilities targeted by exploits, giving security teams direct visibility into which specific vulnerabilities are being actively targeted in their environment. The IDS/IPS dashboard provides monitoring and analysis of intrusion events, and Security Services Platform collects metrics to monitor IDS/IPS readiness and performance across the environment. Malicious IP reputation feeds, managed centrally through the Global Manager, automatically update threat intelligence so that known attacker infrastructure is blocked without manual intervention.

The Threat Event Monitoring dashboard in Security Services Platform displays the top IPs on which an intrusion was attempted and the top VMs based on Vulnerability Severity criteria. The Threat Event Monitoring tab on the Security Overview dashboard surfaces key insights about the current state of various security issues in the data center, helping security teams understand network activity and prioritize focus areas.

Security Intelligence, a feature within Security Services Platform, provides posture assessment and segmentation monitoring capabilities. Administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Security Posture dashboard presents information that can be used to plan and implement additional security policies. The Security Explorer provides a visual representation of workloads, their traffic flows, and connection status, which helps identify workloads that may be exposed to unpatched vulnerabilities. Security Services Platform also generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, providing the visibility needed to plan subsequent protection stages. The Security Operator role in Security Services Platform is designated to monitor security systems and respond to security incidents, supporting the operational dimension of vulnerability management monitoring.

vDefend Advanced Threat Prevention extends detection capabilities to include behavioral analysis and sandboxing, identifying malware and exploit attempts that signature-based detection might miss. The Security Overview dashboard in Security Services Platform displays file inspection statistics organized by different ranges of threat score, giving security teams a quantitative view of file-based threats detected in their environment. This provides an additional layer of protection for systems awaiting patches.

These capabilities address the detection and monitoring dimensions of vulnerability management. Patch deployment and software lifecycle management are handled by other VCF components such as VCF Operations and vSphere Lifecycle Manager.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an `se_group_refs` parameter to target a specific Service Engine group for patching; when `se_group_refs` is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 2.1

> A patch management process for tracking, evaluating, and installing cyber security patches for applicable Cyber Assets. The tracking portion shall include the identification of a source or sources that the Responsible Entity tracks for the release of cyber security patches for applicable Cyber Assets that are updateable and for which a patching source exists.

SCF Controls: VPM-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated vulnerability and patch management capabilities across its infrastructure stack, addressing both the implementation and monitoring aspects of this control.

VCF includes built-in lifecycle management that automates the process of applying updates and patches to software components within the stack. Patch releases provide time-sensitive fixes to security and critical issues and can be applied selectively to individual components without requiring synchronized updates across all VCF components. VCF Operations includes a patch planner that identifies available updates for VCF core components, downloads binaries from online depots (or stages them for offline environments), and orchestrates installation across the stack. Pre-update validation runs health checks and compatibility verification before applying changes. VCF Operations automatically backs up components during the patch process to provide a recovery point in case of failure. For vCenter appliance patching, an LVM snapshot is automatically created before the patching process begins; if patching fails, the orchestrator offers the option to roll back to that snapshot or continue after addressing the underlying issue. Lifecycle management also provides tools for planning updates so that administrators can schedule maintenance windows and coordinate changes with minimal disruption to services.

vSphere Lifecycle Manager (vLCM) manages the desired-state configuration for ESX hosts, including firmware and drivers through Hardware Support Manager (HSM) plugins provided by OEM vendors. vLCM images consist of a base image, vendor add-ons, components, and firmware add-ons that can be independently retrieved and applied to hosts. vLCM scans hosts against the desired image specification, flags deviations, and remediates non-compliant hosts. vSphere Lifecycle Manager also supports Live Patch for applicable updates, enabling patches to be applied to ESX hosts without requiring them to enter maintenance mode. It works with three types of software depots (online, offline, and UMDS) to provide flexibility in how patches are sourced and distributed. Update Manager supports dynamic baselines that automatically adjust their patch data based on specified criteria each time new patches are downloaded, allowing administrators to define patching policies that stay current without manual intervention. The Update Manager PowerCLI module provides cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating virtual machines and hosts, enabling automation of patching workflows.

For the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, Security Technical Implementation Guides (STIGs) are available for Supervisor and VMware Kubernetes Release (VKr) components through Tanzu STIG Hardening, providing a structured security configuration baseline against which VKS deployments can be assessed and remediated. VKr components and Standard Packages are updated using the VCF CLI ``vcf package installed update`` command, which upgrades a package installation to a newer version and applies new configuration values, giving administrators a structured mechanism for applying package-level updates to components running in the Supervisor environment. VCF building-block services have independent lifecycles, enabling components to be updated individually without affecting the broader environment. The Node Problem Detector can be deployed within VKS clusters to monitor node health and report infrastructure-level problems through configurable detection rules, supporting the monitoring dimension of vulnerability management at the workload tier.

For container workloads running on VKS, Harbor is available as a deployable Standard Package with built-in vulnerability scanning using the Trivy database, which can be configured to use a custom or mirrored repository for air-gapped deployments. Harbor also provides content trust features that support image signing and policy-based replication, giving operations teams mechanisms to detect and restrict deployment of images containing known vulnerabilities. Harbor packages are updated using the ``vcf package installed update harbor`` command. Kubernetes guidance recommends that container images be regularly scanned during creation and in deployment, with known vulnerable software patched before workloads reach the runtime environment. Kubernetes security vulnerabilities are tracked and announced through the Kubernetes

Security Response Committee, which maintains an official list of known CVEs and publishes security-related announcements to the kubernetes-announce mailing list. For CI/CD pipelines running on VCF, Harness CI/CD is available as a Supervisor Service with integrated Security Testing Orchestration (STO) that incorporates the Wiz CLI to automate vulnerability management throughout the pipeline, performing infrastructure-as-code (IaC) and secret detection scans and container image scans against artifacts stored in JFrog Artifactory. Vulnerability scan findings from Wiz are reported to the Harness security dashboard, and Harness STO automatically deduplicates findings and displays them on the vulnerabilities tab of each pipeline execution for review.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. The Security Operations dashboard in VCF Operations provides a consolidated view of security posture, helping administrators identify areas requiring attention. VCF Operations compliance management continuously monitors infrastructure for policy violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity of the non-compliance, automated remediation actions can be configured to bring the object back into compliance.

Configuration drift monitoring provides an additional layer of ongoing assurance. VCF Operations provides unified configuration management that supports scheduled drift detection for vCenter and cluster objects. It detects deviations from assigned configuration template values, displays drift results across all configuration templates, and allows administrators to compare changes against desired values. This helps identify unauthorized or unintended changes to the infrastructure that could introduce vulnerabilities.

Patching operations are governed by role-based access controls. Editing remediation settings in vSphere Lifecycle Manager requires specific privileges (`VcIntegrity.lifecycleSettings.Read` and `VcIntegrity.lifecycleSettings.Write`), and image remediation operations require a separate set of API privileges.

Broadcom publishes security advisories (VMSAs) for VCF vulnerabilities and releases patches to address them.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability management through network-layer detection, virtual patching, and security posture monitoring capabilities that complement traditional patch management workflows.

vDefend Distributed IDS/IPS provides signature-based detection of vulnerability exploitation attempts across east-west traffic within the data center. When a new vulnerability is disclosed, administrators can deploy custom IDS/IPS signatures to detect and block exploitation attempts before official patches are available, a practice commonly referred to as virtual patching. In 9.1, IDS/IPS event monitoring displays Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by exploits, giving security teams direct visibility into which specific vulnerabilities are being actively targeted in their environment. The IDS/IPS dashboard provides monitoring and analysis of intrusion events, and Security Services Platform collects metrics to monitor IDS/IPS readiness and performance across the environment. Malicious IP reputation feeds, managed centrally through the Global Manager, automatically update threat intelligence so that known attacker infrastructure is blocked without manual intervention.

The Threat Event Monitoring dashboard in Security Services Platform displays the top IPs on which an intrusion was attempted and the top VMs based on Vulnerability Severity criteria. The Threat Event Monitoring tab on the Security Overview dashboard surfaces key insights about the current state of various security issues in the data center, helping security teams understand network activity and prioritize focus areas.

Security Intelligence, a feature within Security Services Platform, provides posture assessment and segmentation monitoring capabilities. Administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment traffic. The Security Posture dashboard presents information that can be used to plan and implement additional security policies. The Security Explorer provides a visual representation of workloads, their traffic flows, and connection status, which helps identify workloads that may be exposed to unpatched vulnerabilities. Security Services Platform also generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows, providing the visibility needed to plan subsequent protection stages. The Security

Operator role in Security Services Platform is designated to monitor security systems and respond to security incidents, supporting the operational dimension of vulnerability management monitoring.

vDefend Advanced Threat Prevention extends detection capabilities to include behavioral analysis and sandboxing, identifying malware and exploit attempts that signature-based detection might miss. The Security Overview dashboard in Security Services Platform displays file inspection statistics organized by different ranges of threat score, giving security teams a quantitative view of file-based threats detected in their environment. This provides an additional layer of protection for systems awaiting patches.

These capabilities address the detection and monitoring dimensions of vulnerability management. Patch deployment and software lifecycle management are handled by other VCF components such as VCF Operations and vSphere Lifecycle Manager.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations

targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a structured patch management lifecycle for both the Controller and Service Engine groups, supporting the application delivery layer's contribution to an organizational vulnerability management program. The CLI patch command offers distinct patching modes (Controller Patch, SE Group Patch, Disruptive Patch, and System Patch), giving administrators flexibility to apply patches to specific components or across the entire system without requiring a full upgrade cycle. The documentation recommends applying patches only to the Service Engine groups that require them, based on Service Engine group segmentation. Patch images are uploaded to the Controller and verified for inclusion in the image bundle before any upgrade operation proceeds.

Rollback capability is available for patch releases via CLI. The ``rollbackpatch controller`` command reverts the Controller to the previous patch version, while ``rollbackpatch system`` rolls back the Controller and all Service Engine groups simultaneously. Rollback transitions the system to the version without the specific patch and does not roll back to the previous major version. The Avi for VCF documentation recommends planning a remediation strategy before re-attempting an upgrade following a rollback. On restore operations, the Controller checks for patches applied as part of the restore to maintain version consistency.

For application-layer vulnerability management, Avi Load Balancer supports virtual patching through two complementary mechanisms. The Web Application Firewall (WAF) integrates with Dynamic Application Security Testing (DAST) scanners; the Avi SDK integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning, allowing scan results to be imported and used to identify application vulnerabilities and apply WAF-based protections while permanent code fixes are developed and deployed. The Live Security Threat Intelligence service, available through the Cloud Console, extends virtual patching coverage with an Application Rules service providing rules designed to block attacks on known application vulnerabilities, including many with associated CVEs. These rules cover over 5,000 applications including WordPress, Drupal, and Apache, and are automatically updated through continuous Application Rules Database synchronization, keeping WAF protections current.

An Application Security Report provides a downloadable PDF documenting security findings and pre-check results, supporting vulnerability management reporting and documentation. The alert automation infrastructure supports ControlScripts that alert actions can invoke to automatically add offending client IP addresses to a blocklist attached to a network security policy, enabling automated response to detected threats.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 2.2

> At least once every 35 calendar days, evaluate security patches for applicability that have been released since the last evaluation from the source or sources identified in Part 2.1.

SCF Controls: VPM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the lcm-bundle-transfer-util command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced, removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query

effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a Remediating condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the kube-security-announce mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as Invalid or Warning, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined

organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 2.3

> For applicable patches identified in Part 2.2, within 35 calendar days of the evaluation completion, take one of the following actions: ☐ Apply the applicable patches; or ☐ Create a dated mitigation plan; or ☐ Revise an existing mitigation plan. Mitigation plans shall include the Responsible Entity's planned actions to mitigate the vulnerabilities addressed by each security patch and a timeframe to complete these mitigations.

SCF Controls: VPM-02, VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the `lcm-bundle-transfer-util` command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced,

removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a Remediating condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the kube-security-announce mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as Invalid or Warning, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection

when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 2.4

> For each mitigation plan created or revised in Part 2.3, implement the plan within the timeframe specified in the plan, unless a revision to the plan or an extension to the timeframe specified in Part 2.3 is approved by the CIP Senior Manager or delegate.

SCF Controls: IAO-05, VPM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the lcm-bundle-transfer-util command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced, removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query

effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a Remediating condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the kube-security-announce mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as Invalid or Warning, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined

organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 3.1

> Deploy method(s) to deter, detect, or prevent malicious code.

SCF Controls: END-04, END-14.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads

running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 3.2

> Mitigate the threat of detected malicious code.

SCF Controls: END-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads

running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 3.3

> For those methods identified in Part 3.1 that use signatures or patterns, have a process for the update of the signatures or patterns. The process must address testing and installing the signatures or patterns.

SCF Controls: END-04, END-04.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads

running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 4.1

> Log events at the BES Cyber System level (per BES Cyber System capability) or at the Cyber Asset level (per Cyber Asset capability) for identification of, and after-the-fact investigations of, Cyber Security Incidents that includes, as a minimum, each of the following types of events: 4.1.1. Detected successful login attempts; 4.1.2. Detected failed access attempts and failed login attempts; 4.1.3. Detected malicious code.

SCF Controls: MON-01.4, MON-03

Aggregate Coverage: Meets

VCF (Meets)

VCF produces structured event logs across its component stack that contain all six content elements specified by this control: event type, timestamp, location, source, outcome, and user identity. The platform's Consumption layer, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends this coverage to Kubernetes workloads using the kube-apiserver audit mechanism and component logging infrastructure.

Event type identification

VCF components classify events by category and severity. VCF Operations generates audit events organized into categories including Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. VCF Operations log entries include a logging level (info, warning, error) and a component class name identifying the subsystem that generated the event, along with a descriptive message. VCF Automation records events for catalog deployments, cloud template operations, Day 2 operations, and resource actions, and its audit logs display a status value or message for each reportable action type. VCF Automation issues specific events such as "Deployment requested" and "Deployment completed" around catalog and cloud template operations. NSX Manager audit logs record administrative changes with structured metadata including request ID, component name, subcomponent, and update status, and include a description of the event for actions such as logon, logoff, and resource access. The VMware vCenter EventEx interface constructs extended events with an explicit eventType and severity parameter, providing machine-readable event classification at the API level. For workloads running on VKS clusters, the kube-apiserver records every API request using the audit.k8s.io/v1 Event schema, where the verb field captures the operation performed (create, get, update, delete, list, watch, patch) and the objectRef field identifies the resource type and API group involved. The audit Event record also includes an auditID that uniquely identifies each event for correlation across log entries, and a stage field indicating which stage of request processing produced the entry (RequestReceived, ResponseStarted, ResponseComplete, or Panic).

Timestamps

All logging subsystems across the VCF stack include date and time information. VCF Operations log events contain a timestamp as the first of eight common fields. VCF Operations Infrastructure Operations records the date and time when events and alerts are generated in the Created On field. NSX Manager audit logs record timestamps in ISO 8601 format for create and modify operations, and each NSX audit log entry includes a timestamp. VCF Automation audit logs record a timestamp for every reportable action. Kubernetes audit events include requestReceivedTimestamp and stageTimestamp fields, recording when the request was received by the API server and when each processing stage completed. Kubernetes system component logs in klog format carry a timestamp in every log entry alongside severity level, source file, and line number.

Event location and source

VCF Operations log entries include the source IP address and host IP of the system that generated the event, along with a source field indicating where the event originated, such as a VMware ESX host or syslog aggregation forwarder. Each event forwarded to VCF Operations contains source information and name-value pair fields extracted from the raw event data. NSX audit logs record the source of each event. VCF Log Management allows operators to search and filter collected log events by source. In VKS clusters, the Kubernetes audit event objectRef field records the namespace, resource type, resource name, API group, and API version; the requestURI field records the full API path; and the sourceIPs field records the originating IP

address of the request, with the `userAgent` field providing additional context for service-to-service calls. Syslog log messages from vSphere Pods include namespace name, pod UID, pod name, container name, and ESX host name as metadata fields when the `LogAgentConfiguration` Custom Resource is applied, providing workload-level source attribution alongside infrastructure-level source data. The Supervisor can also be configured to preserve the source IP addresses of authentication requests and Kubernetes API Server requests, making those addresses available for inspection in audit logs.

Outcome

VCF Operations log events can be filtered by logging level, and the Analyze page allows searching and filtering based on timestamp, text, source, and extracted fields. NSX audit logs include a result field that records the success or failure of the logged action. NSX Manager audit logging records operation status with detailed change tracking for administrative operations, including old and new values. VCF Automation audit logs contain a status value for each action indicating the outcome. Audit events across the platform capture success and failure states for operations. Kubernetes audit events record outcome in the `responseStatus` field, which contains the HTTP response status code indicating success or failure; at the `RequestResponse` audit level, response bodies are also captured, including error messages for failed operations. VM Operator logs record VM creation failures and reconciliation events for `VirtualMachineService` resources in VKS clusters, capturing failure details such as OVF deployment errors caused by insufficient ESX host resources.

User identity

VCF Operations audit logs can be filtered by User ID, User Name, Auth Source, Session, Client IP, Category, and Message. User permission events are sourced from VMware vCenter logs and can be filtered by event, status, updated by, object name, and object type. VCF Automation events record the user who triggered each event in the `Owner` field, and event logs record API access token usage by including the UUID of the token that performed the action. VCF Automation audit logs also include the user name and project name associated with each action, along with a trace ID for correlation. NSX Manager generates audit logs that record `UserName`, `ModuleName`, `Operation`, and `Operation status` with timestamps and request identifiers. The vCenter `EventEx` interface accepts a `userName` parameter when constructing event records, associating user identity with the logged action at the API level. VCF SSO audit event records include the timestamp, the user who performed the action, an event description, severity, and the IP address of the client connection to vCenter. Kubernetes audit events capture identity in the `user` field, which records the authenticated username, UID, group memberships, and extra attributes of the requester; for requests made through service accounts, the service account name and namespace are recorded as part of the user context.

Log detail and centralized management

ESX hosts support configurable syslog log levels that can be adjusted using `esxcli system syslog` commands, and the host agent log level can be set to verbose or other levels to control the detail captured. ESX syslog messages conform with RFC 3164, which defines structured message formatting. ESX audit records conform to RFC 5424 and contain event time, status, description, and user information for security-relevant activity tracked on the host. The `Syslog.global.auditRecord.remote` parameter enables forwarding ESX audit records to the remote syslog collector specified by `Syslog.global.logHost`. VCF Operations log events contain eight common parts: timestamp, thread name, host IP, logging level, class name, message text, token number, and duration. For centralized log management, VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the `vpzd.event.syslog.enabled` option in the vCenter Management Interface; forwarded events carry the fields `eventId`, `createdTime`, `eventType`, `severity`, `user`, `target`, `chainId`, and `desc`. The VCF Operations audit log is integrated with syslog, allowing collection of all audit log data through the syslog collector. The VCF Log Management Analyze page provides a centralized interface for searching and correlating log events across all sources. NSX audit log messages are stored in `/var/log/audit/audit.log`. For deployments evaluated against global compliance frameworks, all auditable events defined by the applicable security requirements are logged by the platform.

For the Consumption layer, Kubernetes audit policy supports four logging levels (None, Metadata, Request, and RequestResponse), giving administrators fine-grained control over the verbosity and scope of audit records for VKS clusters. Audit events are written in JSONlines format to a log file via the kube-apiserver Log backend, configured through the `--audit-log-path`, `--audit-log-maxage`, `--audit-log-maxbackup`, and `--audit-log-maxsize` flags; audit events can also be forwarded in

real time to an external system using the Webhook backend, which delivers batched events as HTTP POST requests to a configured endpoint. Kubernetes audit records are collected by node log agents and forwarded to a central log store as part of the cluster observability pipeline. Fluent Bit logging agents deployed in the vmware-system-logging namespace collect and forward logs from nodes across the cluster; on VKS clusters, Fluent Bit collects Kubernetes container logs, Kubernetes API audit logs, Linux daemon logs, Linux authentication logs, and container runtime interface logs through configurable parsers and filters, and supports forwarding to Syslog, HTTP, Elasticsearch, Kafka, and Splunk. Workload logs from vSphere Pods and vSphere Namespaces are streamed to a remote Syslog server by applying a LogAgentConfiguration Custom Resource; each syslog message carries namespace name, pod UID, pod name, container name, and ESX host name as metadata fields. Kubernetes seccomp supports the SCMP_ACT_LOG action, which logs syscall execution to syslog or auditd without restricting the syscall, and the audit.json seccomp profile logs all syscalls of a process for detailed syscall-level auditing. For Windows workloads on VKS, the support bundle collects Windows Event Logs covering System, Security, Application, Windows Firewall, and networking event sources. Pod-level events accessible through kubectl describe pod record each event with a From field indicating the component source, a Reason field indicating why the event occurred, and a Message field providing details, all with associated timestamps.

VMware Private AI Services (PAIS) includes several event logging and observability mechanisms across its AI-specific components that contribute to the requirements of this control.

PAIS observability is configured through the PAISConfiguration custom resource. When activated, PAIS collects metrics in an integrated Prometheus server and supports forwarding LLM traces to an OpenTelemetry Collector over http/protobuf or gRPC. The spec.observability.prometheusRuntime section enables Prometheus with configurable storage class and metrics retention period, and the spec.observability.llmTraces section activates trace forwarding. These traces capture timing, event type, and source component information for model inference, agent execution flow, and knowledge base indexing. MLOps engineers and application developers use observability platforms such as Grafana to monitor model health, quality, and behavior of AI applications. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service and can also stream to VCF Operations through Telegraf with namepass filters that capture controller runtime worker counts, work queue depth, and reconcile concurrency.

Model endpoints built on the vLLM inference server support the VLLM_LOGGING_LEVEL environment variable to control inference logging verbosity, with DEBUG available as a supported value. Operators can retrieve logs for a specific model endpoint pod in the pais namespace by running kubectl logs against the pais-kubeconfig. Knowledge base operations record timing metrics for file downloads, embedding generation, and index operations, along with size metrics including total megabytes downloaded, number of new chunks indexed, and final index size. These records identify the type and duration of each operation.

Deep Learning VMs write cloud-init deployment logs to /var/log/dl.log and vGPU or NVIDIA data center GPU driver installation logs to /var/log/gpu-install.log. Deep Learning VMs also expose vGPU performance metrics through Prometheus for collection and visualization. These logs and metrics capture deployment progress, driver installation outcomes, and runtime performance.

Configuring all Technology Assets, Applications, and Services with sufficient event log content, including complete user identity trails and system-level API audit records across the full stack, requires configuration at the underlying VCF platform layer, including Kubernetes API server audit logging through VMware Kubernetes Service (VKS), VMware vCenter event logs, and VMware ESX host logs.

VMware vDefend (Contributes)

VMware vDefend (vDefend) produces event logs across its components that contain the information elements specified by this control, covering the network security layer of the VCF infrastructure.

Event type identification: vDefend components categorize events by type across multiple security functions. The Distributed Firewall (DFW) logs firewall rule hits with the action taken (allow, drop, or reject) and the rule ID that matched. IDS/IPS generates detection events categorized by signature severity level and threat category. Security Intelligence provides a View Full Event History capability that displays all events associated with a signature ID and the intrusion severity. Malware

Prevention Service logs file analysis events categorized by detection status, verdict (BENIGN, malicious, or suspicious), and malware family. Network Detection and Response (NDR) generates detection events forwarded to SIEM endpoints with structured metadata identifying the type of network threat detected.

Timestamps: All vDefend event logs include timestamps. Malware Prevention Service event logs record an inspection timestamp and event timestamps for each file analysis operation. Security Services Platform (SSP) logs certificate loading events with timestamp and component name information. Guest Introspection Platform Host Agent (MUX) messages written to /var/log/syslog.log include a timestamp in each log entry.

Event source: vDefend event logs identify the source of each event. DFW logs identify the specific vNIC, virtual machine, and security policy involved in each rule evaluation. IDS/IPS logs identify the affected workload and the network segment where the detection occurred. Malware Prevention Service logs include the client VM ID, submission source, server information, and gateway identification for each file analysis event, enabling analysts to trace events back to the originating workload. NDR events identify the network flows and endpoints involved in detected anomalies.

Outcome: vDefend logs capture the outcome of security operations. DFW logs record whether traffic was allowed, dropped, or rejected based on rule evaluation. IDS/IPS events record whether a signature match triggered an alert or a block action. Malware Prevention Service logs record the verdict (BENIGN, malicious, or other classification) and a numeric risk assessment score alongside the analysis completion status for each inspected file. Malware Prevention Service event logs also capture file hashes (SHA-256, SHA-1, MD5), file metadata including file name, file type, and file size, as well as HTTP domain, HTTP method, user agent, and file upload status for web-based file transfers. NDR detection events capture the severity and confidence level of detected threats.

User identity: vDefend captures user identity through multiple mechanisms. The Identity Firewall component collects Windows event logs from configured Event Log Servers to associate network traffic with Active Directory users and groups, enabling user-attributed firewall rule enforcement. Event Log Scraping is configurable on a per-domain basis from Servers & Site Mapping; in federated environments, Event Log Scraping and processing occur only at the Local Manager site. Event Log Sources are configured in Security > General Settings > Identity Firewall Event Log Sources, with the option to forward user identity events to VCF Log Management. NSX Manager audit logs capture the identity of administrators making configuration changes to firewall rules, security policies, and other objects through administrator identity fields, providing accountability for policy creation and modification.

Centralized log collection: VCF Log Management provides a centralized log management framework for vDefend. Unified Security Logs in VCF Log Management contain log messages for DFW, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering, enabling correlation across vDefend security functions from a single interface. Logs can be forwarded to VCF Log Management by configuring it as a syslog server.

SIEM integration: NDR forwards event logs to SIEM endpoints supporting Splunk (on-premises or cloud-hosted) and custom endpoints with configurable HTTP headers for authentication. NDR supports SSL verification for event logs sent over HTTPS and integrates with VCF Log Management as a SIEM server. Security Services Platform sends campaign and event logs to the connected SIEM as they occur. IDS/IPS events can be exported to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default); this requires remote syslog to be configured on the ESX host. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Guest Introspection Platform Host Agent (MUX) logs are written to /var/log/syslog.log on ESX hosts in a structured format that includes a timestamp, ContextMUX identifier, and thread ID.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) produces structured event logs that capture the information elements required for audit trail analysis.

PNR events are identified by named event types that indicate what occurred. vSphere Replication generates typed audit events when virtual machines and hosts are configured for or removed from replication, with event types including `com.vmware.vcHms.replicationConfiguredEvent`, `com.vmware.vcHms.replicationUnconfiguredEvent`, `com.vmware.vcHms.hostConfiguredForHbrEvent`, and `com.vmware.vcHms.hostUnconfiguredForHbrEvent`. Protection group

and consistency group lifecycle changes are recorded with assigned severity levels: adding or removing a consistency group from a protection group records an Info-level event, and consistency group errors or warnings record an Error-level event. Authorization errors are logged with timestamps and component information for security tracking. Each event type has a corresponding alarm that PNR can trigger if the event occurs.

Events include timestamps for time-based correlation. Login events record timestamp, log level, component, operation ID, and session details including userName and loginTime. Logout events record timestamp, user identity, source IP address, and operation ID. The Clean Room Orchestrator event details panel displays event severity, timestamp, target system information for replication or failover tasks, and event description.

Events are associated with specific objects, including protection groups, consistency groups, virtual machines, datastores, and sites, establishing where the event occurred and what was affected. The PNR global console displays all events occurring in the system, including both system-generated events and user actions. vSphere Replication maintains an audit log at /opt/vmware/support/logs/hms/hms-audit.log on the appliance, with broker logs at /opt/vmware/support/logs/hbr on the appliance and at /var/run/log on VMware ESX hosts.

Login events include the userName and loginTime fields, establishing the identity and session context of the user. Logout events record user identity and source IP address. The SrmDpxAgentUser role enables the DPX agent service to log events to VMware vCenter Event Manager.

Error-level events distinguish failed or abnormal conditions from informational state changes. Consistency group errors and warnings generate Error-level events; normal lifecycle transitions such as configuring replication or adding datastores record at the Info level. Snapshot task completion is logged and accessible through the Snapshot log interface in the Clean Room event details panel.

The PNR Appliance supports forwarding log files to a remote syslog server. Event forwarding to VCF Log Management version 9.0 or later is supported for centralized collection and retention. Clean Room Orchestrator events can be forwarded for external analysis, with event payloads that include timestamp, priority, message, component name, severity, configuration ID, component ID, and event type. Documented event forwarding destinations for Clean Room events include VCF Log Management, Microsoft Sentinel, and Splunk Cloud.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at /var/log/tdm/provider/audit/ with filenames in the format gateway-audit-timestamp.log. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) includes a native event logging system across both the Avi Controller and Service Engines that records structured event data covering all six fields this control specifies.

Avi system events capture a defined set of fields per entry: Timestamp (the date and time the event occurred), Resource Name and Resource Type (identifying the specific object and category of resource involved, establishing where the event occurred), Event Code (a named classification such as CONFIG_CREATE or CONFIG_UPDATE that identifies the type of event), and Description (a brief account of the event). Event logs track who made configuration changes and when, and can be filtered by event type using search parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE. For operational events such as configuration restores, the event record includes task name, status, node IP address, and success or failure messages, capturing the outcome of the operation.

Service Engine application logs apply the same structured fields at the data-plane layer, with each entry recording Timestamp, Resource Name, Resource Type, Event Code, and Description for virtual service and pool events. This extends structured logging beyond administrative actions on the Controller to application-layer events processed by the Service Engines.

The Controller's global event log, accessible via Operations > All Events, displays events across all objects including deleted objects and sub-objects such as profiles and certificates. Object-specific event logs are also available from the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to that object. The analytics API endpoint /api/analytics/logs retrieves event logs with configurable type, duration (up to one year), page_size, and end parameters to support queries across specific time periods.

Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and function failures to Events, Syslog, and Splunk. The Avi Web Application Firewall (WAF) logs matched application-layer events including matched variable name and matched variable content, with audit log parts configurable to include full event data. Avi Controller also logs denial of service attack events with event_id, attack_count, threshold values, and alert level.

The Controller's Syslog-Audit-Persistence alert action template supports forwarding events to external syslog servers for audit compliance. Note that syslog notifications push alerts but do not automatically export virtual service logs; virtual service logs must be pulled from an external logging system through the API or scripted to push from the Controller to a remote destination.

Control CIP-007-6 4.1.1

> Log events at the BES Cyber System level (per BES Cyber System capability) or at the Cyber Asset level (per Cyber Asset capability) for identification of, and after-the-fact investigations of, Cyber Security Incidents that includes, as a minimum, each of the following types of events: 4.1.1. Detected successful login attempts;

SCF Controls: MON-03

Aggregate Coverage: Meets

VCF (Meets)

VCF produces structured event logs across its component stack that contain all six content elements specified by this control: event type, timestamp, location, source, outcome, and user identity. The platform's Consumption layer, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends this coverage to Kubernetes workloads using the kube-apiserver audit mechanism and component logging infrastructure.

Event type identification

VCF components classify events by category and severity. VCF Operations generates audit events organized into categories including Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. VCF Operations log entries include a logging level (info, warning, error) and a component class name identifying the subsystem that generated the event, along with a descriptive message. VCF Automation records events for catalog deployments, cloud template operations, Day 2 operations, and resource actions, and its audit logs display a status value or message for each reportable action type. VCF Automation issues specific events such as "Deployment requested" and "Deployment completed" around catalog and cloud template operations. NSX Manager audit logs record administrative changes with structured metadata including request ID, component name, subcomponent, and update status, and include a description of the event for actions such as logon, logoff, and resource access. The VMware vCenter EventEx interface constructs extended events with an explicit eventType and severity parameter, providing machine-readable event classification at the API level. For workloads running on VKS clusters, the kube-apiserver records every API request using the audit.k8s.io/v1 Event schema, where the verb field captures the operation performed (create, get, update, delete, list, watch, patch) and the objectRef field identifies the resource type and API group involved. The audit Event record also includes an auditID that uniquely identifies each event for correlation across log entries, and a stage field indicating which stage of request processing produced the entry (RequestReceived, ResponseStarted, ResponseComplete, or Panic).

Timestamps

All logging subsystems across the VCF stack include date and time information. VCF Operations log events contain a timestamp as the first of eight common fields. VCF Operations Infrastructure Operations records the date and time when events and alerts are generated in the Created On field. NSX Manager audit logs record timestamps in ISO 8601 format for create and modify operations, and each NSX audit log entry includes a timestamp. VCF Automation audit logs record a timestamp for every reportable action. Kubernetes audit events include requestReceivedTimestamp and stageTimestamp fields, recording when the request was received by the API server and when each processing stage completed. Kubernetes system component logs in klog format carry a timestamp in every log entry alongside severity level, source file, and line number.

Event location and source

VCF Operations log entries include the source IP address and host IP of the system that generated the event, along with a source field indicating where the event originated, such as a VMware ESX host or syslog aggregation forwarder. Each event forwarded to VCF Operations contains source information and name-value pair fields extracted from the raw event data. NSX audit logs record the source of each event. VCF Log Management allows operators to search and filter collected log events by source. In VKS clusters, the Kubernetes audit event objectRef field records the namespace, resource type, resource name, API group, and API version; the requestURI field records the full API path; and the sourceIPs field records the originating IP address of the request, with the userAgent field providing additional context for service-to-service calls. Syslog log messages

from vSphere Pods include namespace name, pod UID, pod name, container name, and ESX host name as metadata fields when the LogAgentConfiguration Custom Resource is applied, providing workload-level source attribution alongside infrastructure-level source data. The Supervisor can also be configured to preserve the source IP addresses of authentication requests and Kubernetes API Server requests, making those addresses available for inspection in audit logs.

Outcome

VCF Operations log events can be filtered by logging level, and the Analyze page allows searching and filtering based on timestamp, text, source, and extracted fields. NSX audit logs include a result field that records the success or failure of the logged action. NSX Manager audit logging records operation status with detailed change tracking for administrative operations, including old and new values. VCF Automation audit logs contain a status value for each action indicating the outcome. Audit events across the platform capture success and failure states for operations. Kubernetes audit events record outcome in the responseStatus field, which contains the HTTP response status code indicating success or failure; at the RequestResponse audit level, response bodies are also captured, including error messages for failed operations. VM Operator logs record VM creation failures and reconciliation events for VirtualMachineService resources in VKS clusters, capturing failure details such as OVF deployment errors caused by insufficient ESX host resources.

User identity

VCF Operations audit logs can be filtered by User ID, User Name, Auth Source, Session, Client IP, Category, and Message. User permission events are sourced from VMware vCenter logs and can be filtered by event, status, updated by, object name, and object type. VCF Automation events record the user who triggered each event in the Owner field, and event logs record API access token usage by including the UUID of the token that performed the action. VCF Automation audit logs also include the user name and project name associated with each action, along with a trace ID for correlation. NSX Manager generates audit logs that record UserName, ModuleName, Operation, and Operation status with timestamps and request identifiers. The vCenter EventEx interface accepts a userName parameter when constructing event records, associating user identity with the logged action at the API level. VCF SSO audit event records include the timestamp, the user who performed the action, an event description, severity, and the IP address of the client connection to vCenter. Kubernetes audit events capture identity in the user field, which records the authenticated username, UID, group memberships, and extra attributes of the requester; for requests made through service accounts, the service account name and namespace are recorded as part of the user context.

Log detail and centralized management

ESX hosts support configurable syslog log levels that can be adjusted using esxcli system syslog commands, and the host agent log level can be set to verbose or other levels to control the detail captured. ESX syslog messages conform with RFC 3164, which defines structured message formatting. ESX audit records conform to RFC 5424 and contain event time, status, description, and user information for security-relevant activity tracked on the host. The Syslog.global.auditRecord.remote parameter enables forwarding ESX audit records to the remote syslog collector specified by Syslog.global.logHost. VCF Operations log events contain eight common parts: timestamp, thread name, host IP, logging level, class name, message text, token number, and duration. For centralized log management, VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the vpxd.event.syslog.enabled option in the vCenter Management Interface; forwarded events carry the fields eventId, createTime, eventType, severity, user, target, chainId, and desc. The VCF Operations audit log is integrated with syslog, allowing collection of all audit log data through the syslog collector. The VCF Log Management Analyze page provides a centralized interface for searching and correlating log events across all sources. NSX audit log messages are stored in /var/log/audit/audit.log. For deployments evaluated against global compliance frameworks, all auditable events defined by the applicable security requirements are logged by the platform.

For the Consumption layer, Kubernetes audit policy supports four logging levels (None, Metadata, Request, and RequestResponse), giving administrators fine-grained control over the verbosity and scope of audit records for VKS clusters. Audit events are written in JSONlines format to a log file via the kube-apiserver Log backend, configured through the --audit-log-path, --audit-log-maxage, --audit-log-maxbackup, and --audit-log-maxsize flags; audit events can also be forwarded in real time to an external system using the Webhook backend, which delivers batched events as HTTP POST requests to a

configured endpoint. Kubernetes audit records are collected by node log agents and forwarded to a central log store as part of the cluster observability pipeline. Fluent Bit logging agents deployed in the vmware-system-logging namespace collect and forward logs from nodes across the cluster; on VKS clusters, Fluent Bit collects Kubernetes container logs, Kubernetes API audit logs, Linux daemon logs, Linux authentication logs, and container runtime interface logs through configurable parsers and filters, and supports forwarding to Syslog, HTTP, Elasticsearch, Kafka, and Splunk. Workload logs from vSphere Pods and vSphere Namespaces are streamed to a remote Syslog server by applying a LogAgentConfiguration Custom Resource; each syslog message carries namespace name, pod UID, pod name, container name, and ESX host name as metadata fields. Kubernetes seccomp supports the SCMP_ACT_LOG action, which logs syscall execution to syslog or auditd without restricting the syscall, and the audit.json seccomp profile logs all syscalls of a process for detailed syscall-level auditing. For Windows workloads on VKS, the support bundle collects Windows Event Logs covering System, Security, Application, Windows Firewall, and networking event sources. Pod-level events accessible through kubectl describe pod record each event with a From field indicating the component source, a Reason field indicating why the event occurred, and a Message field providing details, all with associated timestamps.

VMware Private AI Services (PAIS) includes several event logging and observability mechanisms across its AI-specific components that contribute to the requirements of this control.

PAIS observability is configured through the PAISConfiguration custom resource. When activated, PAIS collects metrics in an integrated Prometheus server and supports forwarding LLM traces to an OpenTelemetry Collector over http/protobuf or gRPC. The spec.observability.prometheusRuntime section enables Prometheus with configurable storage class and metrics retention period, and the spec.observability.llmTraces section activates trace forwarding. These traces capture timing, event type, and source component information for model inference, agent execution flow, and knowledge base indexing. MLOps engineers and application developers use observability platforms such as Grafana to monitor model health, quality, and behavior of AI applications. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service and can also stream to VCF Operations through Telegraf with namepass filters that capture controller runtime worker counts, work queue depth, and reconcile concurrency.

Model endpoints built on the vLLM inference server support the VLLM_LOGGING_LEVEL environment variable to control inference logging verbosity, with DEBUG available as a supported value. Operators can retrieve logs for a specific model endpoint pod in the pais namespace by running kubectl logs against the pais-kubeconfig. Knowledge base operations record timing metrics for file downloads, embedding generation, and index operations, along with size metrics including total megabytes downloaded, number of new chunks indexed, and final index size. These records identify the type and duration of each operation.

Deep Learning VMs write cloud-init deployment logs to /var/log/dl.log and vGPU or NVIDIA data center GPU driver installation logs to /var/log/gpu-install.log. Deep Learning VMs also expose vGPU performance metrics through Prometheus for collection and visualization. These logs and metrics capture deployment progress, driver installation outcomes, and runtime performance.

Configuring all Technology Assets, Applications, and Services with sufficient event log content, including complete user identity trails and system-level API audit records across the full stack, requires configuration at the underlying VCF platform layer, including Kubernetes API server audit logging through VMware Kubernetes Service (VKS), VMware vCenter event logs, and VMware ESX host logs.

VMware vDefend (Contributes)

VMware vDefend (vDefend) produces event logs across its components that contain the information elements specified by this control, covering the network security layer of the VCF infrastructure.

Event type identification: vDefend components categorize events by type across multiple security functions. The Distributed Firewall (DFW) logs firewall rule hits with the action taken (allow, drop, or reject) and the rule ID that matched. IDS/IPS generates detection events categorized by signature severity level and threat category. Security Intelligence provides a View Full Event History capability that displays all events associated with a signature ID and the intrusion severity. Malware Prevention Service logs file analysis events categorized by detection status, verdict (BENIGN, malicious, or suspicious), and

malware family. Network Detection and Response (NDR) generates detection events forwarded to SIEM endpoints with structured metadata identifying the type of network threat detected.

Timestamps: All vDefend event logs include timestamps. Malware Prevention Service event logs record an inspection timestamp and event timestamps for each file analysis operation. Security Services Platform (SSP) logs certificate loading events with timestamp and component name information. Guest Introspection Platform Host Agent (MUX) messages written to `/var/log/syslog.log` include a timestamp in each log entry.

Event source: vDefend event logs identify the source of each event. DFW logs identify the specific vNIC, virtual machine, and security policy involved in each rule evaluation. IDS/IPS logs identify the affected workload and the network segment where the detection occurred. Malware Prevention Service logs include the client VM ID, submission source, server information, and gateway identification for each file analysis event, enabling analysts to trace events back to the originating workload. NDR events identify the network flows and endpoints involved in detected anomalies.

Outcome: vDefend logs capture the outcome of security operations. DFW logs record whether traffic was allowed, dropped, or rejected based on rule evaluation. IDS/IPS events record whether a signature match triggered an alert or a block action. Malware Prevention Service logs record the verdict (BENIGN, malicious, or other classification) and a numeric risk assessment score alongside the analysis completion status for each inspected file. Malware Prevention Service event logs also capture file hashes (SHA-256, SHA-1, MD5), file metadata including file name, file type, and file size, as well as HTTP domain, HTTP method, user agent, and file upload status for web-based file transfers. NDR detection events capture the severity and confidence level of detected threats.

User identity: vDefend captures user identity through multiple mechanisms. The Identity Firewall component collects Windows event logs from configured Event Log Servers to associate network traffic with Active Directory users and groups, enabling user-attributed firewall rule enforcement. Event Log Scraping is configurable on a per-domain basis from Servers & Site Mapping; in federated environments, Event Log Scraping and processing occur only at the Local Manager site. Event Log Sources are configured in Security > General Settings > Identity Firewall Event Log Sources, with the option to forward user identity events to VCF Log Management. NSX Manager audit logs capture the identity of administrators making configuration changes to firewall rules, security policies, and other objects through administrator identity fields, providing accountability for policy creation and modification.

Centralized log collection: VCF Log Management provides a centralized log management framework for vDefend. Unified Security Logs in VCF Log Management contain log messages for DFW, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering, enabling correlation across vDefend security functions from a single interface. Logs can be forwarded to VCF Log Management by configuring it as a syslog server.

SIEM integration: NDR forwards event logs to SIEM endpoints supporting Splunk (on-premises or cloud-hosted) and custom endpoints with configurable HTTP headers for authentication. NDR supports SSL verification for event logs sent over HTTPS and integrates with VCF Log Management as a SIEM server. Security Services Platform sends campaign and event logs to the connected SIEM as they occur. IDS/IPS events can be exported to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default); this requires remote syslog to be configured on the ESX host. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Guest Introspection Platform Host Agent (MUX) logs are written to `/var/log/syslog.log` on ESX hosts in a structured format that includes a timestamp, ContextMUX identifier, and thread ID.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) produces structured event logs that capture the information elements required for audit trail analysis.

PNR events are identified by named event types that indicate what occurred. vSphere Replication generates typed audit events when virtual machines and hosts are configured for or removed from replication, with event types including `com.vmware.vcHms.replicationConfiguredEvent`, `com.vmware.vcHms.replicationUnconfiguredEvent`, `com.vmware.vcHms.hostConfiguredForHbrEvent`, and `com.vmware.vcHms.hostUnconfiguredForHbrEvent`. Protection group and consistency group lifecycle changes are recorded with assigned severity levels: adding or removing a consistency group

from a protection group records an Info-level event, and consistency group errors or warnings record an Error-level event. Authorization errors are logged with timestamps and component information for security tracking. Each event type has a corresponding alarm that PNR can trigger if the event occurs.

Events include timestamps for time-based correlation. Login events record timestamp, log level, component, operation ID, and session details including userName and loginTime. Logout events record timestamp, user identity, source IP address, and operation ID. The Clean Room Orchestrator event details panel displays event severity, timestamp, target system information for replication or failover tasks, and event description.

Events are associated with specific objects, including protection groups, consistency groups, virtual machines, datastores, and sites, establishing where the event occurred and what was affected. The PNR global console displays all events occurring in the system, including both system-generated events and user actions. vSphere Replication maintains an audit log at /opt/vmware/support/logs/hms/hms-audit.log on the appliance, with broker logs at /opt/vmware/support/logs/hbr on the appliance and at /var/run/log on VMware ESX hosts.

Login events include the userName and loginTime fields, establishing the identity and session context of the user. Logout events record user identity and source IP address. The SrmDpxAgentUser role enables the DPX agent service to log events to VMware vCenter Event Manager.

Error-level events distinguish failed or abnormal conditions from informational state changes. Consistency group errors and warnings generate Error-level events; normal lifecycle transitions such as configuring replication or adding datastores record at the Info level. Snapshot task completion is logged and accessible through the Snapshot log interface in the Clean Room event details panel.

The PNR Appliance supports forwarding log files to a remote syslog server. Event forwarding to VCF Log Management version 9.0 or later is supported for centralized collection and retention. Clean Room Orchestrator events can be forwarded for external analysis, with event payloads that include timestamp, priority, message, component name, severity, configuration ID, component ID, and event type. Documented event forwarding destinations for Clean Room events include VCF Log Management, Microsoft Sentinel, and Splunk Cloud.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at /var/log/tdm/provider/audit/ with filenames in the format gateway-audit-timestamp.log. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) includes a native event logging system across both the Avi Controller and Service Engines that records structured event data covering all six fields this control specifies.

Avi system events capture a defined set of fields per entry: Timestamp (the date and time the event occurred), Resource Name and Resource Type (identifying the specific object and category of resource involved, establishing where the event occurred), Event Code (a named classification such as CONFIG_CREATE or CONFIG_UPDATE that identifies the type of event), and Description (a brief account of the event). Event logs track who made configuration changes and when, and can be filtered by event type using search parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE. For operational events such as configuration restores, the event record includes task name, status, node IP address, and success or failure messages, capturing the outcome of the operation.

Service Engine application logs apply the same structured fields at the data-plane layer, with each entry recording Timestamp, Resource Name, Resource Type, Event Code, and Description for virtual service and pool events. This extends structured logging beyond administrative actions on the Controller to application-layer events processed by the Service Engines.

The Controller's global event log, accessible via Operations > All Events, displays events across all objects including deleted objects and sub-objects such as profiles and certificates. Object-specific event logs are also available from the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to that object. The analytics API endpoint /api/analytics/logs retrieves event logs with configurable type, duration (up to one year), page_size, and end parameters to support queries across specific time periods.

Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and function failures to Events, Syslog, and Splunk. The Avi Web Application Firewall (WAF) logs matched application-layer events including matched variable name and matched variable content, with audit log parts configurable to include full event data. Avi Controller also logs denial of service attack events with event_id, attack_count, threshold values, and alert level.

The Controller's Syslog-Audit-Persistence alert action template supports forwarding events to external syslog servers for audit compliance. Note that syslog notifications push alerts but do not automatically export virtual service logs; virtual service logs must be pulled from an external logging system through the API or scripted to push from the Controller to a remote destination.

Control CIP-007-6 4.1.2

> Log events at the BES Cyber System level (per BES Cyber System capability) or at the Cyber Asset level (per Cyber Asset capability) for identification of, and after-the-fact investigations of, Cyber Security Incidents that includes, as a minimum, each of the following types of events: 4.1.2. Detected failed access attempts and failed login attempts;

SCF Controls: MON-03

Aggregate Coverage: Meets

VCF (Meets)

VCF produces structured event logs across its component stack that contain all six content elements specified by this control: event type, timestamp, location, source, outcome, and user identity. The platform's Consumption layer, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends this coverage to Kubernetes workloads using the kube-apiserver audit mechanism and component logging infrastructure.

Event type identification

VCF components classify events by category and severity. VCF Operations generates audit events organized into categories including Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. VCF Operations log entries include a logging level (info, warning, error) and a component class name identifying the subsystem that generated the event, along with a descriptive message. VCF Automation records events for catalog deployments, cloud template operations, Day 2 operations, and resource actions, and its audit logs display a status value or message for each reportable action type. VCF Automation issues specific events such as "Deployment requested" and "Deployment completed" around catalog and cloud template operations. NSX Manager audit logs record administrative changes with structured metadata including request ID, component name, subcomponent, and update status, and include a description of the event for actions such as logon, logoff, and resource access. The VMware vCenter EventEx interface constructs extended events with an explicit eventTypeId and severity parameter, providing machine-readable event classification at the API level. For workloads running on VKS clusters, the kube-apiserver records every API request using the audit.k8s.io/v1 Event schema, where the verb field captures the operation performed (create, get, update, delete, list, watch, patch) and the objectRef field identifies the resource type and API group involved. The audit Event record also includes an auditID that uniquely identifies each event for correlation across log entries, and a stage field indicating which stage of request processing produced the entry (RequestReceived, ResponseStarted, ResponseComplete, or Panic).

Timestamps

All logging subsystems across the VCF stack include date and time information. VCF Operations log events contain a timestamp as the first of eight common fields. VCF Operations Infrastructure Operations records the date and time when events and alerts are generated in the Created On field. NSX Manager audit logs record timestamps in ISO 8601 format for create and modify operations, and each NSX audit log entry includes a timestamp. VCF Automation audit logs record a timestamp for every reportable action. Kubernetes audit events include requestReceivedTimestamp and stageTimestamp fields, recording when the request was received by the API server and when each processing stage completed. Kubernetes system component logs in klog format carry a timestamp in every log entry alongside severity level, source file, and line number.

Event location and source

VCF Operations log entries include the source IP address and host IP of the system that generated the event, along with a source field indicating where the event originated, such as a VMware ESX host or syslog aggregation forwarder. Each event forwarded to VCF Operations contains source information and name-value pair fields extracted from the raw event data. NSX audit logs record the source of each event. VCF Log Management allows operators to search and filter collected log events by source. In VKS clusters, the Kubernetes audit event objectRef field records the namespace, resource type, resource name, API group, and API version; the requestURI field records the full API path; and the sourceIPs field records the originating IP address of the request, with the userAgent field providing additional context for service-to-service calls. Syslog log messages

from vSphere Pods include namespace name, pod UID, pod name, container name, and ESX host name as metadata fields when the LogAgentConfiguration Custom Resource is applied, providing workload-level source attribution alongside infrastructure-level source data. The Supervisor can also be configured to preserve the source IP addresses of authentication requests and Kubernetes API Server requests, making those addresses available for inspection in audit logs.

Outcome

VCF Operations log events can be filtered by logging level, and the Analyze page allows searching and filtering based on timestamp, text, source, and extracted fields. NSX audit logs include a result field that records the success or failure of the logged action. NSX Manager audit logging records operation status with detailed change tracking for administrative operations, including old and new values. VCF Automation audit logs contain a status value for each action indicating the outcome. Audit events across the platform capture success and failure states for operations. Kubernetes audit events record outcome in the responseStatus field, which contains the HTTP response status code indicating success or failure; at the RequestResponse audit level, response bodies are also captured, including error messages for failed operations. VM Operator logs record VM creation failures and reconciliation events for VirtualMachineService resources in VKS clusters, capturing failure details such as OVF deployment errors caused by insufficient ESX host resources.

User identity

VCF Operations audit logs can be filtered by User ID, User Name, Auth Source, Session, Client IP, Category, and Message. User permission events are sourced from VMware vCenter logs and can be filtered by event, status, updated by, object name, and object type. VCF Automation events record the user who triggered each event in the Owner field, and event logs record API access token usage by including the UUID of the token that performed the action. VCF Automation audit logs also include the user name and project name associated with each action, along with a trace ID for correlation. NSX Manager generates audit logs that record UserName, ModuleName, Operation, and Operation status with timestamps and request identifiers. The vCenter EventEx interface accepts a userName parameter when constructing event records, associating user identity with the logged action at the API level. VCF SSO audit event records include the timestamp, the user who performed the action, an event description, severity, and the IP address of the client connection to vCenter. Kubernetes audit events capture identity in the user field, which records the authenticated username, UID, group memberships, and extra attributes of the requester; for requests made through service accounts, the service account name and namespace are recorded as part of the user context.

Log detail and centralized management

ESX hosts support configurable syslog log levels that can be adjusted using esxcli system syslog commands, and the host agent log level can be set to verbose or other levels to control the detail captured. ESX syslog messages conform with RFC 3164, which defines structured message formatting. ESX audit records conform to RFC 5424 and contain event time, status, description, and user information for security-relevant activity tracked on the host. The Syslog.global.auditRecord.remote parameter enables forwarding ESX audit records to the remote syslog collector specified by Syslog.global.logHost. VCF Operations log events contain eight common parts: timestamp, thread name, host IP, logging level, class name, message text, token number, and duration. For centralized log management, VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the vpxd.event.syslog.enabled option in the vCenter Management Interface; forwarded events carry the fields eventId, createTime, eventType, severity, user, target, chainId, and desc. The VCF Operations audit log is integrated with syslog, allowing collection of all audit log data through the syslog collector. The VCF Log Management Analyze page provides a centralized interface for searching and correlating log events across all sources. NSX audit log messages are stored in /var/log/audit/audit.log. For deployments evaluated against global compliance frameworks, all auditable events defined by the applicable security requirements are logged by the platform.

For the Consumption layer, Kubernetes audit policy supports four logging levels (None, Metadata, Request, and RequestResponse), giving administrators fine-grained control over the verbosity and scope of audit records for VKS clusters. Audit events are written in JSONlines format to a log file via the kube-apiserver Log backend, configured through the --audit-log-path, --audit-log-maxage, --audit-log-maxbackup, and --audit-log-maxsize flags; audit events can also be forwarded in real time to an external system using the Webhook backend, which delivers batched events as HTTP POST requests to a

configured endpoint. Kubernetes audit records are collected by node log agents and forwarded to a central log store as part of the cluster observability pipeline. Fluent Bit logging agents deployed in the vmware-system-logging namespace collect and forward logs from nodes across the cluster; on VKS clusters, Fluent Bit collects Kubernetes container logs, Kubernetes API audit logs, Linux daemon logs, Linux authentication logs, and container runtime interface logs through configurable parsers and filters, and supports forwarding to Syslog, HTTP, Elasticsearch, Kafka, and Splunk. Workload logs from vSphere Pods and vSphere Namespaces are streamed to a remote Syslog server by applying a LogAgentConfiguration Custom Resource; each syslog message carries namespace name, pod UID, pod name, container name, and ESX host name as metadata fields. Kubernetes seccomp supports the SCMP_ACT_LOG action, which logs syscall execution to syslog or auditd without restricting the syscall, and the audit.json seccomp profile logs all syscalls of a process for detailed syscall-level auditing. For Windows workloads on VKS, the support bundle collects Windows Event Logs covering System, Security, Application, Windows Firewall, and networking event sources. Pod-level events accessible through kubectl describe pod record each event with a From field indicating the component source, a Reason field indicating why the event occurred, and a Message field providing details, all with associated timestamps.

VMware Private AI Services (PAIS) includes several event logging and observability mechanisms across its AI-specific components that contribute to the requirements of this control.

PAIS observability is configured through the PAISConfiguration custom resource. When activated, PAIS collects metrics in an integrated Prometheus server and supports forwarding LLM traces to an OpenTelemetry Collector over http/protobuf or gRPC. The spec.observability.prometheusRuntime section enables Prometheus with configurable storage class and metrics retention period, and the spec.observability.llmTraces section activates trace forwarding. These traces capture timing, event type, and source component information for model inference, agent execution flow, and knowledge base indexing. MLOps engineers and application developers use observability platforms such as Grafana to monitor model health, quality, and behavior of AI applications. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service and can also stream to VCF Operations through Telegraf with namepass filters that capture controller runtime worker counts, work queue depth, and reconcile concurrency.

Model endpoints built on the vLLM inference server support the VLLM_LOGGING_LEVEL environment variable to control inference logging verbosity, with DEBUG available as a supported value. Operators can retrieve logs for a specific model endpoint pod in the pais namespace by running kubectl logs against the pais-kubeconfig. Knowledge base operations record timing metrics for file downloads, embedding generation, and index operations, along with size metrics including total megabytes downloaded, number of new chunks indexed, and final index size. These records identify the type and duration of each operation.

Deep Learning VMs write cloud-init deployment logs to /var/log/dl.log and vGPU or NVIDIA data center GPU driver installation logs to /var/log/gpu-install.log. Deep Learning VMs also expose vGPU performance metrics through Prometheus for collection and visualization. These logs and metrics capture deployment progress, driver installation outcomes, and runtime performance.

Configuring all Technology Assets, Applications, and Services with sufficient event log content, including complete user identity trails and system-level API audit records across the full stack, requires configuration at the underlying VCF platform layer, including Kubernetes API server audit logging through VMware Kubernetes Service (VKS), VMware vCenter event logs, and VMware ESX host logs.

VMware vDefend (Contributes)

VMware vDefend (vDefend) produces event logs across its components that contain the information elements specified by this control, covering the network security layer of the VCF infrastructure.

Event type identification: vDefend components categorize events by type across multiple security functions. The Distributed Firewall (DFW) logs firewall rule hits with the action taken (allow, drop, or reject) and the rule ID that matched. IDS/IPS generates detection events categorized by signature severity level and threat category. Security Intelligence provides a View Full Event History capability that displays all events associated with a signature ID and the intrusion severity. Malware Prevention Service logs file analysis events categorized by detection status, verdict (BENIGN, malicious, or suspicious), and

malware family. Network Detection and Response (NDR) generates detection events forwarded to SIEM endpoints with structured metadata identifying the type of network threat detected.

Timestamps: All vDefend event logs include timestamps. Malware Prevention Service event logs record an inspection timestamp and event timestamps for each file analysis operation. Security Services Platform (SSP) logs certificate loading events with timestamp and component name information. Guest Introspection Platform Host Agent (MUX) messages written to `/var/log/syslog.log` include a timestamp in each log entry.

Event source: vDefend event logs identify the source of each event. DFW logs identify the specific vNIC, virtual machine, and security policy involved in each rule evaluation. IDS/IPS logs identify the affected workload and the network segment where the detection occurred. Malware Prevention Service logs include the client VM ID, submission source, server information, and gateway identification for each file analysis event, enabling analysts to trace events back to the originating workload. NDR events identify the network flows and endpoints involved in detected anomalies.

Outcome: vDefend logs capture the outcome of security operations. DFW logs record whether traffic was allowed, dropped, or rejected based on rule evaluation. IDS/IPS events record whether a signature match triggered an alert or a block action. Malware Prevention Service logs record the verdict (BENIGN, malicious, or other classification) and a numeric risk assessment score alongside the analysis completion status for each inspected file. Malware Prevention Service event logs also capture file hashes (SHA-256, SHA-1, MD5), file metadata including file name, file type, and file size, as well as HTTP domain, HTTP method, user agent, and file upload status for web-based file transfers. NDR detection events capture the severity and confidence level of detected threats.

User identity: vDefend captures user identity through multiple mechanisms. The Identity Firewall component collects Windows event logs from configured Event Log Servers to associate network traffic with Active Directory users and groups, enabling user-attributed firewall rule enforcement. Event Log Scraping is configurable on a per-domain basis from Servers & Site Mapping; in federated environments, Event Log Scraping and processing occur only at the Local Manager site. Event Log Sources are configured in Security > General Settings > Identity Firewall Event Log Sources, with the option to forward user identity events to VCF Log Management. NSX Manager audit logs capture the identity of administrators making configuration changes to firewall rules, security policies, and other objects through administrator identity fields, providing accountability for policy creation and modification.

Centralized log collection: VCF Log Management provides a centralized log management framework for vDefend. Unified Security Logs in VCF Log Management contain log messages for DFW, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering, enabling correlation across vDefend security functions from a single interface. Logs can be forwarded to VCF Log Management by configuring it as a syslog server.

SIEM integration: NDR forwards event logs to SIEM endpoints supporting Splunk (on-premises or cloud-hosted) and custom endpoints with configurable HTTP headers for authentication. NDR supports SSL verification for event logs sent over HTTPS and integrates with VCF Log Management as a SIEM server. Security Services Platform sends campaign and event logs to the connected SIEM as they occur. IDS/IPS events can be exported to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default); this requires remote syslog to be configured on the ESX host. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Guest Introspection Platform Host Agent (MUX) logs are written to `/var/log/syslog.log` on ESX hosts in a structured format that includes a timestamp, ContextMUX identifier, and thread ID.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) produces structured event logs that capture the information elements required for audit trail analysis.

PNR events are identified by named event types that indicate what occurred. vSphere Replication generates typed audit events when virtual machines and hosts are configured for or removed from replication, with event types including `com.vmware.vcHms.replicationConfiguredEvent`, `com.vmware.vcHms.replicationUnconfiguredEvent`, `com.vmware.vcHms.hostConfiguredForHbrEvent`, and `com.vmware.vcHms.hostUnconfiguredForHbrEvent`. Protection group and consistency group lifecycle changes are recorded with assigned severity levels: adding or removing a consistency group

from a protection group records an Info-level event, and consistency group errors or warnings record an Error-level event. Authorization errors are logged with timestamps and component information for security tracking. Each event type has a corresponding alarm that PNR can trigger if the event occurs.

Events include timestamps for time-based correlation. Login events record timestamp, log level, component, operation ID, and session details including userName and loginTime. Logout events record timestamp, user identity, source IP address, and operation ID. The Clean Room Orchestrator event details panel displays event severity, timestamp, target system information for replication or failover tasks, and event description.

Events are associated with specific objects, including protection groups, consistency groups, virtual machines, datastores, and sites, establishing where the event occurred and what was affected. The PNR global console displays all events occurring in the system, including both system-generated events and user actions. vSphere Replication maintains an audit log at /opt/vmware/support/logs/hms/hms-audit.log on the appliance, with broker logs at /opt/vmware/support/logs/hbr on the appliance and at /var/run/log on VMware ESX hosts.

Login events include the userName and loginTime fields, establishing the identity and session context of the user. Logout events record user identity and source IP address. The SrmDpxAgentUser role enables the DPX agent service to log events to VMware vCenter Event Manager.

Error-level events distinguish failed or abnormal conditions from informational state changes. Consistency group errors and warnings generate Error-level events; normal lifecycle transitions such as configuring replication or adding datastores record at the Info level. Snapshot task completion is logged and accessible through the Snapshot log interface in the Clean Room event details panel.

The PNR Appliance supports forwarding log files to a remote syslog server. Event forwarding to VCF Log Management version 9.0 or later is supported for centralized collection and retention. Clean Room Orchestrator events can be forwarded for external analysis, with event payloads that include timestamp, priority, message, component name, severity, configuration ID, component ID, and event type. Documented event forwarding destinations for Clean Room events include VCF Log Management, Microsoft Sentinel, and Splunk Cloud.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at /var/log/tdm/provider/audit/ with filenames in the format gateway-audit-timestamp.log. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) includes a native event logging system across both the Avi Controller and Service Engines that records structured event data covering all six fields this control specifies.

Avi system events capture a defined set of fields per entry: Timestamp (the date and time the event occurred), Resource Name and Resource Type (identifying the specific object and category of resource involved, establishing where the event occurred), Event Code (a named classification such as CONFIG_CREATE or CONFIG_UPDATE that identifies the type of event), and Description (a brief account of the event). Event logs track who made configuration changes and when, and can be filtered by event type using search parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE. For operational events such as configuration restores, the event record includes task name, status, node IP address, and success or failure messages, capturing the outcome of the operation.

Service Engine application logs apply the same structured fields at the data-plane layer, with each entry recording Timestamp, Resource Name, Resource Type, Event Code, and Description for virtual service and pool events. This extends structured logging beyond administrative actions on the Controller to application-layer events processed by the Service Engines.

The Controller's global event log, accessible via Operations > All Events, displays events across all objects including deleted objects and sub-objects such as profiles and certificates. Object-specific event logs are also available from the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to that object. The analytics API endpoint /api/analytics/logs retrieves event logs with configurable type, duration (up to one year), page_size, and end parameters to support queries across specific time periods.

Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and function failures to Events, Syslog, and Splunk. The Avi Web Application Firewall (WAF) logs matched application-layer events including matched variable name and matched variable content, with audit log parts configurable to include full event data. Avi Controller also logs denial of service attack events with event_id, attack_count, threshold values, and alert level.

The Controller's Syslog-Audit-Persistence alert action template supports forwarding events to external syslog servers for audit compliance. Note that syslog notifications push alerts but do not automatically export virtual service logs; virtual service logs must be pulled from an external logging system through the API or scripted to push from the Controller to a remote destination.

Control CIP-007-6 4.1.3

> Log events at the BES Cyber System level (per BES Cyber System capability) or at the Cyber Asset level (per Cyber Asset capability) for identification of, and after-the-fact investigations of, Cyber Security Incidents that includes, as a minimum, each of the following types of events: 4.1.3. Detected malicious code.

SCF Controls: MON-03

Aggregate Coverage: Meets

VCF (Meets)

VCF produces structured event logs across its component stack that contain all six content elements specified by this control: event type, timestamp, location, source, outcome, and user identity. The platform's Consumption layer, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends this coverage to Kubernetes workloads using the kube-apiserver audit mechanism and component logging infrastructure.

Event type identification

VCF components classify events by category and severity. VCF Operations generates audit events organized into categories including Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. VCF Operations log entries include a logging level (info, warning, error) and a component class name identifying the subsystem that generated the event, along with a descriptive message. VCF Automation records events for catalog deployments, cloud template operations, Day 2 operations, and resource actions, and its audit logs display a status value or message for each reportable action type. VCF Automation issues specific events such as "Deployment requested" and "Deployment completed" around catalog and cloud template operations. NSX Manager audit logs record administrative changes with structured metadata including request ID, component name, subcomponent, and update status, and include a description of the event for actions such as logon, logoff, and resource access. The VMware vCenter EventEx interface constructs extended events with an explicit eventType and severity parameter, providing machine-readable event classification at the API level. For workloads running on VKS clusters, the kube-apiserver records every API request using the audit.k8s.io/v1 Event schema, where the verb field captures the operation performed (create, get, update, delete, list, watch, patch) and the objectRef field identifies the resource type and API group involved. The audit Event record also includes an auditID that uniquely identifies each event for correlation across log entries, and a stage field indicating which stage of request processing produced the entry (RequestReceived, ResponseStarted, ResponseComplete, or Panic).

Timestamps

All logging subsystems across the VCF stack include date and time information. VCF Operations log events contain a timestamp as the first of eight common fields. VCF Operations Infrastructure Operations records the date and time when events and alerts are generated in the Created On field. NSX Manager audit logs record timestamps in ISO 8601 format for create and modify operations, and each NSX audit log entry includes a timestamp. VCF Automation audit logs record a timestamp for every reportable action. Kubernetes audit events include requestReceivedTimestamp and stageTimestamp fields, recording when the request was received by the API server and when each processing stage completed. Kubernetes system component logs in klog format carry a timestamp in every log entry alongside severity level, source file, and line number.

Event location and source

VCF Operations log entries include the source IP address and host IP of the system that generated the event, along with a source field indicating where the event originated, such as a VMware ESX host or syslog aggregation forwarder. Each event forwarded to VCF Operations contains source information and name-value pair fields extracted from the raw event data. NSX audit logs record the source of each event. VCF Log Management allows operators to search and filter collected log events by source. In VKS clusters, the Kubernetes audit event objectRef field records the namespace, resource type, resource name, API group, and API version; the requestURI field records the full API path; and the sourceIPs field records the originating IP address of the request, with the userAgent field providing additional context for service-to-service calls. Syslog log messages

from vSphere Pods include namespace name, pod UID, pod name, container name, and ESX host name as metadata fields when the LogAgentConfiguration Custom Resource is applied, providing workload-level source attribution alongside infrastructure-level source data. The Supervisor can also be configured to preserve the source IP addresses of authentication requests and Kubernetes API Server requests, making those addresses available for inspection in audit logs.

Outcome

VCF Operations log events can be filtered by logging level, and the Analyze page allows searching and filtering based on timestamp, text, source, and extracted fields. NSX audit logs include a result field that records the success or failure of the logged action. NSX Manager audit logging records operation status with detailed change tracking for administrative operations, including old and new values. VCF Automation audit logs contain a status value for each action indicating the outcome. Audit events across the platform capture success and failure states for operations. Kubernetes audit events record outcome in the responseStatus field, which contains the HTTP response status code indicating success or failure; at the RequestResponse audit level, response bodies are also captured, including error messages for failed operations. VM Operator logs record VM creation failures and reconciliation events for VirtualMachineService resources in VKS clusters, capturing failure details such as OVF deployment errors caused by insufficient ESX host resources.

User identity

VCF Operations audit logs can be filtered by User ID, User Name, Auth Source, Session, Client IP, Category, and Message. User permission events are sourced from VMware vCenter logs and can be filtered by event, status, updated by, object name, and object type. VCF Automation events record the user who triggered each event in the Owner field, and event logs record API access token usage by including the UUID of the token that performed the action. VCF Automation audit logs also include the user name and project name associated with each action, along with a trace ID for correlation. NSX Manager generates audit logs that record UserName, ModuleName, Operation, and Operation status with timestamps and request identifiers. The vCenter EventEx interface accepts a userName parameter when constructing event records, associating user identity with the logged action at the API level. VCF SSO audit event records include the timestamp, the user who performed the action, an event description, severity, and the IP address of the client connection to vCenter. Kubernetes audit events capture identity in the user field, which records the authenticated username, UID, group memberships, and extra attributes of the requester; for requests made through service accounts, the service account name and namespace are recorded as part of the user context.

Log detail and centralized management

ESX hosts support configurable syslog log levels that can be adjusted using esxcli system syslog commands, and the host agent log level can be set to verbose or other levels to control the detail captured. ESX syslog messages conform with RFC 3164, which defines structured message formatting. ESX audit records conform to RFC 5424 and contain event time, status, description, and user information for security-relevant activity tracked on the host. The Syslog.global.auditRecord.remote parameter enables forwarding ESX audit records to the remote syslog collector specified by Syslog.global.logHost. VCF Operations log events contain eight common parts: timestamp, thread name, host IP, logging level, class name, message text, token number, and duration. For centralized log management, VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the vpxd.event.syslog.enabled option in the vCenter Management Interface; forwarded events carry the fields eventId, createTime, eventType, severity, user, target, chainId, and desc. The VCF Operations audit log is integrated with syslog, allowing collection of all audit log data through the syslog collector. The VCF Log Management Analyze page provides a centralized interface for searching and correlating log events across all sources. NSX audit log messages are stored in /var/log/audit/audit.log. For deployments evaluated against global compliance frameworks, all auditable events defined by the applicable security requirements are logged by the platform.

For the Consumption layer, Kubernetes audit policy supports four logging levels (None, Metadata, Request, and RequestResponse), giving administrators fine-grained control over the verbosity and scope of audit records for VKS clusters. Audit events are written in JSONlines format to a log file via the kube-apiserver Log backend, configured through the --audit-log-path, --audit-log-maxage, --audit-log-maxbackup, and --audit-log-maxsize flags; audit events can also be forwarded in real time to an external system using the Webhook backend, which delivers batched events as HTTP POST requests to a

configured endpoint. Kubernetes audit records are collected by node log agents and forwarded to a central log store as part of the cluster observability pipeline. Fluent Bit logging agents deployed in the vmware-system-logging namespace collect and forward logs from nodes across the cluster; on VKS clusters, Fluent Bit collects Kubernetes container logs, Kubernetes API audit logs, Linux daemon logs, Linux authentication logs, and container runtime interface logs through configurable parsers and filters, and supports forwarding to Syslog, HTTP, Elasticsearch, Kafka, and Splunk. Workload logs from vSphere Pods and vSphere Namespaces are streamed to a remote Syslog server by applying a LogAgentConfiguration Custom Resource; each syslog message carries namespace name, pod UID, pod name, container name, and ESX host name as metadata fields. Kubernetes seccomp supports the SCMP_ACT_LOG action, which logs syscall execution to syslog or auditd without restricting the syscall, and the audit.json seccomp profile logs all syscalls of a process for detailed syscall-level auditing. For Windows workloads on VKS, the support bundle collects Windows Event Logs covering System, Security, Application, Windows Firewall, and networking event sources. Pod-level events accessible through kubectl describe pod record each event with a From field indicating the component source, a Reason field indicating why the event occurred, and a Message field providing details, all with associated timestamps.

VMware Private AI Services (PAIS) includes several event logging and observability mechanisms across its AI-specific components that contribute to the requirements of this control.

PAIS observability is configured through the PAISConfiguration custom resource. When activated, PAIS collects metrics in an integrated Prometheus server and supports forwarding LLM traces to an OpenTelemetry Collector over http/protobuf or gRPC. The spec.observability.prometheusRuntime section enables Prometheus with configurable storage class and metrics retention period, and the spec.observability.llmTraces section activates trace forwarding. These traces capture timing, event type, and source component information for model inference, agent execution flow, and knowledge base indexing. MLOps engineers and application developers use observability platforms such as Grafana to monitor model health, quality, and behavior of AI applications. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service and can also stream to VCF Operations through Telegraf with namepass filters that capture controller runtime worker counts, work queue depth, and reconcile concurrency.

Model endpoints built on the vLLM inference server support the VLLM_LOGGING_LEVEL environment variable to control inference logging verbosity, with DEBUG available as a supported value. Operators can retrieve logs for a specific model endpoint pod in the pais namespace by running kubectl logs against the pais-kubeconfig. Knowledge base operations record timing metrics for file downloads, embedding generation, and index operations, along with size metrics including total megabytes downloaded, number of new chunks indexed, and final index size. These records identify the type and duration of each operation.

Deep Learning VMs write cloud-init deployment logs to /var/log/dl.log and vGPU or NVIDIA data center GPU driver installation logs to /var/log/gpu-install.log. Deep Learning VMs also expose vGPU performance metrics through Prometheus for collection and visualization. These logs and metrics capture deployment progress, driver installation outcomes, and runtime performance.

Configuring all Technology Assets, Applications, and Services with sufficient event log content, including complete user identity trails and system-level API audit records across the full stack, requires configuration at the underlying VCF platform layer, including Kubernetes API server audit logging through VMware Kubernetes Service (VKS), VMware vCenter event logs, and VMware ESX host logs.

VMware vDefend (Contributes)

VMware vDefend (vDefend) produces event logs across its components that contain the information elements specified by this control, covering the network security layer of the VCF infrastructure.

Event type identification: vDefend components categorize events by type across multiple security functions. The Distributed Firewall (DFW) logs firewall rule hits with the action taken (allow, drop, or reject) and the rule ID that matched. IDS/IPS generates detection events categorized by signature severity level and threat category. Security Intelligence provides a View Full Event History capability that displays all events associated with a signature ID and the intrusion severity. Malware Prevention Service logs file analysis events categorized by detection status, verdict (BENIGN, malicious, or suspicious), and

malware family. Network Detection and Response (NDR) generates detection events forwarded to SIEM endpoints with structured metadata identifying the type of network threat detected.

Timestamps: All vDefend event logs include timestamps. Malware Prevention Service event logs record an inspection timestamp and event timestamps for each file analysis operation. Security Services Platform (SSP) logs certificate loading events with timestamp and component name information. Guest Introspection Platform Host Agent (MUX) messages written to `/var/log/syslog.log` include a timestamp in each log entry.

Event source: vDefend event logs identify the source of each event. DFW logs identify the specific vNIC, virtual machine, and security policy involved in each rule evaluation. IDS/IPS logs identify the affected workload and the network segment where the detection occurred. Malware Prevention Service logs include the client VM ID, submission source, server information, and gateway identification for each file analysis event, enabling analysts to trace events back to the originating workload. NDR events identify the network flows and endpoints involved in detected anomalies.

Outcome: vDefend logs capture the outcome of security operations. DFW logs record whether traffic was allowed, dropped, or rejected based on rule evaluation. IDS/IPS events record whether a signature match triggered an alert or a block action. Malware Prevention Service logs record the verdict (BENIGN, malicious, or other classification) and a numeric risk assessment score alongside the analysis completion status for each inspected file. Malware Prevention Service event logs also capture file hashes (SHA-256, SHA-1, MD5), file metadata including file name, file type, and file size, as well as HTTP domain, HTTP method, user agent, and file upload status for web-based file transfers. NDR detection events capture the severity and confidence level of detected threats.

User identity: vDefend captures user identity through multiple mechanisms. The Identity Firewall component collects Windows event logs from configured Event Log Servers to associate network traffic with Active Directory users and groups, enabling user-attributed firewall rule enforcement. Event Log Scraping is configurable on a per-domain basis from Servers & Site Mapping; in federated environments, Event Log Scraping and processing occur only at the Local Manager site. Event Log Sources are configured in Security > General Settings > Identity Firewall Event Log Sources, with the option to forward user identity events to VCF Log Management. NSX Manager audit logs capture the identity of administrators making configuration changes to firewall rules, security policies, and other objects through administrator identity fields, providing accountability for policy creation and modification.

Centralized log collection: VCF Log Management provides a centralized log management framework for vDefend. Unified Security Logs in VCF Log Management contain log messages for DFW, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering, enabling correlation across vDefend security functions from a single interface. Logs can be forwarded to VCF Log Management by configuring it as a syslog server.

SIEM integration: NDR forwards event logs to SIEM endpoints supporting Splunk (on-premises or cloud-hosted) and custom endpoints with configurable HTTP headers for authentication. NDR supports SSL verification for event logs sent over HTTPS and integrates with VCF Log Management as a SIEM server. Security Services Platform sends campaign and event logs to the connected SIEM as they occur. IDS/IPS events can be exported to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default); this requires remote syslog to be configured on the ESX host. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Guest Introspection Platform Host Agent (MUX) logs are written to `/var/log/syslog.log` on ESX hosts in a structured format that includes a timestamp, ContextMUX identifier, and thread ID.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) produces structured event logs that capture the information elements required for audit trail analysis.

PNR events are identified by named event types that indicate what occurred. vSphere Replication generates typed audit events when virtual machines and hosts are configured for or removed from replication, with event types including `com.vmware.vcHms.replicationConfiguredEvent`, `com.vmware.vcHms.replicationUnconfiguredEvent`, `com.vmware.vcHms.hostConfiguredForHbrEvent`, and `com.vmware.vcHms.hostUnconfiguredForHbrEvent`. Protection group and consistency group lifecycle changes are recorded with assigned severity levels: adding or removing a consistency group

from a protection group records an Info-level event, and consistency group errors or warnings record an Error-level event. Authorization errors are logged with timestamps and component information for security tracking. Each event type has a corresponding alarm that PNR can trigger if the event occurs.

Events include timestamps for time-based correlation. Login events record timestamp, log level, component, operation ID, and session details including userName and loginTime. Logout events record timestamp, user identity, source IP address, and operation ID. The Clean Room Orchestrator event details panel displays event severity, timestamp, target system information for replication or failover tasks, and event description.

Events are associated with specific objects, including protection groups, consistency groups, virtual machines, datastores, and sites, establishing where the event occurred and what was affected. The PNR global console displays all events occurring in the system, including both system-generated events and user actions. vSphere Replication maintains an audit log at /opt/vmware/support/logs/hms/hms-audit.log on the appliance, with broker logs at /opt/vmware/support/logs/hbr on the appliance and at /var/run/log on VMware ESX hosts.

Login events include the userName and loginTime fields, establishing the identity and session context of the user. Logout events record user identity and source IP address. The SrmDpxAgentUser role enables the DPX agent service to log events to VMware vCenter Event Manager.

Error-level events distinguish failed or abnormal conditions from informational state changes. Consistency group errors and warnings generate Error-level events; normal lifecycle transitions such as configuring replication or adding datastores record at the Info level. Snapshot task completion is logged and accessible through the Snapshot log interface in the Clean Room event details panel.

The PNR Appliance supports forwarding log files to a remote syslog server. Event forwarding to VCF Log Management version 9.0 or later is supported for centralized collection and retention. Clean Room Orchestrator events can be forwarded for external analysis, with event payloads that include timestamp, priority, message, component name, severity, configuration ID, component ID, and event type. Documented event forwarding destinations for Clean Room events include VCF Log Management, Microsoft Sentinel, and Splunk Cloud.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at /var/log/tdm/provider/audit/ with filenames in the format gateway-audit-timestamp.log. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) includes a native event logging system across both the Avi Controller and Service Engines that records structured event data covering all six fields this control specifies.

Avi system events capture a defined set of fields per entry: Timestamp (the date and time the event occurred), Resource Name and Resource Type (identifying the specific object and category of resource involved, establishing where the event occurred), Event Code (a named classification such as CONFIG_CREATE or CONFIG_UPDATE that identifies the type of event), and Description (a brief account of the event). Event logs track who made configuration changes and when, and can be filtered by event type using search parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE. For operational events such as configuration restores, the event record includes task name, status, node IP address, and success or failure messages, capturing the outcome of the operation.

Service Engine application logs apply the same structured fields at the data-plane layer, with each entry recording Timestamp, Resource Name, Resource Type, Event Code, and Description for virtual service and pool events. This extends structured logging beyond administrative actions on the Controller to application-layer events processed by the Service Engines.

The Controller's global event log, accessible via Operations > All Events, displays events across all objects including deleted objects and sub-objects such as profiles and certificates. Object-specific event logs are also available from the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to that object. The analytics API endpoint /api/analytics/logs retrieves event logs with configurable type, duration (up to one year), page_size, and end parameters to support queries across specific time periods.

Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and function failures to Events, Syslog, and Splunk. The Avi Web Application Firewall (WAF) logs matched application-layer events including matched variable name and matched variable content, with audit log parts configurable to include full event data. Avi Controller also logs denial of service attack events with event_id, attack_count, threshold values, and alert level.

The Controller's Syslog-Audit-Persistence alert action template supports forwarding events to external syslog servers for audit compliance. Note that syslog notifications push alerts but do not automatically export virtual service logs; virtual service logs must be pulled from an external logging system through the API or scripted to push from the Controller to a remote destination.

Control CIP-007-6 4.2

> Generate alerts for security events that the Responsible Entity determines necessitates an alert, that includes, as a minimum, each of the following types of events (per Cyber Asset or BES Cyber System capability): 4.2.1. Detected malicious code from Part 4.1; and 4.2.2. Detected failure of Part 4.1 event logging.

SCF Controls: MON-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered alerting infrastructure across VMware vCenter and VCF Operations that generates system alerts based on defined conditions, correlates related alerts through intelligent grouping, and forwards them to external management systems through multiple outbound channels. These capabilities address the cybersecurity and data protection dimensions of this control, though the physical and supply chain alert domains require organizational processes and tooling outside of VCF.

At the vCenter layer, the built-in alarm system monitors objects in the virtual infrastructure and triggers alerts when defined conditions are met. vCenter includes an SNMP agent that sends traps when the system starts or when alarms fire. The SNMP agent supports SNMP v1 and v2c traps as well as SNMP v3 traps with all security levels; when configured for v1 or v2c, the agent also handles incoming GET requests, supporting both push-based alerting and poll-based monitoring from management systems. Alarm notifications can also be delivered via email with configurable recipient addresses and subject lines. Alarm rules are configured per event, so administrators must create individual rules for each event type they wish to monitor. VCF PowerCLI supports programmatic creation of SNMP alarm actions using the New-AlarmAction -Snmpp parameter, enabling automation of alert configuration across managed vCenter instances. VMware vCenter High Availability can also be configured to send SNMP trap notifications for vCenter HA cluster events, extending alert coverage to vCenter availability and failover scenarios.

VCF Operations provides a more extensive alerting framework built on symptom-based alert definitions. Alerts are generated when collected metric or property data is compared against alert definitions and the defined symptom conditions evaluate as true. Each alert definition includes configurable impact and criticality metadata so administrators can prioritize responses. When an alert triggers, it presents the triggering symptoms alongside recommendations for resolution, giving operators the context they need to act. Administrators can attach recommendations to alert definitions so that engineers have documented remediation steps when alerts fire. Alert definitions support best practices such as consistent naming, actionable recommendations, and appropriate severity levels. The Wait Cycle setting, which defaults to 1, controls how many collection cycles a symptom condition must persist before an alert is generated, and should be adjusted based on the environment's tolerance for repeated alerts on recurring conditions. Administrators can create alert definitions with tighter symptom parameters to track alerts and identify problems before users encounter further issues.

The Alerts data grid in VCF Operations lists all generated alerts and their status. Generated alerts feed the top-level Health, Risk, and Efficiency badges, providing a consolidated operational view across the monitored environment. Alerts can be added by adapters, users, or the VCF Operations system itself. The system supports self-monitoring through internal metrics such as analytics operation counts, threshold check durations, and incoming observation sizes, allowing administrators to verify that the monitoring platform is functioning correctly.

For alert correlation, VCF Operations includes intelligent alert clustering, which groups related alerts together based on their creation time and topology distance. Each alert cluster includes a graphical timeline and an object-relationship chart, helping administrators trace root causes across related infrastructure objects rather than investigating each alert in isolation. This reduces alert noise and helps operators identify underlying root causes.

VCF Operations supports alert definitions based on log events from monitored systems. VCF Log Management collects logs from all VCF components and provides pre-built content packs with dashboards, alerts, and queries for common operational and security scenarios. An NSX-specific content pack includes alerts for NSX environment monitoring. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear, connecting log analysis with the

broader alerting framework. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture.

For alert distribution and external integration, VCF Operations supports multiple outbound notification plug-in types. Notification options can be configured to specify which alerts are sent through each channel. Supported outbound plug-in types include Standard Email, SNMP Trap, Webhook Notification (for REST-based integration with external systems), Slack, Log File, and ServiceNow Notification. Payload templates are available for each plug-in type, allowing administrators to customize the alert content delivered to each destination. At least one instance of the relevant outbound plug-in must be configured and running before notifications can be sent.

SNMP trap notifications can be sent to up to four configurable destinations, and notification rules support filtering to control which alerts are forwarded to which destinations. VCF Operations for Networks also supports SNMP trap forwarding to up to four destinations. VCF Operations can log alerts to an existing SNMP Trap server in the environment. The Management Pack for SNMP plug-in can receive events from vCenter over the SNMP protocol, enabling centralized collection of alerts from across the VCF stack. VCF Operations generates a critical alert when no SNMP targets are configured, helping ensure that outbound notification paths remain active.

The Management Pack for ServiceNow provides alert-sync functionality that synchronizes alerts between VCF Operations and ServiceNow. It creates ServiceNow alerts for VCF Operations alerts and associates them with their Configuration Item if present in the CMDB. Sample configurations allow alerts to be sent to ServiceNow as alerts, events, or incidents without applying filters, and each alerting configuration supports a callerId parameter that identifies the caller for ServiceNow integration. The Slack plugin supports forwarding alerts to Slack channels for notification and troubleshooting purposes.

Cloud proxy instances can be configured to generate their own alerts and notifications. It is recommended to create notification rules for cloud proxy alerts so that remediation steps can be taken promptly when connectivity or service health issues arise. An alert is displayed in VCF Operations when one or more services on a cloud proxy are down.

Out-of-the-box customizable alerts and reports are included with predefined dashboards to assist with operational awareness from initial deployment. Administrators can also create custom dashboards with alert-related widgets to monitor alerts for specific object groups.

At the VMware Kubernetes Service (VKS) layer, the Prometheus standard package provides a built-in alerting stack for containerized workloads. When installed on a VKS cluster, it deploys Prometheus AlertManager as a StatefulSet with multiple replicas in the `tanzu-system-monitoring` namespace. Prometheus instances on VKS clusters send alerts to AlertManager via HTTP on the configured web port. The `AlertManagerConfig` custom resource definition specifies how alerts are grouped, inhibited, and forwarded to external notification systems; the default-receiver routing configuration applies a group wait of 10 seconds, group interval of 5 minutes, and a repeat interval of 3 hours. Administrators can extend these notifications to external incident management systems through AlertManager receiver configurations. AlertManager instances are deployed with a securityContext that enforces non-root execution, running as user and group 65534. VCF Automation provides an Alerts tab on deployment resources that surfaces active alerts sourced from VCF Operations, and Grafana Operator is available alongside Prometheus for visualization of cluster-level monitoring data.

For supply chain integrity alerting, VKS supports configuring Kubernetes admission controllers to verify container image signatures at deploy time. The sigstore policy-controller admission controller validates image authenticity and integrity before workloads are scheduled, blocking or flagging images that fail signature checks. Harbor Registry, available as a standard package on VKS clusters, signs images as trusted to provide image authenticity verification. When copying VKS images to a private registry, the `imgpkg copy` command supports the `--cosign-signatures` flag to verify and transfer Cosign signatures alongside images, preserving supply chain traceability. The VCF Consumption CLI binary integrity can be verified using a SHA256 checksum file available for download from the VCF Automation Tenant Portal. Admission policy violations are recorded in the Kubernetes audit log, generating traceable security events that can be forwarded to external monitoring or SIEM platforms.

To achieve the integrated situational awareness described in this control, organizations should configure outbound notification plug-ins from vCenter, VCF Operations, and AlertManager on VKS clusters to forward alerts to a centralized security

information and event management (SIEM) or network management platform. Alert definitions should be tuned following the built-in best practices guidance, outbound plug-in instances should be configured and verified as active, and container image signature verification should be enabled on VKS admission controllers to surface supply chain integrity events. The physical security domain of this control and the full cross-domain correlation function require processes and systems outside of VCF's scope.

VMware vDefend (Contributes)

VMware vDefend contributes to cybersecurity alert generation and monitoring within its network security domain but does not cover physical security, supply chain, or data protection alerting.

The Distributed IDS/IPS generates alerts based on configurable threshold conditions, tracking events by source with a count threshold and time period so that alerts fire only after a minimum number of matching events occur within a defined window. Alert logs capture source IP, source port, destination IP, destination port, IP protocol, and timestamp for each triggered event. Signature severity levels are adjustable, allowing tuning of which events generate alerts based on organizational security requirements. To manage alert volume, IDS/IPS supports a Limit option that caps alert generation per host within a specified time frame and a Both threshold type that applies thresholding and rate limiting simultaneously to reduce flooding from high-volume signature matches.

The Threat Event Monitoring dashboard in vDefend provides visibility into the current state of security issues across the data center, helping security teams understand network activity and prioritize focus areas. An alarm triggers and remains active until dropped events are no longer detected, keeping administrators aware of ongoing event-drop conditions beyond the initial notification banner.

Security Services Platform (SSP) generates alarms when allocated resources exceed predetermined threshold values, with deployment status and platform alarms visible in the System Dashboard. SSP alarm records include detailed descriptions, recommended actions, and the date and time each alarm triggered. Alarms can be acknowledged, suppressed, or resolved to manage the alert lifecycle, and the entity ID that caused each alarm is available for correlation. The License Hub dashboard within SSP highlights platform-related alarms displaying system alerts and critical errors requiring attention. SSP also generates alarms on the Bare Metal Server page when certificate updates fail, providing operational awareness of certificate lifecycle issues on bare metal infrastructure.

Security Intelligence continuously monitors for new traffic flows between environments and alerts administrators to unauthorized or unexpected traffic, supporting ongoing policy adjustment. The Monitor and Plan Overview dashboard displays high-level information about the most recent state of network activities managed by Security Intelligence, while the Environments Monitoring view provides traffic flow analysis with protection status summaries for selected environment pairs across configurable time ranges.

Network Detection and Response (NDR) integrates with external SIEM systems to send security-related event logs about network infrastructure, generating and forwarding logs both when a detection event occurs and when an existing detection is updated. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

Physical security, supply chain monitoring, and data protection alerts are outside vDefend's scope and require complementary controls to achieve integrated situational awareness.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides alert generation and notification capabilities for data protection activities, integrating with the VMware vCenter alarm framework and supporting outbound notification to external response systems.

PNR extends vCenter's alarm system with recovery-specific alarm types. Alarms are generated automatically when connectivity issues are encountered or when protection groups and recovery plans enter an error state. PNR logs events and triggers corresponding alarms to track system health and address potential issues before they affect protection. Administrators can define and configure the action taken by each alarm type.

Alarm notifications can be configured to send email, SNMP traps, or run scripts on the vCenter host when an alarm triggers. For email notifications to function, Mail settings must be configured in vCenter Settings. PNR requires an administrator email address to be configured during appliance registration with vCenter. Licensing event alerts can also be configured so that licensing administrators receive email notifications when licensing compliance issues occur.

vSphere Replication supports configurable alarms for replication events. Administrators can define and edit alarms so that specific replication events, such as after configuring a virtual machine for replication, trigger notifications.

In 9.1, the unified PNR appliance includes the Clean Room Orchestrator, which adds a distinct alerting surface for cyber recovery operations. The Clean Room Orchestrator sends email alerts to configured recipients when the status of recovery environment components changes, such as when the Orchestrator or connector moves from good to warning status. PNR maintains an Alarms list for the clean room showing a history of all notifications requiring attention, with search and filtering by severity. PNR also supports configuration of email alerts for critical events to notify users of important recovery operations and system events.

The Protection and Recovery Overview Dashboard displays alerts with severity levels of Critical, Immediate, and Warning for snapshots, protection groups, recovery plans, and deployment settings. Through the VMware Live Recovery Cloud Management Pack integration with VCF Operations, administrators receive health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites.

For environments using PNR's Cyber Recovery capability, PNR supports integration with CrowdStrike, which provides CrowdScore for Incident Detections. CrowdScore measures the real-time threat level to recovery endpoints on a scale of 0 to 100, calculated using factors including frequency, severity, and correlation of security alerts, giving administrators a data protection-scoped view of security conditions relevant to recovery readiness.

These PNR-native alerting mechanisms contribute to situational awareness for data protection activities. Physical infrastructure alerting, network security alerting, and supply chain alerting fall outside PNR's scope and depend on the broader VCF platform and supplementary tools.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) generates system alerts for conditions within its operational scope, covering database engine health, infrastructure connectivity, cybersecurity events, and data protection activities. The Dashboard displays Global Alerts at a glance, and a dedicated Global Alerts page, accessible from both the plug-in UI within vSphere Client and the standalone UI, provides a consolidated view of non-catastrophic alerts and overall system status. An Alerts pane in the Monitoring tab gives administrators a database-scoped view of active conditions for individual instances.

DSM categorizes alert conditions at three severity levels: OK, WARNING, and CRITICAL. Named alert types include `INFRASTRUCTURE_POLICY_VC_ALARMS`, triggered when one or more infrastructure resource alarms found in VMware vCenter (vCenter) are active; `VCENTER_CONNECTIVITY`, triggered when vCenter connectivity fails; `DATABASE_ENGINE_HEALTH_ALERT`, triggered when the database engine service is experiencing problems or disruptions; and alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates alerts for authentication failures, backup and restore corruptions, and certificate errors. When critical alarms are active for vCenter hosts, DSM surfaces guidance to avoid create, upgrade, and scale operations to reduce the risk of failures during degraded infrastructure states. Each alert includes resolution suggestions that give operators actionable steps to resolve conditions without disrupting database services. Alert notification settings and threshold values for database alerts are configurable.

To support integration with broader monitoring and incident response workflows, DSM can forward alerts as email notifications or as webhook notifications to external systems. Named integration targets include Slack channels and ServiceNow. Webhooks support customizable payload templates and AlertLevel filtering, restricting delivery to CRITICAL or WARNING conditions as appropriate for the operational model. Alert payloads include the alert name, alert level, alert description, trigger timestamp, alert message, database cluster identifier, cluster name, triggered user email, task status, previous status, and task type. At the individual database level, administrators can configure alert notifications to route to Email, Slack, or ServiceNow endpoints. This mechanism supports routing DSM-generated alerts into enterprise monitoring platforms, SIEM systems, or ticketing workflows.

DSM integrates with VCF Operations to surface monitoring data for database services, providing an additional visibility channel for triggered or active alerts scoped to individual nodes or the overall cluster within the broader VCF observability stack.

DSM's alert coverage is scoped to the database-as-a-service layer: database instance health, infrastructure policy compliance, connectivity to platform components, authentication events, and backup operation outcomes. Physical security, network-level cybersecurity events, and supply chain activities are outside DSM's scope and require monitoring through the broader VCF platform and organizational tooling. Correlating DSM alerts with alerts from other platform components, and implementing a coordinated response workflow that spans physical, cybersecurity, data protection, and supply chain domains, requires organizational processes and enterprise monitoring capabilities beyond what DSM provides on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer has a native alerting subsystem that generates, routes, and responds to alerts from application delivery and cybersecurity events. Alert Configurations define the conditions under which alerts are generated, drawing from system events or metrics as the configurable source, with parameters specifying when an alert should fire and what actions to take. When conditions are met, Avi executes the configured Action Groups that trigger notifications for new alerts. The Alert Manager captures alert details across the system, including information for Service Engines, Virtual Services, and Pools, along with event identifiers and cloud-specific metadata such as Service Engine VM UUIDs.

For alert routing, the Avi Controller supports four notification destinations: the local Controller UI (visible under Operations > Alerts > All Alerts, categorized by configured Alert Level), email, syslog, and SNMP traps. SNMP trap support covers both SNMPv2c and SNMPv3 protocols. In 9.1, SNMP notifications can additionally be configured with TLS encryption and strict certificate verification for secure transport to external SNMP servers, and multiple SNMP servers can be specified for notification delivery to support redundancy. Syslog Audit Persistence forwards alert events to remote syslog servers for centralized monitoring and audit trail collection. All destinations are configured through Operations > Notifications in the Controller UI. The Controller cluster leader issues SNMP trap notifications based on system events, and event-based traps can include status-change events such as virtual-service-down conditions. Local alert notifications are generated by default in addition to any configured external alert actions.

For automated response, Avi Alert Actions support ControlScripts: Python scripts executed on the Controller that receive the triggering alert's `EVENT_DESCRIPTION` as an environment variable and full alert details as JSON. Alert Actions can be associated with specific system events and can trigger email, Syslog, SNMP Trap, or ControlScript responses. Avi logs configured alerts and their execution status in the Alert Actions tab under Operations > Alerts. Custom Alert Actions can be created alongside or in place of the default system alert actions (such as System-Alert-Level-High), allowing organizations to tailor alerting and automated response to their operational and security requirements.

For VCF-integrated deployments in 9.1, the Avi Load Balancer Observability Management Pack provides unified alert reporting across multiple Avi instances, giving VCF platform operators a consolidated view of alerting state across the Avi deployment.

Auditors should verify that Alert Configurations and Alert Actions are configured under Operations in the Avi Controller UI, that syslog or SNMP trap destinations are set to route events to the organization's centralized monitoring platform, and that alert thresholds reflect the cybersecurity and application availability events within the Avi scope. The organization is responsible for routing Avi alerts into the broader monitoring stack and for establishing the cross-domain correlation required to achieve integrated situational awareness across physical, data protection, and supply chain domains.

Control CIP-007-6 4.2.1

> Generate alerts for security events that the Responsible Entity determines necessitates an alert, that includes, as a minimum, each of the following types of events (per Cyber Asset or BES Cyber System capability): 4.2.2. Detected failure of Part 4.1 event logging.

SCF Controls: END-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to

suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot

of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 4.2.2

> Generate alerts for security events that the Responsible Entity determines necessitates an alert, that includes, as a minimum, each of the following types of events (per Cyber Asset or BES Cyber System capability): 4.2.1. Detected malicious code from Part 4.1; and

SCF Controls: MON-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms to detect log processing failures, alert operations personnel, and support remediation of disruptions across its monitoring stack.

VCF Operations monitors the health of its own alerting and log processing infrastructure. When no SNMP targets are configured for alert delivery, VCF Operations generates a critical alert (`vmwSNMPNotConfiguredEvent`), flagging that the alerting pipeline is not operational. It also generates critical alerts for invalid SNMP connection events (`vmwSNMPConnectionInvalidEvent`). At the network layer, VCF Operations monitors the status of the NSX Management Node SNMP Service and generates a warning-severity alert when the service stops running. NSX-T itself generates an alert event when the Syslog Service has stopped running on NSX-T Manager nodes. The NSX Manager Logging Monitor adds a further detection mechanism through the System Health Agent framework, tracking each log's generation rate and rotation settings to estimate how long log data will be retained and raising log duration alarms when abnormal rates risk flushing log data before it is collected, so operators can intervene before records are lost. These self-monitoring capabilities detect failures in the event log processing and alert delivery chain before administrators need to discover them manually.

The alert framework in VCF Operations supports definitions built from one or more symptom sets. Symptom definitions identify conditions on attributes, properties, metrics, and events. The framework supports multiple event types relevant to log processing failures, including System Degradation, Data Availability, Collector Down, and Object Error. Administrators can create alert definitions with tighter symptom parameters to track problems before users encounter further issues. Recommendations can be attached to alert definitions so that engineers know how to resolve the alert when it fires, providing clear remediation guidance tied to specific failure conditions. Alerts are generated when collected data for an object is compared against the alert definitions for that object type and the defined symptoms evaluate to true.

For alert delivery, VCF supports multiple notification channels. vCenter can send both SNMP traps and email notifications when alarms are triggered, with configurable recipient addresses and subject lines. The vCenter SNMP agent supports SNMPv1, v2c, and v3 trap formats, including SNMPv3 with all security levels. VCF Operations supports outbound SNMP trap notifications to up to four destinations and can filter notifications based on defined criteria. As a fallback, VCF Operations can log alerts to a file on each of its nodes, providing an on-node record that persists even if external alert delivery is disrupted. This multi-channel approach helps ensure that alerts about log processing disruptions reach the appropriate personnel even if one delivery mechanism is impaired.

VCF Operations provides log-based alerting through Symptom Definitions, accessible under Infrastructure Operations > Configurations. Administrators can create log-based conditions and symptoms that trigger alerts when specific log patterns are detected, including patterns that indicate log processing failures or disruptions. The Log File plug-in supports notification rules that filter and route alerts to the appropriate teams. Log-based alert definitions can monitor host systems for specific conditions such as cluster performance failures, and they generate alerts when those conditions are detected. These alerts can be forwarded to external monitoring systems via SNMP traps.

VCF Log Management is a centralized log collection platform that pulls tasks, events, and alerts from vCenter instances and receives syslog feeds from ESX hosts. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be configured to collect all audit logs. This centralized architecture makes it possible to detect when expected log streams stop arriving, which is itself an indicator of a log processing failure. When audit record transmission is active on ESX hosts, the syslog daemon (`vmsyslogd`) emits records documenting its own operational status, including daemon start, stop, and error

conditions, enabling detection of syslog service disruptions at the host level. vCenter event streaming to a remote syslog server is configured via the `vpzd.event.syslog.enabled` option in the vCenter Management Interface.

VCF Operations logs task execution details including Script Return Result status, script names, target object types, parameters passed, and unexpected exceptions. When automated remediation tasks fail, these logs provide the diagnostic detail needed to understand what went wrong and why. Task events are displayed in the messages area, allowing administrators to troubleshoot failed tasks directly.

Adapters for external monitored systems and the REST API are inbound channels for collecting events from external sources. VCF Operations correlates a subset of events published by monitored systems and delivers them as faults. Fault symptoms can be defined based on these events and added to alert definitions, so failures in external log sources are surfaced within the central monitoring platform. For organizations that forward logs to external SIEM systems via syslog, any disruption in log forwarding is itself a monitorable condition, since VCF components generate alerts when syslog services stop running.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters include instrumentation to detect and report log processing failures in workload environments. The Kubernetes API server exposes the `apiserver_audit_error_total` metric, which counts audit events dropped due to export errors, and the companion `apiserver_audit_event_total` metric, which tracks total audit event volume; a sustained rise in the error count relative to the event count indicates a failure in the audit export pipeline. When Prometheus is installed as a standard package on a VKS cluster, Prometheus instances are configured to send alerts to Alertmanager in the `tanzu-system-monitoring` namespace. Alertmanager is deployed as a StatefulSet with multiple replicas in that namespace, and administrators can configure alert rules targeting these metrics to route notifications to designated personnel when audit event exports fail. Prometheus discovers Alertmanager pods through Kubernetes service discovery, filtering by namespace, app label, and component label.

VKS clusters include Fluent Bit logging agents for cluster-wide log collection and forwarding. Fluent Bit supports output to Syslog, HTTP, Elasticsearch, Kafka, and Splunk destinations, so disruptions in log forwarding are detectable through the health of the centralized log collection infrastructure. For workloads running in vSphere Namespaces, the LogAgentConfiguration Custom Resource streams logs to a remote Syslog server once applied to the namespace; each log message includes namespace name, pod UID, pod name, container name, and ESX host name as metadata fields, allowing operations teams to correlate forwarding gaps with specific workloads or nodes.

The Node Problem Detector provides a SystemLogMonitor daemon that monitors system logs and reports problems to the API server as NodeConditions or Events, according to predefined rules covering log sources such as filelog, kmsg, and kernel logs. This surfaces node-level log source failures as cluster events that can be queried or routed through alert management infrastructure. In Kubernetes audit logging batch mode, if the rate of incoming events overflows the buffer, events are dropped without notification from the logging subsystem itself, which makes metric-based monitoring of `apiserver_audit_error_total` the primary signal for detecting silent audit pipeline failures. VM Operator logs record reconciliation events for VirtualMachineService resources in VKS clusters, providing additional log sources for troubleshooting provisioning and service failures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides event logging with configurable alarms that can alert administrators to operational failures across the disaster recovery environment. Each event type has a corresponding alarm that can be configured to send email notifications, SNMP traps, or execute a script when triggered, giving administrators multiple channels to reach appropriate personnel when problems occur. For email notifications, mail settings must be configured in the vCenter Settings menu before alarm-triggered notifications function. PNR also requires an administrator email address to be configured during appliance registration with vCenter.

The PNR Server logging level can be configured to one of five levels: error, warning, info, verbose, or trivia, by modifying the log configuration. Error and warning levels capture conditions that indicate problems in the environment. When recovery plan execution encounters failures, PNR logs diagnostic details in the recovery site server logs, including plan identifiers, plan names, and detailed error messages with fault codes.

The PNR Appliance can forward log files to a remote syslog server for centralized log analysis and monitoring. vSphere Replication maintains separate audit logs at /opt/vmware/support/logs/hms/hms-audit.log for tracking security-relevant events, including authorization errors with timestamps and component information.

The Clean Room Orchestrator provides an additional monitoring layer for ransomware recovery workflows. Administrators can configure email alerts for critical events in the clean room environment. The orchestrator can forward events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud; event forwarding to VCF Log Management requires version 9.0 or above.

VCF Operations provides an alert system that notifies administrators when specific symptoms of monitored objects are detected, including health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. In environments with more than one vCenter, PNR displays all events from PNR servers registered as extensions.

PNR logs when a protected consistency group has errors or warnings, recording this as an Error-level event. These mechanisms surface operational failures and log-related disruptions as part of broader recovery environment monitoring. Dedicated log pipeline health monitoring and log processing failure detection are provided by the underlying VCF platform monitoring stack.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports log processing failure detection and personnel notification through its audit record failure logging capability and event alerting framework.

Avi Controller and Avi Service Engine explicitly record audit record failures for three log destinations: Events, Syslog, and Splunk. The failure categories captured include initiation and termination of trusted channel connections, failure of trusted channel functions, unsuccessful certificate validation attempts, client authentication failures, SSH session establishment failures, and identification of the initiators and targets of failed trusted channel establishment attempts. This capability is configured in the Application Monitoring section of the Avi documentation under Audit Logging > Audit Record Failures.

When log processing failures or system events occur, Avi Controller can route notifications to four destinations: the local Controller UI (displayed as colored bell icons), email, syslog, and SNMP trap servers. These notification channels are configured under Operations > Notifications in the Controller UI. Avi supports both SNMPv2c and SNMPv3 protocols for SNMP trap notifications, and SNMP notification channels can be configured with TLS encryption and strict certificate verification for secure transport. The Avi Controller cluster leader issues SNMP trap notifications and supports multiple SNMP servers, providing redundancy for alert delivery. The Syslog-Audit-Persistence alert action template is available for configuring alert actions that stream events to external syslog servers, which can feed into a centralized log management or SIEM platform.

Auditors should be aware of two scoping boundaries when evaluating this control. First, Avi debug logs and Event Logs are not transmitted to remote syslog servers through the OS-level syslog configuration; Event Logs require the Syslog notification configuration within the Controller UI or API-based export. Second, configuring Syslog notifications in Avi Controller pushes alerts to syslog servers but does not export virtual service logs; virtual service logs must be pulled from an external logging system through the API or scripted to be pushed from the Controller to a remote destination.

Auditors verifying this control should confirm that Alert Actions are configured in the Operations section of the Avi Controller UI, that notification destinations (email addresses, SNMP trap server addresses, or syslog server targets) are defined, and that organizational runbooks or response procedures define who receives these alerts and what remediation steps follow.

Not applicable for this control: VMware vDefend, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 4.3

> Where technically feasible, retain applicable event logs identified in Part 4.1 for at least the last 90 consecutive calendar days except under CIP Exceptional Circumstances.

SCF Controls: MON-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable event log retention across its component products, allowing organizations to align retention periods with their records retention requirements and support after-the-fact investigations of security incidents.

VCF Automation offers direct control over log history retention through its Activity Log configuration. Administrators can specify the number of days of log history to keep before automatic deletion, or set the value to zero to retain logs indefinitely. This flexibility allows organizations to match retention to their specific statutory, regulatory, or contractual obligations without external tooling.

VCF Log Management is the centralized log aggregation platform and provides configurable data retention periods that govern how long collected audit events remain available for query and analysis. Within VCF Log Management, administrators define log partitions that segregate collected logs by criteria such as source or category, each with its own retention period measured in days, so that security audit records can be retained longer than routine operational logs to match differing records-retention obligations. VCF Log Management removes logs from disk once a partition's retention period is met, and partitions can be archived to external NFS or S3 storage for retention beyond the active log store. VCF Operations surfaces audit events with selectable time ranges of 1, 6, 12, 24, and 48 hours for immediate review, with longer-term availability determined by the retention policy configured in the VCF Log Management instance. When the retention period is set to zero, logs are kept indefinitely and are not automatically removed based on time. VCF Operations for Networks adds its own retention controls, with entity metrics retention configurable from one month to six months. Administrators should back up log files before reducing any retention period, as the change deletes all data older than the newly specified window. Audit logs in VCF Operations for Networks capture administrative actions carried out in the system, including regular CRUD operations and login/logout alerts.

At the host layer, VMware ESX (ESX) provides log file rotation controls that govern how many log files the system maintains locally. When the configured limit is reached, the oldest file is removed. The local syslog directory location is configurable through the Syslog.global.logDir parameter, allowing administrators to point log storage to a volume sized for their retention needs. ESX audit records can be directed to a remote syslog host separately from general syslog messages by enabling the Syslog.global.auditRecord.remote parameter, which works in conjunction with Syslog.global.logHost to specify the destination. ESX and vCenter services maintain separate log files, each with their own rotation and retention behavior.

The Consumption layer of VCF, encompassing VMware Kubernetes Service (VKS) clusters, vSphere Supervisor, and vSphere Namespaces, produces structured audit and operational log data and includes built-in forwarding infrastructure so that organizational retention policies can be applied at external receivers. The Kubernetes API server (kube-apiserver) running on VKS clusters generates audit events conforming to the audit.k8s.io API group. Each event captures the requesting user, timestamp, resource accessed, and the audit level at which it was generated. The --audit-log-path flag directs these events to a file on the node, and the --audit-log-maxage parameter defines the maximum number of days to retain old audit log files based on the timestamp encoded in the filename, providing a direct file-level retention control that can be aligned to statutory or regulatory requirements. Audit policy rules govern which events are recorded at four levels: None (not recorded), Metadata, Request, or RequestResponse. Organizations should note that standard Kubernetes cluster Event objects in the core API group have limited in-cluster retention and should not be relied upon as a compliance log source; the kube-apiserver audit logging subsystem, written to files or forwarded via webhook, is the appropriate mechanism for compliance-relevant event data.

VKS clusters include Fluent Bit logging agents deployed in the vmware-system-logging namespace. These agents collect container logs, Linux daemon logs, Linux authentication logs, and Kubernetes API server audit logs, tagging each category

separately to support targeted routing and retention policies at the receiving system. Fluent Bit can forward logs to Syslog servers, HTTP endpoints, Elasticsearch, Kafka, Splunk, and VCF Log Management; a sample configuration for forwarding to VCF Log Management is included in the Fluent Bit standard package available on VKS clusters. For workloads running as vSphere Pods in a vSphere Namespace, applying a LogAgentConfiguration Custom Resource to the namespace directs syslog messages to a remote Syslog server; each message carries metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, supporting forensic traceability after a security incident. Kubernetes handles log rotation for applications writing to standard output to prevent uncontrolled growth on local node storage. VKS clusters generate additional component logs from CAPI, CAPV, VM Operator, and the VKS Controller Manager, which are accessible via kubectl and gathered in support bundles along with containerd journal logs for incident investigation.

The vSphere Supervisor control plane collects its own kube-apiserver audit logs through Fluent Bit, tagging them with the audit.apiserver.* prefix and reading from /var/log/vmware/audit/kube-apiserver.log on the Supervisor nodes. The Supervisor can also be configured to preserve the source IP addresses of authentication and Kubernetes API Server requests, making them available for inspection in audit logs and supporting forensic reconstruction of access events.

For long-term and centralized retention, VCF supports forwarding event logs from all major components to remote syslog infrastructure. ESX hosts can be configured to send syslog messages to a remote log server using the esxcli system syslog config set command. VMware vCenter can also stream events to a remote syslog server by enabling the vpxd.event.syslog.enabled parameter in the vCenter Management Interface. The vCenter local database is not intended for long-term archival retention: events are deleted at the end of the configured retention period, and extending retention beyond the default requires corresponding database capacity increases. NSX sends audit logs directly to the configured remote syslog server, with NSX Manager audit logging enabled by default and recording security policy changes with request identifiers and timestamps for traceability. VCF Operations integrates its audit log with syslog and supports configuring a syslog collector to gather all audit records. VCF Log Management can also pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. Log collection from vCenter can be activated directly from VCF Operations when vCenter is integrated. This centralized collection architecture enables organizations to apply retention policies at the aggregation layer that match their compliance requirements, independent of local component retention limits.

The audit events captured across VCF components include administrative actions such as login, logout, object creation and deletion, configuration modifications, capability checks, and security policy changes. NSX audit logs include structured fields for audit flag, component, log level, request ID, and subcomponent, providing the detail needed for forensic analysis. NSX supports logging and auditing capabilities that can be integrated with external logging and monitoring solutions to monitor for security events and anomalies. VCF Operations audit events are designed to facilitate security and compliance audits and provide the detail needed for security forensics investigations.

Defining the retention period required by statute, regulation, contract, and internal policy is an organizational data-governance decision.

VMware vDefend (Contributes)

VMware vDefend retains security event data generated by its own features across defined periods. Network Detection and Response (NDR) collects and retains detection events and campaign data for 12 months. For active subscriptions, IDS events, network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year, and for 90 days following subscription expiration. Security Services Platform (SSP) stores intrusion events and flow data for 30 days each. The IDS/IPS monitoring view retains detailed logs for the last 14 days. SSP provides the ssp_flow_storage.avg_flow_storage_ratio metric, which gives operators visibility into the ratio of current retention days to predicted full days for flow storage.

For forwarding events to external systems, vDefend Distributed IDS/IPS can be configured to send IDS events to external syslog consumers; this setting is disabled by default and must be explicitly enabled. Syslog messages from vDefend appliances conform to RFC 5424, and messages from ESX hosts conform to RFC 3164. SSP can be configured to collect and

transmit log messages to a remote syslog server. Identity Firewall Event Log Sources can be integrated with VCF Log Management for centralized logging and monitoring.

VMware vDefend is not an organization-wide log retention or SIEM solution. Meeting statutory, regulatory, and contractual retention periods requires organizations to forward vDefend events to a dedicated log management or SIEM platform, where custom retention policies can be applied.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates and preserves multiple categories of operational and security-specific logs that support after-the-fact investigation of recovery-related events.

PNR records operational information into log files that exclude sensitive data such as private keys and passwords. vSphere Replication maintains dedicated security audit logs at `/opt/vmware/support/logs/hms/hms-audit.log`` and broker logs at `/opt/vmware/support/logs/hbr`` on the appliance and at `/var/run/log`` on ESX hosts. Security-relevant events captured in these logs include authorization error messages, certificate verification failures, and session activity such as logout events with timestamps, user identity, source IP address, and operation IDs.

PNR records structured event data across its components, with each event carrying a corresponding alarm that PNR can trigger for health tracking and issue resolution. Protection group activity is logged as typed events: consistency group additions, datastore membership changes, and protection group errors are recorded as Info- or Error-level events, respectively. vSphere Replication generates typed audit events for replication lifecycle transitions, including when virtual machines and hosts are configured or unconfigured for replication. Recovery operations are preserved in a per-plan history log; reprotect operations are included in this log and can be exported as a report, providing a record for post-recovery verification.

The Clean Room Orchestrator records events with a structured schema that includes timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Snapshot task events are captured upon completion and are accessible through the Snapshot log interface in the event details panel.

For forwarding and long-term retention, the PNR Appliance natively supports forwarding log files to remote syslog servers for log analysis and centralized monitoring. PNR supports forwarding events to VCF Log Management (version 9.0 and above), enabling log data to flow into centralized log management infrastructure. PNR also integrates with Microsoft Azure Log Analytics Workspace for custom log collection using Data Collection Rules (DCR) and Data Collection Endpoints (DCE), providing a cloud-native retention path.

Per-component logging levels can be adjusted through the advanced configuration interface. The `logManager.Persistence`` setting controls the logging verbosity for persistence-related events, with a default value of verbose, allowing administrators to tune log volume to match available storage and retention requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains an event log system that records system activities, configuration changes, and operational events, with an audit trail that tracks who made configuration changes and when. The Avi Controller preserves a permanent log of the underlying events and metrics that triggered alerts, retaining those records beyond the alert expiry period.

The 9.1 documentation specifies that events raised by Avi Load Balancer components must persist in a secure manner for a minimum of 90 days for audit compliance. The retention policy is configurable: administrators can adjust the periodic interval and the threshold that triggers policy enforcement based on system and infrastructure requirements. The Avi Controller analytics API supports querying event logs for periods of up to one year, and the documentation recommends reviewing event logs over a one-year window to maintain audit trails of configuration changes.

For compliance-grade long-term retention beyond the on-appliance minimum, Avi provides the Syslog-Audit-Persistence feature, configured through the Controller's Alert Actions settings. This feature streams audit compliance events to external syslog servers. The Avi Controller and Service Engine also log audit records for trusted channel initiation, termination, and

failures to Events, Syslog, and Splunk destinations. The documentation recommends streaming all logs directly to an external server such as Splunk for assured retention; Avi's Controller Settings allow specification of syslog server destination details.

There are retention constraints that organizations should account for when designing their log retention architecture. Configuring syslog notifications in the Avi Controller forwards alert events to syslog servers but does not directly export virtual service logs; those must be pulled from an external logging system through the API or scripted to be pushed from the Controller to a remote destination. In the absence of active queries, application logs do not leave the Service Engines that collected them. For retention periods beyond the built-in minimum, administrators must configure Syslog-Audit-Persistence or an equivalent export mechanism to an external destination and maintain that destination's storage capacity and retention settings independently.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 4.4

> Review a summarization or sampling of logged events as determined by the Responsible Entity at intervals no greater than 15 calendar days to identify undetected Cyber Security Incidents.

SCF Controls: MON-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides log analysis, event triage, and incident tracking capabilities through VCF Operations and VCF Log Management that give administrators the technical foundation to build event log review processes integrated with organizational incident response workflows.

VCF Log Management is the centralized log aggregation and analysis platform. It can be configured to pull tasks, events, and alerts from VMware vCenter instances and receive syslog feeds from VMware ESX hosts through Log Collections configuration. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be configured to collect all audit logs from across the infrastructure. Once logs are centralized, the Analyze page provides a Logs tab where administrators can search and filter log events and create queries to extract events based on timestamp, text, source, and fields within log entries. Each log event includes structured data: timestamp, thread identifier, source IP address, log level, component class name, and event message content.

For trend analysis and anomaly detection, VCF Operations provides the Event Trends tab, where administrators can construct and run queries using search text and filters, then compare query results against the same time period immediately prior. This comparison capability supports triage by highlighting deviations from normal patterns. The Log Analysis Widget allows further customization of the visual representation of events through aggregation queries, enabling teams to build dashboards tailored to their review processes.

VCF Operations supports log-based alerting that can trigger automated triage workflows. Alert definitions support log-based symptoms configured through the Symptom Definitions card in Infrastructure Operations, under Configurations. Log-based conditions can also be created as alternatives to symptom-based approaches, giving flexibility in how events are flagged for review. Event auditing provides visibility into platform interaction changes across the VCF infrastructure and surfaces insights into suspicious access events and policy violations.

The platform includes incident tracking capabilities that align with structured triage and response processes. VCF Operations incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. During incident investigation, administrators can flag specific metrics and mark them as root cause, supporting structured triage. The Troubleshooting Incident Page displays incident information including status, root cause metrics, closing remarks, and creation timestamps, providing an audit trail for each investigated event. Diagnostic Findings consolidates a list of log-based and property-based findings with specific resolution rules, integrating VCF Log Management to provide depth and flexibility in troubleshooting. It displays affected objects, recommendations for resolution, and links to knowledge base articles for each finding.

At the infrastructure layer, the vCenter events and alarms framework provides real-time event monitoring. vCenter includes preconfigured alarms to monitor the operations of vSphere inventory objects, and administrators can create custom alarms for specific event conditions. vCenter syslog forwarding can be configured through the vCenter Management API to forward syslog messages to remote servers; event streaming to a remote syslog server is enabled by setting the ``vpxd.event.syslog.enabled`` option in the vCenter Management Interface, and each forwarded event record includes the `eventId`, `partInfo`, `createdTime`, `eventType`, `severity`, `user`, `target`, `chainId`, and `description` fields. ESX hosts can also be configured to send syslog messages to remote log servers using the `esxcli` command line, and audit records specifically can be directed to a remote host by enabling the ``Syslog.global.auditRecord.remote`` parameter, which forwards audit records to the host specified by ``Syslog.global.logHost``.

Across the VCF stack, audit logs are generated for security-relevant events including logon, logoff, and resource access. NSX logs all auditable events related to security and compliance requirements, with each audit log entry containing the timestamp,

source, result, and a description of the event. NSX syslog and audit log messages include timestamps generated by an NTP server when configured. Auditable events required by global compliance frameworks are logged by the platform.

VCF Automation creates audit logs when reportable actions are performed, such as deploying a blueprint or catalog item, performing Day 2 actions on resources or deployments, or creating, deleting, or updating property groups. Each audit log entry can contain the timestamp, message, user name, project name, and trace ID value. Each reportable action type creates an initial log entry with a Submitted status, followed by an additional entry showing Successful, Failed, or Canceled status. VCF Operations audit logging can filter data by User ID, User Name, Auth Source, Session, Client IP, Category, and Message, with date range filtering spanning hours to years.

Log Assist can generate log bundles and automatically attach property-based diagnostic findings to accelerate resolution of support cases, bridging the gap between internal triage and vendor escalation. vSphere Supervisor logs can be forwarded to external syslog servers through Fluent Bit configuration using RFC 5424 syslog format.

Organizations deploying VCF should establish formal log review schedules, define triage criteria that map to their incident response plans, and configure VCF Operations alerting rules to surface events that require immediate attention. The platform provides the analysis, alerting, and tracking tools, but the review cadence, triage decision trees, escalation procedures, and integration with external incident response systems such as SIEM platforms and SOC workflows are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support event log analysis and triage at the application delivery layer, contributing to the organization's broader incident response capability.

Avi Event Logs provide detailed records of system activities, configuration changes, and operational events, including an audit trail that tracks who made configuration changes and when. Administrators can retrieve event data using the `/api/analytics/logs`` analytics API endpoint, which supports filtering by event type, duration, page size, and end time to query logs across specific time periods up to one year. When an event log query returns more than 10,000 entries, Avi documentation recommends querying shorter time periods via the analytics API to avoid memory-intensive operations. Event logs are not forwarded to remote syslog servers through OS-level syslog configuration; they require the Syslog-Audit-Persistence alert action template for external export. Similarly, virtual service logs are not pushed to syslog by default and must be pulled via the API or scripted for forwarding to a remote log aggregation system.

Avi supports Syslog-Audit-Persistence, a built-in alert action template that streams audit events to external syslog servers for audit compliance. The Controller's alert feature processes system events and metrics against user-defined rules and generates alert actions such as syslog messages, email notifications, or SNMP traps. The Avi Controller and Avi Service Engine log audit record failures to Events, Syslog, and Splunk, including trusted channel initiation and termination failures, certificate validation failures, client authentication failures, and SSH session establishment failures. The Avi License Hub can also be configured to transmit log messages to a remote syslog server.

The Avi Controller supports integration with VCF Log Management for centralized event logging and monitoring, enabling Fluent Bit and JSON parsing for log aggregation and downstream analysis. The Controller also logs denial-of-service attack events with structured event details including event ID, attack count, threshold values, and alert level, supporting triage of volumetric threats at the load balancer layer.

At the application layer, VMware Avi Web Application Firewall (WAF) App Log Analytics captures events when Application Rules are triggered, containing information about the type of attack detected, including matched variable names and content for rules such as XSS detection. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, and administrators are directed to review application logs and analytics to distinguish genuine threats from false positives before creating WAF exceptions.

Integrating these capabilities with the organization's established incident response processes requires organizational IR procedures, SIEM or log aggregation configuration, and defined triage playbooks that Avi cannot itself define or operate.

Organizations should configure Syslog-Audit-Persistence or VCF Log Management integration, define alert thresholds and notification routing, and map WAF and audit events into IR workflow tooling to fulfill this control.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 5.1

> Have a method(s) to enforce authentication of interactive user access, where technically feasible.

SCF Controls: IAC-01, IAC-01.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS

supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA` parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events

generate audit log entries, for example the AutoprotectEnabledRpEvent entry that indicates Automatic Protection has been activated for a replication provider.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions,

TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control CIP-007-6 5.2

> Identify and inventory all known enabled default or other generic account types, either by system, by groups of systems, by location, or by system type(s).

SCF Controls: IAC-01.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides user and service account management capabilities across its component products, giving administrators the interfaces, APIs, and identity infrastructure needed to enumerate, create, modify, and remove accounts. While VCF does not automatically generate or maintain a consolidated account inventory, it supplies the building blocks an organization can use to construct and maintain one.

VCF SSO is the centralized identity store for the platform. When federated to an external identity provider, user and group information is synchronized from the organization's directory. The VCF Identity Broker syncs groups and users from configured Active Directory domains, and VCF SSO queries Active Directory to locate groups during identity provider synchronization. This gives administrators a consolidated view of who has access to the platform. After configuring a new identity provider, administrators may need to assign service roles in each component to the newly provisioned users and groups.

In VCF Operations, user accounts can be created, edited, exported, deleted, and imported through the Access Control interface. Each account carries structured metadata including First Name, Last Name, Email Address, and a Description field that identifies the type of user and summarizes their access privileges. VCF Operations also supports importing user accounts from an external authorization source, allowing administrators to synchronize account records with a central identity provider. The ability to export user account data provides a mechanism for periodically extracting an account list for review or reconciliation.

VCF Automation manages service accounts through the Infrastructure > Access Control > Service Accounts interface. System administrators with the View Service Accounts and Manage Service Accounts privileges can create service accounts from the user interface or through the REST API. Administrators can also manage service account attributes, revoke previously granted access, and delete service accounts. Service accounts are distinguished from user accounts by their API-only access model, with no access to a user interface, which simplifies identification during account inventory reviews. A System Administrator can create other system administrator and user accounts in the provider organization, establishing a controlled provisioning chain.

VCF Automation provides a Limited Service Accounts View right that can be granted to certain roles to restrict the service account information that users can see. This supports the principle of least privilege when multiple teams share a VCF Automation environment, limiting visibility of service account details to those who need it.

Service accounts authenticate using API access tokens, which rotate after each use in accordance with RFC 6749 section 6. Access tokens normally last one hour and are based on a refresh token that normally lasts 90 days but can be revoked earlier and optionally rotated for each access. This automatic rotation reduces the risk of token reuse if credentials are intercepted.

VCF Automation supports bulk remapping of users between identity providers. Administrators can export users to a CSV file, modify the providerType field to SAML, LDAP, or OAUTH values, and re-import the file. Individual users can also be remapped through the API. This capability is relevant to account inventory maintenance during identity provider migrations, as it preserves user associations without requiring manual re-creation.

VMware vCenter provides the UserDirectory service, a lookup mechanism that returns user-account information to the AuthorizationManager or to client applications. The AuthorizationManager associates permissions with managed entities in the inventory and can be used to enumerate which accounts hold permissions on specific objects. vCenter also provides the localaccounts.user.list appliance shell command, which enumerates local user accounts with their username, status, role, password status, full name, and email, giving administrators a direct enumeration tool for local accounts independent of the directory service.

NSX Manager exposes an API endpoint at `/api/v1/node/users` with a filter parameter that retrieves the list of service accounts, including the VCF Operations service account, allowing programmatic enumeration of network infrastructure accounts.

VMware ESX hosts maintain an Exception Users list, configured through the DCUI. Access advanced system setting, that identifies service accounts permitted to retain direct host access when lockdown mode is enabled. These accounts, typically backup agents and third-party solution service accounts, are an enumerable record of accounts with privileged host-level access that administrators can review as part of an account inventory.

Within the VMware Kubernetes Service (VKS) and vSphere Supervisor layer of VCF, service accounts exist as namespaced ServiceAccount API objects. The API server automatically creates a default service account in each namespace, and administrators can create additional accounts with `kubectl create serviceaccount`. Because service accounts are Kubernetes API objects, the complete cluster-wide inventory is directly enumerable with `kubectl get serviceaccounts --all-namespaces`. Each service account authenticates to the API server under the username `system:serviceaccount:<namespace>:<name>` and belongs to both the `system:serviceaccounts` and `system:serviceaccounts:<namespace>` groups, allowing administrators to identify service account activity in audit logs by filtering on these standardized prefixes. Service account tokens are stored in associated Secret objects of type `kubernetes.io/service-account-token`. The `LegacyServiceAccountTokenCleanup` feature gate enables automatic cleanup of unused Secret-based tokens after a configurable retention period (one year by default), which helps remove stale credentials from the inventory over time. IAM role trust policies for VKS ClusterClass configurations should be scoped to specific service accounts and namespaces to enforce least privilege boundaries within the cluster.

Human user accounts are not stored as objects in the Kubernetes API; the API server authenticates users through VCF SSO, OIDC tokens, or X.509 certificates but treats user identity as opaque data. The authoritative inventory of authorized human users within VKS clusters is constructed by querying RoleBinding and ClusterRoleBinding objects, which associate usernames and groups with roles, combined with the identity provider's active user directory. Kubernetes RBAC requires that user account creation prevent reuse of deleted usernames so that new accounts with identical names do not inadvertently inherit prior permissions. Separating ServiceAccount creation from human user onboarding processes supports differentiated audit strategies for each account type, since the audit trail for API-driven service account activity differs structurally from that of human user sessions.

For Windows workloads running on VKS clusters, vSphere Supervisor supports Group Managed Service Accounts (gMSA) through the Windows gMSA Webhook. gMSA identities are created in Active Directory using the `New-ADServiceAccount` cmdlet, specifying service principal names and authorized security groups, which extends the service account inventory to AD-managed identities used by Windows containerized workloads. The Argo CD Supervisor Service supports declaring named local accounts through the `spec.localAccounts` manifest field, with RBAC policy using email address as the user identifier, providing a structured and enumerable list of local accounts within that service.

To satisfy this control fully, the organization must establish a process for periodically collecting account data from each VCF component, including VCF SSO, VCF Operations, VCF Automation, VMware vCenter, NSX, VMware ESX, and VKS clusters, consolidating it into a single inventory, and reviewing it for accuracy. VCF and its Kubernetes consumption layer provide the export capabilities, APIs, identity synchronization, and management interfaces to support this process, but the organizational discipline of maintaining and reviewing an authoritative account inventory is outside the platform's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to maintaining a current list of authorized users and service accounts through its identity management and user administration capabilities.

DSM supports two categories of user accounts: local users, stored in DSM's own database, and LDAPS users, authenticated through a configured LDAPS server. The first account provisioned is the DSM administrator, created during deployment of the DSM Provider Appliance; this account is mandatory and cannot be deleted. Local users are identified by a unique email address, which is also the login username. Both local and LDAPS users are managed independently within DSM, and administrators can use one or both identity sources within a single installation. When both identity sources are active, user login precedence applies and must be accounted for when creating or importing accounts.

The Permissions view in the DSM dashboard provides a centralized interface for creating, monitoring, and managing configured users, including a Directory Service Groups interface for LDAPS-sourced accounts. Administrators can use this view to review the current set of authorized local users, modify role assignments and namespace access, and remove accounts that are no longer needed. In environments upgraded from versions earlier than 9.0.2, a user must not own any active DSM objects before the account can be deleted. LDAPS-sourced accounts, once imported, appear in DSM but cannot be edited or deleted from within DSM itself; lifecycle management for those accounts is handled by the external directory service.

DSM provisions several categories of service accounts as part of its operation. A VMware vCenter administrator user account must exist and be granted appropriate privileges for DSM to provision and manage resources; the vCenter-bound service account is used for ongoing operations. The DSM user account used for Consumption Operator authentication must be a DSM Admin user. DSM generates service account rotation logs that can be checked to verify service account management activities.

For provisioned database instances, each database carries its own admin account. DSM adds SQL Server as a supported database type, which requires a service account for each SQL Server cluster; that account must be a standard Active Directory user account and a member of the Domain Users group. SQL Server databases use contained database users, with identity information stored within the database so that permissions persist after failover. A privileged account can be configured in DSM to automate the management of service principal names (SPNs) and DNS records for SQL Server. DSM maps the dbo user to administrator-controlled identities for SQL Server database access. MySQL read replicas synchronize admin credentials and database users from the source instance when user synchronization is enabled. At the database level, DSM can automatically generate database engine admin credentials during database creation, or accept administrator-specified credentials. PostgreSQL databases can be configured with additional custom users through the `pg_hba.conf` mechanism.

Maintaining the currency of the user list requires organizational process beyond what DSM provides technically. LDAPS user lifecycle is governed by the external directory service, not DSM. Organizations must establish processes to periodically review DSM's Permissions view, reconcile active accounts against current staff and role requirements, and monitor the status of the vCenter service account, which can cause authentication failures and operational disruptions if allowed to expire.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own user account database independently from VCF identity infrastructure, which means Avi user and service accounts must be managed and inventoried as a distinct population within the organization's access governance process.

User accounts in Avi are categorized as local users or remote users. Local users are defined directly in the Avi Controller's account store; remote users authenticate through external AAA servers (LDAP, TACACS+, SAML, or OIDC/OAuth) and have their user records created or updated in the Avi Controller on each successful login. The Controller evaluates authorization mapping rules on every login to assign tenant and role pairs to the user record, accessible through Administration > Accounts > Users. The Avi Controller holds records for all accounts that have authenticated, whether local or remote, and each record carries a tenant association and a role assignment. The admin user is the standard administrative account, maintained locally even when the system is configured for remote authentication, and is responsible for user creation, authorization, and tenant management. Administrators can remove accounts through the Controller web interface or via the DELETE operation in the REST API; deletion removes an account entirely from the system.

Avi introduces a License Hub component with its own local account population: an Admin account with the `enterprise_admin` role for full access to manage the Software Supply Platform, and an Audit account with the `auditor` role for full access to APIs and services for system auditing. These License Hub accounts are system-defined and remain available even if external identity providers such as LDAP are disconnected. Organizations must include License Hub accounts in their authorized-account inventory alongside Avi Controller accounts.

In Avi for VCF deployments, the NSX Manager Admin API provides a GET endpoint at `/api/v1/node/users` with a service account filter parameter to help identify service account user IDs. When Avi is deployed through VCF Operations in VCF environments, only the Default User Account Profile is available after upgrade and all users are associated with it. Users must

be added to the organization before Service Engine Groups can be created, which provides a workflow checkpoint for account provisioning.

For Avi Kubernetes Operator (AKO) deployments, Avi Controller user accounts are configured with tenant and role assignments through the Administration > Accounts > Users interface, scoped per Kubernetes cluster or namespace as configured.

Because Avi's account store is independent from VCF SSO, organizations must treat Avi as a separate identity population in their broader inventory governance. The inventory must cover Avi Controller local accounts, remote-authenticated user records, License Hub Admin and Audit accounts, and service accounts associated with cloud integrations and VCF deployment.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 5.3

> Identify individuals who have authorized access to shared accounts.

SCF Controls: IAC-15, IAC-15.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 5.4

> Change known default passwords, per Cyber Asset capability

SCF Controls: IAC-10.8

Aggregate Coverage: Meets

VCF (Meets)

VCF requires administrators to establish unique credentials at every stage of platform deployment rather than shipping with pre-set default passwords. The deployment architecture enforces this by making credential configuration a mandatory step that must be completed before the platform becomes operational.

During initial installation, the VCF Installer Deployment Wizard requires the administrator to specify passwords for all components or to auto-generate them. Each appliance, including VCF Operations, VMware vCenter, NSX, VMware ESX hosts, and VCF Automation, requires its own password configuration at deployment time, and the deployment process will not proceed without it. The wizard allows administrators to view generated passwords at the end of the deployment process, so auto-generated credentials are recorded and known from the start. Authentication sources for VCF Operations are also defined during initial server setup, requiring the deployer to make deliberate authentication configuration decisions before the system enters production. When organizations are created within VCF Automation, organization administrators use credentials that are configured during the organization creation process itself, so every administrative account begins with purposefully chosen authenticators rather than vendor-supplied defaults.

After deployment, VCF Operations provides centralized password management for all VCF components. Administrators can rotate passwords on demand through the Password Management page or schedule automatic rotation on a recurring basis. During rotation, VCF Operations generates a randomized password that conforms to the component's password policy and re-establishes the relevant component integrations automatically. The VCF Operations API also supports scheduling rotation at custom intervals for automation workflows. VCF Operations also provides credential rotation for system-managed endpoint credentials through a Rotate function, and administrators are required to rotate these credentials for individual endpoints on a regular schedule.

For programmatic access, service accounts in VCF Automation authenticate using API access tokens that rotate after each use, as specified by RFC 6749 section 6. Access tokens normally last one hour and are based on a refresh token that normally lasts 90 days but can be revoked earlier. When rotation is activated on a service account, each refresh token grant call returns a new access token along with a new refresh token, and the original refresh token is invalidated. This prevents token reuse and limits the window of exposure for any single credential.

VCF SSO allows configuration changes to the identity provider after initial setup, giving administrators the ability to migrate from locally defined credentials to enterprise identity sources as the environment matures. When the identity broker is changed for VCF Operations or VCF Automation, the previous authentication source is deactivated and existing provisioned users and groups can no longer be used. Roles must then be reassigned to users and groups from the new authentication source, which enforces a clean transition rather than leaving stale default credentials in place. Administrators should document substantial modifications to the initial identity source configuration so that the VCF SSO configuration can be reverted to a recognized and stable state if necessary.

Within the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, the same principle of replacing default credentials at installation time extends to components deployed on Kubernetes workload clusters. Harbor Registry, available as a standard package or as a Supervisor service on VKS clusters, ships with a known default administrative password and requires administrators to set the harborAdminPassword to a strong, unique value during installation; the documented default is Harbor12345, and the installation documentation requires this to be changed before the registry enters production. Harbor provides a generate-passwords.sh script bundled with the Harbor package image that auto-generates all mandatory passwords and secrets, and the documentation recommends using this script rather than manually specifying values. The Harbor inter-component secrets, specifically core.secret, jobservice.secret, and registry.secret, must each be changed from their default values during installation; changing core.secret after deployment breaks inter-component authentication and logs

out all active users, creating a strong operational incentive to configure these values correctly at install time rather than relying on a post-deployment correction.

At the Kubernetes API server level, anonymous authentication is enabled by default and must be explicitly configured or restricted. The `AuthenticationConfiguration` file provides control over which endpoints support anonymous access, allowing administrators to disable anonymous authentication or limit it to specific paths; if the `anonymous` field is set in `AuthenticationConfiguration`, the command-line `anonymous-auth` flag cannot be used, so all anonymous access control flows through the configuration file. The Kubernetes hardening guidance recommends enabling as few authentication mechanisms as possible to reduce the surface area of default credential exposure. Similarly, the Kubelet's authorization mode defaults to `AlwaysAllow`, a configuration that organizations deploying VKS clusters are expected to change to `Webhook` mode during cluster setup; operational runbooks should confirm this change before clusters enter production. Infrastructure credentials within VKS clusters benefit from short certificate lifetimes with automated rotation to reduce the window of exposure for any single credential.

For developer access to VKS workload clusters, DevOps users authenticate through VCF SSO using their identity provider credentials, and custom `ClusterClass` configurations can direct developers to authenticate through existing corporate identity systems. This integration shifts user credential management to the external identity provider, reducing the scope of locally managed default credentials on the Kubernetes platform to system service accounts and component secrets that are covered by the installation-time requirements above.

VMware Private AI Services (PAIS) includes several deployment-time mechanisms that require credential setup or prompt credential changes as part of system installation.

When Deep Learning VMs are deployed through VCF Automation self-service catalog items, PAIS requires a password to be specified for the default vmware user account via OVF properties at deployment time. Deep Learning VMs also accept a `public-keys` OVF property that populates the default user's `SSH authorized_keys` with provided SSH public key values, supporting key-based access without leaving default keys in place. Deep Learning VM workload deployment fails when invalid authentication credentials are provided for downloading DL workloads, so placeholder or blank credentials cannot persist after first deployment.

PAIS organization-level authentication has no operational default. PAIS authentication is configured with OIDC using an issuer URL, client ID `pais-authentication-id`, and scopes including `openid`, `groups`, and `offline_access`. The `jwtauthenticator` configuration requires specification of an issuer URL, audience ID, username claim field set to `preferred_username`, groups claim field set to `groups`, and TLS certificate authority data. PAIS activation requires coordination with the OIDC provider administrator to set up identity and access management, so authentication is non-functional until these values are configured. OIDC authentication also supports configuration of Extra Audiences for additional OAuth 2.0 clients when required by the OIDC provider. The `vcf cluster register-vcfa-jwt-authenticator` command enables JWT authentication for VKS cluster login to PAIS.

Registry credential configuration is required throughout the PAIS setup workflow. The `oras login` command authenticates to a private Harbor registry using username and password credentials for subsequent image operations. PAIS air-gapped deployments require the location of a self-hosted registry to be provided, and login credentials must be supplied if the registry requires authentication. All passwords entered in the PAIS quickstart, including the private container registry password and proxy password, are saved as secrets in VCF Automation rather than left in plain text. For Model Runtime image pulls, a robot account must be configured in the Harbor registry, and model endpoints deployed via `kubectl` can specify an optional `pullSecrets` image pull secret for OCI registry authentication.

PAIS observability and tooling integrations use bearer-token credentials configured at setup time. PAIS LLM Traces authentication to the OpenTelemetry collector is configured through a Kubernetes Secret containing authorization headers, including a Bearer token and custom headers. Authentication to VCF Automation using the VCF Consumption CLI requires generation of an API token for the user's account in their VCF Automation organization. Knowledge Base data source authentication for Confluence uses either a user name and password or a personal access token, configured according to the Confluence administrator's settings. Remote MCP servers connected to PAIS can optionally use static authentication tokens.

One default that requires explicit organizational action: PAIS Prometheus TLS client authentication and certificate validation are turned off by default in the Grafana setup for PAIS metrics. Operators who require client-certificate authentication on the metrics path must turn this on as part of the deployment process.

The underlying identity framework, including identity federation, organizational user management, and single sign-on, is provided by VCF SSO and VCF Automation rather than by PAIS itself.

VMware vDefend (Contributes)

The Security Services Platform (SSP) component of VMware vDefend (vDefend) requires mandatory password configuration for its local accounts during initial deployment. When deploying the SSP Installer OVA, the administrator must set passwords for the admin account, which has full privileges to manage the platform, and the audit account, which has access to APIs and services for auditing the system. A password for the sysadmin appliance management account is also required before deployment completes. All passwords must conform to specified password rules at the time of configuration, making it structurally impossible to leave these accounts with default credentials after installation.

After initial deployment, the admin and audit account passwords can be changed by an authorized administrator through either the SSP Installer UI or the SSP Platform UI. The installer user password can also be changed via the command-line interface using the `-u` flag. Any password set or changed through these interfaces must continue to meet the platform's defined password criteria.

The SSP Installer also requires configuration of a System GRUB password during deployment, which controls access to the appliance-level password reset mechanism for local system users. If no GRUB password is explicitly configured during deployment, the SSP Installer applies a default value. Administrators should set a custom GRUB password during deployment to address this additional default authenticator.

vDefend's contribution is scoped to its own management plane. The organizational requirement to change default authenticators on all other systems and accounts across the environment is outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support changing default authenticators during account creation and system installation.

For local user accounts, DSM includes a `force_password_change` flag. When set to true, this flag requires the user to change their password at next login. Administrators configure this flag when creating or resetting local user accounts through the DSM administration interface (Administering Data Services Manager > Managing LDAP Users in Data Services Manager). The flag can also be set to false, which means enforcement depends on the administrative policies organizations establish at account creation time.

For MySQL databases, DSM creates a default database user with a defined privilege set, including a default username that can be changed before provisioning the database. When credentials are not manually specified during creation, DSM automatically generates a unique database engine administrator username and password, removing the reliance on a static default credential that would otherwise need to be changed post-deployment.

DSM adds SQL Server as a supported database engine. During SQL Server cluster creation, DSM automatically creates a cluster administrator login and can automatically generate the administrator username and password if they are not manually provided. SQL Server Authentication logins can be created for individual users, and Active Directory integration is available for Windows Authentication when a Privileged Account is configured.

PostgreSQL instances provisioned through DSM use `pg_hba.conf` host-based authentication configuration, which defines authentication methods for specific users and connection types. The default configuration uses `scram-sha-256` as the password authentication method, with `reject` and `cert` as alternatives. Custom HBA entries can be configured at provisioning time and adjusted in the Additional Settings step of the VCF Automation provisioning interface. Organizations should review and customize HBA configurations after deployment to match their access control requirements.

DSM supports LDAPS integration as an alternative to local user accounts, delegating authentication and authorization to the configured directory service. LDAP or Active Directory-based authentication can also be enabled for individual MySQL and PostgreSQL database instances, either during initial provisioning or during cloning from a snapshot. When directory service authentication is in use, password lifecycle management, including change-at-first-login requirements, is governed by the directory service's own policies.

Auditors should verify that the `force_password_change` flag is used during initial local account setup, that MySQL default database usernames are changed or that auto-generated credentials are used before provisioning, that SQL Server cluster credentials are reviewed after creation, and that PostgreSQL HBA configurations are customized post-deployment to match site security requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to this control through credential management mechanisms that address the intent of avoiding shared, well-known defaults across deployments.

For administrative access, local authentication is the default method on the Avi Controller. The default deployment creates an admin account that does not mandate specific password requirements at the account level; organizations must configure strong password enforcement separately through User Account Security profiles. When a new user is created and no profile is explicitly selected, the system automatically assigns the Default-User-Account-Profile. Administrators can create custom User Account Security profiles under Administration > User Account Security in the Controller UI, specifying password history, login failure thresholds, and account lock settings beyond what the default profile provides. In multi-node controller clusters, follower nodes may use a default initial admin password or a user-configured one, so post-deployment credential rotation should address all cluster members.

A specific credential-change requirement applies to the audit user account: the Avi Controller audit user password must be changed and must meet required criteria before the system is placed in production.

Default system accounts in Avi cannot be deactivated or removed. Organizations must establish a post-deployment rotation procedure that explicitly addresses these accounts. Locally authenticated users can change their own passwords through My Account in the Controller UI by entering the old password followed by the new one. Administrators can also generate a random password or set a new password manually during a password reset operation.

Because Avi does not enforce a mandatory credential rotation step at first login or as part of account creation for the general admin account, and because default system accounts cannot be disabled, organizations are responsible for the post-deployment procedures that satisfy this control.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 5.5.1

> For password-only authentication for interactive user access, either technically or procedurally enforce the following password parameters: 5.5.1. Password length that is, at least, the lesser of eight characters or the maximum length supported by the Cyber Asset; and

SCF Controls: IAC-10.1

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces password complexity, length, and lifespan requirements across its component stack, with each component providing configurable password policies.

At the platform level, VCF uses the Linux PAM (Pluggable Authentication Module) framework to enforce default password complexity rules. The default policy requires passwords of at least 12 characters containing at least one lowercase letter, one uppercase letter, one digit, one special character, and at least five different characters. The PAM module limits password entry attempts to a maximum of three retries before returning an error. On VMware ESX hosts, the password complexity policy is enforced for the root user, helping maintain strong credentials on the hypervisor layer.

VMware vCenter's built-in authentication service, VCF SSO, enforces a password policy for local domain accounts with a default password lifetime of 90 days, configurable through the VCF SSO password policy settings in vCenter. For users authenticated through external identity sources such as Active Directory, password restrictions, expiration, and account lockout are governed by the identity source domain rather than VCF SSO policies.

NSX Manager and NSX Edge enforce password complexity through Linux PAM modules. Default requirements include a minimum of 12 characters (maximum 128), at least one lowercase letter, one uppercase letter, one numeric character, one special character, and at least five different characters. NSX Edge adds restrictions against dictionary words, palindromes, and monotonic character sequences of more than four. All of these parameters are configurable through the NSX Authentication Policy Settings or the NSX Manager API, including minimum and maximum password length, required count of uppercase, lowercase, special, and numeric characters, password uniqueness, and hashing algorithm. NSX Manager enforces a retry limit of three attempts when setting a new password. For password lifespan, NSX Manager supports configuring password expiration with a range from 1 to 9,999 days.

VCF Operations applies password complexity requirements at multiple levels. The admin user account requires a minimum of 15 characters with at least one uppercase letter, one lowercase letter, one digit, and one special character. The default password strength policy allows configuration of the minimum password length starting at eight characters. The password policy settings are managed through Administration > Global Settings > User Access > Password Policy, which provides controls for password strength, password change policy, and account lockout. VCF Operations locks user accounts based on the password lockout policy, with a default threshold of seven failed login attempts, or if a user enters an incorrect password three times within five minutes. VCF Operations for Networks locks a user account after five consecutive failed login attempts for 15 minutes.

VCF Automation supports its own password policy system settings, including account lockout after a configurable number of invalid login attempts. The lockout interval specifying the duration before automatic unlock is also configurable. Provider administrators can unlock a user account manually without waiting for the lockout interval to expire. VCF Automation passwords require a minimum of 15 characters.

VCF Operations provides centralized password lifecycle management for all VCF components. Administrators can rotate passwords on demand or schedule automatic rotation on a recurring basis. During rotation, VCF Operations generates a randomized password that conforms to the component's password policy and re-establishes the relevant component integrations automatically. The VCF Operations UI offers preset rotation intervals, and the API supports custom scheduling. VCF Operations also provides a password remediation capability through the Security > Password management interface, allowing administrators to update service account credentials and synchronize passwords when they have drifted out of sync between components.

The VCF API supports managing the local accounts global password policy in vCenter. The `Invoke-GetLocalAccountsGlobalPolicy` and `Invoke-SetLocalAccountsGlobalPolicy` operations allow administrators to retrieve and update the vCenter password policy programmatically through the vSphere Automation SDK for PowerShell.

VCF documentation recommends setting passwords following a common set of requirements across all accounts. While individual components support different password parameters and defaults, administrators can align password policies across the environment to establish a consistent security posture. The combination of enforced defaults, per-component customization options, password expiration controls, and centralized rotation provides the mechanisms needed to enforce complexity, length, and lifespan requirements for password-based authentication throughout the VCF stack.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces password complexity, length, and lifespan requirements for its management interface accounts, contributing to the organization's password-based authentication posture.

Security Services Platform (SSP) is the centralized management console for vDefend. SSP enforces password policies for local user accounts: admin and audit user passwords require a minimum of 12 characters and a maximum of 128 characters, and must contain at least one uppercase letter, one lowercase letter, one numeric character, and one special character. The same complexity criteria apply during password changes and resets. Local user passwords are valid for 180 days; a notification banner appears in the SSP UI 30 days before expiration to prompt users to update their password. Installer user passwords are valid for 60 days. The License Hub component of SSP also enforces password complexity requirements during local password change operations.

SSP supports integration with directory services, including Active Directory over LDAP and OpenLDAP. When remote users or remote user groups are configured through LDAP, SSP applies the password expiration settings configured in the directory service; password expiry for these accounts cannot be modified from the SSP UI. SSP uses Authelia, an open-source authentication and authorization server, to handle authentication requests, including two-factor authentication and single sign-on.

For Identity Firewall, vDefend uses an LDAP password to authenticate connections to the directory service used for identity-based policy enforcement.

vDefend is a network security product and not a general-purpose identity management system. Its management interfaces enforce password complexity, length, and lifespan policies for vDefend administrative access. Satisfying this control fully requires applying equivalent password policies across all systems within the organization's environment, which is an organizational responsibility beyond vDefend's scope.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) enforces password complexity and length requirements for all local user accounts. Local user passwords must contain a minimum of 8 and a maximum of 20 characters, including at least one uppercase letter, one lowercase letter, one number, and one special character from the set `(?!@#$$%^&*)`. These requirements apply both at account creation and at every subsequent password reset; DSM rejects any new password that does not satisfy all criteria before accepting the change. Administrators can set the `force_password_change` flag on individual local user accounts to require a password reset at the next login, supporting periodic credential rotation and post-provisioning hygiene workflows.

The root account for the DSM provider VM carries its own complexity requirements: a minimum of 15 and a maximum of 32 characters, requiring at least one uppercase letter, one lowercase letter, one number, and one special character. These constraints are enforced during OVA deployment, so the appliance cannot be instantiated with a weak root credential. The root password expiry date must be set to a valid future date and cannot be configured to never expire, making root credential rotation mandatory. DSM checks root password status at regular intervals and generates a `ROOT_USER_PASSWORD_EXPIRE_SOON` alert when the credential is approaching expiration, giving administrators advance notice before a reset is required.

For PostgreSQL database instances managed by DSM, the default host-based authentication (HBA) configuration applies the `scram-sha-256` algorithm, a salted challenge-response mechanism that avoids transmitting cleartext passwords during

authentication. Custom `pg_hba.conf` entries also default to `scram-sha-256` as the password-based authentication method. Local user management passwords within the DSM platform are encrypted using PGP symmetric encryption with dedicated keys (`PGCRYPTO_PASSWORD` and `PGCRYPTO_ALGORITHM`).

DSM supports both local user authentication and LDAPS-based directory service authentication for platform access. Local users are authenticated by validating the email address and password against DSM's internal store. When LDAPS is configured, password lifecycle management, including organizational complexity and lifespan policies, is delegated to the directory service. PostgreSQL and MySQL database instances can independently be configured for LDAP or Active Directory authentication, allowing database-level credential management to align with enterprise directory policies. For PostgreSQL, the Enable Directory Service Authentication toggle on the database creation form activates this integration when a default directory service is configured. Administrators should configure LDAPS where enterprise password governance policies must extend to database-level credentials, or rely on DSM's built-in local user password policy where directory integration is not used.

For SQL Server database instances, DSM supports SQL User authentication with standard SQL Server logins and passwords. The DSM privileged service account used for automated SQL Server tasks must be configured with its password policy set to Never Expire to prevent service interruptions; administrators should account for this service account exception when reviewing password lifespan policies across DSM-managed database instances.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) enforces password-based authentication controls through the Avi Controller's administrative identity plane, addressing complexity, length, and lifespan for locally authenticated accounts.

The Controller's strong password enforcement feature requires each password to contain at least one uppercase character, at least one lowercase character, at least one numeric character, and at least one special character from the allowed set. The Controller rejects passwords consisting of sequences of adjacent keyboard keys. These requirements apply to both newly created accounts and to existing accounts when a user changes their password. Complexity enforcement is controlled through the `password_strength_check` setting, which the Controller applies at the portal level regardless of the administrative interface used.

The minimum permissible password length is configurable through the `minimum_password_length` setting. The Controller enforces a minimum of 8 characters by default; administrators can raise this threshold via the REST API or CLI. The Avi License Hub enforces stricter length requirements for its admin and audit accounts: a minimum of 12 characters and a maximum of 128 characters.

Password expiration is enforced through user account profiles using the `password_expiration_days` setting. The Default-User-Account-Profile sets password expiration at 365 days. The Controller displays a notification banner in the UI 30 days before a password expires to prompt renewal. The expiration period is configurable per profile.

Password history enforcement restricts users from reusing recent passwords by comparing proposed updates against a configurable list of previous password hashes. The history count is configurable from 1 to 10 previous passwords, with a default of 5.

Locally authenticated users change their own password through the My Account menu, which requires entry of the current password before accepting a new one. Administrators can generate a random password for a local user account or input a new password manually during a password reset. User-initiated password recovery through the GUI is supported when SMTP email is configured.

These controls apply to locally authenticated Avi Controller accounts. For administrators who authenticate against external directories such as LDAP, password complexity and lifespan are managed by those external directories.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 5.5.2

> For password-only authentication for interactive user access, either technically or procedurally enforce the following password parameters: 5.5.2. Minimum password complexity that is the lesser of three or more different types of characters (e.g., uppercase alphabetic, lowercase alphabetic, numeric, nonalphanumeric) or the maximum complexity supported by the Cyber Asset.

SCF Controls: IAC-10.1

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces password complexity, length, and lifespan requirements across its component stack, with each component providing configurable password policies.

At the platform level, VCF uses the Linux PAM (Pluggable Authentication Module) framework to enforce default password complexity rules. The default policy requires passwords of at least 12 characters containing at least one lowercase letter, one uppercase letter, one digit, one special character, and at least five different characters. The PAM module limits password entry attempts to a maximum of three retries before returning an error. On VMware ESX hosts, the password complexity policy is enforced for the root user, helping maintain strong credentials on the hypervisor layer.

VMware vCenter's built-in authentication service, VCF SSO, enforces a password policy for local domain accounts with a default password lifetime of 90 days, configurable through the VCF SSO password policy settings in vCenter. For users authenticated through external identity sources such as Active Directory, password restrictions, expiration, and account lockout are governed by the identity source domain rather than VCF SSO policies.

NSX Manager and NSX Edge enforce password complexity through Linux PAM modules. Default requirements include a minimum of 12 characters (maximum 128), at least one lowercase letter, one uppercase letter, one numeric character, one special character, and at least five different characters. NSX Edge adds restrictions against dictionary words, palindromes, and monotonic character sequences of more than four. All of these parameters are configurable through the NSX Authentication Policy Settings or the NSX Manager API, including minimum and maximum password length, required count of uppercase, lowercase, special, and numeric characters, password uniqueness, and hashing algorithm. NSX Manager enforces a retry limit of three attempts when setting a new password. For password lifespan, NSX Manager supports configuring password expiration with a range from 1 to 9,999 days.

VCF Operations applies password complexity requirements at multiple levels. The admin user account requires a minimum of 15 characters with at least one uppercase letter, one lowercase letter, one digit, and one special character. The default password strength policy allows configuration of the minimum password length starting at eight characters. The password policy settings are managed through Administration > Global Settings > User Access > Password Policy, which provides controls for password strength, password change policy, and account lockout. VCF Operations locks user accounts based on the password lockout policy, with a default threshold of seven failed login attempts, or if a user enters an incorrect password three times within five minutes. VCF Operations for Networks locks a user account after five consecutive failed login attempts for 15 minutes.

VCF Automation supports its own password policy system settings, including account lockout after a configurable number of invalid login attempts. The lockout interval specifying the duration before automatic unlock is also configurable. Provider administrators can unlock a user account manually without waiting for the lockout interval to expire. VCF Automation passwords require a minimum of 15 characters.

VCF Operations provides centralized password lifecycle management for all VCF components. Administrators can rotate passwords on demand or schedule automatic rotation on a recurring basis. During rotation, VCF Operations generates a randomized password that conforms to the component's password policy and re-establishes the relevant component integrations automatically. The VCF Operations UI offers preset rotation intervals, and the API supports custom scheduling. VCF Operations also provides a password remediation capability through the Security > Password management interface,

allowing administrators to update service account credentials and synchronize passwords when they have drifted out of sync between components.

The VCF API supports managing the local accounts global password policy in vCenter. The `Invoke-GetLocalAccountsGlobalPolicy` and `Invoke-SetLocalAccountsGlobalPolicy` operations allow administrators to retrieve and update the vCenter password policy programmatically through the vSphere Automation SDK for PowerShell.

VCF documentation recommends setting passwords following a common set of requirements across all accounts. While individual components support different password parameters and defaults, administrators can align password policies across the environment to establish a consistent security posture. The combination of enforced defaults, per-component customization options, password expiration controls, and centralized rotation provides the mechanisms needed to enforce complexity, length, and lifespan requirements for password-based authentication throughout the VCF stack.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces password complexity, length, and lifespan requirements for its management interface accounts, contributing to the organization's password-based authentication posture.

Security Services Platform (SSP) is the centralized management console for vDefend. SSP enforces password policies for local user accounts: admin and audit user passwords require a minimum of 12 characters and a maximum of 128 characters, and must contain at least one uppercase letter, one lowercase letter, one numeric character, and one special character. The same complexity criteria apply during password changes and resets. Local user passwords are valid for 180 days; a notification banner appears in the SSP UI 30 days before expiration to prompt users to update their password. Installer user passwords are valid for 60 days. The License Hub component of SSP also enforces password complexity requirements during local password change operations.

SSP supports integration with directory services, including Active Directory over LDAP and OpenLDAP. When remote users or remote user groups are configured through LDAP, SSP applies the password expiration settings configured in the directory service; password expiry for these accounts cannot be modified from the SSP UI. SSP uses Authelia, an open-source authentication and authorization server, to handle authentication requests, including two-factor authentication and single sign-on.

For Identity Firewall, vDefend uses an LDAP password to authenticate connections to the directory service used for identity-based policy enforcement.

vDefend is a network security product and not a general-purpose identity management system. Its management interfaces enforce password complexity, length, and lifespan policies for vDefend administrative access. Satisfying this control fully requires applying equivalent password policies across all systems within the organization's environment, which is an organizational responsibility beyond vDefend's scope.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) enforces password complexity and length requirements for all local user accounts. Local user passwords must contain a minimum of 8 and a maximum of 20 characters, including at least one uppercase letter, one lowercase letter, one number, and one special character from the set `(?!@#$$%^&*)`. These requirements apply both at account creation and at every subsequent password reset; DSM rejects any new password that does not satisfy all criteria before accepting the change. Administrators can set the `force_password_change` flag on individual local user accounts to require a password reset at the next login, supporting periodic credential rotation and post-provisioning hygiene workflows.

The root account for the DSM provider VM carries its own complexity requirements: a minimum of 15 and a maximum of 32 characters, requiring at least one uppercase letter, one lowercase letter, one number, and one special character. These constraints are enforced during OVA deployment, so the appliance cannot be instantiated with a weak root credential. The root password expiry date must be set to a valid future date and cannot be configured to never expire, making root credential rotation mandatory. DSM checks root password status at regular intervals and generates a `ROOT_USER_PASSWORD_EXPIRE_SOON` alert when the credential is approaching expiration, giving administrators advance notice before a reset is required.

For PostgreSQL database instances managed by DSM, the default host-based authentication (HBA) configuration applies the scram-sha-256 algorithm, a salted challenge-response mechanism that avoids transmitting cleartext passwords during authentication. Custom `pg_hba.conf` entries also default to scram-sha-256 as the password-based authentication method. Local user management passwords within the DSM platform are encrypted using PGP symmetric encryption with dedicated keys (`PGCRYPTO_PASSWORD` and `PGCRYPTO_ALGORITHM`).

DSM supports both local user authentication and LDAPS-based directory service authentication for platform access. Local users are authenticated by validating the email address and password against DSM's internal store. When LDAPS is configured, password lifecycle management, including organizational complexity and lifespan policies, is delegated to the directory service. PostgreSQL and MySQL database instances can independently be configured for LDAP or Active Directory authentication, allowing database-level credential management to align with enterprise directory policies. For PostgreSQL, the Enable Directory Service Authentication toggle on the database creation form activates this integration when a default directory service is configured. Administrators should configure LDAPS where enterprise password governance policies must extend to database-level credentials, or rely on DSM's built-in local user password policy where directory integration is not used.

For SQL Server database instances, DSM supports SQL User authentication with standard SQL Server logins and passwords. The DSM privileged service account used for automated SQL Server tasks must be configured with its password policy set to Never Expire to prevent service interruptions; administrators should account for this service account exception when reviewing password lifespan policies across DSM-managed database instances.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) enforces password-based authentication controls through the Avi Controller's administrative identity plane, addressing complexity, length, and lifespan for locally authenticated accounts.

The Controller's strong password enforcement feature requires each password to contain at least one uppercase character, at least one lowercase character, at least one numeric character, and at least one special character from the allowed set. The Controller rejects passwords consisting of sequences of adjacent keyboard keys. These requirements apply to both newly created accounts and to existing accounts when a user changes their password. Complexity enforcement is controlled through the `password_strength_check` setting, which the Controller applies at the portal level regardless of the administrative interface used.

The minimum permissible password length is configurable through the `minimum_password_length` setting. The Controller enforces a minimum of 8 characters by default; administrators can raise this threshold via the REST API or CLI. The Avi License Hub enforces stricter length requirements for its admin and audit accounts: a minimum of 12 characters and a maximum of 128 characters.

Password expiration is enforced through user account profiles using the `password_expiration_days` setting. The Default-User-Account-Profile sets password expiration at 365 days. The Controller displays a notification banner in the UI 30 days before a password expires to prompt renewal. The expiration period is configurable per profile.

Password history enforcement restricts users from reusing recent passwords by comparing proposed updates against a configurable list of previous password hashes. The history count is configurable from 1 to 10 previous passwords, with a default of 5.

Locally authenticated users change their own password through the My Account menu, which requires entry of the current password before accepting a new one. Administrators can generate a random password for a local user account or input a new password manually during a password reset. User-initiated password recovery through the GUI is supported when SMTP email is configured.

These controls apply to locally authenticated Avi Controller accounts. For administrators who authenticate against external directories such as LDAP, password complexity and lifespan are managed by those external directories.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-007-6 5.6

> Where technically feasible, for password-only authentication for interactive user access, either technically or procedurally enforce password changes or an obligation to change the password at least once every 15 calendar months.

SCF Controls: IAC-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered authentication infrastructure that supports secure management of authenticators across the platform's components and the Kubernetes workload consumption layer, though the broader organizational policies governing authenticator lifecycle management require processes and governance beyond what VCF itself provides.

VCF Identity Broker integrates with a selected identity provider for user authentication, establishing trust through metadata exchange between the service provider and the identity provider. This centralized approach allows organizations to manage authenticators through their existing identity management systems rather than maintaining separate credential stores for each VCF component. VCF SSO provides a single sign-on environment where a user provides credentials once, and components in the environment perform operations based on the original authentication. Administrators can federate VMware vCenter with an enterprise identity provider, which enables multifactor authentication (MFA), automatic user provisioning and deprovisioning, and token-based authentication that reduces the risk of credential exposure. VCF SSO supports SCIM (System for Cross-domain Identity Management) for automating user identity exchange across identity domains, and named providers including Okta are supported through the identity provider federation mechanism. When configured for identity provider federation, the external provider handles all authentication mechanisms, including passwords, MFA, and biometrics, delegating full authenticator management to the organization's existing identity infrastructure. The Authorization Code grant type in VMware Identity Broker supports MFA workflows, while the Password OAuth 2.0 grant type is incompatible with MFA requirements, so organizations should use the Authorization Code flow when MFA is needed.

VMware Kubernetes Service (VKS) extends this identity architecture to the workload consumption layer. VKS clusters support two authentication methods: VCF SSO and any OIDC-compliant external identity provider, including Okta, so identity lifecycle management, including onboarding, offboarding, and group membership changes, can remain in the organization's central identity system. Users authenticated through an external identity provider are granted Kubernetes RBAC permissions using the `sso:<username>@<domain>` naming convention in `ClusterRoleBindings`. Custom `ClusterClass` configurations allow organizations to authenticate developers against existing corporate identity systems. When provisioning clusters based on a custom `ClusterClass`, the authentication Secret can be configured with multiple JWT issuers to support distinct identity providers simultaneously, such as Keycloak for contractors and Microsoft Entra ID for employees. At the `kube-apiserver` level, VKS supports multiple authenticator types: client certificates, bearer tokens, an authenticating proxy, and HTTP basic auth. The `--authentication-config` file provides structured control, allowing multiple JWT authenticators each with a unique issuer URL and discovery URL, and CEL expressions to map claims to user attributes and validate claims. When multiple authenticator modules are active, the first to successfully authenticate a request short-circuits further evaluation, making authenticator order significant; Kubernetes hardening guidance recommends enabling as few authentication mechanisms as possible to simplify user management and reduce the risk of users retaining access after it is no longer needed. The `kube-apiserver` can also leverage existing authentication methods such as LDAP or Kerberos through plugins, and `kubectl` integrates with credential plugins for centralized operator credential management. The `system:auth-delegator` `ClusterRole` provides unified authentication and authorization flows for add-on API servers deployed into VKS clusters. Production VKS clusters should enable Kubelet authentication and authorization to restrict direct access to the kubelet API. For Windows node pools, VKS clusters support Group Managed Service Accounts (gMSA) for authenticating Windows nodes to Active Directory; gMSAs are managed by security groups that control password retrieval and delegation permissions, allowing Windows workloads to use Active Directory-managed identities.

Standard packages deployable on VKS clusters extend authenticator management to workload-level services. Argo CD, available as a standard package, supports local account authentication with global RBAC policies and OIDC authentication for federated identity, allowing GitOps workflow access to be governed through the same identity infrastructure used for cluster

access. The Harbor container registry package provides authentication and token management for artifact access, with role-based access control restricting image push and pull operations.

VCF Operations integrates with VCF SSO for centralized authentication through an identity provider. NSX Manager can be configured to authenticate users from identity management providers or through a directory service such as Active Directory over LDAP or OpenLDAP. NSX authentication best practices include integrating with identity providers, enabling multi-factor authentication, and defining access controls based on user roles and permissions. NSX Manager requires authentication prior to establishing a management connection for administrative access. The VCF Automation Provider Management Portal supports authentication via local users and SAML users, and Organization Administrators use credentials configured during organization creation to access their respective organizations.

For local accounts, each VCF component enforces password complexity and lifecycle policies. NSX Manager requires passwords of at least 12 characters with uppercase, lowercase, numeric, and special character requirements, enforced through Linux PAM modules. Each NSX user password has an expiration date tracked by NSX, with a default expiration period of 90 days. Password expiration is configurable between 1 and 9,999 days. VCF Operations enforces a minimum of 15 characters with similar complexity rules. VCF Automation passwords must also be at least 15 characters in length.

VCF provides configurable account lockout policies across its components. VCF Operations locks accounts after five consecutive failed login attempts for 15 minutes. A separate policy locks VCF Operations accounts if a user enters an incorrect password three times within five minutes. VCF Automation supports account lockout in password policy system settings, which locks user accounts after a configurable number of invalid login attempts. VCF Automation also provides a configurable account lockout interval that specifies the duration before an account is automatically unlocked, and provider administrators can unlock a user account manually without waiting for that interval to expire.

For service-to-service authentication, VCF uses certificate-based credentials. VCF SSO supports X.509 certificate authentication, and vCenter extensions can authenticate using `loginExtensionByCertificate()` with an extension key certificate. Provider management accounts authenticate using API access tokens that rotate after each use. VCF Automation provides service accounts with the same access restrictions as user API tokens, so service accounts cannot perform user management or create refresh tokens. NSX supports Principal Identity certificates for cloud management platform integration, requiring SHA256-based certificates with RSA/DSA message algorithm and 2048-bit or larger key sizes. At the Kubernetes layer, service account authentication uses bearer token secrets generated automatically for service accounts. Kubernetes hardening guidance recommends setting short lifetimes on certificates and automating their rotation, and recommends using an authentication provider that controls how long issued tokens remain valid; using short-lived Secrets helps detect or limit the impact of credential exposure. The `system:masters` group functions as a break-glass super-user group that bypasses the RBAC authorization layer and should be reserved for emergency access scenarios only.

VCF Operations provides API endpoints for trusted certificate management and displays certificate expiration status for each workload domain through its Certificates tab. NSX supports non-disruptive certificate rotation in VCF and later, allowing certificate replacement without service interruption.

VCF also provides visibility into authenticator usage through audit logging. User authentication details are viewable in VCF Operations, including user name, successful or failed authentications, and events such as user login and guest operation authentication. This logging supports detection of compromised or misused authenticators.

While VCF provides the technical controls for authenticator strength, complexity, expiration, lockout, and rotation within its own components, as well as identity provider integration for MFA enforcement and centralized authentication, and the VKS consumption layer provides configurable multi-method kube-apiserver authentication, external identity provider integration, short-lived credential support, and gMSA for Windows workloads, the broader organizational policies for initial authenticator issuance, periodic credential rotation schedules, revocation upon personnel changes, and mapping authentication strength requirements to data classification levels require processes and governance outside VCF's scope.

VMware Private AI Services (PAIS) provides authentication mechanisms specific to its AI infrastructure components, integrating with externally managed identity systems to control access to AI services, model endpoints, and training data.

PAIS uses OIDC-based authentication as its primary access control mechanism. The PAISConfiguration custom resource configures the OIDC provider with issuerUrl, clientId, and scopes including openid, groups, and offline_access. Access is restricted to user accounts whose membership matches OIDC groups listed in the authorizedGroups field, and the Access Token carries a groups claim that PAIS validates against the authorized group list. The OIDC configuration also supports configurable group claim names and Extra Audiences for additional OAuth2.0 clients that PAIS will accept when validating the Access Token.

The PAISConfiguration custom resource supports client TLS for outbound authentication to the OIDC provider and Harbor registry, configured through the worker.clientTls.caBundleRefs field. This binds certificate-based trust to identity provider and registry connections so that authentication exchanges are integrity-checked against approved CAs.

Authenticator management for the Harbor registry that stores AI models and artifacts follows a credential-based pattern. The oras login command authenticates to a private Harbor registry using username and password credentials for artifact push operations, and docker login is used for pushing models to Harbor projects through the Model Gallery. Harbor project access capabilities restrict access to the sensitive data that is used to train and tune models. Model endpoints support authentication through harbor-pull-secret-readonly to control access to container images stored in private registries, and Harbor model retrieval requires certificate-based trust in addition to credential authentication.

Internal service-to-service authentication is addressed at the component level. PAIS authenticates to the OpenTelemetry Collector using a Kubernetes Secret containing Authorization Bearer tokens and custom headers, and the LLM Traces flow uses the same pattern with semi-colon separated headers. The PAIS MCP server supports custom HTTP headers including User-Agent and Authorization headers for API authentication, and remote MCP servers can optionally use static authentication tokens. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication.

For Knowledge Base data sources, PAIS supports authentication to Confluence using either a username and password or a personal access token, configured according to the Confluence administrator's settings. Personal access tokens are generated from user account settings and used for programmatic access to Knowledge Bases and data sources. Microsoft SharePoint data sources require username and password authentication, with support limited to SharePoint On-Premises deployments.

Deep Learning VMs deployed through self-service catalog items in VCF Automation, when configured with the PyTorch NGC software bundle, support optional JupyterLab authentication activation for interactive notebook access.

The underlying user accounts, credential storage, password policies, and OIDC provider administration are owned by VCF SSO or an external identity provider. PAIS configures and enforces authentication using those systems but does not manage authenticator lifecycle itself.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms for managing authenticators across both the administrative plane and the database layer, supporting the secure credential management aspect of this control.

For administrative access to the DSM platform, the system supports two authentication paths: local user accounts authenticated by email ID and password, and LDAPS-integrated accounts authenticated by matching the email domain against a registered LDAPS server. When directory service credentials are non-functional, DSM falls back to local user authentication, maintaining access continuity. Administrators configure and manage these authentication sources through the DSM Admin UI, which also provides a Permissions view for creating, monitoring, and managing configured users. LDAPS integration supports certificate-based validation of the directory service connection, with administrators able to upload directory service server certificates through the Admin UI to establish trusted connections. LDAP groups can be assigned roles within DSM, enabling group-based access control aligned with directory service group membership.

At the database layer, DSM supports directory service authentication for PostgreSQL, MySQL, SQL Server, and MinIO databases. For PostgreSQL, host-based authentication (HBA) rules determine how clients are authenticated, using ordered matching rules that evaluate connection type, client address, requested database, and user name. The default HBA configuration includes a final catch-all entry using scram-sha-256, with optional LDAP entries for directory-integrated authentication. This HBA configuration can be modified through the DSM interface. For MySQL databases, LDAPS

authentication is available using Active Directory Global Catalog, with support for multi-domain controller deployments via the AD Secure/SSL Global Catalog on port 3269. Directory service authentication for individual database instances can be enabled or disabled through the Enable Directory Service Authentication toggle in the database settings.

For SQL Server databases, DSM uses contained database users, where users authenticate directly against the database and identity information resides within the database. DSM supports Windows Authentication for SQL Server server-level logins through Active Directory integration, enabling Kerberos-based single sign-on for clients joined to the same domain. SQL Server Authentication logins can also be created on all DSM clusters. Administrators configure which user types are permitted per data service policy, selecting between Windows Principal authentication using Active Directory credentials and SQL User authentication using standard SQL Server logins. An internal management login (`dsm_mgmt`) restricts access to system-level objects, keeping administrative operations within an isolated context.

DSM enforces password policies for local accounts, including complexity requirements, and applies a root password expiry on a three-month rotation cycle. For service-to-service communication, DSM uses authentication secrets (`dsm-auth-creds`) containing endpoint credentials and root CA certificates, with automatic secret generation available through the Consumption Operator installation. Prometheus metrics forwarding supports configurable authentication options, including no authentication, certificate-only authentication, basic authentication with username and password, or a combination of certificate and basic authentication.

Regarding authentication strength appropriate to data classification, DSM provides the authentication mechanisms that administrators can configure to match organizational security policies, but it does not automatically enforce differentiated authentication strength based on data classification. Organizations must define their data classification scheme and determine which DSM authentication options (local credentials, LDAPS, HBA rules, certificate validation, Kerberos) apply to each tier of sensitivity. DSM contributes the technical controls; the alignment between authentication strength and data classification requires organizational governance to establish and maintain.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms to securely manage authenticators across two distinct planes: the Controller management plane (admin access) and the application data plane (end-user client authentication for load-balanced applications).

For the management plane, Avi maintains user accounts in two categories: local users managed directly on the Controller, and remote users authenticated through an external authentication, authorization, and accounting (AAA) server. Avi uses Authentication Profiles to configure how administrators authenticate to the Controller. Authentication Profiles support LDAP for credential validation against a directory service, SAML for federated authentication that delegates the process to a centralized identity provider (IdP), and basic authentication. The recommended approach is federated authentication, which centralizes the authentication process by delegating to an external IdP rather than managing credentials locally on the Controller. SAML profiles verify user identity without storing credentials on untrusted systems, and Avi Controller SAML authentication profiles can be integrated with Workspace ONE Access for catalog-based application access. Admin users can also authenticate using password-less SSH-based login as an alternative to password-based authentication. On every user login, the Auth Mapping Profile evaluates authorization mapping rules and updates the user record with tenant and role pairs drawn from the IdP's assertions.

For the application data plane, Avi acts as a proxy that applies client authentication policies to inbound application traffic. Supported methods include LDAP authentication (checking client credentials against a directory service), SAML single sign-on (enabling federated application access with a single credential set), OAuth and OIDC (where Avi acts as a client and resource server, with the authorization server authenticating clients and validating authorization codes before issuing tokens), and JSON Web Token (JWT) validation. The SSO Policy supports configurable Authentication Rules and Authorization Rules with path-based matching criteria, allowing different authentication requirements to be applied to different application paths. More granular authorization in OAuth/OIDC flows is available through Authorization Policies or DataScript.

Organizations configure which authentication method applies to each virtual service or application based on the sensitivity of the data accessed. Avi's Authentication Profiles and SSO Policies provide the technical enforcement points to apply different

authentication strengths across the application portfolio, but the mapping from data classification tier to required authentication method is an organizational governance decision that must be defined and maintained by the organization.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-007-6 5.7

> Where technically feasible, either: ☐ Limit the number of unsuccessful authentication attempts; or ☐ Generate alerts after a threshold of unsuccessful authentication attempts.

SCF Controls: IAC-22

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides account lockout mechanisms across its management components, each with configurable thresholds, lockout durations, and automatic unlock behavior. These capabilities allow an organization to enforce limits on consecutive invalid login attempts in line with its defined security policies.

NSX Manager enforces account lockout on both its API and CLI interfaces. The API authentication policy defaults to a maximum of 5 authentication failures before lockout, with a lockout period of 900 seconds (15 minutes). The CLI interface similarly defaults to 5 maximum authentication failures before lockout, with a `cli_failed_auth_lockout_period` of 900 seconds. These values are configurable through the NSX authentication policy endpoint (`/api/v1/node/aaa/auth-policy`) and through the "set auth-policy cli" command, which exposes parameters for lockout-period and max-auth-failures. Administrators can also disable account lockout on the CLI by setting the maximum failed attempts to 0, though this is not recommended in production environments.

VMware ESX hosts implement account lockout through two advanced system settings: `Security.AccountLockFailures` specifies the maximum number of failed login attempts before an account is locked (default 5 within a 3-minute window), and `Security.AccountUnlockTime` specifies the number of seconds the account remains locked (default 900 seconds, or 15 minutes). Both settings are configurable through the VMware Host Client under Manage > System Settings or through the ESX advanced system settings interface. Setting `Security.AccountLockFailures` to 0 deactivates account locking entirely, which is not recommended in production environments. Administrators should note that the Direct Console User Interface (DCUI) and the ESX Shell do not support account lockout, so access through those interfaces is not subject to the same enforcement.

VCF SSO implements a configurable Lockout Policy that specifies the maximum number of failed login attempts, the time interval in which failures must occur to trigger a lockout, and the duration of the lockout. By default, VCF SSO users are locked out after five consecutive failed attempts within three minutes, and locked accounts are automatically unlocked after five minutes. Setting the unlock time to 0 disables automatic unlock and requires an administrator to manually release the account.

VCF Operations enforces account lockout with a default threshold of seven failed login attempts, or if a user enters an incorrect password three times within five minutes. The account lockout policy is activated by default for super administrator users, and this policy cannot be deactivated. Super administrator accounts are locked for approximately one hour after lockout is triggered and then automatically unlocked. VCF Operations exposes a `Locked` attribute on user accounts that indicates whether the account has been locked, allowing administrators to monitor lockout status.

VCF Operations for Networks implements a progressive lockout model. After five consecutive failed login attempts, the account is temporarily locked for 15 minutes. Each subsequent failed login attempt after the initial lockout adds an additional 15 minutes to the lockout duration. An account can remain locked for a maximum of one day if login attempts continue after the initial lockout.

VCF Automation supports account lockout through its password policy system settings. Accounts are locked after a configurable number of invalid login attempts, and an account lockout interval specifies the duration before an account is automatically unlocked. Provider administrators can also unlock a user account manually without waiting for the configured lockout interval to expire.

VCF Operations HCX locks user accounts after three failed login attempts. If an account becomes locked, it can be reset by accessing the HCX Manager through the Web Console in VMware vCenter and running the `faillock` command with the `--reset` option.

To fully satisfy this control, the organization must define its own time periods and attempt thresholds for account lockout, then configure each VCF component accordingly. The default values vary across components (3, 5, or 7 attempts depending on the component), so a consistent lockout policy requires reviewing and aligning the settings across all management interfaces. The organization should also establish procedures for monitoring lockout events and handling account unlock requests.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) maintains account lockout state for local user accounts through dedicated tracking fields. DSM records `failed_login_count`, `last_failed_login_time`, `locked_state_start_time`, and `force_password_change` on each local user account, providing DSM administrators with visibility into failed login activity, account lock status, and pending password-change requirements. These fields are accessible through the DSM administration interface in the "Managing LDAP Users in Data Services Manager" section of the administration guide.

When a local user account becomes locked, DSM provides two recovery paths. Administrators can manually reset a locked account through the DSM administration console. DSM also exposes a "Forgot Password" link on the login screen that allows users to initiate a password reset via email; reset links are active for 20 minutes. This self-service path is available only if an SMTP server has been configured in the DSM settings. If no SMTP server is configured, self-service password recovery is unavailable, and all locked accounts require direct administrator intervention.

For users who authenticate through LDAPS, DSM delegates authentication and lockout enforcement to the external directory service. The lockout threshold, time window, and automatic unlock behavior for LDAPS-authenticated users are governed by the organization's LDAP or Active Directory configuration, not by DSM. LDAPS users who need to reset a password must contact their LDAPS administrator rather than using the local password reset mechanism.

Organizations deploying DSM should configure lockout policies in their directory services for all LDAPS-authenticated users, configure SMTP to support self-service account recovery for local users, and establish administrator procedures for unlocking local accounts when self-service recovery is not available.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes a native account lockout mechanism for the Avi Controller administrative identity plane, configured through User Account Profiles. Each profile defines three lockout settings: Max Authentication Failures (the maximum number of consecutive failed login attempts before the account is locked), the Evaluation Period (the time window, in seconds, within which failures are counted toward lockout), and the lockout duration (the period the account remains locked after reaching the threshold). These settings are accessible through the Controller UI under Administration > User Account Security and through the Avi REST API.

The Default-User-Account-Profile ships with `max_login_failure_count` set to 20 and an `account_lock_timeout` of 30 minutes. Organizations can modify the failure threshold and lockout duration by editing the default profile or by creating a custom User Account Profile and assigning it to specific users. A built-in No-Lockout-User-Account-Profile sets Max Authentication Failures to 0, which disables lockout for any account assigned to it; when this setting is 0, the Evaluation Period and Lockout Period values have no effect. Auditors should verify that accounts assigned to the No-Lockout-User-Account-Profile carry an explicit authorization exception, as this profile bypasses the lockout control.

The Avi GSLB administrative interface has a parallel lockout configuration, where a specified number of authentication failures triggers an account lockout for a configured duration. This is controlled by the `login-failure-lockout-duration` setting in the GSLB configuration; the default lockout duration is 30 minutes.

Organizations using remote authentication sources such as LDAP, TACACS+, SAML, or RADIUS for Controller access will rely on the lockout policies of those external directories rather than on Avi's own profile settings. The organization is responsible for configuring Max Authentication Failures and the Evaluation Period to reflect its defined policy thresholds and time periods.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 1.1

> One or more processes to identify, classify, and respond to Cyber Security Incidents.

SCF Controls: IRO-01, IRO-02, IRO-02.4, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-008-6 1.2.1

> That include criteria to evaluate and define attempts to compromise;

SCF Controls: IRO-02, IRO-02.4, IRO-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-008-6 1.2.2

> To determine if an identified Cyber Security Incident is: • A Reportable Cyber Security Incident; or • An attempt to compromise, as determined by applying the criteria from Part 1.2.1, one or more systems identified in the “Applicable Systems” column for this Part; and

SCF Controls: IRO-02.4, IRO-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several monitoring, alerting, and network analysis capabilities that contribute to an organization's ability to define and detect Indicators of Compromise (IOC), though fully operationalizing IOC management requires integration with external threat intelligence platforms and organizational processes.

VCF Operations includes a Security Operations dashboard that provides a consolidated view of the security posture across the managed infrastructure. This dashboard brings together user and infrastructure security elements, helping operators identify areas that might require attention based on security exposure. By centralizing security-relevant telemetry in a single pane, the dashboard supports detection of anomalous conditions that could signal a cybersecurity event.

VCF Operations continuously monitors infrastructure by evaluating collected data against defined policies. Each object or group receives a compliance score based on how well it adheres to those policies, and alerts are triggered when deviations occur. Organizations can create custom compliance benchmarks that monitor specific alert definitions and policies, allowing security teams to codify their own detection criteria and receive notifications when infrastructure drifts from expected baselines. This policy-based alerting mechanism supports operationalizing certain classes of IOCs, particularly those related to configuration drift, unauthorized changes, or compliance violations.

VCF Operations supports custom alert definitions that can combine metric-based and log-based symptoms, allowing administrators to define conditions that flag suspicious activity. Alert definitions can incorporate Smart Early Warning conditions and log event patterns from monitored systems. Alert definition Impact settings can be configured to Risk to indicate potential problems that require attention in the near future, providing an early-warning mechanism that organizations can incorporate into incident detection workflows. Problem alerts are logged to syslog, and outbound notification plug-ins (SNMP Trap, webhook, email) allow alerts to be forwarded to external security tools for correlation and triage. VCF Log Management enables log-based symptom definitions that can match patterns across aggregated log data from across the VCF environment.

At the network layer, NSX provides flow-based observability capabilities. NSX flow queries support filtering and analysis of VTEP traffic, management traffic, and extended L2 network traffic for monitoring and audit purposes. NSX Traceflow provides traffic analysis by specifying source and destination information and returning tables of observed packets. These capabilities help surface unusual communication patterns that organizations can correlate with defined IOCs.

Log forwarding across VCF components supports IOC operationalization. VMware vCenter, NSX, and VMware ESX hosts can all forward syslog data to external SIEM platforms, where IOC matching and correlation typically occur. NSX audit logs include structured syslog fields that identify security-relevant events, and remote logging can be filtered by severity level and message categories including MONITORING, SECURITY, and SYSTEM.

For full threat intelligence correlation and signature-based IOC detection, VMware vDefend is a separate product that extends NSX networking with security-specific capabilities: IDS/IPS with support for importing custom and third-party threat intelligence signatures, custom signature bundle management for tailored IOC definitions, Malicious IP Feed integration that downloads known-malicious IP lists from the NTICS cloud service for use in network policy, virtual Deep Packet Inspection (vDPI) for payload pattern matching, and Advanced Threat Prevention combining IDS/IPS with network sandboxing, Network Traffic Analysis (NTA), and Network Detection and Response (NDR) correlation engines.

To fully satisfy this control, organizations need to supplement VCF's built-in monitoring with processes for defining, curating, and updating IOC libraries. This typically involves integrating third-party threat intelligence feeds, establishing procedures for

translating threat intelligence into detection rules across VCF Operations and network policy, and deploying a SIEM or endpoint detection platform to correlate VCF's telemetry with broader IOC databases.

VMware vDefend (Contributes)

VMware vDefend (vDefend) provides IOC detection and visualization mechanisms through its Security Services Platform and Security Intelligence components. The Network Detection and Response (NDR) feature correlates related events into campaigns, organizes threat events within a campaign into a timeline for security analyst triage, and maps threats to the tactics and techniques described in the MITRE ATT&CK framework, giving analysts structured context for identifying signs of compromise.

The Security Services Platform Campaign Blueprint provides an interactive graphical view of correlated security events and key actors for incident investigation. Campaign graph nodes show "IOC for Threat" relationships connecting a specific Indicator of Compromise to a threat, and "Affected by an IOC" relationships identifying workloads affected by a given IOC. IOC Summary panels surface details for File IOC (file score, verdict, SHA hashes, and a View Reports link) and for Malware IOC (impact score, detection details, and malware family details). A workload summary panel within the Blueprint shows the workload's maximum impact score, IP address or UUID, and lists threats in which the workload acts as an attacker or is targeted.

Campaign Correlation Rules calculate an impact score based on detection types, threat severity, and the count of affected workloads, enabling prioritization of IOC-driven investigations. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to further support response prioritization. The Security Overview Dashboard Threat Event Monitoring displays the number of intrusions detected in each severity category for unique intrusion signatures, giving security teams a current view of network activity.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The organizational process of formally defining and managing an IOC program, including sourcing, vetting, and curating IOCs, is a governance activity that vDefend's detection capabilities support but do not replace.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support IOC identification at the application delivery layer.

The WAF custom rules framework allows security teams to define application-layer attack signatures with configurable severity levels and cumulative anomaly scoring. These custom rules are the primary mechanism for defining application-specific attack patterns within Avi, covering the attack signatures most relevant to load-balancing and reverse-proxy functions.

The IP Reputation service provides continuously updated IP-based indicator classification. Avi classifies source IP addresses across threat categories including DoS/DDoS attacks, malware-infected hosts, phishing sites, proxy services, and other network threats using a bitmap representation that enables granular, category-specific policy enforcement at the application entry point. Virtual Service Network Security Policies can match on IP Reputation to identify or categorize source IP addresses based on associated threats.

In 9.1, the Live Security Threat Intelligence service, available through the Avi Cloud Console, delivers real-time threat intelligence feeds for various attack vectors to protect applications from evolving threats on Avi Load Balancer deployments.

The WAF Evaluation Report and Application Security Report surface identified attack indicators in a form suited to incident response workflows. The WAF Evaluation Report identifies types of attacks detected, source IP addresses and their geographic locations, and the top URLs targeted during the evaluation period. The Application Security Report provides an executive summary, ranked lists of top attack types such as SQL injection and cross-site scripting, lists of attacking IP addresses, and trend summaries comparing total and flagged requests, designed to help security teams understand the current threat posture and maintain audit-ready records.

Avi Service Engines generate DOS_ATTACK alert events capturing attack type, attack count, source IP addresses, affected virtual service name, and report timestamp. These events can be retrieved programmatically via ControlScripts for automated

event correlation. The Avi Controller also logs denial of service attack events with event details including event ID, attack count, threshold values, and alert level, and generates configurable severity-level alerts (ALERT_HIGH) for detected attack activity.

The config events overlay enables correlation of configuration changes with traffic anomalies by displaying timestamps of administrative changes to virtual service security settings alongside traffic data, helping administrators identify whether a shift in traffic was caused by a configuration modification.

These capabilities are scoped to application-layer traffic passing through Avi's Service Engines. Network-layer IOC detection, host-based indicators, and east-west traffic analysis are handled by other components within VCF. The organizational process of defining, maintaining, and correlating IOCs across the full environment extends beyond Avi's application delivery scope.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 1.3

> The roles and responsibilities of Cyber Security Incident response groups or individuals.

SCF Controls: HRS-03, IRO-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 1.4

> Incident handling procedures for Cyber Security Incidents.

SCF Controls: IRO-02, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-008-6 2.1

> Test each Cyber Security Incident response plan(s) at least once every 15 calendar months: • By responding to an actual Reportable Cyber Security Incident; • With a paper drill or tabletop exercise of a Reportable Cyber Security Incident; or • With an operational exercise of a Reportable Cyber Security Incident.

SCF Controls: IRO-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 2.2

> Use the Cyber Security Incident response plan(s) under Requirement R1 when responding to a Reportable Cyber Security Incident, responding to a Cyber Security Incident that attempted to compromise a system identified in the “Applicable Systems” column for this Part, or performing an exercise of a Reportable Cyber Security Incident. Document deviations from the plan(s) taken during the response to the incident or exercise.

SCF Controls: IRO-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 2.3

> Retain records related to Reportable Cyber Security Incidents and Cyber Security Incidents that attempted to compromise a system identified in the “Applicable Systems” column for this Part as per the Cyber Security Incident response plan(s) under Requirement R1.

SCF Controls: IRO-08, IRO-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support digital forensic investigations and evidence preservation, though the organization retains responsibility for chain-of-custody procedures, legal compliance, and formal forensic processes.

VCF Operations includes a Forensics Widget that can be added to custom dashboards for operational analysis during investigations. The widget displays data based on configurable filter sections, where each section progressively filters objects and passes the results to the next section. Administrators can search for and select specific objects in the environment on which to base the widget data, using text filters and tag-based filtering to narrow scope. The widget supports comparing data across two time periods, which is useful when investigating changes in environment behavior around a suspected incident. After adding the Forensics Widget to a dashboard, administrators should configure its options to tailor the output to the specific investigative needs of the dashboard users.

For evidence capture, VMware vCenter supports VM snapshots that record the memory, disk, and settings state of a virtual machine at a specific point in time. Reverting to a snapshot returns all of these to the exact state they were in when the snapshot was taken, making snapshots useful for preserving system state during an investigation. VM files (VMDKs, memory snapshots, log files) can also be collected and copied without powering down the workload, allowing incident responders to capture volatile and non-volatile evidence without altering the running state of the original workload. vSAN extends snapshot capabilities with immutable snapshots through its data protection service. An immutable vSAN snapshot is a read-only copy of data that cannot be modified or deleted, even by an attacker with administrative privileges. Once immutability mode is enabled on a protection group, it cannot be disabled by an administrator. This property helps protect forensic evidence from tampering. The `vmkfstools` command on VMware ESX hosts supports a `--chainConsistent` option that checks the entire virtual disk snapshot chain for corrupted links or invalid parent-child relationships, allowing investigators to verify the structural integrity of snapshot evidence before relying on it. VCF Automation exposes day-2 resource actions (Suspend, Create Snapshot, Delete Snapshot, Power On) through its API, allowing forensic preservation steps to be invoked programmatically as part of an incident response workflow. Day-2 action policies can be configured to entitle specific roles to perform snapshot actions and can be scoped at the organization level.

Audit logging across VCF components provides the evidentiary foundation that forensic investigators rely on. VCF Operations audit events capture operational details that facilitate security and compliance audits and provide information for conducting security forensics. The audit log feature in VCF Operations for Networks is always on and captures CRUD operations, login/logout events, and actions from the API, UI, and CLI. VCF Automation creates audit logs for reportable actions including catalog deployments, template operations, and day-2 actions. NSX audit logs use structured syslog fields with an `audit="true"` marker to identify security-related events, and a separate `nsx-audit-write.log` captures modification events. These audit records, combined with event logs from vCenter, ESX hosts, and VCF Operations, create a detailed trail of administrative actions, configuration changes, authentication events, and system state transitions. ESX hosts maintain audit records as a separately configurable logging feature from general event logs; these audit records must be explicitly activated and are not enabled by default, a step auditors should verify when assessing the forensic readiness of the platform.

For centralized evidence preservation, VCF components support log forwarding to external SIEM platforms via syslog. NSX remote logging supports TLS-encrypted transport with certificate verification. vSphere Supervisor similarly supports TLS-encrypted syslog forwarding with CA-based certificate verification. Forwarding logs to external systems with their own retention and integrity controls helps organizations maintain an independent, tamper-resistant record of events for forensic analysis.

Organizations deploying VCF should establish documented forensic procedures that define how to collect, handle, and preserve digital evidence from the virtualized environment. This includes defining who has authority to initiate evidence collection, how VM snapshots and log exports are stored to maintain integrity, and how the chain of custody is recorded from initial collection through analysis and potential legal proceedings. VCF provides the raw technical capabilities for evidence capture, audit logging, and secure log forwarding, but the procedural controls, trained personnel, legal chain-of-custody documentation, evidentiary handling procedures, and specialized forensic tooling required to maintain a legally defensible chain of custody are organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend provides several technical capabilities that support digital forensic investigations by capturing, preserving, and exporting network-level evidence. While vDefend does not manage chain-of-custody documentation or legal evidentiary procedures, it generates and retains the forensic artifacts that investigators rely on during incident analysis.

vDefend IDS/IPS captures and stores packet capture (PCAP) files associated with detected intrusion events, which can be exported in TAR format for detailed analysis and forensic investigation. IDS/IPS also provides a filestore capability that stores matched files to disk when a signature rule is triggered, and stores TLS/SSL certificates on disk for forensic analysis and threat investigation. These artifacts preserve the raw network traffic, file evidence, and certificate data surrounding a security event. The NDR Sensor extends this by recording raw network packets associated with detected intrusion events through its IDS Packet Capture capability.

Malware Prevention generates detailed analysis reports for both file-based and process-based (fileless) malware detections. The File Analysis Report and Process Analysis Report each support downloading screenshots and PCAP files from the inspection analysis. These artifacts document the behavior observed during sandboxing and can serve as evidence of malicious activity during a forensic investigation.

Network Detection and Response (NDR) correlates individual detections into campaigns using correlation rules that link related events across workloads. Campaign data includes detection types, identified threats, affected workloads, and mapped MITRE ATT&CK tactics. This correlated view helps investigators reconstruct the sequence and scope of an attack, connecting individual events into a coherent narrative. NDR campaign correlation rules link file transfer detections with command-and-control events, IDS drive-by events with subsequent malicious file transfers, and custom IDS signature events sharing the same signature ID on the same workload. Security Intelligence also detects and categorizes suspicious events using MITRE tactics and techniques, recording the number of occurrences during the selected time period.

The Distributed Firewall (DFW) and Gateway Firewall both support per-rule logging. Administrators can attach log labels to firewall rules, which tag matched traffic in log output for easier parsing in a log aggregator. These timestamped, attributable records of firewall rule hits provide evidence of network access patterns during and around a security incident. Security Explorer tracks compute entities that were in the inventory during the selected time period and separately identifies entities deleted from inventory, helping investigators establish a forensic timeline of asset activity.

The Security Services Platform supports role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Auditor role allows forensic investigators to review security data without the ability to modify it, supporting the integrity of the evidence under review. The Security Operator role monitors security systems and responds to security incidents.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports forensic investigation and evidence preservation through event logging, security-related audit trails, and protection group state tracking. PNR records operational information in log files that exclude sensitive information such as private keys and passwords, making these logs suitable for sharing with forensic investigators or external auditors without exposing credentials. PNR also logs certificate verification error messages in security-related log files, providing an audit trail of authentication events relevant to incident investigation.

PNR captures Info-level events when users include or remove datastores in protection groups, recording protection group membership changes that contribute to a chronological record of administrative activity. PNR tracks collection state for each

protection group to indicate which operational phase the group is in, including modifying, testing, replicating, or recovering, which gives investigators context for reconstructing administrative actions during an incident. The VCF Operations Recovery Plans Dashboard exposes PNR operational state for monitoring and after-action review.

Organizations performing forensic investigation should forward PNR log files to a centralized log aggregation system such as VCF Log Management to preserve evidence integrity beyond the appliance's local log retention. Chain of custody documentation, evidence handling procedures, and integration with broader incident response workflows remain organizational responsibilities outside PNR's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer visibility and reporting mechanisms that support an organization's incident documentation and status communication processes. The primary reporting tool is the Application Security Report, accessible under Application Monitoring in the Avi Controller UI. This report can be generated per virtual service and downloaded in PDF format, with report generation status visible on the Reports page. It produces a structured summary of WAF findings and pre-check results, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, trend summaries showing total and flagged requests, and overall application security posture. The Application Security Report is designed for security teams, executives, and auditors, providing audit-ready documentation of WAF activity that personnel can distribute to internal stakeholders as part of incident documentation workflows.

Avi generates structured alert events for security-relevant and operational conditions. The Alert feature processes system events and metrics against user-defined rules and generates alerts that initiate configured actions such as sending an email, a syslog message, or an SNMP trap, enabling integration with an organization's broader incident management tooling. Alert configurations define triggers with configurable parameters that determine when alerts fire and what actions follow. Metric-based alerts can be configured with multiple events combined using logical operators against specified thresholds. The Service Engine Analytics Anomalies Overlay generates alerts with a timestamp, a resource name identifying the object reporting the alert, and a severity level of High, Medium, or Low that determines whether additional notification is triggered. Avi also logs denial of service attack events with detailed context including event ID, attack count, threshold values, and alert level.

Avi Controller and Avi Service Engine log audit records for certificate validation failures, client authentication failures, SSH session establishment failures, and identification of initiators and targets of failed trusted channel establishment attempts. These audit records are forwarded to Events, Syslog, and Splunk, providing integration points for an organization's centralized incident monitoring and log aggregation infrastructure.

Avi does not provide an end-to-end incident management and tracking system. Defining incident categories, assigning ownership, tracking status through resolution, communicating updates to internal stakeholders at each stage, and maintaining incident records beyond Avi's application-layer logs and reports are organizational responsibilities. Avi's reporting and alerting capabilities feed the organization's incident management process as inputs alongside other tools and workflows.

Control CIP-008-6 3.1

> No later than 90 calendar days after completion of a Cyber Security Incident response plan(s) test or actual Reportable Cyber Security Incident response: 3.1.1. Document any lessons learned or document the absence of any lessons learned; 3.1.2. Update the Cyber Security Incident response plan based on any documented lessons learned associated with the plan; and 3.1.3. Notify each person or group with a defined role in the Cyber Security Incident response plan of the updates to the Cyber Security Incident response plan based on any documented lessons learned.

SCF Controls: IRO-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 3.1.1

> No later than 90 calendar days after completion of a Cyber Security Incident response plan(s) test or actual Reportable Cyber Security Incident response: 3.1.1. Document any lessons learned or document the absence of any lessons learned;

SCF Controls: IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 3.1.2

> No later than 90 calendar days after completion of a Cyber Security Incident response plan(s) test or actual Reportable Cyber Security Incident response: 3.1.2. Update the Cyber Security Incident response plan based on any documented lessons learned associated with the plan; and

SCF Controls: IRO-04.2, IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 3.1.3

> No later than 90 calendar days after completion of a Cyber Security Incident response plan(s) test or actual Reportable Cyber Security Incident response: 3.1.3. Notify each person or group with a defined role in the Cyber Security Incident response plan of the updates to the Cyber Security Incident response plan based on any documented lessons learned.

SCF Controls: IRO-04.2, IRO-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 3.2

> No later than 60 calendar days after a change to the roles or responsibilities, Cyber Security Incident response groups or individuals, or technology that the Responsible Entity determines would impact the ability to execute the plan: 3.2.1. Update the Cyber Security Incident response plan(s); and 3.2.2. Notify each person or group with a defined role in the Cyber Security Incident response plan of the updates.

SCF Controls: IRO-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VMware Live Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 3.2.1

> No later than 60 calendar days after a change to the roles or responsibilities, Cyber Security Incident response groups or individuals, or technology that the Responsible Entity determines would impact the ability to execute the plan: 3.2.2. Notify each person or group with a defined role in the Cyber Security Incident response plan of the updates.

SCF Controls: IRO-04.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 3.2.2

> No later than 60 calendar days after a change to the roles or responsibilities, Cyber Security Incident response groups or individuals, or technology that the Responsible Entity determines would impact the ability to execute the plan: 3.2.1. Update the Cyber Security Incident response plan(s); and

SCF Controls: IRO-04.2, IRO-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 4.1

> Initial notifications and updates shall include the following attributes, at a minimum, to the extent known: 4.1.1 The functional impact; 4.1.2 The attack vector used; and 4.1.3 The level of intrusion that was achieved or attempted.

SCF Controls: IRO-10.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 4.1.1

> Initial notifications and updates shall include the following attributes, at a minimum, to the extent known: 4.1.1 The functional impact;

SCF Controls: IRO-10.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 4.1.2

> Initial notifications and updates shall include the following attributes, at a minimum, to the extent known: 4.1.2 The attack vector used; and

SCF Controls: IRO-10.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 4.1.3

> Initial notifications and updates shall include the following attributes, at a minimum, to the extent known: 4.1.3 The level of intrusion that was achieved or attempted.

SCF Controls: IRO-10.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 4.2

> After the Responsible Entity's determination made pursuant to documented process(es) in Requirement R1, Part 1.2, provide initial notification within the following timelines: • One hour after the determination of a Reportable Cyber Security Incident. • By the end of the next calendar day after determination that a Cyber Security Incident was an attempt to compromise a system identified in the "Applicable Systems" column for this Part.

SCF Controls: IRO-10, IRO-10.2, IRO-10.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 4.3

> Provide updates, if any, within 7 calendar days of determination of new or changed attribute information required in Part 4.1.

SCF Controls: IRO-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 R1

> Each Responsible Entity shall document one or more Cyber Security Incident response plan(s) that collectively include each of the applicable requirement parts in CIP-008-6 Table R1 – Cyber Security Incident Response Plan Specifications. [Violation Risk Factor: Lower] [Time Horizon: Long Term Planning].

SCF Controls: IRO-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 R2

> Each Responsible Entity shall implement each of its documented Cyber Security Incident response plans to collectively include each of the applicable requirement parts in CIP-008-6 Table R2 – Cyber Security Incident Response Plan Implementation and Testing. [Violation Risk Factor: Lower] [Time Horizon: Operations Planning and Real-Time Operations].

SCF Controls: IRO-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 R3

> Each Responsible Entity shall maintain each of its Cyber Security Incident response plans according to each of the applicable requirement parts in CIP-008-6 Table R3 – Cyber Security Incident Response Plan Review, Update, and Communication. [Violation Risk Factor: Lower] [Time Horizon: Operations Assessment].

SCF Controls: IRO-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-008-6 R4

> Each Responsible Entity shall notify the Electricity Information Sharing and Analysis Center (E-ISAC) and, if subject to the jurisdiction of the United States, the United States National Cybersecurity and Communications Integration Center (NCCIC), 1 or their successors, of a Reportable Cyber Security Incident and a Cyber Security Incident that was an attempt to compromise, as determined by applying the criteria from Requirement R1, Part 1.2.1, a system identified in the “Applicable Systems” column, unless prohibited by law, in accordance with each of the applicable requirement parts in CIP-008-6 Table R4 – Notifications and Reporting for Cyber Security Incidents. [Violation Risk Factor: Lower] [Time Horizon: Operations Assessment].

SCF Controls: IRO-10.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 1.1

> Conditions for activation of the recovery plan(s).

SCF Controls: BCD-01.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's ability to define and meet Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) as part of business continuity and disaster recovery planning, though the organizational criteria for when to initiate BC/DR plans remain a governance responsibility.

VCF includes configurable RPO settings at multiple levels of the stack. vSphere Replication allows administrators to specify an RPO value directly through the replication specification's Rpo parameter, giving precise control over the maximum acceptable data loss window for replicated workloads. For VCF Operations for Networks deployments, replication can be configured for each node that requires protection, with recommended RPO values varying by deployment size. For migration scenarios involving VCF Operations HCX, delta synchronization with a configurable recovery point objective runs continuously after initial synchronization completes, maintaining data currency while waiting for a scheduled switchover. The VCF documentation explicitly notes that application disaster recovery may result in some data loss during failover depending on the configured RPO, which helps organizations understand the tradeoffs when setting their recovery criteria. Storage Policy Based Management (SPBM) provides an additional mechanism for encoding RPO requirements at the policy level: SPBM rules can define the maximum recovery point objective for Virtual Volumes objects and can include RPO settings within replication policy components, allowing administrators to associate data protection requirements directly with VM storage policies.

For RTO support, vSphere HA and vSAN stretched clusters provide automated failover capabilities that directly influence achievable recovery times. vSAN stretched clusters extend a single logical cluster across two availability zones with synchronous data mirroring between sites, providing near-zero RPO for site-level events since data is written to both sites before acknowledging the write. When the site disaster tolerance parameter is set to site mirroring, the cluster can tolerate one site failure and data remains accessible from the surviving site. vSphere HA restarts virtual machines on the remaining active site during a site failure. When vSphere HA admission control is configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, the platform can restart all VMs from one site on the other site. vSAN stretched clusters can also tolerate a witness host failure when one site is unavailable, provided the storage policy Site disaster tolerance rule is configured for Site mirroring. These automated recovery mechanisms give organizations measurable recovery time baselines against which to set their initiation criteria.

vSphere HA automatically restarts virtual machines on surviving hosts when a host failure is detected, providing fast recovery times for host-level failures. Admission control policies can be specified in VMware vCenter to reserve capacity and set failover share thresholds, coordinated with corresponding vSAN failure tolerance policy settings. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure by maintaining a live shadow instance of a virtual machine on a separate host, with no data loss or downtime during failover. When vSphere HA is used alongside DRS, the cluster can bring hosts out of standby mode or migrate virtual machines to defragment resources, helping to maintain the capacity required for HA failovers even when aggregate cluster resources are constrained.

VCF supports multiple disaster recovery deployment models at the application level. Disaster recovery with failover to a secondary site maintains operations during major disruptions. The platform documentation recommends combining real-time high availability with sitewide disaster recovery for maximum resilience. Disaster recovery can also be implemented for fleet-level components, and NSX Federation supports both planned and unplanned disaster recovery scenarios for Global Manager, extending recovery capabilities across the networking layer.

vSAN Data Protection provides snapshot-based recovery with configurable retention and scheduling through protection groups. Each protection group contains snapshot policies that define retention duration and snapshot scheduling intervals, allowing organizations to align snapshot frequency with their RPO requirements. Protection groups can be configured for

hourly snapshots with hour-based retention, and snapshots can be replicated to external targets for offsite protection. vSAN Distributed File System Snapshot provides the ability to retrieve data from files in the event of accidental deletion.

Changed Block Tracking (CBT) tracks modified disk sectors to enable incremental backups through VADP-integrated backup solutions. vCenter tracks changes on disk sectors, and VADP-based backup partner solutions can automatically perform backup, full restore, and registration of VMs. This reduces backup windows and supports tighter RPO targets by allowing backup tools to capture only the blocks that have changed since the last backup rather than performing full copies each time.

VCF's backup infrastructure supports recovery operations through scheduled backup jobs that capture the state of related management components at a common point in time. The documentation recommends implementing scheduled backups to prepare for critical failures, upgrades, or certificate updates of management components. VCF Operations backup can be configured to take a backup on state change, providing additional data protection for management plane components.

VCF Operations monitors the infrastructure and generates alerts when conditions change, which can inform decisions about when to activate contingency plans. VCF Operations supports creation and configuration of alert definitions to monitor infrastructure events and conditions, including log-based alerts. Alert definitions can be configured with criticality and impact metadata that reflects business priorities. VCF Operations also reports capacity and availability metrics through dashboards, including capacity remaining widgets and capacity summary views across all monitored environments, giving operations teams visibility into whether the environment is meeting its availability targets.

The VCF documentation explicitly states that organizations must plan and test disaster recovery strategies regularly to meet their recovery time objectives and recovery point objectives. While VCF provides the technical mechanisms for configurable RPO, automated RTO through HA and stretched clusters, snapshot-based data protection, incremental backup support, and infrastructure monitoring, the definition of specific initiation criteria for BC/DR plans remains an organizational responsibility. The thresholds that trigger activation, the governance processes around those decisions, and the alignment of technical capabilities with business requirements all require organizational planning beyond what the platform provides.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) enforces technical preconditions that must be satisfied before recovery operations can execute, providing the operational criteria layer for BC/DR plan initiation.

Recovery plan state management gates which operations are permitted at each stage. The state of a recovery plan is determined by the states of the protection groups within that plan, and the plan state determines which operations are allowed. Plans transition through defined states including Ready, Test in progress, Test complete, and recovery states. The recovery plan must be in a "failedOver" state before a reprotect process can be initiated, and the originally protected site must be operational before reprotection can proceed. This state-based gating is enforced both through the PNR interface and through the VCF Operations orchestrator plugin for PNR, which provides workflow-based verification of preconditions before initiating reprotect operations.

Two distinct recovery types define the criteria path for initiation: Planned Migration for orderly workload evacuation when both sites are operational, and Disaster Recovery for unplanned site failures. In PNR, the same recovery plan can be used for both disaster recovery and cyber recovery operations, consolidating the criteria framework across recovery scenarios. Most recovery plans require different configurations for emergency scenarios at the protected site versus planned migration of services from one site to another.

vSphere Replication provides the RPO configuration layer that determines what recovery state is available when initiation occurs. RPO can be configured using a slider with a range from 1 minute to 24 hours to set the acceptable period for which data can be lost if a site failure occurs. Per-VM retention policies using the Latest instances option support up to 200 recovery points. Recovery point configuration should balance storage consumption and snapshot consolidation time; the guidance recommends using the fewest recovery points that meets business requirements. When a recovery is initiated, administrators can select whether to synchronize recent changes from the source site before the recovery operation, reducing exposure to data loss, or to recover immediately using the latest data already available at the target site.

PNR integrates with VCF Automation through replication classes, which are preconfigured with RPO values that define the acceptable amount of data loss after a disaster. This allows organizations using VCF Automation to define recovery criteria at the replication class level for consistent policy application across workloads. Protection and Recovery Dashboards in VCF Operations provide monitoring of RPO status and vSAN snapshots and replication metrics, giving administrators visibility into whether recovery thresholds are being maintained across protection groups.

Recovery plan testing validates that the technical criteria for successful recovery are met before relying on the plan in an actual event. PNR records the result of test recovery operations, including cancellation status, in the recovery plan state. A recovery plan must also reflect the current state of its protection groups; if any members show a status other than OK, the problems must be corrected before any changes can be made to the plan.

The organizational criteria for when to declare a disaster and authorize plan initiation are governance responsibilities outside PNR's scope.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 1.2

> Roles and responsibilities of responders.

SCF Controls: HRS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 1.3

> One or more processes for the backup and storage of information required to recover BES Cyber System functionality.

SCF Controls: BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds.

VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a

separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages,

including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30

minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage

target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uuid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control CIP-009-6 1.4

> One or more processes to verify the successful completion of the backup processes in Part 1.3 and to address any backup failures.

SCF Controls: BCD-11, BCD-11.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or

periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through

the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period.

PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy

Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control CIP-009-6 1.5

> One or more processes to preserve data, per Cyber Asset capability, for determining the cause of a Cyber Security Incident that triggers activation of the recovery plan(s). Data preservation should not impede or restrict recovery.

SCF Controls: IRO-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support digital forensic investigations and evidence preservation, though the organization retains responsibility for chain-of-custody procedures, legal compliance, and formal forensic processes.

VCF Operations includes a Forensics Widget that can be added to custom dashboards for operational analysis during investigations. The widget displays data based on configurable filter sections, where each section progressively filters objects and passes the results to the next section. Administrators can search for and select specific objects in the environment on which to base the widget data, using text filters and tag-based filtering to narrow scope. The widget supports comparing data across two time periods, which is useful when investigating changes in environment behavior around a suspected incident. After adding the Forensics Widget to a dashboard, administrators should configure its options to tailor the output to the specific investigative needs of the dashboard users.

For evidence capture, VMware vCenter supports VM snapshots that record the memory, disk, and settings state of a virtual machine at a specific point in time. Reverting to a snapshot returns all of these to the exact state they were in when the snapshot was taken, making snapshots useful for preserving system state during an investigation. VM files (VMDKs, memory snapshots, log files) can also be collected and copied without powering down the workload, allowing incident responders to capture volatile and non-volatile evidence without altering the running state of the original workload. vSAN extends snapshot capabilities with immutable snapshots through its data protection service. An immutable vSAN snapshot is a read-only copy of data that cannot be modified or deleted, even by an attacker with administrative privileges. Once immutability mode is enabled on a protection group, it cannot be disabled by an administrator. This property helps protect forensic evidence from tampering. The `vmkfstools` command on VMware ESX hosts supports a `--chainConsistent` option that checks the entire virtual disk snapshot chain for corrupted links or invalid parent-child relationships, allowing investigators to verify the structural integrity of snapshot evidence before relying on it. VCF Automation exposes day-2 resource actions (Suspend, Create Snapshot, Delete Snapshot, Power On) through its API, allowing forensic preservation steps to be invoked programmatically as part of an incident response workflow. Day-2 action policies can be configured to entitle specific roles to perform snapshot actions and can be scoped at the organization level.

Audit logging across VCF components provides the evidentiary foundation that forensic investigators rely on. VCF Operations audit events capture operational details that facilitate security and compliance audits and provide information for conducting security forensics. The audit log feature in VCF Operations for Networks is always on and captures CRUD operations, login/logout events, and actions from the API, UI, and CLI. VCF Automation creates audit logs for reportable actions including catalog deployments, template operations, and day-2 actions. NSX audit logs use structured syslog fields with an `audit="true"` marker to identify security-related events, and a separate `nsx-audit-write.log` captures modification events. These audit records, combined with event logs from vCenter, ESX hosts, and VCF Operations, create a detailed trail of administrative actions, configuration changes, authentication events, and system state transitions. ESX hosts maintain audit records as a separately configurable logging feature from general event logs; these audit records must be explicitly activated and are not enabled by default, a step auditors should verify when assessing the forensic readiness of the platform.

For centralized evidence preservation, VCF components support log forwarding to external SIEM platforms via syslog. NSX remote logging supports TLS-encrypted transport with certificate verification. vSphere Supervisor similarly supports TLS-encrypted syslog forwarding with CA-based certificate verification. Forwarding logs to external systems with their own retention and integrity controls helps organizations maintain an independent, tamper-resistant record of events for forensic analysis.

Organizations deploying VCF should establish documented forensic procedures that define how to collect, handle, and preserve digital evidence from the virtualized environment. This includes defining who has authority to initiate evidence collection, how VM snapshots and log exports are stored to maintain integrity, and how the chain of custody is recorded from initial collection through analysis and potential legal proceedings. VCF provides the raw technical capabilities for evidence capture, audit logging, and secure log forwarding, but the procedural controls, trained personnel, legal chain-of-custody documentation, evidentiary handling procedures, and specialized forensic tooling required to maintain a legally defensible chain of custody are organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend provides several technical capabilities that support digital forensic investigations by capturing, preserving, and exporting network-level evidence. While vDefend does not manage chain-of-custody documentation or legal evidentiary procedures, it generates and retains the forensic artifacts that investigators rely on during incident analysis.

vDefend IDS/IPS captures and stores packet capture (PCAP) files associated with detected intrusion events, which can be exported in TAR format for detailed analysis and forensic investigation. IDS/IPS also provides a filestore capability that stores matched files to disk when a signature rule is triggered, and stores TLS/SSL certificates on disk for forensic analysis and threat investigation. These artifacts preserve the raw network traffic, file evidence, and certificate data surrounding a security event. The NDR Sensor extends this by recording raw network packets associated with detected intrusion events through its IDS Packet Capture capability.

Malware Prevention generates detailed analysis reports for both file-based and process-based (fileless) malware detections. The File Analysis Report and Process Analysis Report each support downloading screenshots and PCAP files from the inspection analysis. These artifacts document the behavior observed during sandboxing and can serve as evidence of malicious activity during a forensic investigation.

Network Detection and Response (NDR) correlates individual detections into campaigns using correlation rules that link related events across workloads. Campaign data includes detection types, identified threats, affected workloads, and mapped MITRE ATT&CK tactics. This correlated view helps investigators reconstruct the sequence and scope of an attack, connecting individual events into a coherent narrative. NDR campaign correlation rules link file transfer detections with command-and-control events, IDS drive-by events with subsequent malicious file transfers, and custom IDS signature events sharing the same signature ID on the same workload. Security Intelligence also detects and categorizes suspicious events using MITRE tactics and techniques, recording the number of occurrences during the selected time period.

The Distributed Firewall (DFW) and Gateway Firewall both support per-rule logging. Administrators can attach log labels to firewall rules, which tag matched traffic in log output for easier parsing in a log aggregator. These timestamped, attributable records of firewall rule hits provide evidence of network access patterns during and around a security incident. Security Explorer tracks compute entities that were in the inventory during the selected time period and separately identifies entities deleted from inventory, helping investigators establish a forensic timeline of asset activity.

The Security Services Platform supports role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Auditor role allows forensic investigators to review security data without the ability to modify it, supporting the integrity of the evidence under review. The Security Operator role monitors security systems and responds to security incidents.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports forensic investigation and evidence preservation through event logging, security-related audit trails, and protection group state tracking. PNR records operational information in log files that exclude sensitive information such as private keys and passwords, making these logs suitable for sharing with forensic investigators or external auditors without exposing credentials. PNR also logs certificate verification error messages in security-related log files, providing an audit trail of authentication events relevant to incident investigation.

PNR captures Info-level events when users include or remove datastores in protection groups, recording protection group membership changes that contribute to a chronological record of administrative activity. PNR tracks collection state for each

protection group to indicate which operational phase the group is in, including modifying, testing, replicating, or recovering, which gives investigators context for reconstructing administrative actions during an incident. The VCF Operations Recovery Plans Dashboard exposes PNR operational state for monitoring and after-action review.

Organizations performing forensic investigation should forward PNR log files to a centralized log aggregation system such as VCF Log Management to preserve evidence integrity beyond the appliance's local log retention. Chain of custody documentation, evidence handling procedures, and integration with broader incident response workflows remain organizational responsibilities outside PNR's scope.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 2.1

> Test each of the recovery plans referenced in Requirement R1 at least once every 15 calendar months: • By recovering from an actual incident; • With a paper drill or tabletop exercise; or • With an operational exercise.

SCF Controls: BCD-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 2.2

> Test a representative sample of information used to recover BES Cyber System functionality at least once every 15 calendar months to ensure that the information is useable and is compatible with current configurations. An actual recovery that incorporates the information used to recover BES Cyber System functionality substitutes for this test.

SCF Controls: BCD-11.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides backup and restore capabilities for its management components and workload layers, along with monitoring features that support organizations in verifying backup reliability. Routine backup testing itself requires organizational processes beyond what the platform automates.

VCF supports file-based and image-based backup methods for its core management components, including VMware vCenter, VCF Operations, and NSX Manager. VCF Operations automatically configures NSX Manager backup during the initial bring-up process, while file-based backup jobs for VCF Operations and vCenter must be configured separately. vCenter file-based backups are configured through the vCenter Management Interface of each vCenter instance. File-based backups can be stored on FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB servers, and the backup can optionally include Stats, Events, and Tasks data from the vCenter database to preserve historical audit records. Backup files support optional encryption with a password that must be provided again during the restore procedure. The platform recommends creating coordinated backup jobs that capture the state of related management components at a common point in time, so that restores can proceed from a consistent baseline. Scheduled backups should be implemented to prepare for critical failure scenarios, component upgrades, or certificate updates. vSphere Supervisor control plane backup and restore is activated through the vCenter backup feature in the vCenter Management Interface, which also protects VMware Kubernetes Service (VKS) cluster node VMs; this backup is accessible from the Workload Management UI. VKS cluster backup and restore operations for workloads and namespaces are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. This interface supports backup and restore of the entire cluster, selected namespaces from a backup, or specific resources identified by a label, and provides a "Restore from another cluster" function that allows a backup from a source cluster to be applied to a different target cluster. For Kubernetes workloads running on VKS, volume backup status and failures can be confirmed using the Velero CLI with the details flag.

Workload data on VKS clusters is protected through Velero integration. Velero supports two backup strategies: vSphere Plugin Snapshot, which captures persistent volumes at the block level and writes data directly to object storage without requiring a backup repository, and CSI Snapshot combined with File System Backup, which captures data at the file-system level with support for deduplication, compression, and encryption when those repository features are required. The CSI Snapshot and File System Backup methods also support incremental backup, where files that have not changed since the last backup are not re-uploaded. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. Third-party backup software can integrate with the CSI snapshot API to perform volume backup and restore operations against VKS clusters. Velero supports scheduled backup operations, enabling organizations to automate regular backup cadences as a foundation for routine testing.

Velero provides inspection capabilities that support backup verification. The `velero backup describe` command with the details flag reports completed and failed Restic volume backup entries along with source file references and pod identifiers, allowing administrators to diagnose backup failures before depending on a given backup for recovery. VKS cluster backup logs record backup failures with detailed error messages that include the process ID, user ID, group ID, and timestamp of the lock holder when a backup cannot proceed due to an existing exclusive lock. Scheduled backups relying on a deleted data protection account credential will fail on their next execution, and this failure creates a detectable gap in backup execution history visible in the backup monitoring interfaces.

For Kubernetes cluster state, etcd serves as the backing store for all cluster configuration and API objects. etcd supports two backup methods: built-in snapshot via the `etcdctl snapshot save` command (specifying the endpoint, CA certificate, client certificate, and client key) and volume snapshots. Snapshots can be restored from a previous backup file or from a remaining

data directory, with cross-patch-version restore supported for the same major.minor etcd version. During kubeadm upgrades, VKS automatically writes time-stamped backup folders for etcd data and control plane manifests to /etc/kubernetes/tmp, providing a rollback point that can be exercised as part of upgrade validation. Kubernetes guidance recommends that clusters verify backup restorability at regular intervals.

The platform includes built-in integrity verification as part of the restore process. Before restoring a vCenter instance from a file-based backup, the administrator must verify that the vCenter version retrieved from VCF Operations matches the version associated with the backup file. The backup must be of the same version as the vCenter appliance on which the restore will be performed. These version-matching checks help confirm that the backup data is consistent and compatible before a restore operation proceeds. Management component restore operations for VCF Operations, vCenter, and NSX can be tested by performing actual restores to validate backup data integrity.

VCF Operations provides monitoring capabilities that track backup success and failure across the environment. Backup failures are counted over time and grouped by error code, giving administrators visibility into recurring issues. Successful and failed inventory backups are also monitored. NSX tracks the total number of times backup configuration was updated, as well as backup successes and failures for both cluster backups and inventory backups. Alert notifications can be configured for backup failures under Platform Health Alerts, and administrators can track backup and restore process failures on the Infrastructure page under Settings, Infrastructure and Support, Overall Health section. NSX generates a BackupFailure alert when a scheduled backup operation fails. After resolving errors in VCF components, administrators can take on-demand manual backups to verify that the backup process is functioning correctly.

The VCF documentation recommends performing an initial on-demand backup after configuring VCF Operations to verify that backups complete successfully. This practice of performing a test backup after configuration is a form of validation, but it is a one-time recommendation rather than an automated recurring test.

For workload-level data protection, vSAN Data Protection allows snapshots to be managed through protection groups with configurable retention policies (duration and time units) and scheduling intervals. Native snapshots in vSAN Express Storage Architecture (ESA) use a B-tree structure instead of a chain structure, allowing more frequent backups and faster recovery than traditional vSphere snapshots. The native Snapshot Service is supported by vSAN ESA but not by vSAN Original Storage Architecture (OSA). Snapshot restore operations can be tested to validate data integrity.

VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions. VADP-based backup partner solutions can automatically perform backup, full restore, and registration of VM Service VMs on a Supervisor. These partner solutions typically include their own backup verification and integrity checking capabilities.

The vCenter API provides the RecoveryBackupJobBackupRequest data structure for programmatic backup operations, specifying backup location, protocol, and authorization details. The com.vmware.appliance.recovery.backup.validate appliance API command validates backup job parameters without starting the job, allowing administrators to confirm that backup configuration is correct before execution. This API access enables organizations to build automated backup testing workflows that trigger backups and verify completion status programmatically.

VCF directly provides backup scheduling, backup monitoring with failure alerting, on-demand backup testing, version-matching integrity checks, restore capabilities, workload-level snapshot management, and VKS cluster backup and restore through the VCF Automation Tenant Portal. Establishing a routine cadence for testing backup reliability and validating restore procedures requires organizational processes, runbooks, and scheduling that go beyond the platform's built-in automation.

VMware vDefend (Contributes)

VMware vDefend Security Services Platform (SSP) provides backup and restore capabilities for the security platform itself, offering several mechanisms that support routine verification of the backup process.

SSP includes a configurable backup schedule that supports recurring backups, which can be toggled on or off. Backup frequency can be set as weekly on a selected day and time, or as an interval-based schedule ranging from a minimum of 6 hours to a maximum of 720 hours. The SSP Backup History section displays backup operation status, showing Completed

when a backup operation is successful, giving operators direct visibility into whether scheduled backups are completing. When a scheduled backup fails, SSP generates a Scheduled Backup Error alarm to notify operators of the failure.

Backup and restore operations generate pod logs that record detailed error messages, including database query failures and volume attachment errors, supporting diagnosis of backup failures. If an operation becomes stuck in a FAILED or QUEUED state, operators can inspect cluster-api pods and backup pod status to troubleshoot the condition.

The SSP Installer data backup produces duplicate platform configuration data that can be restored in the event of hardware malfunctions, software malfunctions, data corruption, malware incidents, or unintentional data deletion. Restore operations require adequate storage on the target server, the same NSX instance that was onboarded at the time of backup, and the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored SSP environments is required to avoid service disruptions, including disruptions to NDR Sensors.

vDefend's contribution is to the operational health and backup completion visibility of the security platform itself. The control asks whether the organization routinely tests backups for reliability and integrity; vDefend provides the scheduling, status tracking, and alerting mechanisms that support such testing, but automated restoration testing and integrity validation of backup content require supplemental organizational procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing capabilities that exercise the recovery process and verify the integrity and availability of replicated data at the recovery site. The cadence and scope of routine testing remain an organizational practice.

Recovery plan tests run virtual machines on a test network and against a temporary snapshot of replicated data at the recovery site, isolating test execution from production data and from ongoing operations at either site. Tests can be run as often as needed and cancelled at any time without impacting production systems. Testing exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. PNR documentation recommends testing recovery plans before use for planned migration or disaster recovery to validate functionality before production execution, as failure to test may result in data loss during an actual disaster recovery. After a reprotect operation completes, running a test recovery verifies that errors are resolved before running a planned migration or disaster recovery. After testing completes, the cleanup capability removes test artifacts so they do not persist in the recovery environment.

Recovery plan testing can be configured to replicate recent changes to the recovery site so that the test exercises the latest copy of protected virtual machines, though this may increase synchronization time. PNR can generate and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup for audit trail purposes, providing a record of testing activity that administrators can reference.

PNR monitors protection group and recovery plan health, detecting critical issues including loss of connectivity to protected or destination sites, snapshot replication failure, and recovery plan malfunction. The Protection and Recovery management pack integrates with VCF Operations to enable data collection from PNR Cloud instances and provide centralized dashboarding of recovery telemetry.

Traditional backup testing capabilities, including platform component backup validation and VADP-based third-party backup verification, are provided by the underlying VCF platform (see VCF Coverage). Establishing a routine test schedule, defining acceptance criteria, and recording test outcomes for audit are organizational responsibilities that sit outside PNR's automated scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides automated backup capabilities, backup health monitoring, integrity-verification mechanisms, and on-demand restore tooling that support an organization's routine backup verification practices. A formal backup testing program itself requires organizational process.

DSM supports automated backups for databases with configurable backup schedules and retention periods. PostgreSQL databases use configurable settings for backup location, retention period, and backup schedule, controlled by the Enable

Automated Backups setting during database creation or through database settings afterward. DSM data service policies can be configured to require automated backups, allow them as optional, or disallow them, giving administrators a way to enforce backup coverage on databases under a policy. High Availability clusters require automated backups to be enabled before databases can be provisioned. Backup chain integrity depends on retaining the last full backup and all subsequent incrementals. If any incremental in the chain is deleted, DSM cannot restore the full data, which is a consideration when designing retention policy and backup chain management procedures.

Backup health is actively monitored. DSM validates the connection and operational status of the backup storage repository, verifies the bucket name, checks credential expiration, confirms certificate expiration dates, and validates that there is sufficient available repository space. Scheduled backup failure alerts notify administrators when a scheduled backup operation fails, and the monitoring framework supports metrics-based and status-condition alerts that identify critical failure conditions including database engine degradation, non-operational status, and automated or transaction log backup failure. Webhook payloads triggered by data service operation failures can be validated using the TEST function before deployment so that failure notifications reach the intended target. A trusted root certificate must be configured for each backup location used by a data service policy that requires or allows automated backups.

For data integrity verification, DSM PostgreSQL distributions include the amcheck extension at versions 1.2, 1.3, and 1.4 across the supported PostgreSQL builds, which provides functions for verifying relation integrity directly inside the database. Administrators can use amcheck to spot-check that a restored database's internal structures are sound after a recovery exercise, giving the testing program a database-engine-level data integrity check.

Administrators have several mechanisms to verify recoverability. DSM supports point-in-time recovery (PITR) that restores a backup at a specific point in time to a new database instance, with restoration possible to any point within the configured backup retention period. The restore creates a new database VM with a user-specified name and datastore location, so the test restore does not affect the source database. Deleted database backups remain available and can be restored to a newly created database VM at the most recent timestamp or to a specific point in time, supporting test restores of historic state. On-demand backups can be triggered manually for primary PostgreSQL databases to capture a known-good state before a planned change or verification exercise. DSM Provider VM recovery from backup is supported through the restore-provider command with the pgbackrest.conf path, which restores the Provider VM to the latest timestamp after a terminal failure during non-upgrade operations. The Provider VM requires a Provider Backup Repo to be configured before recovery is possible. Tenants can also restore a database to a specified restore point through the VCF Automation UI when DSM is consumed through VCF Automation.

While DSM provides the backup infrastructure, monitoring, validation, integrity-verification, and restore capabilities that form the technical foundation of a backup testing program, the organization must conduct scheduled restore tests against non-production environments to validate actual data recoverability, document the results, and maintain a formal testing cadence. DSM does not automate test restores to a separate environment, so these organizational procedures are required to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides backup and restore capabilities for the Avi Controller configuration, including automated scheduling, multiple storage destinations, pre-restore integrity validation, and post-restore verification.

The Controller backup scheduler automates periodic backup operations. Configuration data can be written to local storage on the Controller with a configurable retention count, or to a remote backup destination. Configuring a remote backup destination is recommended to protect against scenarios where the Controller cluster fails in a non-recoverable fashion. In VCF-integrated deployments, VCF Operations is used to configure the external backup server and storage path; by default, Avi Load Balancer backups are stored on the same server where VCF Operations appliance backups are stored. For single-node Controller deployments and when recovering from a complete VM or disk failure, enabling periodic external configuration backups is mandatory. Administrators can use the `show backups` CLI command to list available backup files, and the `export` command to capture a full system configuration or individual virtual service configurations. A backup must be

verified as taken prior to initiating any upgrade operation. After upgrades, backups should be stored with clear labeling that includes version and date.

Restore operations can be initiated through the CLI using the `import` command with the `keep_uuid` option to restore to an empty Controller, or through the REST API by attaching a configuration backup file and providing the decryption passphrase. Before any restore proceeds, the Avi Controller performs pre-restore validation checks that verify Controller Cluster readiness, upgrade operation status, ServiceEngineGroup upgrade status, backup configuration version compatibility, FIPS mode alignment between the backup and the target environment, the presence of required file objects, and configuration validity. These checks are logged with timestamps, including FIPS configuration status and image validation state. In VCF-integrated environments, the restored Controller instance must remain synchronized with the VCF Operations lifecycle.

After a restore completes, the Controller performs post-restore validation tasks that verify the successful restoration of configuration objects, including counts of restored Clouds and ServiceEngineGroups. This confirms that backup data has been correctly applied before the system returns to service.

Organizations should establish a defined process to periodically execute test restores, verify that recovered configurations are complete, and record results as evidence of backup program effectiveness.

Control CIP-009-6 2.3

> Test each of the recovery plans referenced in Requirement R1 at least once every 36 calendar months through an operational exercise of the recovery plans in an environment representative of the production environment. An actual recovery response may substitute for an operational exercise.

SCF Controls: BCD-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 3.1

> No later than 90 calendar days after completion of a recovery plan test or actual recovery: 3.1.1. Document any lessons learned associated with a recovery plan test or actual recovery or document the absence of any lessons learned;

SCF Controls: BCD-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 3.1.1

> No later than 90 calendar days after completion of a recovery plan test or actual recovery: 3.1.1. Document any lessons learned associated with a recovery plan test or actual recovery or document the absence of any lessons learned; 3.1.2. Update the recovery plan based on any documented lessons learned associated with the plan; and 3.1.3. Notify each person or group with a defined role in the recovery plan of the updates to the recovery plan based on an

SCF Controls: BCD-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 3.1.2

> No later than 90 calendar days after completion of a recovery plan test or actual recovery: 3.1.2. Update the recovery plan based on any documented lessons learned associated with the plan; and

SCF Controls: BCD-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 3.1.3

> No later than 90 calendar days after completion of a recovery plan test or actual recovery: 3.1.3. Notify each person or group with a defined role in the recovery plan of the updates to the recovery plan based on an

SCF Controls: BCD-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 3.2

> No later than 60 calendar days after a change to the roles or responsibilities, responders, or technology that the Responsible Entity determines would impact the ability to execute the recovery plan: 3.2.1. Update the recovery plan; and 3.2.2. Notify each person or group with a defined role in the recovery plan of the updates.

SCF Controls: BCD-06.1

Aggregate Coverage: Contributes

VCF (Contributes)

BCD-06.1 asks the organization to identify components whose changes could affect the execution of contingency plans, across five dimensions: personnel roles, business processes, deployed technologies, data repositories and data flows, and physical infrastructure. VCF addresses the deployed technologies, data flow, and physical infrastructure dimensions through infrastructure visualization, capacity management, network topology mapping, and configuration change assessment capabilities.

VCF Operations Capacity Management provides three sets of capabilities: assess, optimize, and plan. The what-if analysis feature allows administrators to define scenarios that model additions or removals of workloads from data centers, plan for new clusters, and evaluate physical infrastructure changes in both traditional and hyperconverged environments. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, giving both capacity management and operations teams visibility into current capacity and upcoming capacity requirements. Saved capacity planning scenarios run cumulatively, allowing planners to layer multiple changes and assess their combined impact. Because contingency plans depend on having sufficient infrastructure resources available, this planning capability helps organizations identify when technology or infrastructure changes could affect their ability to execute those plans.

VCF Operations delivers topology visualization through the Topology Graph Widget, which displays network topology with configurable toolbar options. These views show compute, storage, and network relationships across the environment, making it straightforward to identify which deployed technologies support which workloads and how they depend on one another. When infrastructure changes occur, VCF Operations reflects those changes in its topology views, helping contingency planners keep their documentation current.

VCF Operations for Networks provides a network map that displays a detailed network model of configured data sources, including end-to-end interactive topology maps showing paths between specified entities with physical and virtual devices. It also supports flow visualization between applications, application tiers, shared services, and the Internet. This visibility into data flows helps organizations understand how changes to network topology or workload placement could affect data flow paths relevant to contingency operations. These capabilities are relevant to identifying changes in deployed technologies and data repositories and data flows as described in the control.

For infrastructure configuration changes, the NSX Config Manager provides a structured workflow that includes validation, compliance checking, impact assessment, and remediation stages. This workflow helps organizations evaluate the impact of transport node configuration changes before they are applied, supporting the identification of technology changes that could affect contingency plan execution.

At the VMware ESX host layer, vSphere Configuration Profiles provides cluster-level configuration drift detection and pre-check operations that compute the remediation impact across all hosts before changes are applied. The Operation Details tab displays summarized or detailed information about remediation operations and any issues that occur, supporting review of host configuration changes that could affect contingency plan execution.

VCF Operations also provides flow planning capabilities covering the total network flows for which the system can perform security planning. Personnel who assess problems in the environment need to understand how the policies applied to objects affect the data that appears in VCF Operations, which implies that the platform supports role-based visibility into infrastructure state for operational staff involved in contingency planning.

VMware vCenter maintains a real-time inventory of all managed objects, and VCF supports linking vCenter instances for centralized inventory management. This centralized view allows teams to document the current state of the infrastructure for contingency planning purposes and to track changes to deployed technologies across the environment.

VCF does not address the personnel roles, business processes, or third-party service dimensions of this control. Those require organizational processes such as human resources management systems, business process documentation, and third-party vendor management programs that operate outside the scope of infrastructure management software.

VMware vDefend (Contributes)

VMware vDefend Security Services Platform supports identification of deployed technologies and data flows through its Segmentation Planning and Security Intelligence capabilities. Segmentation Planning requires the scope hierarchy to be defined before analysis begins, since it cannot be changed once an analysis is in progress; this makes early identification of infrastructure components a prerequisite for accurate policy coverage. The scope hierarchy assigns 1-5 columns for hierarchical scopes such as region, zone, environment, application, and tier, providing a structured inventory of data center assets. Security Intelligence generates recommended policies based on observed traffic and defined hierarchies, and tracks status changes for compute entities within the selected scope boundary during policy recommendation analysis, helping surface changes to deployed technologies as they occur.

Security Services Platform generates Security Segmentation Reports that include an Environment Overview summarizing inter-environment policies and rules, along with a segmentation score breakdown that evaluates whether workloads are protected by environment-specific policies such as Dev, Prod, and Test. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, providing visibility into data flows relevant to contingency planning (components 3 and 4 of the control). When the Monitoring capability is enabled, Security Intelligence checks for changes in the scope of input entities every hour, giving administrators a continuous mechanism to detect modifications to deployed technologies.

vDefend does not address contingency planning impacts related to personnel roles (component 1), business processes including third-party services (component 2), or physical infrastructure changes (component 5). Coverage across all five categories requires additional organizational processes and tooling beyond vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) tracks the technology and data-flow components that directly affect disaster recovery plan execution. Protection groups define which virtual machines are part of each contingency plan, and recovery plans organize these groups into sequenced execution workflows with defined dependencies and priority ordering.

Recovery plan state management provides ongoing visibility into whether contingency plans remain executable. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state determines which operations are permitted. When deployed technologies change in ways that affect DR readiness, such as a replication failure or a protection group becoming unavailable, the recovery plan state reflects that impact. Administrators can monitor plan status to determine which operations are permitted in each state.

The Recovery Plans Details Dashboard, surfaced through VCF Operations, tracks recovery plan status including protection group associations, execution history, failover and re-protection status, and cleanup completion. PNR dashboards also display a compliance status timeline that shows the historical change in compliance status for a selected recovery plan, giving administrators visibility into when compliance issues have occurred.

PNR generates events when recovery plan configurations are modified. A PlanEdit event is recorded when an existing plan is edited, providing a change record for plan configurations. PNR also signals a PlanPromptResponse event when a prompt step is closed during plan execution, supporting step-level execution tracking.

PNR does not provide mechanisms for tracking personnel roles, business process changes, third-party service dependencies, or physical infrastructure changes. These organizational and facility components are outside PNR's scope.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 3.2.1

> No later than 60 calendar days after a change to the roles or responsibilities, responders, or technology that the Responsible Entity determines would impact the ability to execute the recovery plan: 3.2.1. Update the recovery plan;

SCF Controls: BCD-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 3.2.2

> No later than 60 calendar days after a change to the roles or responsibilities, responders, or technology that the Responsible Entity determines would impact the ability to execute the recovery plan: 3.2.2. Notify each person or group with a defined role in the recovery plan of the updates.

SCF Controls: BCD-06.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-009-6 R1

> Each Responsible Entity shall have one or more documented recovery plan(s) that collectively include each of the applicable requirement parts in CIP-009-6 Table R1 – Recovery Plan Specifications. [Violation Risk Factor: Medium] [Time Horizon: Long Term Planning].

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-009-6 R2

> Each Responsible Entity shall implement its documented recovery plan(s) to collectively include each of the applicable requirement parts in CIP-009-6 Table R2 – Recovery Plan Implementation and Testing. [Violation Risk Factor: Lower] [Time Horizon: Operations Planning and Real-time Operations.]

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-009-6 R3

> Each Responsible Entity shall maintain each of its recovery plan(s) in accordance with each of the applicable requirement parts in CIP-009-6 Table R3 – Recovery Plan Review, Update and Communication. [Violation Risk Factor: Lower] [Time Horizon: Operations Assessment].

SCF Controls: BCD-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-3 R1

> Each Responsible Entity shall implement one or more documented process(es) that collectively include each of the applicable requirement parts in CIP-010-3 Table R1 – Configuration Change Management. [Violation Risk Factor: Medium] [Time Horizon: Operations Planning].

SCF Controls: CFG-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered configuration management capability spanning infrastructure state definition, drift detection, policy enforcement, and workload-level configuration automation.

VCF Operations includes a Configuration Templates feature that allows administrators to define a desired state as a set of configurations and then monitor the environment against those definitions. Configuration templates are created and managed through the Fleet Management > Configuration Drifts interface in VCF Operations, or through the Infrastructure Operations > Configurations > Policy Definition interface. VCF Operations supports managing global configuration templates across multiple vCenter instances, with the ability to assign templates to policies, activate them, and enforce them across the fleet.

The Configuration Drifts feature provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters, comparing the current vCenter value against the configuration template value for each instance. When a deviation from assigned template values occurs, a configuration drift notification alerts administrators. The Configuration Drift dashboard allows viewing and comparing drifts, and the Detect Drift function can be run across all configuration templates to display results in a consolidated drifts table. Drift detection can also be scheduled, enabling continuous detection of configuration deviations from the desired state without manual intervention.

Source control integration extends the configuration management program with version control, change tracking, and auditability. VCF Operations can synchronize configuration templates to and from a supported source control repository, enabling versioning, auditing, and controlled management of templates. This integration facilitates accurate configuration updates, supports change control with reviews, and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes.

VCF Operations provides policy management capabilities through the Infrastructure Operations Configurations module, including the ability to add, edit, and remove policies. The Configure Host Security Config Data workflow allows selective enforcement of host security hardening rules by configuring enforcement options for individual configuration elements. VCF Operations also supports export of configuration content, including configuration files, policies, compliance scorecards, and global settings, enabling backup and portability of configuration baselines. The config polling interval can be adjusted to control how frequently configuration data is collected from data sources, allowing administrators to tune the monitoring cadence to their operational requirements.

vSphere Lifecycle Manager (vLCM) provides image-based lifecycle management for ESX hosts, maintaining consistency by defining and enforcing approved host images across the fleet. vLCM manages all hosts in a cluster collectively with a single image, and clusters are assigned a base image and optional vendor add-on to define the desired state. When hosts deviate from the defined image, the cluster reports a non-compliant status, and remediation installs the approved image across all hosts in the cluster. vSphere Lifecycle Manager images are created in the vSphere Client and then imported into VCF using VCF Operations.

vSphere Host Profiles provide a complementary mechanism that captures the configuration of a validated reference host, including memory, storage, networking, and advanced settings, stores it as a managed object, and enforces it against other hosts to detect and remediate configuration deviations. vSphere Configuration Profiles extend this to the cluster level through JSON configuration documents that can be downloaded, edited offline, and imported, with built-in alarm support to notify administrators of configuration drift via email or SNMP traps.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) extends configuration management with a Kubernetes-native declarative model in which every cluster component, workload, and security policy is expressed as a YAML manifest. Kubernetes recommends that object configuration be stored in a source control system such as Git to enable change review processes and audit trails. VKS cluster security configurations are immutable and persistent by design, moving away from manual node-level configuration. ClusterClass configuration variables expose granular control over cluster infrastructure across releases, and the VKS Add-on Management feature provides a declarative API for add-on installation and configuration across a fleet of workload clusters through AddonConfig resources. The Cluster API, which underlies VKS cluster creation and management, provides declarative, Kubernetes-style APIs for the full cluster lifecycle including creation, configuration, and ongoing management. StatefulSet controllers use ControllerRevision objects to track historical configuration changes, supporting rollback and version tracing. Kubernetes Operators extend the declarative model to custom resources by interacting with the API server to reconcile the actual state of complex stateful applications and services against a declared desired state, enabling management of domain-specific workloads beyond native Kubernetes primitives. Kubernetes ConfigMaps separate application configuration from container images by storing configuration data as key-value pairs; they can be updated at runtime to propagate changes to running pods without requiring a pod restart. The KubeletConfiguration API type, managed through kubeadm, centralizes kubelet configuration across cluster nodes.

The Argo CD Supervisor Service implements a GitOps model for the consumption layer: all infrastructure and application configurations are expressed declaratively in a Git repository, and Argo CD can automatically apply changes from the repository to the target environment. Argo CD also manages VKS cluster lifecycle, with applications defined in Git referencing cluster lifecycle management manifests that target a specific namespace and Kubernetes API server endpoint, extending configuration-as-code governance from workloads to the clusters themselves. Argo CD continuously monitors the live application state against the desired state in Git, tracks per-resource sync status and health state, and reports deviations as OutOfSync. It provides both a CLI and a web-based UI for defining applications and visualizing cluster configuration drift, paralleling the drift-detection capability at the VCF Operations layer. Kustomize, available as a Kubernetes-native configuration management tool, transforms base resource manifests through declarative patching, field customization, and resource composition, enabling environment-specific variation without modifying source manifests. VKS Cluster Management Policies use the open-source OPA Gatekeeper as the policy engine for Security, Registry, Mutation, and Custom policy types; custom Security Policy templates allow organizations to fine-tune security context parameters and governance controls to their specific requirements. Security Technical Implementation Guides (STIGs) for Supervisor and VMware Kubernetes Release (VKr) deployments are available through Tanzu STIG Hardening, providing a structured configuration baseline for organizations building a configuration management program across the full VCF stack.

VCF Automation extends configuration management to workloads through integration with Ansible Open Source, Ansible Automation Platform, and Puppet Enterprise. Ansible integration is configured through Infrastructure > Connections > Integrations > Add Integration > Ansible Tower, and allows automated configuration management of VM-based applications deployed on the platform. Puppet Enterprise integration requires establishing a connection between the external Puppet system and the VCF Automation instance and is available on all projects by default. VCF Automation policies apply to both current and new deployments, and the Provisioning Service API allows programmatic integration and centralization of configuration properties.

VMware Private AI Services (PAIS), formerly Private AI Services, provides structured, configurable mechanisms that organizations can apply as part of a configuration management program for AI infrastructure on VCF.

The PAISConfiguration Custom Resource Definition (CRD) is the central PAIS configuration artifact. Administrators define PAIS settings in a YAML file compliant with the PAISConfiguration CRD, with sections for storage policy, CA trust bundles, PostgreSQL database connection, OIDC provider integration, and ingress service type. Configuration is managed using kubectl to update or patch the PAISConfiguration custom resource. Client TLS configuration references CA bundles for OIDC provider and Harbor authentication, with trust bundles supplied through ConfigMap resources referenced in the spec.clientTls.caBundleRefs section. The documentation recommends organizing CA trust bundles per application and monitoring them for certificate expiration so renewals are applied before associated certificates expire. When a CA certificate is selected and added from the namespace, PAIS is updated with a new ConfigMap resource.

Harbor Registry integration provides configuration control points for AI model distribution and lifecycle management. PAIS deployment uses Harbor replication rules with configurable filters, target namespaces, and trigger mode controls, including manual trigger mode for explicit replication runs. Disconnected (air-gapped) environments use a Bastion and Admin host pattern for PAIS setup, with replication configured to a destination registry aligned to organizational requirements.

The VCF Automation Provider Management surface manages region configuration and quotas for PAIS deployments. Provider administrators configure regions by selecting an NSX Manager instance integrated with the vCenter instances for the region, then assign region quota based on the zones selected for one or more supervisors. Regions are associated with supervisor clusters for PAIS deployment. VCF Automation aggregates zones with the same name across multiple supervisors in a region, combining their CPU, memory, and reserved VM class resources and presenting them as a single unit at the region level.

VCF Automation provides catalog items for provisioning AI workloads, including Deep Learning VMs and GPU-accelerated VMware Kubernetes Service (VKS) clusters, through a self-service catalog organizations configure to their deployment standards. The PAIS Quickstart generates blueprints that can be customized for deployment on VCF Automation. Passwords entered in the PAIS Quickstart, including the private container registry password and proxy password, are saved as secrets in VCF Automation rather than embedded in catalog item definitions. PAIS Data Services Manager (DSM) database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes.

PAIS observability is configured through the same PAISConfiguration custom resource. Prometheus runtime metrics collection is activated by uncommenting the `spec.observability.prometheusRuntime` section and supplying a storage class and configurable metrics retention period; LLM traces can be exported to an OpenTelemetry Collector through the same configuration path. VI administrators can visualize PAIS controller pod operation metrics in VCF Operations, with Telegraf user configuration stored in a `telegraf-user-config` ConfigMap in the `vmware-system-monitoring` namespace. The VCF Consumption CLI provides a command-line interface for cluster management capabilities through a plugin installation command, giving administrators a scriptable surface for repeatable PAIS workload operations.

VMware vDefend (Contributes)

VMware vDefend provides configuration management mechanisms for its network security policy infrastructure, contributing to an organization's broader configuration management program.

The vDefend distributed firewall (DFW) supports a draft configuration management workflow that separates policy authoring from activation. Administrators prepare and review firewall policy changes in draft form before publishing them to the enforcement plane. Draft configurations can be saved as a new configuration or as an update to an existing one, and can be locked with an optional comment requirement to enforce change control discipline. Auto drafts and manual drafts can be cloned and saved, with the option to edit the name and lock the configuration with a required comment. Export options include the published configuration, an auto-saved draft, or a manually saved draft. The Publish function commits a draft and makes it active; the Revert function returns the environment to the previous published configuration. Auto-drafts and saved manual drafts can be loaded and published at any time, giving administrators the ability to restore a prior policy state after a change.

In federated deployments, a Global Manager provides centralized configuration management across distributed Local Manager sites. IDS/IPS signatures, profiles, Distributed Firewall and Gateway Firewall policies, oversubscription settings, and syslog settings can all be managed centrally from the Global Manager and applied across all Local Managers. This enables consistent security policy baselines across geographically distributed environments.

The vDefend also supports full rollback capability, which deletes newly added policies and reverts the security configuration to its prior state in reverse order. This applies to broader policy migration and transition scenarios, beyond the draft-level Revert function.

Security Services Platform (SSP) extends configuration management to vDefend's detection and prevention services. The SSP deployment wizard conducts validations before implementing configuration changes to confirm that configurations are correct and compatible. The SSP Configuration Database is the storage layer for system settings and configurations. SSP also extracts

all IDS policies, rules, and security profiles to support multiple remediations, clean up stale policies, and suggest policies that do not conflict with each other. IDS/IPS remediation policies can be verified by navigating to Security > IDS/IPS & Malware Prevention > Emergency Threat Rules. Security policies defined within SSP are propagated and enforced across Bare Metal servers as well, extending policy management scope beyond virtual workloads.

Administrators can use flow inactivity data and Security Intelligence recommendations to identify and remove unused or outdated DFW policies and rules, supporting configuration lifecycle hygiene. Security Intelligence's segmentation posture assessment stores data in a Configuration Management Database (CMDB) within the Security Services Platform, maintaining application context and workload attributes. Segmentation planning supports importing workload context from flat files containing IP addresses, subnets, virtual machines, logical segments, and organizational roles, allowing administrators to establish a baseline for policy configuration decisions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides several configuration management mechanisms specific to disaster recovery operations.

The Configuration Import/Export Tool allows administrators to export and import PNR configuration data, including inventory mappings, recovery plans, protection groups, and related objects, into XML files. This capability supports configuration versioning and backup by capturing the complete disaster recovery configuration state: server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information with Storage Replication Adapter details. The tool provides schema support for programmatic configuration management and offers multiple export and import modes. Administrators can use a properties file (`srm_configuration.properties`) to simplify or automate the import process, invoke the `import-export.jar` utility interactively using the `--importInteractive` flag with parameters for the XML file path, delay, and retry count, or use a script-based method that exports configuration data without requiring credential entry. Exports can be integrated directly into recovery plans as callout steps, so configuration data is captured automatically during recovery operations.

The Protection and Recovery Appliance Management Interface allows administrators to configure network settings on the appliance after initial deployment. PNR upgrade procedures preserve advanced settings and configurations from the prior release, maintaining configuration continuity across version changes. Advanced settings can also be modified through the Site Pair > Configure > Advanced Settings interface in the product UI.

The DR IP Customizer tool provides structured management of network configuration for protected virtual machines. It generates CSV files describing the IP properties of protected VMs grouped by site and recovery plan, which administrators can modify with recovery-site-specific values and reapply. This structured approach supports repeatable and auditable network configuration changes during recovery operations.

Storage Replication Adapter (SRA) configuration management is supported through the Appliance Management Interface, which provides a Download Configuration Archive function for retrieving and importing SRA configurations. PNR also rescans storage arrays every 24 hours by default to detect configuration changes.

In deployments that integrate with VCF Automation, Provider Administrators install PNR in desired regions, pair regions together, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. The VCF Operations Orchestrator Plugin for Protection and Recovery requires administrator login to access and execute workflows for managing site mappings and network configurations.

Access to PNR configuration changes is governed by role-based access control. Granular permissions restrict who can modify advanced settings, manage array managers, and create, modify, or execute protection groups and recovery plans, supporting separation of duties for configuration change management.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports configuration management by providing structured mechanisms for defining, applying, and monitoring the configuration of database infrastructure components. Administrators interact with DSM through two primary interfaces: the Provider UI for system-wide settings and the vSphere Client for infrastructure configuration. The

Settings view in the Provider interface is the central location for managing system-wide settings, including LDAPS integration, SMTP configuration, and directory service settings. The Administrator Dashboard displays at-a-glance metrics covering the number of configured users, their assigned roles, and the types and counts of provisioned database services, giving administrators a current view of deployment state.

Infrastructure configuration in DSM is governed by infrastructure policies. These policies define which VM classes are available for database VMs, which storage policies apply, and which vSphere clusters and namespaces are used during provisioning. Infrastructure policy configuration requires that placements, storage policies, VM classes, and IP ranges be correctly configured for valid policy status. Policies that are actively in use by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added; unused policies can be changed at any time. VM classes are configurable resource profiles that specify vCPU cores and memory allocation, and can be defined to match organizational capacity standards. Infrastructure policies also establish guardrails that restrict the quantity and quality of resources DSM users can consume from vSphere clusters. Configuration tasks performed during initial deployment include configuring IP pools, defining VM classes, assigning user permissions, creating infrastructure policies, and selecting storage policies.

Database-level configuration is managed through the database instance settings. DSM allows configuration of database instances using either custom or default configuration profiles, with configuration properties varying by database type (PostgreSQL, MySQL, MinIO, or SQL Server). DSM automates provisioning, backups, and security patch application for managed database instances. After initial provisioning, database VM resource configuration can be adjusted at runtime. Optional database configuration parameters for PostgreSQL and MySQL databases can be added or removed after database creation. Maintenance windows can be configured to control when software updates and database option changes are applied, providing a mechanism for scheduled, controlled configuration changes.

DSM provides a Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, for configuring automatic software updates of the DSM plug-in within defined maintenance windows. The DSM controller manages component and feature dependencies through status monitoring and automated remediation.

When integrated with VCF Automation, DSM supports data service policies that define and enforce configurations for each tenant or organization. These policies can be enforced across different namespaces and namespace labels to maintain a uniform configuration posture. The Consumption Operator automates database deployments based on predefined infrastructure and backup policies, reducing the scope for manual configuration drift.

DSM provides visibility into configuration activity through the Operations tab, which displays the progress of database configuration changes, resource changes, and disk extension tasks. A support bundle can be created and downloaded to collect diagnostic information for troubleshooting system configuration failures. DSM system configuration is also managed through a `dsmsystemconfig` Custom Resource within the gateway, which can be inspected via SSH access to the appliance VM to review directory service status and configuration details.

DSM's contribution to a configuration management program is at the platform level: it provides technical mechanisms for defining baseline configurations through policies and VM classes, enforcing them during provisioning, and tracking changes through operational visibility. The broader configuration management program, including change control processes, configuration baseline documentation and approval, configuration audits against external standards, and periodic review cycles, must be established and maintained by the organization.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides several mechanisms that support the implementation of configuration management controls across the application delivery layer.

The Controller maintains a centralized Configuration Database that stores all configuration information including tenants, virtual services, pools, policies, and accounts. This is the single source of truth for all system settings. When an administrator makes a change through the web interface, CLI, or REST API, that change is automatically propagated to all Controller cluster members, so any node can assume leadership with a complete and current configuration.

The Controller CLI provides direct access to the full configuration surface. The `configure systemconfiguration` command allows administrators to modify system-wide parameters including DNS, NTP, portal settings, and cryptographic algorithm configuration, with changes synchronized to Service Engines. The `configure` command covers a broad range of objects including virtual services, pools, health monitors, authentication profiles, application profiles, and policy sets, and supports creation, modification, and deletion of those objects. The REST API exposes comparable capabilities programmatically, including the `PUT api/systemconfiguration` endpoint for system-wide settings and the `/api/cloud` endpoint for cloud configuration resources.

Configuration management in Avi can be automated through the Ansible `aviconfig` role, which allows configurations to be expressed as structured dictionaries and applied in a repeatable manner, reducing the need for multiple individual task definitions. The Controller supports on-demand configuration backup and restore, enabling disaster recovery and configuration migration across Controller instances.

In the 9.1 VCF integration, Avi distinguishes between two operational modes: Provider-Managed Mode, where the provider administrator manages Service Engine Group settings including scale-out, CPU, and memory configurations; and Organization-Managed Mode, where the organization administrator manages their own Service Engine Group configurations and infrastructure settings. This separation clarifies ownership and scope of configuration responsibilities within a shared VCF deployment. After upgrading Avi components, a drift check should be performed against VCF Operations, vCenter, and NSX Manager to verify configuration consistency across the stack.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) configuration is customized through the `AddonConfig` resource, a Supervisor namespace-scoped resource that supports modification of parameters such as logging level and shard virtual service size.

The Config Events overlay in the Service Engine Analytics view allows operators to correlate configuration changes with observed traffic behavior, supporting investigation of the impact of individual changes. Avi Load Balancer events provide the building blocks for configuration automation workflows.

Organizations should define change control procedures, assign ownership of configuration baselines, and determine which changes require approval before these mechanisms can function within a formal configuration management program. Avi provides the technical instruments; the program structure requires organizational governance.

Control CIP-010-4 1.1

> Develop a baseline configuration, individually or by group, which shall include the following items: 1.1.1. Operating system(s) (including version) or firmware where no independent operating system exists; 1.1.2. Any commercially available or open-source application software (including version) intentionally installed; 1.1.3. Any custom software installed; 1.1.4. Any logical network accessible ports; and 1.1.5. Any security patches applied.

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure.

components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to

restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgm_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the

postgrescluster-allow-non-ssl-system-users setting in the advanced-system-config ConfigMap within the dsm-system namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control CIP-010-4 1.1.1

> Develop a baseline configuration, individually or by group, which shall include the following items: 1.1.1. Operating system(s) (including version) or firmware where no independent operating system exists;

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control CIP-010-4 1.1.2

> Develop a baseline configuration, individually or by group, which shall include the following items: 1.1.2. Any commercially available or open-source application software (including version) intentionally installed;

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control CIP-010-4 1.1.3

> Develop a baseline configuration, individually or by group, which shall include the following items: 1.1.3. Any custom software installed;

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the `advanced-system-config` ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control CIP-010-4 1.1.4

> Develop a baseline configuration, individually or by group, which shall include the following items: 1.1.4. Any logical network accessible ports; and

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control CIP-010-4 1.1.5

> Develop a baseline configuration, individually or by group, which shall include the following items: 1.1.5. Any security patches applied.

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control CIP-010-4 1.2

> Authorize and document changes that deviate from the existing baseline configuration.

SCF Controls: CFG-02.7

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's process for documenting, assessing, and approving or denying deviations from standardized configurations. These capabilities span compliance monitoring, deviation detection, change approval workflows, and source control integration, though the broader governance process of risk-assessing and formally approving deviations requires organizational procedures beyond the platform itself.

VCF Operations includes a compliance benchmarking framework that measures the settings on managed objects against a set of standard rules, regulatory best practices, or custom alert definitions. Organizations can define what constitutes their standardized configuration baseline by creating custom compliance benchmarks, which are configured through a multi-step process of naming, selecting alert definitions, and activating policies. Up to five custom compliance score cards can be created to track adherence. These score cards provide a breakdown of the total number of objects that are compliant and non-compliant for each benchmark, giving administrators a clear view of where deviations exist. The compliance score for each object is based on the most critical of the violated standards, helping administrators prioritize which deviations to address first. Custom compliance benchmarks can be exported and imported in XML format across VCF Operations instances, allowing organizations to define a standard once and reuse it consistently. The VCF security baseline can be used to evaluate both default and non-default configurations, which helps organizations identify where deployed settings differ from the expected standard. VCF documentation also acknowledges that configuration decisions should be tailored to individual customer environments rather than applying uniform standards across all customers, recognizing that legitimate deviations are expected.

When an object deviates from its assigned configuration template values, VCF Operations generates a configuration drift notification identifying the specific changes. The Configuration Drifts view shows what changed, when it changed, and how the current state compares to the desired values. The Detect Drift function detects configuration drift across all configuration templates and displays results in the Drifts table, and the Configuration Drift dashboard allows viewing and comparing drifts to identify settings that have changed. Drift details show the comparison between the current VMware vCenter value and the configuration template value for each instance.

At the VMware ESX host level, vSphere Host Profiles provide an automated and centrally managed mechanism for host configuration and configuration compliance, and scheduled compliance check automation can detect whether any configuration parameters differ from those specified in the host profile. vSphere Configuration Profiles extends this to the cluster level, displaying host settings with their respective desired and current values to identify the cause of noncompliance when reviewing compliance results.

Integrating VCF Operations configuration drift templates with a source control repository supports versioning, auditing, change control through reviews, and continuous integration workflows. When an organization uses this integration, accepting a deviation can be handled as a reviewed and approved commit to the configuration template, providing a documented approval trail. However, this workflow depends on the organization establishing the source control integration and review process. A supported source control solution must be used for this integration.

NSX provides a compliance report that identifies non-compliant configurations, including details such as the non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. This structured reporting helps document the specifics of each deviation and supports risk assessment by making the scope and nature of non-compliance visible.

Each VCF Operations policy can inherit settings from other policies, allowing organizations to customize and override analysis settings, alert definitions, and symptom definitions for specific object types. This provides a mechanism to document approved configuration variations at the policy level.

For changes to deployed resources, VCF Automation provides approval policies that require designated approvers to review requests before resources are consumed or changes are made to provisioned items. Approval policies can be filtered based on deployment criteria that apply to deployments and day 2 actions, and the enforcement type can be set to HARD to enforce mandatory approval before any deployment action proceeds. When multiple valid approval policies exist and the approvers are different people, all approvers are added to the approval chain. Organizations can configure these policies to require project administrator review of all changes to deployed catalog items, particularly those used by many users, to gate potentially impactful modifications. These policies gate new changes and modifications but do not directly address the review of detected configuration drift. The decision to remediate a detected deviation or accept it as an approved exception is made by the administrator outside of any formal VCF workflow.

VCF provides strong deviation detection, documentation, and change approval capabilities, but the risk assessment and formal approve/deny process for deviations depends on organizational governance layered on top of VCF's tooling.

VMware vDefend (Contributes)

VMware vDefend provides configuration validation, anomaly detection, and assessment capabilities that support the broader organizational process of managing deviations from standardized configurations. The formal approval and denial workflow for configuration changes is handled at the VCF platform level through VCF Operations and VCF Automation.

The Security Services Platform (SSP) deployment wizard conducts thorough validations before implementing any configuration changes, verifying that configurations are correct and compatible with the current environment. This pre-implementation validation step helps identify potential deviations from expected configurations before they take effect.

Rule Analysis, a feature of the Security Services Platform, identifies anomalies in firewall rule sets including duplicate rules where two rules share the same configuration and action, and shadowed or conflicting rules that may represent unintended deviations from the intended security policy. Administrators can use Rule Analysis reports to review rule anomalies and update configurations accordingly. Rule Analysis depends on configuration synchronization from NSX Manager; a failure in that synchronization is indicated by an alarm in the NSX UI, allowing administrators to detect when analysis results may not reflect current state.

Security Intelligence, part of the Security Services Platform, provides assessment and monitoring tools that help administrators evaluate their security configuration against desired baselines. The Security Segmentation Report supports two scoring modes: Strict mode applies stricter penalties for allowed unidentified traffic and provides a more stringent posture assessment, while Relaxed mode applies less severe penalties and is suited to environments where strict application rules have not yet been fully implemented. The segmentation score breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, making configuration gaps visible. Security Intelligence also tracks new configurations per configuration type on an hourly basis, providing a running count of changes across the platform.

When changes occur to group membership or policy scope, Security Intelligence displays a change-detected indicator prompting administrators to review the changes and rerun policy recommendations. Security Intelligence policy recommendations are generated from observed traffic flows and must be reviewed for accuracy before publishing to vDefend, creating a structured review step between traffic analysis and enforcement. The Security Policies view for each environment pair displays the number of unpublished recommendations, giving administrators visibility into pending configuration decisions.

The staged segmentation workflow supports a measured approach to configuration changes. Administrators can publish environment pair protection rules in a permissive mode first, allow traffic analysis to complete, and then review Security Intelligence policy recommendations before committing to enforcement rules. This staged process provides a structured mechanism for evaluating proposed configuration changes against observed traffic patterns before applying them.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) includes a Configuration Import/Export Tool that exports the complete system configuration as structured XML, covering server version, build number, local and remote site names, inventory mappings,

placeholder datastores, advanced settings, and array manager information including Storage Replication Adapter (SRA) details. The exported XML can be validated against a bundled XSD schema to confirm structural integrity, and PNR supports programmatic configuration management through the same schema framework. Organizations can use these export capabilities to capture baseline snapshots of approved configurations and compare subsequent exports against them to identify deviations.

PNR configuration files contain settings that affect the security of the environment, and incorrect settings can affect proper functioning. The system configuration is defined in the `va-configurator.xml` file and is modifiable through the Advanced Settings interface on the Site Pair tab. When PNR settings are modified, the same changes must be applied to all instances on both the protected and recovery sites to maintain consistency. This consistency requirement creates a visible signal when partial or unauthorized modifications have occurred.

Replication mappings can be tested on demand for individual mappings or all existing mappings simultaneously to validate that the current replication configuration matches expected state. After reprotect operations, PNR recommends conducting tests to confirm that the new site configuration is valid. After upgrades, protection groups and recovery plans must be verified to confirm continued operational capability. The Clean Room Orchestrator's Monitoring page shows the operational status of configurations related to recoverability and supportability, providing visibility into whether isolation environment configurations are in an expected state.

These capabilities provide the technical foundation for identifying when protection and recovery configurations deviate from established baselines. The processes for formally documenting deviations, assessing risk, and approving or denying exceptions require organizational governance outside PNR's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configuration tracking and change documentation capabilities that support the governance processes organizations use to manage deviations from standardized configurations.

The Avi Controller maintains configuration event logs that record changes made through the web interface, CLI, or REST API. Each configuration change entry displays a difference comparison of the previous configuration versus the new configuration, with additions highlighted in green and removals highlighted in red. The Config Events overlay in Service Engine Analytics correlates these configuration changes with traffic metrics, allowing administrators to determine whether a specific change caused a traffic anomaly or change in application behavior. The Avi documentation recommends that configuration changes be made through the Avi UI and verified by checking the event logs to confirm what was created or changed.

When a configuration change is made on any Controller cluster node, that change is automatically propagated to all cluster members, maintaining a consistent authoritative configuration state across the cluster. This means the event trail reflects the running configuration of the entire deployment.

For WAF policy management, Avi provides an explicit recommendation acceptance mechanism. After WAF learning mode or anomaly analysis identifies false positives in the active configuration, administrators can review proposed changes and explicitly accept or deny each recommendation. This discrete accept-or-deny step within WAF policy management provides a documented approval action for this category of configuration change.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) uses Custom Resource Definitions (CRDs) to perform syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. `RouteBackendExtension` resources include a `STATUS` field indicating whether the configuration was Accepted or Rejected, which administrators should check to identify and resolve configuration issues before they affect production traffic.

The audit trail and event records Avi generates supply the raw documentation that an organization's configuration deviation management process requires. The process itself, including defining the authoritative configuration baseline, routing proposed deviations through a risk assessment and approval workflow, and maintaining a register of approved exceptions, is an organizational governance activity that must be defined and operated by the organization outside of Avi.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.3

> For a change that deviates from the existing baseline configuration, update the baseline configuration as necessary within 30 calendar days of completing the change.

SCF Controls: CFG-02.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated lifecycle management (LCM) capabilities that directly address the need to review and update baseline configurations on a regular cadence, in response to changing conditions, and as part of system component installations and upgrades.

VCF follows a structured release model with major, minor, maintenance, and patch releases. Major and minor releases advance all components to a new, consistent feature level, while maintenance releases are scheduled, cumulative updates focused on platform stability and support. These maintenance releases provide bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. Patch releases address time-sensitive security and catastrophic issues between scheduled releases. This tiered release structure provides a natural cadence for reviewing and updating baseline configurations at least annually and more frequently when conditions require it.

VCF's lifecycle management simplifies and automates the process of applying updates and patches to the software components within the VCF stack. When updating to a maintenance release version, fleet-level management components such as VCF Operations fleet management must be updated before updating core components in individual VCF instances. Specifically, the VCF Operations fleet management appliance must be patched to the desired target version before the remaining VCF management components can be upgraded or patched to that version. Administrators can also selectively apply patches to specific VCF and VMware ESX components based on the impact on their environment and operational needs.

When system component installations and upgrades occur, VCF includes built-in mechanisms to review configurations as part of the process. Pre-checks verify component connectivity, version compatibility, and component status among other environment readiness checks before an upgrade proceeds. Administrators are directed to run an upgrade assessment before upgrading a management component to identify potential issues. Configuration updates must be performed during a maintenance window, and configuration tasks should be completed only after the upgrade process finishes. After an upgrade completes, VCF performs post-upgrade auto-reconciliation of configuration drift fixes, which automatically detects and addresses deviations from expected baselines introduced during the upgrade.

After a VCF Operations upgrade, administrators should review changes in upgraded alert definitions, symptom definitions, recommendations, and views to determine whether to retain previously modified versions or use the upgraded versions. Newly added or updated default policies, including new alerts and symptoms, should be analyzed and modified to optimize them for the current environment.

For ongoing operational management, VCF provides configuration guidance where a configuration choice exists for components, with documented requirements and recommendations available for each choice. As an operations best practice, VCF documentation directs administrators to keep the infrastructure up to date by running current component versions. vSAN system baselines provide the best available release to keep hardware in a supported state, and vSAN build recommendations include all necessary drivers and patch updates for the recommended release to keep each cluster at the current hardware compatibility status or better. ESX host updates follow a cumulative model: the most recent update contains the patches from all previous releases, so verifying that a host is running the latest update is sufficient to confirm that all prior patches have been applied. vSphere Lifecycle Manager supports dynamic baselines, which allow administrators to manually include or exclude specific patches from a baseline, providing granular control over which updates are applied to ESX host clusters. VMware vCenter exposes a REST API endpoint for checking pending updates from custom or online sources, enabling automated monitoring for available configuration and software updates.

VCF Operations provides compliance scanning capabilities that continuously monitor infrastructure against industry standards and custom policies. The VCF 9 Security Baseline is a consolidated out-of-the-box benchmark within VCF Operations for evaluating environment security and compliance posture. Administrators can activate regulatory benchmark compliance packs and enable specific compliance pack policies to assess objects against the installed benchmarks. VCF Compliance based on the VCF Audit Guides can also be enabled in VCF Operations. These tools allow organizations to review baselines regularly and identify configuration drift between scheduled update cycles.

The Consumption layer of VCF, delivered through VMware Kubernetes Service (VKS) running on vSphere Supervisor, extends these lifecycle management capabilities to Kubernetes workloads. VKS rolling updates proceed through three coordinated stages: updating add-ons, updating the control plane, and updating the worker nodes. VKS Controller updates can include configuration updates for supporting services such as the Container Network Interface, Container Storage Interface, and Cloud Provider Interface components, keeping their configurations aligned with each release. Before a VKS version upgrade can proceed, all system components must be upgraded and VKS must be in its currently installed state, enforcing a structured upgrade sequence that mirrors VCF's broader lifecycle management discipline. Control plane instances are upgraded sequentially to maintain cluster availability during the update process. The VKS AddonRelease resource allows platform engineers to specify whether a given add-on must be upgraded during a cluster upgrade and at what stage, providing fine-grained control over which configuration components are updated within each release cycle. When the "Latest compatible version" option is selected, VKS cluster management provisions add-ons using standardized defaults, which helps reduce configuration drift across clusters. Platform engineers are directed to adjust VKS cluster add-on configuration and perform updates to keep VKS clusters aligned with their organization's current operational and security requirements. Kubernetes guidance recommends upgrading to the latest patch releases promptly and running a supported minor release to maintain a secure configuration baseline, and recommends updating dependencies in response to security announcements as part of supply chain security.

VKS also provides namespace-level baseline security configuration through Kubernetes Pod Security Admission (PSA). Namespaces in VKS clusters can be labeled to enforce, audit, or warn against pod security policies at privileged, baseline, or restricted levels. The audit mode records policy violations without blocking pod creation, which supports reviewing whether running workloads conform to the applicable security baseline before tightening enforcement. Pod Security Admission is enabled by default in VKS, and clusters at version 1.25 and later enforce the baseline Pod Security Admission standard on namespaces by default. When VCF Automation is used, IaaS Resource Policies can require that a Kubernetes cluster maintain baseline pod security level enforcement, extending configuration baseline governance to the cluster provisioning process.

The VCF Consumption CLI notifies administrators when a new version is available for upgrade, with the notification interval configurable through the `VCF_CLI_RECOMMEND_VERSION_DELAY_DAYS` environment variable.

VMware vDefend (Contributes)

VMware vDefend contributes to baseline configuration review and update processes through two mechanisms available in the 9.1 platform.

The Security Intelligence Policy Recommendations capability, accessible through the Security Services Platform (SSP) Monitor & Plan > Policy Recommendations interface, analyzes observed traffic to generate segmentation policy recommendations that can be reviewed, modified, and published to the vDefend distributed firewall. Recommendation analysis progresses through tracked states (Waiting, Discovery in Progress, Ready to Publish, Published), providing visibility into the review lifecycle at each stage. When the applied-to scope of security policies changes from the scope used at the start of a recommendation analysis, a change-detected icon appears in the Policy Recommendations interface, prompting security teams to review the changes and rerun the analysis to keep segmentation policy current. This mechanism directly supports both periodic and change-triggered review cycles. Policy recommendations should be reviewed for accuracy and modified as needed before publishing; the Review and Rerun Security Intelligence Policy Recommendations interface allows security teams to examine input entities including applications, groups, members, and VMs included in the recommendation scope. Compute entity classifications within Security Intelligence carry a Review Status field that administrators can update to confirm or adjust the infrastructure classifier's inferred assessments.

The vDefend Threat Intelligence Service Portal includes a Bundle Change Log feature that records updates and modifications to application IDs and IDS signatures over time. Security teams can consult this log to review changes to the threat signature baseline, supporting annual and change-triggered review requirements for intrusion detection configurations.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports baseline configuration review and updates primarily through its integrated software update and upgrade management capabilities. These mechanisms align with the third criterion of this control: applying configuration updates as part of system component installations and upgrades.

DSM provides a Maintenance Policy that administrators configure to schedule automatic software updates for DSM appliances. The Maintenance Policy requires specification of a start date and time, which must be set to a future value in UTC, along with a duration parameter that defines the time window for applying updates. This policy is configurable from both the vSphere Client and the DSM UI. When automatic updates fail, DSM supports manual software updates of appliances as an alternative path.

For managed databases, DSM allows each database instance to have its own maintenance window governing automatic minor software updates. PostgreSQL, MySQL, and SQL Server databases each support a configurable maintenance window with a default schedule of Saturday at 23:59 UTC and a six-hour duration. MySQL databases activate this through the Enable Maintenance Window toggle. For environments requiring more granular scheduling, the Monthly Occurrences setting allows refinement from a standard weekly cadence to specific weeks within a month. SQL Server instances follow the Cumulative Update (CU) branch, which contains the complete set of functional, performance, and security updates for the major version.

Upgrade operations applied during the maintenance window may include CVE fixes, bug fixes, and performance improvements. DSM provides visibility through the Check for Upgrade function, accessible from both the vSphere Client and the DSM UI, which displays available updates in an Available Upgrades table with version, release date, and status. DSM also displays the status, version, and release date of uploaded update bundles for administrative review. Upgrade history remains accessible after updates are applied.

Upgrading DSM within a VCF environment requires a specific sequence to support compatibility across the control plane, data plane, and underlying vSphere infrastructure. A database upgrade encompasses updates to the database engine, the pods' operating system, supporting internal components, and the underlying Kubernetes infrastructure. DSM does not support partial upgrades; each release determines the complete scope, and the upgrade runs in its entirety.

Because this control also requires annual review of baseline configurations and review triggered by events or changes, additional organizational processes are needed beyond what DSM provides. DSM's mechanisms support the operational execution of updates but do not themselves schedule or enforce periodic baseline reviews on a calendar-driven or event-driven basis. Those reviews are organizational responsibilities that must be defined and carried out by the teams managing the DSM environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own configuration baseline through the Avi Controller, which manages virtual services, WAF policies, SSL profiles, and Service Engine settings as a distinct configuration plane from the broader VCF platform. The Controller provides structured mechanisms for reviewing and updating that baseline as part of system upgrades and patches.

Before any upgrade, the Avi Controller runs a pre-check phase that validates the current configuration against upgrade requirements. Pre-checks verify Controller Cluster readiness, confirm that all cluster member nodes are time-synchronized, validate system configuration integrity, verify Service Engine reachability, and check resource requirements such as CPU and memory. Upgrades fail automatically if minimum resource requirements are not met. Operators can initiate pre-checks from the Controller UI under Administration > Update > System, or use the `prechecks_only` flag to run them independently before committing to an upgrade. The CLI command `show upgrade status detail filter pre_check_status` displays pre-check warnings and validation results that must be reviewed before proceeding. A configuration backup must be taken prior to initiating any upgrade operation.

System reports generated during upgrade operations provide a documented record of configuration state and readiness. These reports include three main sections: System Readiness, Dry Run Report, and System Task, along with statistics on warnings, errors, and success for each operation performed per node. System readiness reporting includes state tracking and a last-changed timestamp for each cluster node. Configuration changes are blocked for the entire duration of a system upgrade until all Service Engines are upgraded, providing a clear point-in-time reference for the configuration baseline during the transition.

The Avi Controller supports a Dry Run mode for upgrade operations, which runs the pre-check phase and produces a preview of the upgrade outcome using the `SYSERR_UPGRADE_OPS_PREVIEW_RESPONSE` status code or via the `/preview/` REST API endpoint suffix, without committing any changes. The Controller also displays overall upgrade status on the System Update page and shows a confirmation message upon successful completion after mandatory checks are complete.

The Avi Load Balancer for VCF guide adds guidance specific to VCF deployments: a maintenance window should be defined and communicated before any upgrade begins, rollback decision criteria and timeframes should be prepared in advance, and the pre-upgrade checklist must include a review of the Controller and Service Engine configurations. Post-upgrade validation requires confirming that Avi Management Plane alarms, alerts, and dashboards are operational.

Patch management follows a structured lifecycle. All patches from a maintenance release are incorporated into successive maintenance releases, so applying a newer maintenance release also incorporates prior fixes. License Hub components should also have prechecks performed before an upgrade if the upgrade plan has changed. For API-driven configuration updates, the Controller supports asynchronous PATCH requests with status tracking via GET requests on `/api/pool-async/status/<patch_id>`, returning QUEUED, IN_PROGRESS, SUCCESS, or FAIL states with timestamps. When concurrent update safety is required, the standard GET/PUT workflow is preferred over PATCH, as GET/PUT triggers a concurrent update error rather than silently overwriting earlier changes. Customers with an Avi WAF Enterprise license can update WAF Core Rule Set (CRS) rules directly from the customer portal, keeping application firewall signatures current as part of the configuration baseline.

Organizations must still establish the annual review cadence, determine what conditions require an ad hoc configuration reassessment, and document approval of changes before they are applied. Those governance steps are outside Avi itself.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.4

> For a change that deviates from the existing baseline configuration: 1.4.1. Prior to the change, determine required cyber security controls in CIP-005 and CIP-007 that could be impacted by the change; 1.4.2. Following the change, verify that required cyber security controls determined in 1.4.1 are not adversely affected; and 1.4.3. Document the results of the verification.

SCF Controls: CFG-02.7

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's process for documenting, assessing, and approving or denying deviations from standardized configurations. These capabilities span compliance monitoring, deviation detection, change approval workflows, and source control integration, though the broader governance process of risk-assessing and formally approving deviations requires organizational procedures beyond the platform itself.

VCF Operations includes a compliance benchmarking framework that measures the settings on managed objects against a set of standard rules, regulatory best practices, or custom alert definitions. Organizations can define what constitutes their standardized configuration baseline by creating custom compliance benchmarks, which are configured through a multi-step process of naming, selecting alert definitions, and activating policies. Up to five custom compliance score cards can be created to track adherence. These score cards provide a breakdown of the total number of objects that are compliant and non-compliant for each benchmark, giving administrators a clear view of where deviations exist. The compliance score for each object is based on the most critical of the violated standards, helping administrators prioritize which deviations to address first. Custom compliance benchmarks can be exported and imported in XML format across VCF Operations instances, allowing organizations to define a standard once and reuse it consistently. The VCF security baseline can be used to evaluate both default and non-default configurations, which helps organizations identify where deployed settings differ from the expected standard. VCF documentation also acknowledges that configuration decisions should be tailored to individual customer environments rather than applying uniform standards across all customers, recognizing that legitimate deviations are expected.

When an object deviates from its assigned configuration template values, VCF Operations generates a configuration drift notification identifying the specific changes. The Configuration Drifts view shows what changed, when it changed, and how the current state compares to the desired values. The Detect Drift function detects configuration drift across all configuration templates and displays results in the Drifts table, and the Configuration Drift dashboard allows viewing and comparing drifts to identify settings that have changed. Drift details show the comparison between the current VMware vCenter value and the configuration template value for each instance.

At the VMware ESX host level, vSphere Host Profiles provide an automated and centrally managed mechanism for host configuration and configuration compliance, and scheduled compliance check automation can detect whether any configuration parameters differ from those specified in the host profile. vSphere Configuration Profiles extends this to the cluster level, displaying host settings with their respective desired and current values to identify the cause of noncompliance when reviewing compliance results.

Integrating VCF Operations configuration drift templates with a source control repository supports versioning, auditing, change control through reviews, and continuous integration workflows. When an organization uses this integration, accepting a deviation can be handled as a reviewed and approved commit to the configuration template, providing a documented approval trail. However, this workflow depends on the organization establishing the source control integration and review process. A supported source control solution must be used for this integration.

NSX provides a compliance report that identifies non-compliant configurations, including details such as the non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. This structured reporting helps document the specifics of each deviation and supports risk assessment by making the scope and nature of non-compliance visible.

Each VCF Operations policy can inherit settings from other policies, allowing organizations to customize and override analysis settings, alert definitions, and symptom definitions for specific object types. This provides a mechanism to document approved configuration variations at the policy level.

For changes to deployed resources, VCF Automation provides approval policies that require designated approvers to review requests before resources are consumed or changes are made to provisioned items. Approval policies can be filtered based on deployment criteria that apply to deployments and day 2 actions, and the enforcement type can be set to HARD to enforce mandatory approval before any deployment action proceeds. When multiple valid approval policies exist and the approvers are different people, all approvers are added to the approval chain. Organizations can configure these policies to require project administrator review of all changes to deployed catalog items, particularly those used by many users, to gate potentially impactful modifications. These policies gate new changes and modifications but do not directly address the review of detected configuration drift. The decision to remediate a detected deviation or accept it as an approved exception is made by the administrator outside of any formal VCF workflow.

VCF provides strong deviation detection, documentation, and change approval capabilities, but the risk assessment and formal approve/deny process for deviations depends on organizational governance layered on top of VCF's tooling.

VMware vDefend (Contributes)

VMware vDefend provides configuration validation, anomaly detection, and assessment capabilities that support the broader organizational process of managing deviations from standardized configurations. The formal approval and denial workflow for configuration changes is handled at the VCF platform level through VCF Operations and VCF Automation.

The Security Services Platform (SSP) deployment wizard conducts thorough validations before implementing any configuration changes, verifying that configurations are correct and compatible with the current environment. This pre-implementation validation step helps identify potential deviations from expected configurations before they take effect.

Rule Analysis, a feature of the Security Services Platform, identifies anomalies in firewall rule sets including duplicate rules where two rules share the same configuration and action, and shadowed or conflicting rules that may represent unintended deviations from the intended security policy. Administrators can use Rule Analysis reports to review rule anomalies and update configurations accordingly. Rule Analysis depends on configuration synchronization from NSX Manager; a failure in that synchronization is indicated by an alarm in the NSX UI, allowing administrators to detect when analysis results may not reflect current state.

Security Intelligence, part of the Security Services Platform, provides assessment and monitoring tools that help administrators evaluate their security configuration against desired baselines. The Security Segmentation Report supports two scoring modes: Strict mode applies stricter penalties for allowed unidentified traffic and provides a more stringent posture assessment, while Relaxed mode applies less severe penalties and is suited to environments where strict application rules have not yet been fully implemented. The segmentation score breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, making configuration gaps visible. Security Intelligence also tracks new configurations per configuration type on an hourly basis, providing a running count of changes across the platform.

When changes occur to group membership or policy scope, Security Intelligence displays a change-detected indicator prompting administrators to review the changes and rerun policy recommendations. Security Intelligence policy recommendations are generated from observed traffic flows and must be reviewed for accuracy before publishing to vDefend, creating a structured review step between traffic analysis and enforcement. The Security Policies view for each environment pair displays the number of unpublished recommendations, giving administrators visibility into pending configuration decisions.

The staged segmentation workflow supports a measured approach to configuration changes. Administrators can publish environment pair protection rules in a permissive mode first, allow traffic analysis to complete, and then review Security Intelligence policy recommendations before committing to enforcement rules. This staged process provides a structured mechanism for evaluating proposed configuration changes against observed traffic patterns before applying them.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) includes a Configuration Import/Export Tool that exports the complete system configuration as structured XML, covering server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information including Storage Replication Adapter (SRA) details. The exported XML can be validated against a bundled XSD schema to confirm structural integrity, and PNR supports programmatic configuration management through the same schema framework. Organizations can use these export capabilities to capture baseline snapshots of approved configurations and compare subsequent exports against them to identify deviations.

PNR configuration files contain settings that affect the security of the environment, and incorrect settings can affect proper functioning. The system configuration is defined in the `va-configurator.xml` file and is modifiable through the Advanced Settings interface on the Site Pair tab. When PNR settings are modified, the same changes must be applied to all instances on both the protected and recovery sites to maintain consistency. This consistency requirement creates a visible signal when partial or unauthorized modifications have occurred.

Replication mappings can be tested on demand for individual mappings or all existing mappings simultaneously to validate that the current replication configuration matches expected state. After reprotect operations, PNR recommends conducting tests to confirm that the new site configuration is valid. After upgrades, protection groups and recovery plans must be verified to confirm continued operational capability. The Clean Room Orchestrator's Monitoring page shows the operational status of configurations related to recoverability and supportability, providing visibility into whether isolation environment configurations are in an expected state.

These capabilities provide the technical foundation for identifying when protection and recovery configurations deviate from established baselines. The processes for formally documenting deviations, assessing risk, and approving or denying exceptions require organizational governance outside PNR's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configuration tracking and change documentation capabilities that support the governance processes organizations use to manage deviations from standardized configurations.

The Avi Controller maintains configuration event logs that record changes made through the web interface, CLI, or REST API. Each configuration change entry displays a difference comparison of the previous configuration versus the new configuration, with additions highlighted in green and removals highlighted in red. The Config Events overlay in Service Engine Analytics correlates these configuration changes with traffic metrics, allowing administrators to determine whether a specific change caused a traffic anomaly or change in application behavior. The Avi documentation recommends that configuration changes be made through the Avi UI and verified by checking the event logs to confirm what was created or changed.

When a configuration change is made on any Controller cluster node, that change is automatically propagated to all cluster members, maintaining a consistent authoritative configuration state across the cluster. This means the event trail reflects the running configuration of the entire deployment.

For WAF policy management, Avi provides an explicit recommendation acceptance mechanism. After WAF learning mode or anomaly analysis identifies false positives in the active configuration, administrators can review proposed changes and explicitly accept or deny each recommendation. This discrete accept-or-deny step within WAF policy management provides a documented approval action for this category of configuration change.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) uses Custom Resource Definitions (CRDs) to perform syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. `RouteBackendExtension` resources include a `STATUS` field indicating whether the configuration was Accepted or Rejected, which administrators should check to identify and resolve configuration issues before they affect production traffic.

The audit trail and event records Avi generates supply the raw documentation that an organization's configuration deviation management process requires. The process itself, including defining the authoritative configuration baseline, routing

proposed deviations through a risk assessment and approval workflow, and maintaining a register of approved exceptions, is an organizational governance activity that must be defined and operated by the organization outside of Avi.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.4.1

> For a change that deviates from the existing baseline configuration: 1.4.1. Prior to the change, determine required cyber security controls in CIP-005 and CIP-007 that could be impacted by the change;

SCF Controls: CFG-02.9

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms for tailoring baseline controls to specific operational requirements, business functions, threat profiles, and environmental conditions.

VCF includes a Security Baseline that builds on top of the platform and addresses frequently requested compliance standards, regulations, and frameworks. This security baseline can be used to evaluate both default and non-default configurations and to assist organizations in securing information systems in a compliance context. The security baseline is designed and validated to allow security configurations to be tailored without impacting VCF's ability to meet its design objectives. Organizations can select from the benchmarks and regulatory frameworks available under VCF based on their specific needs. For environments with specific regulatory requirements, Broadcom also provides DISA Security Technical Implementation Guides (STIGs), which contain detailed instructions on how to secure and configure operating systems, applications, and network devices. DISA Security Requirements Guides (SRGs) outline security requirements for specific technology platforms, providing additional tailoring guidance for regulated environments.

VCF Operations provides a policy framework with built-in inheritance and override capabilities that directly supports baseline tailoring. Baseline policies ship as starting points for creating new policies, and all settings from a base policy are inherited as default settings in a new policy. The policy workspace allows administrators to select base policies and override settings across multiple dimensions, including metrics and properties, alerts and symptoms, capacity, compliance, workload automation, and groups and objects. Each policy can inherit settings from other policies, and administrators can customize and override analysis settings, alert definitions, and symptom definitions for specific object types. Override policies can be selected to overwrite specific settings in the base policy according to service level agreement requirements, and additional policy settings can be applied to specific object types. Custom policies can be created from default or predefined policies and scoped to a specific environment, allowing organizations to maintain a standard baseline while applying targeted adjustments for different workload types or business functions.

VCF Operations also supports custom compliance benchmarks that monitor the alert definitions and policies selected during benchmark creation, allowing organizations to define compliance criteria tailored to their specific mission or business requirements. The VCF 9 Security Baseline is a consolidated out-of-the-box benchmark available in VCF Operations for evaluating environment security and compliance. A compliance threshold can be configured in the Compliance workspace when creating operational policies, giving administrators control over acceptable deviation from baseline settings. Organizations can also activate regulatory benchmark compliance packs and enable specific compliance pack policies to assess objects against installed regulatory benchmarks.

VCF Automation provides a separate policy layer where policies are evaluated, ranked, and merged to produce an effective policy. The highest-ranking policy becomes the baseline, the second-level policy is applied on top of it, and subsequent policies are applied in descending rank order. Deployment criteria narrow the scope of policy application so that policies apply only to deployments where the criteria are true, allowing organizations to define policies scoped to specific deployment characteristics. Day 2 action policies can also be narrowed to particular aspects of deployments. This ranked, scoped approach allows organizations to adapt controls for different mission functions or operational conditions without modifying the underlying baseline.

The Consumption layer within VCF, provided through VMware Kubernetes Service (VKS) and the vSphere Supervisor platform, extends baseline tailoring to containerized workloads. Pod Security Admission (PSA) is the primary baseline tailoring mechanism at the Kubernetes layer, defining three cumulative Pod Security Standard profiles that are applied independently per namespace: Privileged (no restrictions), Baseline (blocks known privilege escalations while maintaining compatibility with

standard containerized workloads), and Restricted (adds controls that limit volume types and require security context settings such as dropping all capabilities and running as a non-root user). Each profile can be activated in three independent modes per namespace: enforce (blocks non-conforming pods at admission), warn (issues admission warnings without blocking), and audit (records policy violations in the audit log). These modes can be configured independently per namespace. A common tailoring pattern is to set enforce to Baseline and audit and warn to Restricted, providing a security floor that blocks known privilege escalations while surfacing workloads that would fail a stricter posture without disrupting operations. Administrators apply these settings through namespace labels such as `pod-security.kubernetes.io/enforce: restricted` for namespaces hosting sensitive workloads, or `pod-security.kubernetes.io/enforce: baseline` for namespaces running infrastructure components that require elevated permissions.

VKS ClusterClass configurations support tailoring at cluster provisioning time through the `podSecurityStandard` ClusterClass variable, which sets default PSA enforcement, warn, and audit levels for all namespaces in a cluster. Different cluster classes can be defined with different default security postures, enabling mission-specific or environment-specific cluster configurations. The VCF Services Consumption interface provides VKS Cluster Management Security Policies with built-in templates including a Baseline template, and supports custom templates as well. Administrators can author custom templates in VCF Automation to tune individual security context fields within the pod spec for specialized requirements, and custom policies can be modified or removed as operational needs evolve to keep governance logic aligned with current security requirements.

Kubernetes ValidatingAdmissionPolicy, built on the Common Expression Language (CEL), allows administrators to define custom admission rules that enforce organization-specific requirements beyond the standard PSA profiles. These policies can check field values, labels, annotations, and resource attributes, and bind to specific resource types or namespaces to address requirements specific to a particular mission, regulatory scope, or threat profile. Kustomize overlays provide a declarative configuration management mechanism for applying targeted customizations on top of base Kubernetes resource definitions, maintaining environment-specific adjustments between development, staging, and production environments without modifying base manifests. Security contexts at the pod and container level allow individual workloads to be configured with specific user IDs, dropped capabilities, and read-only root filesystems, providing workload-level tailoring that complements namespace-level PSA controls.

For infrastructure patch management, VCF supports both fixed and dynamic patch baselines. Fixed baselines contain only specifically selected patches, while dynamic baselines update their patch data based on administrator-defined criteria each time new patches are downloaded. Patch baselines can be attached to individual objects or to container objects such as folders, hosts, clusters, and data centers, allowing administrators to tailor patch application scope to match organizational structure and operational requirements. vSphere Lifecycle Manager further classifies baselines as predefined, recommendation, or custom depending on how they are created and managed. Predefined baselines cannot be edited or deleted; administrators can only attach or detach them to inventory objects, which preserves the integrity of vendor-supplied baseline definitions. Custom baselines can be combined with predefined baselines to form baseline groups, which allow administrators to scan and remediate inventory objects against multiple baselines simultaneously. Security administrators can also create user-defined security baselines that define a set of security standards and compare hosts and virtual machines against those baselines to identify and address deviations. Access to baseline creation and management is governed by the VMware vSphere Lifecycle Manager Manage Baseline privilege.

VMware vDefend (Contributes)

VMware vDefend provides mechanisms for tailoring network security baselines to match specific mission functions, operational environments, threat conditions, and business requirements. The Distributed Firewall organizes security policies into pre-defined categories: Infrastructure, Environment, and Application. Hierarchical rule precedence is enforced in that order, from highest to lowest, so that global infrastructure policies take precedence over environment-specific rules, which in turn take precedence over application-tier controls. Enforcement scope can be set at the rule level; when the policy-level Applied-To setting remains at its default of DFW, the system honors the specific applied-to settings for each individual rule, enabling targeting of security controls to particular workloads or segments.

In 9.1, vDefend introduces a persona-based multi-tenant security model that enables role-differentiated baseline tailoring. A Provider Admin manages global resources and high-precedence rules in the /infra space, while a Project Admin orchestrates security within a project. Security profiles are pre-defined and created per Project, with each Security Strategy representing a collection of policies and rules applied at the project level. Project Admins can select a pre-defined high-level security posture that applies Secure by Default principles, reducing the need to manually configure individual firewall rules for each new VPC. The operational scope available to a Project Admin differs significantly depending on whether they are interacting with a shared or dedicated VPC, allowing the platform to adapt to different tenancy and operational environments.

For organizations operating across multiple sites or regions, vDefend supports federated policy management through the Global Manager and Local Manager architecture. Distributed Firewall policies can be scoped to specific regions, with each Local Manager automatically added as a region. Customized regions can be created for selective policy application, establishing a consistent global security baseline while preserving the ability to apply site-specific configuration on top.

The Security Services Platform extends baseline tailoring through its segmentation planning and recommendation capabilities. Microsegmentation proceeds in two phases: application ring-fencing to define cross-application controls, followed by application-tier segmentation to establish controls within individual applications across tiers such as web, application, and database. Workloads are associated to applications and application tiers to implement these controls, and application-level prioritization overrides group-level settings for fine-grained adjustment. When an existing Distributed Firewall rule that contains Layer 7 context profiles is modified, those profiles are retained in the modified rule, preserving application-aware controls through policy updates. The rule analysis dashboard allows administrators to identify and update the anchor rule based on observed anomaly types, adjusting security posture to address specific threat conditions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support customizing database platform controls to meet specific operational and organizational requirements.

The primary tailoring mechanism in DSM is the data service policy. Administrators can create and assign data service policies that define what resources users can consume, what database options are permitted, and what backup schedules apply. Data service policies apply to MySQL, PostgreSQL, and SQL Server databases, allowing administrators to enforce different standards across different teams or workloads. Policies can be assigned to one or more namespaces or namespace labels, enabling administrators to scope controls to specific tenants or deployment contexts. When multiple policies are assigned to a namespace, DSM aggregates them by applying the more restrictive policy, so the most restrictive assigned policy determines the effective baseline.

Within data service policies, administrators control the degree of customization available to end users through three settings: "Allow Custom Database Options" permits users to add any database parameters; "Allow with a List" creates an allowlist of approved parameters users can select from, restricting self-service to options vetted for the environment; and "Disallow Custom Database Options" fully restricts users from adding any database parameters, enforcing a tighter baseline for sensitive namespaces.

Infrastructure policies complement data service policies by creating guardrails on resource consumption. These policies restrict the quality and quantity of compute and storage resources that DSM users can consume from vSphere clusters, enforcing resource boundaries appropriate to each team's operational context. Infrastructure policy bindings are namespace-scoped via the InfrastructurePolicyBinding resource, allowing different namespaces to receive different infrastructure constraints. Infrastructure policies that are actively used by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added.

DSM supports runtime adjustment of database VM resource configuration after initial provisioning, with administrators selecting from predefined VM classes for vCPU and memory combinations. When a new database is created through cloning, restoring from on-demand backups, or establishing a secondary instance, the new database automatically inherits the configured database options and host-based access configuration of the source database, propagating the established baseline to derived databases.

For operational monitoring, DSM allows administrators and users to configure alert threshold values for CPU Health, Data Disk Health, System Disk Health, and Maximum Connections, with separate thresholds for warning and critical conditions. These thresholds can be adjusted to reflect the specific performance expectations and risk tolerance of each deployment.

The baseline tailoring decisions themselves, including determining which control profiles apply to which business functions, assessing threats and vulnerabilities to inform control selection, and documenting tailoring decisions, remain organizational responsibilities that fall outside DSM's scope. DSM provides the technical mechanisms to implement and enforce tailored configurations once those decisions have been made.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that allow its application delivery security baseline to be specialized and customized for specific operational contexts.

At the virtual service level, Avi supports per-virtual-service policy sets that govern traffic handling at Layers 4 and 7. Layer 4 Policy Sets are organized hierarchically within a connection policy, with rules that match on Layer 3 and Layer 4 fields such as client IP address and port. Individual rules within a policy set can be selectively enabled or disabled, allowing operators to apply only the traffic control policies appropriate to a given application or environment. Policy sets are associated with specific virtual services and are configurable through both the Controller UI and CLI, with match conditions including client IP and port defined at rule creation.

The Web Application Firewall (WAF) policy includes Application Rules that provide targeted protection for specific application types and threat profiles. WAF Application Rules can be tuned so that the protections applied reflect the specific risk profile of the application being protected. This allows administrators to build a differentiated security baseline for different application workloads rather than applying a single uniform ruleset across all virtual services.

Application profiles are configurable objects that attach to virtual services and define HTTP processing behavior, including per-profile compression parameters. Avi exposes all advanced configuration settings for editing after a virtual service is created, allowing profiles to be adjusted as operational requirements evolve. Service Engine Group settings can also be customized per requirement when creating a new Service Engine Group, providing control over data-plane behavior for specific workloads or environments.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) deployment can be customized using the AddonConfig resource, a Supervisor namespace-scoped resource that allows modification of configuration parameters such as log level and shard virtual service size to change default behaviors. This enables per-namespace tailoring of load balancing behavior for Kubernetes workloads within VCF.

For user and account security, Avi allows administrators to create custom user account profiles with thresholds for password history and account security policies that differ from the default profile. The Avi Controller also supports granular role-based access controls (RBAC) at the field level, enabling administrators to define roles with write access restricted to specific sub-resources within objects. This supports tailoring administrative permissions to specific mission or operational requirements.

ControlScripts provide a mechanism for automated responses to system events, including altering Avi configuration dynamically based on health scores or triggering actions in external systems such as VMware vCenter. Alert Actions trigger ControlScripts in response to system events, enabling automated remediation actions rather than manual administrator intervention. This supports tailored responses to operational conditions that could affect mission success.

In organization-managed mode within VCF deployments, a provider administrator can adjust the service units limit for each organization, enabling resource allocation to be specialized per organizational unit.

Avi's contribution to this control applies specifically to the application delivery layer. The broader platform baseline management infrastructure, including hypervisor and infrastructure baselines, is owned by VCF, and a complete baseline tailoring program also requires organizational governance processes that determine what tailoring actions are appropriate for each mission or business function.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.4.2

> For a change that deviates from the existing baseline configuration: 1.4.2. Following the change, verify that required cyber security controls determined in 1.4.1 are not adversely affected; and

SCF Controls: CHG-02.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support testing, validating, and documenting changes in non-production environments before deploying them to production, though establishing formal non-production environments and test procedures remains an organizational responsibility.

vSphere Lifecycle Manager (vLCM) supports a draft-based workflow for managing software specifications on clusters and standalone hosts. Administrators create a draft software specification, add or modify components within the draft, and validate the draft before committing it as the desired state. The Drafts service provides a `validate_Task` method that checks whether a draft software specification is complete, whether there are any conflicts between components, and whether there are unresolved dependencies. Administrators can also check whether a draft drifts from the current state of the cluster or host before committing changes. Software specifications can be imported and edited as drafts via API. This staged approach allows proposed software changes, including host software, drivers, firmware, and add-on components, to be reviewed and validated before they take effect. vSphere Configuration Profiles provide an additional layer of periodic host configuration assessment, enabling management of the configuration of all hosts in a cluster collectively to help maintain consistency at a cluster level. vSphere Auto Deploy supports a working rule set that allows administrators to test changes to deployment rules before making them active. The `Test-DeployRuleSetCompliance PowerCLI cmdlet` tests rule set compliance for an ESX host and returns a table of current and expected configuration items, enabling verification of what changes would be applied prior to committing them.

VCF Operations governs lifecycle management for VCF components, including updates and patches. Before any update can be applied, VCF Operations requires a precheck to verify that the environment is ready for the change. This built-in gate helps keep untested changes from being applied to production infrastructure. vSphere Lifecycle Manager synchronizes to its download sources, including VCF Operations, on a regular and automatic basis, providing a controlled channel for software updates. If out-of-band changes are made directly through VMware vCenter or NSX Manager, VCF Operations can detect these changes and update its inventory accordingly, providing visibility into changes made outside the standard change control process.

VCF Automation supports iterative blueprint development with built-in versioning. Administrators can capture a snapshot of a working design before making further changes, following a minimum viable blueprint approach and adding features iteratively. The platform integrates with Git-based source control for version control, with supported systems including GitHub, Bitbucket, and Ansible, enabling Infrastructure-as-Code practices that allow teams to track, review, and roll back changes. VCF Automation also provides a blueprint validation API endpoint that accepts requests to validate cloud templates before creation, allowing proposed infrastructure changes to be checked for errors before deployment. Cloud templates can be tested for deployment viability before being released to production, and the validation process tests the connection and provides the number of released templates associated with a project. Approval policies can be layered on top of these workflows to require designated approvers to review deployment requests for catalog items before they take effect, including day 2 actions on deployed resources.

At the Consumption layer, VMware Kubernetes Service (VKS) running on vSphere Supervisor extends pre-production change validation to Kubernetes workloads. The Kubernetes API supports server-side dry-run requests, which route a proposed resource creation or modification through the full admission control and mutation chain without persisting any changes, allowing teams to verify that a configuration will pass all validating and mutating admission webhooks before it reaches production. The `kubectl diff` command shows exactly what changes would be applied to existing objects before any modification is committed. Declarative configuration management with `kubectl apply` and version-controlled manifest files allows teams to track configuration history, review proposed changes in source control, and roll back to prior revisions.

CustomResourceDefinition schemas enable schema-based validation that kubectl consumes client-side when processing kubectl create and kubectl apply commands against custom resources, and VKS AddonConfig resources provide configuration validation against a predefined schema before add-on installation. The VCF Consumption CLI supports named contexts that allow operators to switch between local development clusters, staging environments, and production environments without modifying configuration files, supporting the separation of test and production environments at the CLI level. Kubernetes guidance directs administrators to test admission webhooks and workloads in staging clusters that closely resemble production before minor version upgrades; vSphere Supervisor enforces pre-checks and compatibility compliance during VKS cluster updates, providing a validation gate before changes are applied. The kubeadm cluster management tool extends dry-run capability to cluster-level administrative operations, including node initialization and upgrade phases, by providing a --dry-run flag that outputs planned changes without applying them, allowing administrators to verify the impact of cluster infrastructure modifications before execution. Documentation for custom ClusterClass clusters explicitly directs customers to test and validate in non-production environments before production deployment. VKS supports GitOps workflows through the Argo CD Supervisor Service and Harness CI/CD integration, where changes to application manifests and infrastructure configuration flow through Git repositories, CI pipelines perform automated building, linting, unit testing, and image publication before changes reach the cluster, and Argo CD continuously compares the desired Git state against the live cluster state while maintaining a complete change history for rollbacks and audit review. Kubernetes Deployments also support a kubernetes.io/change-cause annotation, settable via kubectl annotate or direct manifest editing, that records the rationale for each rollout revision alongside the technical change record, providing inline change documentation within the object's history.

VCF Operations contributes through several capabilities. Its Configuration Drifts feature, accessible through Fleet Management, tracks changes in product configurations over time and allows administrators to compare current configurations against assigned desired values for vCenter instances and vSphere clusters. When drift is detected, administrators are alerted so they can investigate and remediate. The config polling interval can be adjusted to control how frequently configuration data is collected, and drift detection can be scheduled at defined intervals. Configuration templates define a desired state for infrastructure configurations and can be assigned to policies, activated or deactivated as needed. The Configuration Drifts feature can be integrated with source control repositories, enabling versioning, auditing, and management of configuration templates. This integration supports change control with reviews and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes. The product documentation recommends testing newly created configuration files against a test instance before applying them to production systems. VCF Operations also provides what-if analysis through committed scenarios, which allow administrators to model capacity changes without requiring actual deployment. This planning capability lets teams evaluate the impact of proposed changes before implementing them. Custom groups with distinct alert policies and capacity calculations allow administrators to differentiate between production and testing environments and apply appropriate operational policies to each. Policy management capabilities through the Infrastructure Operations Configurations module allow policies to be added, edited, and removed, with settings that can be inherited from existing policies and modified with appropriate permissions.

VCF includes configuration validation capabilities that examine configuration files for possible errors and conflicts before they are applied, returning output that helps administrators avoid configuration issues.

Change documentation is supported through audit logging across VCF components, which records configuration changes, the authenticated user who initiated them, and their outcomes. VCF Operations tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when. User permission changes are also tracked to capture when such changes were made and who made them. NSX audit logs record new values of configuration changes including resource type, display name, path, and unique identifier information, with metadata such as audit flags, component names, log levels, and request IDs. Role-based access control across VCF components restricts which users can initiate configuration changes. The general guidance in the product documentation is to change only one thing at a time and document each change and its result. Content Libraries provide version tracking for VM templates, recording check-in comments, the name of the user who made each change, and the date, creating a change history for template modifications used in deployments.

While VCF provides these testing, validation, and modeling tools, the control also requires organizational processes for maintaining non-production environments that mirror production, documenting test plans and results, and establishing formal change approval workflows that require successful non-production testing before production deployment. VCF's technical capabilities support these processes but do not replace them.

VMware Private AI Services (PAIS) includes AI-specific workflows that support testing and validation before deploying changes to production. The Model Gallery workflow designates a Deep Learning VM as a sandbox environment where MLOps engineers validate ML models against the organization's security, privacy, and technical requirements. Model integrity is confirmed by checking file hash codes, scanning for malware, scanning for serialization attacks, and testing inference behavior with Triton Inference Server before the model is uploaded to the Model Gallery. Operators also examine inference requests for malicious behavior and perform hands-on functional tests as part of the sandbox evaluation. Only models that pass validation are uploaded and made available to AI application developers, establishing a gate between the validation stage and production deployment. The `vcf pais models push` command uploads validated models to a Harbor registry project, with support for custom model names, target model stores, and revision tagging.

When deploying model endpoints through PAIS, A/B testing is available to compare the performance of different embedding or completion models in real-world settings before committing to a production configuration. DevOps engineers and application developers monitor LLM completion API response at the 95th percentile, inference engine tokens-per-second generation rate, and GPU compute and memory resource allocation through observability platforms such as Grafana to identify undersized or oversized configurations before scaling to production.

Model revisions in the Model Gallery are immutable OCI artifacts identified by content digest. Each push of changed model data creates a new revision, and identical model data pushed multiple times results in only one revision being stored. The Model Gallery assigns a unique digest to each revision when the same model is pushed again, and revisions can be tagged for promotion through development and production stages. This versioned artifact storage provides an audit record of model changes and supports rollback if a newly promoted model does not perform as expected.

The broader organizational change management process for the PAIS deployment, including changes to VCF infrastructure, VMware Kubernetes Service (VKS) configurations, GPU cluster sizing, and PAIS configuration itself, requires processes and non-production test environments that extend beyond the AI model validation workflow. Testing and documenting those infrastructure-layer changes is an organizational responsibility that PAIS tooling does not directly cover.

VMware vDefend (Contributes)

VMware vDefend contributes to testing and documenting proposed changes before production deployment through its draft configuration management system for firewall policy, migration evaluation tooling, and pre-deployment validation workflows. Establishing formal non-production environments remains an organizational responsibility; vDefend provides structured workflows that allow changes to be reviewed and validated before taking effect in the production environment.

The vDefend distributed firewall supports a draft-based change workflow that separates authoring firewall rules from their enforcement. Administrators create draft configurations representing proposed changes. These drafts are saved as working configurations before being published, and the draft details view displays the required changes needed to synchronize the current firewall configuration with the draft, giving administrators visibility into the impact of proposed changes before committing them. Publishing the draft applies all visible changes to the active firewall configuration, providing a clear boundary between proposed and enforced policy states. During publishing, a new auto draft is created capturing the pre-publish configuration, which can be republished to revert to the previous state if a change produces unexpected results. In Global Manager deployments, both automatic and manual drafts follow the same rules as local Distributed Firewall drafts, extending this workflow to federated environments.

The 9.1 documentation introduces a migration tool for workload transitions from VCD to VCF Automation. Before any changes are committed, the tool runs an Evaluation phase that generates an Evaluation Plan providing upfront insight into which components will be migrated or skipped. Administrators can remediate identified issues in the source environment before rerunning migration plan generation. The migration tool records a detailed plan capturing the previous state and new state of

every rule for audit and compliance purposes. A successful rollback is confirmed when the infrastructure state in VCF Automation matches the state documented before the migration began.

The Security Services Platform deployment wizard conducts validations before implementing configuration changes to verify that configurations are correct and compatible. When upgrades are planned, conducting prechecks on all components is essential to detecting issues before proceeding. The Security Services Platform also evaluates whether workloads are protected by environment-specific segmentation policies covering Dev, Prod, and Test tiers, and the documentation recommends blocking all traffic between Testing and Production environments as an initial segmentation step, supporting isolation between non-production and production workloads. Isolating development, staging, and production environments through segmentation can reduce the risk of cross-environment contamination.

For IDS/IPS signature management, vDefend recommends exporting the existing custom signature bundle to a local system before modifying it with new signatures and uploading the revised bundle. The IDS/IPS system provides bulk edit functionality to modify signature action settings (Alert, Drop, or Reject) and operational status (Included or Excluded) across multiple pages simultaneously, enabling efficient review of signature configuration changes before deployment. The vDefend Threat Intelligence Service Portal includes a Bundle Change Log where administrators can review updates and modifications made to application IDs and IDS signatures over time, supporting documentation of signature changes as part of a change management workflow. NDR sensor upgrades include a verify upgrade-bundle command that extracts the bundle contents and verifies the bundle signature before the upgrade proceeds.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides built-in testing capabilities that allow administrators to validate disaster recovery configurations and changes before they affect production workloads, though establishing broader non-production environments and formal change management procedures remains an organizational responsibility.

Recovery plan testing is a core capability of PNR. Administrators can run a test of any recovery plan, which executes all steps in the plan except for powering down virtual machines at the protected site and forcing devices at the recovery site to assume control of replicated data. Testing has no lasting effects on either the protected or the recovery site, providing a non-production validation of the entire recovery workflow. Tests run virtual machines on a test network using a temporary snapshot of replicated data at the recovery site, so no production data is modified. Recovery plan tests can be run as often as necessary and can be cancelled at any time without impacting production replication. An optional setting (Replicate recent changes to recovery site) synchronizes the latest data to the recovery site before the test begins, so the test exercises the most current data state. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Custom recovery step scripts and commands should be tested on the Protection and Recovery Server at the recovery site before being added to a recovery plan, providing a pre-integration validation stage for recovery automation.

PNR configuration data can be exported in XML format and validated against an XSD schema, providing a structured method to verify configuration integrity before applying changes to production.

vSphere Replication supports on-demand testing of enhanced replication mappings to validate replication configuration and connectivity before those configurations are relied upon for an actual recovery event.

Cyber Recovery validation uses a snapshot validation workflow, with VMs transitioning through a preparation state before entering the validation state when a snapshot is selected and validation is initiated.

PNR includes a cleanup capability that removes test artifacts and isolates recovery environments after validation testing, so no changes persist beyond the test window.

The VCF Operations orchestrator Plug-In for PNR includes an "Initiate Test Recovery Plan" workflow, enabling integration of recovery plan testing into automated change validation pipelines.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support pre-production change validation across different types of configuration changes. These mechanisms address the technical layer of change testing, but the control requires organizational processes and a dedicated non-production environment beyond what Avi itself provides.

For environment isolation, Avi supports running test and production virtual services on separate Service Engine (SE) groups, allowing administrators to manage applications in both environments through a single controller while keeping workloads isolated. Virtual services for different environments of the same application should be deployed on different SE groups, though both can reside in the same tenant for ease of management.

For custom logic and scripting, DataScript rules must be tested and validated after modification to isolate problems without impacting other users. External health monitor scripts require manual testing for successful execution before production deployment. GSLB external health monitor custom scripts require thorough stability validation before pointing them at production servers.

For infrastructure-as-code change review, Terraform's plan phase allows administrators to see what changes will be made to the Avi Controller deployment before they are applied. VCF Automation's Assembler provides versioned, cloud-agnostic templates for Avi deployments that can be deployed consistently across environments. Ansible can be integrated with CI/CD pipelines to trigger automated Avi Controller deployments upon code changes.

For upgrade validation, Avi Controller supports dry run upgrade operations that execute pre-check validations before applying software updates, with status visibility in the UI and detailed transcript logging of all pre-check operations performed. The system report for upgrade operations records pre-check validation results including check code, description, state, start time, end time, and duration for each check. Pre- and post-upgrade object operational state verification should be performed on virtual services and pools to confirm no unintended state changes occurred during the upgrade process. Virtual service disruption must be assessed and communicated before upgrade operations proceed.

For change documentation, the Avi Load Balancer for VCF guide requires that the rollback reason and any issues encountered during a rollback procedure be documented. The Avi Controller maintains a checksum and creation timestamp for custom IPAM script files to track file integrity and provide an audit trail.

For Kubernetes operator deployments, Avi Kubernetes Operator (AKO) CRDs perform syntactical validations at the time of CRD object creation to verify configuration correctness and provide effective status messages before resources become active.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.4.3

> For a change that deviates from the existing baseline configuration: 1.4.3. Document the results of the verification.

SCF Controls: CFG-02.7

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's process for documenting, assessing, and approving or denying deviations from standardized configurations. These capabilities span compliance monitoring, deviation detection, change approval workflows, and source control integration, though the broader governance process of risk-assessing and formally approving deviations requires organizational procedures beyond the platform itself.

VCF Operations includes a compliance benchmarking framework that measures the settings on managed objects against a set of standard rules, regulatory best practices, or custom alert definitions. Organizations can define what constitutes their standardized configuration baseline by creating custom compliance benchmarks, which are configured through a multi-step process of naming, selecting alert definitions, and activating policies. Up to five custom compliance score cards can be created to track adherence. These score cards provide a breakdown of the total number of objects that are compliant and non-compliant for each benchmark, giving administrators a clear view of where deviations exist. The compliance score for each object is based on the most critical of the violated standards, helping administrators prioritize which deviations to address first. Custom compliance benchmarks can be exported and imported in XML format across VCF Operations instances, allowing organizations to define a standard once and reuse it consistently. The VCF security baseline can be used to evaluate both default and non-default configurations, which helps organizations identify where deployed settings differ from the expected standard. VCF documentation also acknowledges that configuration decisions should be tailored to individual customer environments rather than applying uniform standards across all customers, recognizing that legitimate deviations are expected.

When an object deviates from its assigned configuration template values, VCF Operations generates a configuration drift notification identifying the specific changes. The Configuration Drifts view shows what changed, when it changed, and how the current state compares to the desired values. The Detect Drift function detects configuration drift across all configuration templates and displays results in the Drifts table, and the Configuration Drift dashboard allows viewing and comparing drifts to identify settings that have changed. Drift details show the comparison between the current VMware vCenter value and the configuration template value for each instance.

At the VMware ESX host level, vSphere Host Profiles provide an automated and centrally managed mechanism for host configuration and configuration compliance, and scheduled compliance check automation can detect whether any configuration parameters differ from those specified in the host profile. vSphere Configuration Profiles extends this to the cluster level, displaying host settings with their respective desired and current values to identify the cause of noncompliance when reviewing compliance results.

Integrating VCF Operations configuration drift templates with a source control repository supports versioning, auditing, change control through reviews, and continuous integration workflows. When an organization uses this integration, accepting a deviation can be handled as a reviewed and approved commit to the configuration template, providing a documented approval trail. However, this workflow depends on the organization establishing the source control integration and review process. A supported source control solution must be used for this integration.

NSX provides a compliance report that identifies non-compliant configurations, including details such as the non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. This structured reporting helps document the specifics of each deviation and supports risk assessment by making the scope and nature of non-compliance visible.

Each VCF Operations policy can inherit settings from other policies, allowing organizations to customize and override analysis settings, alert definitions, and symptom definitions for specific object types. This provides a mechanism to document approved configuration variations at the policy level.

For changes to deployed resources, VCF Automation provides approval policies that require designated approvers to review requests before resources are consumed or changes are made to provisioned items. Approval policies can be filtered based on deployment criteria that apply to deployments and day 2 actions, and the enforcement type can be set to HARD to enforce mandatory approval before any deployment action proceeds. When multiple valid approval policies exist and the approvers are different people, all approvers are added to the approval chain. Organizations can configure these policies to require project administrator review of all changes to deployed catalog items, particularly those used by many users, to gate potentially impactful modifications. These policies gate new changes and modifications but do not directly address the review of detected configuration drift. The decision to remediate a detected deviation or accept it as an approved exception is made by the administrator outside of any formal VCF workflow.

VCF provides strong deviation detection, documentation, and change approval capabilities, but the risk assessment and formal approve/deny process for deviations depends on organizational governance layered on top of VCF's tooling.

VMware vDefend (Contributes)

VMware vDefend provides configuration validation, anomaly detection, and assessment capabilities that support the broader organizational process of managing deviations from standardized configurations. The formal approval and denial workflow for configuration changes is handled at the VCF platform level through VCF Operations and VCF Automation.

The Security Services Platform (SSP) deployment wizard conducts thorough validations before implementing any configuration changes, verifying that configurations are correct and compatible with the current environment. This pre-implementation validation step helps identify potential deviations from expected configurations before they take effect.

Rule Analysis, a feature of the Security Services Platform, identifies anomalies in firewall rule sets including duplicate rules where two rules share the same configuration and action, and shadowed or conflicting rules that may represent unintended deviations from the intended security policy. Administrators can use Rule Analysis reports to review rule anomalies and update configurations accordingly. Rule Analysis depends on configuration synchronization from NSX Manager; a failure in that synchronization is indicated by an alarm in the NSX UI, allowing administrators to detect when analysis results may not reflect current state.

Security Intelligence, part of the Security Services Platform, provides assessment and monitoring tools that help administrators evaluate their security configuration against desired baselines. The Security Segmentation Report supports two scoring modes: Strict mode applies stricter penalties for allowed unidentified traffic and provides a more stringent posture assessment, while Relaxed mode applies less severe penalties and is suited to environments where strict application rules have not yet been fully implemented. The segmentation score breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, making configuration gaps visible. Security Intelligence also tracks new configurations per configuration type on an hourly basis, providing a running count of changes across the platform.

When changes occur to group membership or policy scope, Security Intelligence displays a change-detected indicator prompting administrators to review the changes and rerun policy recommendations. Security Intelligence policy recommendations are generated from observed traffic flows and must be reviewed for accuracy before publishing to vDefend, creating a structured review step between traffic analysis and enforcement. The Security Policies view for each environment pair displays the number of unpublished recommendations, giving administrators visibility into pending configuration decisions.

The staged segmentation workflow supports a measured approach to configuration changes. Administrators can publish environment pair protection rules in a permissive mode first, allow traffic analysis to complete, and then review Security Intelligence policy recommendations before committing to enforcement rules. This staged process provides a structured mechanism for evaluating proposed configuration changes against observed traffic patterns before applying them.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) includes a Configuration Import/Export Tool that exports the complete system configuration as structured XML, covering server version, build number, local and remote site names, inventory mappings,

placeholder datastores, advanced settings, and array manager information including Storage Replication Adapter (SRA) details. The exported XML can be validated against a bundled XSD schema to confirm structural integrity, and PNR supports programmatic configuration management through the same schema framework. Organizations can use these export capabilities to capture baseline snapshots of approved configurations and compare subsequent exports against them to identify deviations.

PNR configuration files contain settings that affect the security of the environment, and incorrect settings can affect proper functioning. The system configuration is defined in the `va-configurator.xml` file and is modifiable through the Advanced Settings interface on the Site Pair tab. When PNR settings are modified, the same changes must be applied to all instances on both the protected and recovery sites to maintain consistency. This consistency requirement creates a visible signal when partial or unauthorized modifications have occurred.

Replication mappings can be tested on demand for individual mappings or all existing mappings simultaneously to validate that the current replication configuration matches expected state. After reprotect operations, PNR recommends conducting tests to confirm that the new site configuration is valid. After upgrades, protection groups and recovery plans must be verified to confirm continued operational capability. The Clean Room Orchestrator's Monitoring page shows the operational status of configurations related to recoverability and supportability, providing visibility into whether isolation environment configurations are in an expected state.

These capabilities provide the technical foundation for identifying when protection and recovery configurations deviate from established baselines. The processes for formally documenting deviations, assessing risk, and approving or denying exceptions require organizational governance outside PNR's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configuration tracking and change documentation capabilities that support the governance processes organizations use to manage deviations from standardized configurations.

The Avi Controller maintains configuration event logs that record changes made through the web interface, CLI, or REST API. Each configuration change entry displays a difference comparison of the previous configuration versus the new configuration, with additions highlighted in green and removals highlighted in red. The Config Events overlay in Service Engine Analytics correlates these configuration changes with traffic metrics, allowing administrators to determine whether a specific change caused a traffic anomaly or change in application behavior. The Avi documentation recommends that configuration changes be made through the Avi UI and verified by checking the event logs to confirm what was created or changed.

When a configuration change is made on any Controller cluster node, that change is automatically propagated to all cluster members, maintaining a consistent authoritative configuration state across the cluster. This means the event trail reflects the running configuration of the entire deployment.

For WAF policy management, Avi provides an explicit recommendation acceptance mechanism. After WAF learning mode or anomaly analysis identifies false positives in the active configuration, administrators can review proposed changes and explicitly accept or deny each recommendation. This discrete accept-or-deny step within WAF policy management provides a documented approval action for this category of configuration change.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) uses Custom Resource Definitions (CRDs) to perform syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. `RouteBackendExtension` resources include a `STATUS` field indicating whether the configuration was Accepted or Rejected, which administrators should check to identify and resolve configuration issues before they affect production traffic.

The audit trail and event records Avi generates supply the raw documentation that an organization's configuration deviation management process requires. The process itself, including defining the authoritative configuration baseline, routing proposed deviations through a risk assessment and approval workflow, and maintaining a register of approved exceptions, is an organizational governance activity that must be defined and operated by the organization outside of Avi.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.5

> Where technically feasible, for each change that deviates from the existing baseline configuration: 1.5.1. Prior to implementing any change in the production environment, test the changes in a test environment or test the changes in a production environment where the test is performed in a manner that minimizes adverse effects, that models the baseline configuration to ensure that required cyber security controls in CIP-005 and CIP-007 are not adversely affected; and 1.5.2. Document the results of the testing and, if a test environment was used, the differences between the test environment and the production environment, including a description of the measures used to account for any differences in operation between the test and production environments

SCF Controls: CFG-02.7

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's process for documenting, assessing, and approving or denying deviations from standardized configurations. These capabilities span compliance monitoring, deviation detection, change approval workflows, and source control integration, though the broader governance process of risk-assessing and formally approving deviations requires organizational procedures beyond the platform itself.

VCF Operations includes a compliance benchmarking framework that measures the settings on managed objects against a set of standard rules, regulatory best practices, or custom alert definitions. Organizations can define what constitutes their standardized configuration baseline by creating custom compliance benchmarks, which are configured through a multi-step process of naming, selecting alert definitions, and activating policies. Up to five custom compliance score cards can be created to track adherence. These score cards provide a breakdown of the total number of objects that are compliant and non-compliant for each benchmark, giving administrators a clear view of where deviations exist. The compliance score for each object is based on the most critical of the violated standards, helping administrators prioritize which deviations to address first. Custom compliance benchmarks can be exported and imported in XML format across VCF Operations instances, allowing organizations to define a standard once and reuse it consistently. The VCF security baseline can be used to evaluate both default and non-default configurations, which helps organizations identify where deployed settings differ from the expected standard. VCF documentation also acknowledges that configuration decisions should be tailored to individual customer environments rather than applying uniform standards across all customers, recognizing that legitimate deviations are expected.

When an object deviates from its assigned configuration template values, VCF Operations generates a configuration drift notification identifying the specific changes. The Configuration Drifts view shows what changed, when it changed, and how the current state compares to the desired values. The Detect Drift function detects configuration drift across all configuration templates and displays results in the Drifts table, and the Configuration Drift dashboard allows viewing and comparing drifts to identify settings that have changed. Drift details show the comparison between the current VMware vCenter value and the configuration template value for each instance.

At the VMware ESX host level, vSphere Host Profiles provide an automated and centrally managed mechanism for host configuration and configuration compliance, and scheduled compliance check automation can detect whether any configuration parameters differ from those specified in the host profile. vSphere Configuration Profiles extends this to the cluster level, displaying host settings with their respective desired and current values to identify the cause of noncompliance when reviewing compliance results.

Integrating VCF Operations configuration drift templates with a source control repository supports versioning, auditing, change control through reviews, and continuous integration workflows. When an organization uses this integration, accepting a deviation can be handled as a reviewed and approved commit to the configuration template, providing a documented approval trail. However, this workflow depends on the organization establishing the source control integration and review process. A supported source control solution must be used for this integration.

NSX provides a compliance report that identifies non-compliant configurations, including details such as the non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. This structured reporting helps document the specifics of each deviation and supports risk assessment by making the scope and nature of non-compliance visible.

Each VCF Operations policy can inherit settings from other policies, allowing organizations to customize and override analysis settings, alert definitions, and symptom definitions for specific object types. This provides a mechanism to document approved configuration variations at the policy level.

For changes to deployed resources, VCF Automation provides approval policies that require designated approvers to review requests before resources are consumed or changes are made to provisioned items. Approval policies can be filtered based on deployment criteria that apply to deployments and day 2 actions, and the enforcement type can be set to HARD to enforce mandatory approval before any deployment action proceeds. When multiple valid approval policies exist and the approvers are different people, all approvers are added to the approval chain. Organizations can configure these policies to require project administrator review of all changes to deployed catalog items, particularly those used by many users, to gate potentially impactful modifications. These policies gate new changes and modifications but do not directly address the review of detected configuration drift. The decision to remediate a detected deviation or accept it as an approved exception is made by the administrator outside of any formal VCF workflow.

VCF provides strong deviation detection, documentation, and change approval capabilities, but the risk assessment and formal approve/deny process for deviations depends on organizational governance layered on top of VCF's tooling.

VMware vDefend (Contributes)

VMware vDefend provides configuration validation, anomaly detection, and assessment capabilities that support the broader organizational process of managing deviations from standardized configurations. The formal approval and denial workflow for configuration changes is handled at the VCF platform level through VCF Operations and VCF Automation.

The Security Services Platform (SSP) deployment wizard conducts thorough validations before implementing any configuration changes, verifying that configurations are correct and compatible with the current environment. This pre-implementation validation step helps identify potential deviations from expected configurations before they take effect.

Rule Analysis, a feature of the Security Services Platform, identifies anomalies in firewall rule sets including duplicate rules where two rules share the same configuration and action, and shadowed or conflicting rules that may represent unintended deviations from the intended security policy. Administrators can use Rule Analysis reports to review rule anomalies and update configurations accordingly. Rule Analysis depends on configuration synchronization from NSX Manager; a failure in that synchronization is indicated by an alarm in the NSX UI, allowing administrators to detect when analysis results may not reflect current state.

Security Intelligence, part of the Security Services Platform, provides assessment and monitoring tools that help administrators evaluate their security configuration against desired baselines. The Security Segmentation Report supports two scoring modes: Strict mode applies stricter penalties for allowed unidentified traffic and provides a more stringent posture assessment, while Relaxed mode applies less severe penalties and is suited to environments where strict application rules have not yet been fully implemented. The segmentation score breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, making configuration gaps visible. Security Intelligence also tracks new configurations per configuration type on an hourly basis, providing a running count of changes across the platform.

When changes occur to group membership or policy scope, Security Intelligence displays a change-detected indicator prompting administrators to review the changes and rerun policy recommendations. Security Intelligence policy recommendations are generated from observed traffic flows and must be reviewed for accuracy before publishing to vDefend, creating a structured review step between traffic analysis and enforcement. The Security Policies view for each environment pair displays the number of unpublished recommendations, giving administrators visibility into pending configuration decisions.

The staged segmentation workflow supports a measured approach to configuration changes. Administrators can publish environment pair protection rules in a permissive mode first, allow traffic analysis to complete, and then review Security Intelligence policy recommendations before committing to enforcement rules. This staged process provides a structured mechanism for evaluating proposed configuration changes against observed traffic patterns before applying them.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) includes a Configuration Import/Export Tool that exports the complete system configuration as structured XML, covering server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information including Storage Replication Adapter (SRA) details. The exported XML can be validated against a bundled XSD schema to confirm structural integrity, and PNR supports programmatic configuration management through the same schema framework. Organizations can use these export capabilities to capture baseline snapshots of approved configurations and compare subsequent exports against them to identify deviations.

PNR configuration files contain settings that affect the security of the environment, and incorrect settings can affect proper functioning. The system configuration is defined in the `va-configurator.xml` file and is modifiable through the Advanced Settings interface on the Site Pair tab. When PNR settings are modified, the same changes must be applied to all instances on both the protected and recovery sites to maintain consistency. This consistency requirement creates a visible signal when partial or unauthorized modifications have occurred.

Replication mappings can be tested on demand for individual mappings or all existing mappings simultaneously to validate that the current replication configuration matches expected state. After reprotect operations, PNR recommends conducting tests to confirm that the new site configuration is valid. After upgrades, protection groups and recovery plans must be verified to confirm continued operational capability. The Clean Room Orchestrator's Monitoring page shows the operational status of configurations related to recoverability and supportability, providing visibility into whether isolation environment configurations are in an expected state.

These capabilities provide the technical foundation for identifying when protection and recovery configurations deviate from established baselines. The processes for formally documenting deviations, assessing risk, and approving or denying exceptions require organizational governance outside PNR's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configuration tracking and change documentation capabilities that support the governance processes organizations use to manage deviations from standardized configurations.

The Avi Controller maintains configuration event logs that record changes made through the web interface, CLI, or REST API. Each configuration change entry displays a difference comparison of the previous configuration versus the new configuration, with additions highlighted in green and removals highlighted in red. The Config Events overlay in Service Engine Analytics correlates these configuration changes with traffic metrics, allowing administrators to determine whether a specific change caused a traffic anomaly or change in application behavior. The Avi documentation recommends that configuration changes be made through the Avi UI and verified by checking the event logs to confirm what was created or changed.

When a configuration change is made on any Controller cluster node, that change is automatically propagated to all cluster members, maintaining a consistent authoritative configuration state across the cluster. This means the event trail reflects the running configuration of the entire deployment.

For WAF policy management, Avi provides an explicit recommendation acceptance mechanism. After WAF learning mode or anomaly analysis identifies false positives in the active configuration, administrators can review proposed changes and explicitly accept or deny each recommendation. This discrete accept-or-deny step within WAF policy management provides a documented approval action for this category of configuration change.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) uses Custom Resource Definitions (CRDs) to perform syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being

deployed. RouteBackendExtension resources include a STATUS field indicating whether the configuration was Accepted or Rejected, which administrators should check to identify and resolve configuration issues before they affect production traffic.

The audit trail and event records Avi generates supply the raw documentation that an organization's configuration deviation management process requires. The process itself, including defining the authoritative configuration baseline, routing proposed deviations through a risk assessment and approval workflow, and maintaining a register of approved exceptions, is an organizational governance activity that must be defined and operated by the organization outside of Avi.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.5.1

> Where technically feasible, for each change that deviates from the existing baseline configuration: 1.5.1. Prior to implementing any change in the production environment, test the changes in a test environment or test the changes in a production environment where the test is performed in a manner that minimizes adverse effects, that models the baseline configuration to ensure that required cyber security controls in CIP-005 and CIP-007 are not adversely affected; and

SCF Controls: CHG-02.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support testing, validating, and documenting changes in non-production environments before deploying them to production, though establishing formal non-production environments and test procedures remains an organizational responsibility.

vSphere Lifecycle Manager (vLCM) supports a draft-based workflow for managing software specifications on clusters and standalone hosts. Administrators create a draft software specification, add or modify components within the draft, and validate the draft before committing it as the desired state. The Drafts service provides a `validate_Task` method that checks whether a draft software specification is complete, whether there are any conflicts between components, and whether there are unresolved dependencies. Administrators can also check whether a draft drifts from the current state of the cluster or host before committing changes. Software specifications can be imported and edited as drafts via API. This staged approach allows proposed software changes, including host software, drivers, firmware, and add-on components, to be reviewed and validated before they take effect. vSphere Configuration Profiles provide an additional layer of periodic host configuration assessment, enabling management of the configuration of all hosts in a cluster collectively to help maintain consistency at a cluster level. vSphere Auto Deploy supports a working rule set that allows administrators to test changes to deployment rules before making them active. The `Test-DeployRuleSetCompliance PowerCLI` cmdlet tests rule set compliance for an ESX host and returns a table of current and expected configuration items, enabling verification of what changes would be applied prior to committing them.

VCF Operations governs lifecycle management for VCF components, including updates and patches. Before any update can be applied, VCF Operations requires a precheck to verify that the environment is ready for the change. This built-in gate helps keep untested changes from being applied to production infrastructure. vSphere Lifecycle Manager synchronizes to its download sources, including VCF Operations, on a regular and automatic basis, providing a controlled channel for software updates. If out-of-band changes are made directly through VMware vCenter or NSX Manager, VCF Operations can detect these changes and update its inventory accordingly, providing visibility into changes made outside the standard change control process.

VCF Automation supports iterative blueprint development with built-in versioning. Administrators can capture a snapshot of a working design before making further changes, following a minimum viable blueprint approach and adding features iteratively. The platform integrates with Git-based source control for version control, with supported systems including GitHub, Bitbucket, and Ansible, enabling Infrastructure-as-Code practices that allow teams to track, review, and roll back changes. VCF Automation also provides a blueprint validation API endpoint that accepts requests to validate cloud templates before creation, allowing proposed infrastructure changes to be checked for errors before deployment. Cloud templates can be tested for deployment viability before being released to production, and the validation process tests the connection and provides the number of released templates associated with a project. Approval policies can be layered on top of these workflows to require designated approvers to review deployment requests for catalog items before they take effect, including day 2 actions on deployed resources.

At the Consumption layer, VMware Kubernetes Service (VKS) running on vSphere Supervisor extends pre-production change validation to Kubernetes workloads. The Kubernetes API supports server-side dry-run requests, which route a proposed resource creation or modification through the full admission control and mutation chain without persisting any changes, allowing teams to verify that a configuration will pass all validating and mutating admission webhooks before it reaches production. The `kubectl diff` command shows exactly what changes would be applied to existing objects before any

modification is committed. Declarative configuration management with `kubectl apply` and version-controlled manifest files allows teams to track configuration history, review proposed changes in source control, and roll back to prior revisions. CustomResourceDefinition schemas enable schema-based validation that `kubectl` consumes client-side when processing `kubectl create` and `kubectl apply` commands against custom resources, and VKS AddonConfig resources provide configuration validation against a predefined schema before add-on installation. The VCF Consumption CLI supports named contexts that allow operators to switch between local development clusters, staging environments, and production environments without modifying configuration files, supporting the separation of test and production environments at the CLI level. Kubernetes guidance directs administrators to test admission webhooks and workloads in staging clusters that closely resemble production before minor version upgrades; vSphere Supervisor enforces pre-checks and compatibility compliance during VKS cluster updates, providing a validation gate before changes are applied. The `kubeadm` cluster management tool extends dry-run capability to cluster-level administrative operations, including node initialization and upgrade phases, by providing a `--dry-run` flag that outputs planned changes without applying them, allowing administrators to verify the impact of cluster infrastructure modifications before execution. Documentation for custom ClusterClass clusters explicitly directs customers to test and validate in non-production environments before production deployment. VKS supports GitOps workflows through the Argo CD Supervisor Service and Harness CI/CD integration, where changes to application manifests and infrastructure configuration flow through Git repositories, CI pipelines perform automated building, linting, unit testing, and image publication before changes reach the cluster, and Argo CD continuously compares the desired Git state against the live cluster state while maintaining a complete change history for rollbacks and audit review. Kubernetes Deployments also support a `kubernetes.io/change-cause` annotation, settable via `kubectl annotate` or direct manifest editing, that records the rationale for each rollout revision alongside the technical change record, providing inline change documentation within the object's history.

VCF Operations contributes through several capabilities. Its Configuration Drifts feature, accessible through Fleet Management, tracks changes in product configurations over time and allows administrators to compare current configurations against assigned desired values for vCenter instances and vSphere clusters. When drift is detected, administrators are alerted so they can investigate and remediate. The config polling interval can be adjusted to control how frequently configuration data is collected, and drift detection can be scheduled at defined intervals. Configuration templates define a desired state for infrastructure configurations and can be assigned to policies, activated or deactivated as needed. The Configuration Drifts feature can be integrated with source control repositories, enabling versioning, auditing, and management of configuration templates. This integration supports change control with reviews and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes. The product documentation recommends testing newly created configuration files against a test instance before applying them to production systems. VCF Operations also provides what-if analysis through committed scenarios, which allow administrators to model capacity changes without requiring actual deployment. This planning capability lets teams evaluate the impact of proposed changes before implementing them. Custom groups with distinct alert policies and capacity calculations allow administrators to differentiate between production and testing environments and apply appropriate operational policies to each. Policy management capabilities through the Infrastructure Operations Configurations module allow policies to be added, edited, and removed, with settings that can be inherited from existing policies and modified with appropriate permissions.

VCF includes configuration validation capabilities that examine configuration files for possible errors and conflicts before they are applied, returning output that helps administrators avoid configuration issues.

Change documentation is supported through audit logging across VCF components, which records configuration changes, the authenticated user who initiated them, and their outcomes. VCF Operations tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when. User permission changes are also tracked to capture when such changes were made and who made them. NSX audit logs record new values of configuration changes including resource type, display name, path, and unique identifier information, with metadata such as audit flags, component names, log levels, and request IDs. Role-based access control across VCF components restricts which users can initiate configuration changes. The general guidance in the product documentation is to change only one thing at a time and document each change and its result. Content Libraries

provide version tracking for VM templates, recording check-in comments, the name of the user who made each change, and the date, creating a change history for template modifications used in deployments.

While VCF provides these testing, validation, and modeling tools, the control also requires organizational processes for maintaining non-production environments that mirror production, documenting test plans and results, and establishing formal change approval workflows that require successful non-production testing before production deployment. VCF's technical capabilities support these processes but do not replace them.

VMware Private AI Services (PAIS) includes AI-specific workflows that support testing and validation before deploying changes to production. The Model Gallery workflow designates a Deep Learning VM as a sandbox environment where MLOps engineers validate ML models against the organization's security, privacy, and technical requirements. Model integrity is confirmed by checking file hash codes, scanning for malware, scanning for serialization attacks, and testing inference behavior with Triton Inference Server before the model is uploaded to the Model Gallery. Operators also examine inference requests for malicious behavior and perform hands-on functional tests as part of the sandbox evaluation. Only models that pass validation are uploaded and made available to AI application developers, establishing a gate between the validation stage and production deployment. The `vcf pais` models push command uploads validated models to a Harbor registry project, with support for custom model names, target model stores, and revision tagging.

When deploying model endpoints through PAIS, A/B testing is available to compare the performance of different embedding or completion models in real-world settings before committing to a production configuration. DevOps engineers and application developers monitor LLM completion API response at the 95th percentile, inference engine tokens-per-second generation rate, and GPU compute and memory resource allocation through observability platforms such as Grafana to identify undersized or oversized configurations before scaling to production.

Model revisions in the Model Gallery are immutable OCI artifacts identified by content digest. Each push of changed model data creates a new revision, and identical model data pushed multiple times results in only one revision being stored. The Model Gallery assigns a unique digest to each revision when the same model is pushed again, and revisions can be tagged for promotion through development and production stages. This versioned artifact storage provides an audit record of model changes and supports rollback if a newly promoted model does not perform as expected.

The broader organizational change management process for the PAIS deployment, including changes to VCF infrastructure, VMware Kubernetes Service (VKS) configurations, GPU cluster sizing, and PAIS configuration itself, requires processes and non-production test environments that extend beyond the AI model validation workflow. Testing and documenting those infrastructure-layer changes is an organizational responsibility that PAIS tooling does not directly cover.

VMware vDefend (Contributes)

VMware vDefend contributes to testing and documenting proposed changes before production deployment through its draft configuration management system for firewall policy, migration evaluation tooling, and pre-deployment validation workflows. Establishing formal non-production environments remains an organizational responsibility; vDefend provides structured workflows that allow changes to be reviewed and validated before taking effect in the production environment.

The vDefend distributed firewall supports a draft-based change workflow that separates authoring firewall rules from their enforcement. Administrators create draft configurations representing proposed changes. These drafts are saved as working configurations before being published, and the draft details view displays the required changes needed to synchronize the current firewall configuration with the draft, giving administrators visibility into the impact of proposed changes before committing them. Publishing the draft applies all visible changes to the active firewall configuration, providing a clear boundary between proposed and enforced policy states. During publishing, a new auto draft is created capturing the pre-publish configuration, which can be republished to revert to the previous state if a change produces unexpected results. In Global Manager deployments, both automatic and manual drafts follow the same rules as local Distributed Firewall drafts, extending this workflow to federated environments.

The 9.1 documentation introduces a migration tool for workload transitions from VCD to VCF Automation. Before any changes are committed, the tool runs an Evaluation phase that generates an Evaluation Plan providing upfront insight into which components will be migrated or skipped. Administrators can remediate identified issues in the source environment before

rerunning migration plan generation. The migration tool records a detailed plan capturing the previous state and new state of every rule for audit and compliance purposes. A successful rollback is confirmed when the infrastructure state in VCF Automation matches the state documented before the migration began.

The Security Services Platform deployment wizard conducts validations before implementing configuration changes to verify that configurations are correct and compatible. When upgrades are planned, conducting prechecks on all components is essential to detecting issues before proceeding. The Security Services Platform also evaluates whether workloads are protected by environment-specific segmentation policies covering Dev, Prod, and Test tiers, and the documentation recommends blocking all traffic between Testing and Production environments as an initial segmentation step, supporting isolation between non-production and production workloads. Isolating development, staging, and production environments through segmentation can reduce the risk of cross-environment contamination.

For IDS/IPS signature management, vDefend recommends exporting the existing custom signature bundle to a local system before modifying it with new signatures and uploading the revised bundle. The IDS/IPS system provides bulk edit functionality to modify signature action settings (Alert, Drop, or Reject) and operational status (Included or Excluded) across multiple pages simultaneously, enabling efficient review of signature configuration changes before deployment. The vDefend Threat Intelligence Service Portal includes a Bundle Change Log where administrators can review updates and modifications made to application IDs and IDS signatures over time, supporting documentation of signature changes as part of a change management workflow. NDR sensor upgrades include a verify upgrade-bundle command that extracts the bundle contents and verifies the bundle signature before the upgrade proceeds.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides built-in testing capabilities that allow administrators to validate disaster recovery configurations and changes before they affect production workloads, though establishing broader non-production environments and formal change management procedures remains an organizational responsibility.

Recovery plan testing is a core capability of PNR. Administrators can run a test of any recovery plan, which executes all steps in the plan except for powering down virtual machines at the protected site and forcing devices at the recovery site to assume control of replicated data. Testing has no lasting effects on either the protected or the recovery site, providing a non-production validation of the entire recovery workflow. Tests run virtual machines on a test network using a temporary snapshot of replicated data at the recovery site, so no production data is modified. Recovery plan tests can be run as often as necessary and can be cancelled at any time without impacting production replication. An optional setting (Replicate recent changes to recovery site) synchronizes the latest data to the recovery site before the test begins, so the test exercises the most current data state. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Custom recovery step scripts and commands should be tested on the Protection and Recovery Server at the recovery site before being added to a recovery plan, providing a pre-integration validation stage for recovery automation.

PNR configuration data can be exported in XML format and validated against an XSD schema, providing a structured method to verify configuration integrity before applying changes to production.

vSphere Replication supports on-demand testing of enhanced replication mappings to validate replication configuration and connectivity before those configurations are relied upon for an actual recovery event.

Cyber Recovery validation uses a snapshot validation workflow, with VMs transitioning through a preparation state before entering the validation state when a snapshot is selected and validation is initiated.

PNR includes a cleanup capability that removes test artifacts and isolates recovery environments after validation testing, so no changes persist beyond the test window.

The VCF Operations orchestrator Plug-In for PNR includes an "Initiate Test Recovery Plan" workflow, enabling integration of recovery plan testing into automated change validation pipelines.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support pre-production change validation across different types of configuration changes. These mechanisms address the technical layer of change testing, but the control requires organizational processes and a dedicated non-production environment beyond what Avi itself provides.

For environment isolation, Avi supports running test and production virtual services on separate Service Engine (SE) groups, allowing administrators to manage applications in both environments through a single controller while keeping workloads isolated. Virtual services for different environments of the same application should be deployed on different SE groups, though both can reside in the same tenant for ease of management.

For custom logic and scripting, DataScript rules must be tested and validated after modification to isolate problems without impacting other users. External health monitor scripts require manual testing for successful execution before production deployment. GSLB external health monitor custom scripts require thorough stability validation before pointing them at production servers.

For infrastructure-as-code change review, Terraform's plan phase allows administrators to see what changes will be made to the Avi Controller deployment before they are applied. VCF Automation's Assembler provides versioned, cloud-agnostic templates for Avi deployments that can be deployed consistently across environments. Ansible can be integrated with CI/CD pipelines to trigger automated Avi Controller deployments upon code changes.

For upgrade validation, Avi Controller supports dry run upgrade operations that execute pre-check validations before applying software updates, with status visibility in the UI and detailed transcript logging of all pre-check operations performed. The system report for upgrade operations records pre-check validation results including check code, description, state, start time, end time, and duration for each check. Pre- and post-upgrade object operational state verification should be performed on virtual services and pools to confirm no unintended state changes occurred during the upgrade process. Virtual service disruption must be assessed and communicated before upgrade operations proceed.

For change documentation, the Avi Load Balancer for VCF guide requires that the rollback reason and any issues encountered during a rollback procedure be documented. The Avi Controller maintains a checksum and creation timestamp for custom IPAM script files to track file integrity and provide an audit trail.

For Kubernetes operator deployments, Avi Kubernetes Operator (AKO) CRDs perform syntactical validations at the time of CRD object creation to verify configuration correctness and provide effective status messages before resources become active.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.5.2

> Where technically feasible, for each change that deviates from the existing baseline configuration: 1.5.2. Document the results of the testing and, if a test environment was used, the differences between the test environment and the production environment, including a description of the measures used to account for any differences in operation between the test and production environments

SCF Controls: CHG-02.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support testing, validating, and documenting changes in non-production environments before deploying them to production, though establishing formal non-production environments and test procedures remains an organizational responsibility.

vSphere Lifecycle Manager (vLCM) supports a draft-based workflow for managing software specifications on clusters and standalone hosts. Administrators create a draft software specification, add or modify components within the draft, and validate the draft before committing it as the desired state. The Drafts service provides a `validate_Task` method that checks whether a draft software specification is complete, whether there are any conflicts between components, and whether there are unresolved dependencies. Administrators can also check whether a draft drifts from the current state of the cluster or host before committing changes. Software specifications can be imported and edited as drafts via API. This staged approach allows proposed software changes, including host software, drivers, firmware, and add-on components, to be reviewed and validated before they take effect. vSphere Configuration Profiles provide an additional layer of periodic host configuration assessment, enabling management of the configuration of all hosts in a cluster collectively to help maintain consistency at a cluster level. vSphere Auto Deploy supports a working rule set that allows administrators to test changes to deployment rules before making them active. The `Test-DeployRuleSetCompliance PowerCLI` cmdlet tests rule set compliance for an ESX host and returns a table of current and expected configuration items, enabling verification of what changes would be applied prior to committing them.

VCF Operations governs lifecycle management for VCF components, including updates and patches. Before any update can be applied, VCF Operations requires a precheck to verify that the environment is ready for the change. This built-in gate helps keep untested changes from being applied to production infrastructure. vSphere Lifecycle Manager synchronizes to its download sources, including VCF Operations, on a regular and automatic basis, providing a controlled channel for software updates. If out-of-band changes are made directly through VMware vCenter or NSX Manager, VCF Operations can detect these changes and update its inventory accordingly, providing visibility into changes made outside the standard change control process.

VCF Automation supports iterative blueprint development with built-in versioning. Administrators can capture a snapshot of a working design before making further changes, following a minimum viable blueprint approach and adding features iteratively. The platform integrates with Git-based source control for version control, with supported systems including GitHub, Bitbucket, and Ansible, enabling Infrastructure-as-Code practices that allow teams to track, review, and roll back changes. VCF Automation also provides a blueprint validation API endpoint that accepts requests to validate cloud templates before creation, allowing proposed infrastructure changes to be checked for errors before deployment. Cloud templates can be tested for deployment viability before being released to production, and the validation process tests the connection and provides the number of released templates associated with a project. Approval policies can be layered on top of these workflows to require designated approvers to review deployment requests for catalog items before they take effect, including day 2 actions on deployed resources.

At the Consumption layer, VMware Kubernetes Service (VKS) running on vSphere Supervisor extends pre-production change validation to Kubernetes workloads. The Kubernetes API supports server-side dry-run requests, which route a proposed resource creation or modification through the full admission control and mutation chain without persisting any changes, allowing teams to verify that a configuration will pass all validating and mutating admission webhooks before it reaches production. The `kubectl diff` command shows exactly what changes would be applied to existing objects before any

modification is committed. Declarative configuration management with `kubectl apply` and version-controlled manifest files allows teams to track configuration history, review proposed changes in source control, and roll back to prior revisions. CustomResourceDefinition schemas enable schema-based validation that `kubectl` consumes client-side when processing `kubectl create` and `kubectl apply` commands against custom resources, and VKS AddonConfig resources provide configuration validation against a predefined schema before add-on installation. The VCF Consumption CLI supports named contexts that allow operators to switch between local development clusters, staging environments, and production environments without modifying configuration files, supporting the separation of test and production environments at the CLI level. Kubernetes guidance directs administrators to test admission webhooks and workloads in staging clusters that closely resemble production before minor version upgrades; vSphere Supervisor enforces pre-checks and compatibility compliance during VKS cluster updates, providing a validation gate before changes are applied. The `kubeadm` cluster management tool extends dry-run capability to cluster-level administrative operations, including node initialization and upgrade phases, by providing a `--dry-run` flag that outputs planned changes without applying them, allowing administrators to verify the impact of cluster infrastructure modifications before execution. Documentation for custom ClusterClass clusters explicitly directs customers to test and validate in non-production environments before production deployment. VKS supports GitOps workflows through the Argo CD Supervisor Service and Harness CI/CD integration, where changes to application manifests and infrastructure configuration flow through Git repositories, CI pipelines perform automated building, linting, unit testing, and image publication before changes reach the cluster, and Argo CD continuously compares the desired Git state against the live cluster state while maintaining a complete change history for rollbacks and audit review. Kubernetes Deployments also support a `kubernetes.io/change-cause` annotation, settable via `kubectl annotate` or direct manifest editing, that records the rationale for each rollout revision alongside the technical change record, providing inline change documentation within the object's history.

VCF Operations contributes through several capabilities. Its Configuration Drifts feature, accessible through Fleet Management, tracks changes in product configurations over time and allows administrators to compare current configurations against assigned desired values for vCenter instances and vSphere clusters. When drift is detected, administrators are alerted so they can investigate and remediate. The config polling interval can be adjusted to control how frequently configuration data is collected, and drift detection can be scheduled at defined intervals. Configuration templates define a desired state for infrastructure configurations and can be assigned to policies, activated or deactivated as needed. The Configuration Drifts feature can be integrated with source control repositories, enabling versioning, auditing, and management of configuration templates. This integration supports change control with reviews and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes. The product documentation recommends testing newly created configuration files against a test instance before applying them to production systems. VCF Operations also provides what-if analysis through committed scenarios, which allow administrators to model capacity changes without requiring actual deployment. This planning capability lets teams evaluate the impact of proposed changes before implementing them. Custom groups with distinct alert policies and capacity calculations allow administrators to differentiate between production and testing environments and apply appropriate operational policies to each. Policy management capabilities through the Infrastructure Operations Configurations module allow policies to be added, edited, and removed, with settings that can be inherited from existing policies and modified with appropriate permissions.

VCF includes configuration validation capabilities that examine configuration files for possible errors and conflicts before they are applied, returning output that helps administrators avoid configuration issues.

Change documentation is supported through audit logging across VCF components, which records configuration changes, the authenticated user who initiated them, and their outcomes. VCF Operations tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when. User permission changes are also tracked to capture when such changes were made and who made them. NSX audit logs record new values of configuration changes including resource type, display name, path, and unique identifier information, with metadata such as audit flags, component names, log levels, and request IDs. Role-based access control across VCF components restricts which users can initiate configuration changes. The general guidance in the product documentation is to change only one thing at a time and document each change and its result. Content Libraries

provide version tracking for VM templates, recording check-in comments, the name of the user who made each change, and the date, creating a change history for template modifications used in deployments.

While VCF provides these testing, validation, and modeling tools, the control also requires organizational processes for maintaining non-production environments that mirror production, documenting test plans and results, and establishing formal change approval workflows that require successful non-production testing before production deployment. VCF's technical capabilities support these processes but do not replace them.

VMware Private AI Services (PAIS) includes AI-specific workflows that support testing and validation before deploying changes to production. The Model Gallery workflow designates a Deep Learning VM as a sandbox environment where MLOps engineers validate ML models against the organization's security, privacy, and technical requirements. Model integrity is confirmed by checking file hash codes, scanning for malware, scanning for serialization attacks, and testing inference behavior with Triton Inference Server before the model is uploaded to the Model Gallery. Operators also examine inference requests for malicious behavior and perform hands-on functional tests as part of the sandbox evaluation. Only models that pass validation are uploaded and made available to AI application developers, establishing a gate between the validation stage and production deployment. The `vcf pais` models push command uploads validated models to a Harbor registry project, with support for custom model names, target model stores, and revision tagging.

When deploying model endpoints through PAIS, A/B testing is available to compare the performance of different embedding or completion models in real-world settings before committing to a production configuration. DevOps engineers and application developers monitor LLM completion API response at the 95th percentile, inference engine tokens-per-second generation rate, and GPU compute and memory resource allocation through observability platforms such as Grafana to identify undersized or oversized configurations before scaling to production.

Model revisions in the Model Gallery are immutable OCI artifacts identified by content digest. Each push of changed model data creates a new revision, and identical model data pushed multiple times results in only one revision being stored. The Model Gallery assigns a unique digest to each revision when the same model is pushed again, and revisions can be tagged for promotion through development and production stages. This versioned artifact storage provides an audit record of model changes and supports rollback if a newly promoted model does not perform as expected.

The broader organizational change management process for the PAIS deployment, including changes to VCF infrastructure, VMware Kubernetes Service (VKS) configurations, GPU cluster sizing, and PAIS configuration itself, requires processes and non-production test environments that extend beyond the AI model validation workflow. Testing and documenting those infrastructure-layer changes is an organizational responsibility that PAIS tooling does not directly cover.

VMware vDefend (Contributes)

VMware vDefend contributes to testing and documenting proposed changes before production deployment through its draft configuration management system for firewall policy, migration evaluation tooling, and pre-deployment validation workflows. Establishing formal non-production environments remains an organizational responsibility; vDefend provides structured workflows that allow changes to be reviewed and validated before taking effect in the production environment.

The vDefend distributed firewall supports a draft-based change workflow that separates authoring firewall rules from their enforcement. Administrators create draft configurations representing proposed changes. These drafts are saved as working configurations before being published, and the draft details view displays the required changes needed to synchronize the current firewall configuration with the draft, giving administrators visibility into the impact of proposed changes before committing them. Publishing the draft applies all visible changes to the active firewall configuration, providing a clear boundary between proposed and enforced policy states. During publishing, a new auto draft is created capturing the pre-publish configuration, which can be republished to revert to the previous state if a change produces unexpected results. In Global Manager deployments, both automatic and manual drafts follow the same rules as local Distributed Firewall drafts, extending this workflow to federated environments.

The 9.1 documentation introduces a migration tool for workload transitions from VCD to VCF Automation. Before any changes are committed, the tool runs an Evaluation phase that generates an Evaluation Plan providing upfront insight into which components will be migrated or skipped. Administrators can remediate identified issues in the source environment before

rerunning migration plan generation. The migration tool records a detailed plan capturing the previous state and new state of every rule for audit and compliance purposes. A successful rollback is confirmed when the infrastructure state in VCF Automation matches the state documented before the migration began.

The Security Services Platform deployment wizard conducts validations before implementing configuration changes to verify that configurations are correct and compatible. When upgrades are planned, conducting prechecks on all components is essential to detecting issues before proceeding. The Security Services Platform also evaluates whether workloads are protected by environment-specific segmentation policies covering Dev, Prod, and Test tiers, and the documentation recommends blocking all traffic between Testing and Production environments as an initial segmentation step, supporting isolation between non-production and production workloads. Isolating development, staging, and production environments through segmentation can reduce the risk of cross-environment contamination.

For IDS/IPS signature management, vDefend recommends exporting the existing custom signature bundle to a local system before modifying it with new signatures and uploading the revised bundle. The IDS/IPS system provides bulk edit functionality to modify signature action settings (Alert, Drop, or Reject) and operational status (Included or Excluded) across multiple pages simultaneously, enabling efficient review of signature configuration changes before deployment. The vDefend Threat Intelligence Service Portal includes a Bundle Change Log where administrators can review updates and modifications made to application IDs and IDS signatures over time, supporting documentation of signature changes as part of a change management workflow. NDR sensor upgrades include a verify upgrade-bundle command that extracts the bundle contents and verifies the bundle signature before the upgrade proceeds.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides built-in testing capabilities that allow administrators to validate disaster recovery configurations and changes before they affect production workloads, though establishing broader non-production environments and formal change management procedures remains an organizational responsibility.

Recovery plan testing is a core capability of PNR. Administrators can run a test of any recovery plan, which executes all steps in the plan except for powering down virtual machines at the protected site and forcing devices at the recovery site to assume control of replicated data. Testing has no lasting effects on either the protected or the recovery site, providing a non-production validation of the entire recovery workflow. Tests run virtual machines on a test network using a temporary snapshot of replicated data at the recovery site, so no production data is modified. Recovery plan tests can be run as often as necessary and can be cancelled at any time without impacting production replication. An optional setting (Replicate recent changes to recovery site) synchronizes the latest data to the recovery site before the test begins, so the test exercises the most current data state. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Custom recovery step scripts and commands should be tested on the Protection and Recovery Server at the recovery site before being added to a recovery plan, providing a pre-integration validation stage for recovery automation.

PNR configuration data can be exported in XML format and validated against an XSD schema, providing a structured method to verify configuration integrity before applying changes to production.

vSphere Replication supports on-demand testing of enhanced replication mappings to validate replication configuration and connectivity before those configurations are relied upon for an actual recovery event.

Cyber Recovery validation uses a snapshot validation workflow, with VMs transitioning through a preparation state before entering the validation state when a snapshot is selected and validation is initiated.

PNR includes a cleanup capability that removes test artifacts and isolates recovery environments after validation testing, so no changes persist beyond the test window.

The VCF Operations orchestrator Plug-In for PNR includes an "Initiate Test Recovery Plan" workflow, enabling integration of recovery plan testing into automated change validation pipelines.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support pre-production change validation across different types of configuration changes. These mechanisms address the technical layer of change testing, but the control requires organizational processes and a dedicated non-production environment beyond what Avi itself provides.

For environment isolation, Avi supports running test and production virtual services on separate Service Engine (SE) groups, allowing administrators to manage applications in both environments through a single controller while keeping workloads isolated. Virtual services for different environments of the same application should be deployed on different SE groups, though both can reside in the same tenant for ease of management.

For custom logic and scripting, DataScript rules must be tested and validated after modification to isolate problems without impacting other users. External health monitor scripts require manual testing for successful execution before production deployment. GSLB external health monitor custom scripts require thorough stability validation before pointing them at production servers.

For infrastructure-as-code change review, Terraform's plan phase allows administrators to see what changes will be made to the Avi Controller deployment before they are applied. VCF Automation's Assembler provides versioned, cloud-agnostic templates for Avi deployments that can be deployed consistently across environments. Ansible can be integrated with CI/CD pipelines to trigger automated Avi Controller deployments upon code changes.

For upgrade validation, Avi Controller supports dry run upgrade operations that execute pre-check validations before applying software updates, with status visibility in the UI and detailed transcript logging of all pre-check operations performed. The system report for upgrade operations records pre-check validation results including check code, description, state, start time, end time, and duration for each check. Pre- and post-upgrade object operational state verification should be performed on virtual services and pools to confirm no unintended state changes occurred during the upgrade process. Virtual service disruption must be assessed and communicated before upgrade operations proceed.

For change documentation, the Avi Load Balancer for VCF guide requires that the rollback reason and any issues encountered during a rollback procedure be documented. The Avi Controller maintains a checksum and creation timestamp for custom IPAM script files to track file integrity and provide an audit trail.

For Kubernetes operator deployments, Avi Kubernetes Operator (AKO) CRDs perform syntactical validations at the time of CRD object creation to verify configuration correctness and provide effective status messages before resources become active.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.6

> Prior to a change that deviates from the existing baseline configuration associated with baseline items in Parts 1.1.1, 1.1.2, and 1.1.5, and when the method to do so is available to the Responsible Entity from the software source: 1.6.1. Verify the identity of the software source; and 1.6.2. Verify the integrity of the software obtained from the software source.

SCF Controls: CFG-02.7

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's process for documenting, assessing, and approving or denying deviations from standardized configurations. These capabilities span compliance monitoring, deviation detection, change approval workflows, and source control integration, though the broader governance process of risk-assessing and formally approving deviations requires organizational procedures beyond the platform itself.

VCF Operations includes a compliance benchmarking framework that measures the settings on managed objects against a set of standard rules, regulatory best practices, or custom alert definitions. Organizations can define what constitutes their standardized configuration baseline by creating custom compliance benchmarks, which are configured through a multi-step process of naming, selecting alert definitions, and activating policies. Up to five custom compliance score cards can be created to track adherence. These score cards provide a breakdown of the total number of objects that are compliant and non-compliant for each benchmark, giving administrators a clear view of where deviations exist. The compliance score for each object is based on the most critical of the violated standards, helping administrators prioritize which deviations to address first. Custom compliance benchmarks can be exported and imported in XML format across VCF Operations instances, allowing organizations to define a standard once and reuse it consistently. The VCF security baseline can be used to evaluate both default and non-default configurations, which helps organizations identify where deployed settings differ from the expected standard. VCF documentation also acknowledges that configuration decisions should be tailored to individual customer environments rather than applying uniform standards across all customers, recognizing that legitimate deviations are expected.

When an object deviates from its assigned configuration template values, VCF Operations generates a configuration drift notification identifying the specific changes. The Configuration Drifts view shows what changed, when it changed, and how the current state compares to the desired values. The Detect Drift function detects configuration drift across all configuration templates and displays results in the Drifts table, and the Configuration Drift dashboard allows viewing and comparing drifts to identify settings that have changed. Drift details show the comparison between the current VMware vCenter value and the configuration template value for each instance.

At the VMware ESX host level, vSphere Host Profiles provide an automated and centrally managed mechanism for host configuration and configuration compliance, and scheduled compliance check automation can detect whether any configuration parameters differ from those specified in the host profile. vSphere Configuration Profiles extends this to the cluster level, displaying host settings with their respective desired and current values to identify the cause of noncompliance when reviewing compliance results.

Integrating VCF Operations configuration drift templates with a source control repository supports versioning, auditing, change control through reviews, and continuous integration workflows. When an organization uses this integration, accepting a deviation can be handled as a reviewed and approved commit to the configuration template, providing a documented approval trail. However, this workflow depends on the organization establishing the source control integration and review process. A supported source control solution must be used for this integration.

NSX provides a compliance report that identifies non-compliant configurations, including details such as the non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. This structured reporting helps document the specifics of each deviation and supports risk assessment by making the scope and nature of non-compliance visible.

Each VCF Operations policy can inherit settings from other policies, allowing organizations to customize and override analysis settings, alert definitions, and symptom definitions for specific object types. This provides a mechanism to document approved configuration variations at the policy level.

For changes to deployed resources, VCF Automation provides approval policies that require designated approvers to review requests before resources are consumed or changes are made to provisioned items. Approval policies can be filtered based on deployment criteria that apply to deployments and day 2 actions, and the enforcement type can be set to HARD to enforce mandatory approval before any deployment action proceeds. When multiple valid approval policies exist and the approvers are different people, all approvers are added to the approval chain. Organizations can configure these policies to require project administrator review of all changes to deployed catalog items, particularly those used by many users, to gate potentially impactful modifications. These policies gate new changes and modifications but do not directly address the review of detected configuration drift. The decision to remediate a detected deviation or accept it as an approved exception is made by the administrator outside of any formal VCF workflow.

VCF provides strong deviation detection, documentation, and change approval capabilities, but the risk assessment and formal approve/deny process for deviations depends on organizational governance layered on top of VCF's tooling.

VMware vDefend (Contributes)

VMware vDefend provides configuration validation, anomaly detection, and assessment capabilities that support the broader organizational process of managing deviations from standardized configurations. The formal approval and denial workflow for configuration changes is handled at the VCF platform level through VCF Operations and VCF Automation.

The Security Services Platform (SSP) deployment wizard conducts thorough validations before implementing any configuration changes, verifying that configurations are correct and compatible with the current environment. This pre-implementation validation step helps identify potential deviations from expected configurations before they take effect.

Rule Analysis, a feature of the Security Services Platform, identifies anomalies in firewall rule sets including duplicate rules where two rules share the same configuration and action, and shadowed or conflicting rules that may represent unintended deviations from the intended security policy. Administrators can use Rule Analysis reports to review rule anomalies and update configurations accordingly. Rule Analysis depends on configuration synchronization from NSX Manager; a failure in that synchronization is indicated by an alarm in the NSX UI, allowing administrators to detect when analysis results may not reflect current state.

Security Intelligence, part of the Security Services Platform, provides assessment and monitoring tools that help administrators evaluate their security configuration against desired baselines. The Security Segmentation Report supports two scoring modes: Strict mode applies stricter penalties for allowed unidentified traffic and provides a more stringent posture assessment, while Relaxed mode applies less severe penalties and is suited to environments where strict application rules have not yet been fully implemented. The segmentation score breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, making configuration gaps visible. Security Intelligence also tracks new configurations per configuration type on an hourly basis, providing a running count of changes across the platform.

When changes occur to group membership or policy scope, Security Intelligence displays a change-detected indicator prompting administrators to review the changes and rerun policy recommendations. Security Intelligence policy recommendations are generated from observed traffic flows and must be reviewed for accuracy before publishing to vDefend, creating a structured review step between traffic analysis and enforcement. The Security Policies view for each environment pair displays the number of unpublished recommendations, giving administrators visibility into pending configuration decisions.

The staged segmentation workflow supports a measured approach to configuration changes. Administrators can publish environment pair protection rules in a permissive mode first, allow traffic analysis to complete, and then review Security Intelligence policy recommendations before committing to enforcement rules. This staged process provides a structured mechanism for evaluating proposed configuration changes against observed traffic patterns before applying them.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) includes a Configuration Import/Export Tool that exports the complete system configuration as structured XML, covering server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information including Storage Replication Adapter (SRA) details. The exported XML can be validated against a bundled XSD schema to confirm structural integrity, and PNR supports programmatic configuration management through the same schema framework. Organizations can use these export capabilities to capture baseline snapshots of approved configurations and compare subsequent exports against them to identify deviations.

PNR configuration files contain settings that affect the security of the environment, and incorrect settings can affect proper functioning. The system configuration is defined in the `va-configurator.xml` file and is modifiable through the Advanced Settings interface on the Site Pair tab. When PNR settings are modified, the same changes must be applied to all instances on both the protected and recovery sites to maintain consistency. This consistency requirement creates a visible signal when partial or unauthorized modifications have occurred.

Replication mappings can be tested on demand for individual mappings or all existing mappings simultaneously to validate that the current replication configuration matches expected state. After reprotect operations, PNR recommends conducting tests to confirm that the new site configuration is valid. After upgrades, protection groups and recovery plans must be verified to confirm continued operational capability. The Clean Room Orchestrator's Monitoring page shows the operational status of configurations related to recoverability and supportability, providing visibility into whether isolation environment configurations are in an expected state.

These capabilities provide the technical foundation for identifying when protection and recovery configurations deviate from established baselines. The processes for formally documenting deviations, assessing risk, and approving or denying exceptions require organizational governance outside PNR's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configuration tracking and change documentation capabilities that support the governance processes organizations use to manage deviations from standardized configurations.

The Avi Controller maintains configuration event logs that record changes made through the web interface, CLI, or REST API. Each configuration change entry displays a difference comparison of the previous configuration versus the new configuration, with additions highlighted in green and removals highlighted in red. The Config Events overlay in Service Engine Analytics correlates these configuration changes with traffic metrics, allowing administrators to determine whether a specific change caused a traffic anomaly or change in application behavior. The Avi documentation recommends that configuration changes be made through the Avi UI and verified by checking the event logs to confirm what was created or changed.

When a configuration change is made on any Controller cluster node, that change is automatically propagated to all cluster members, maintaining a consistent authoritative configuration state across the cluster. This means the event trail reflects the running configuration of the entire deployment.

For WAF policy management, Avi provides an explicit recommendation acceptance mechanism. After WAF learning mode or anomaly analysis identifies false positives in the active configuration, administrators can review proposed changes and explicitly accept or deny each recommendation. This discrete accept-or-deny step within WAF policy management provides a documented approval action for this category of configuration change.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) uses Custom Resource Definitions (CRDs) to perform syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. `RouteBackendExtension` resources include a `STATUS` field indicating whether the configuration was Accepted or Rejected, which administrators should check to identify and resolve configuration issues before they affect production traffic.

The audit trail and event records Avi generates supply the raw documentation that an organization's configuration deviation management process requires. The process itself, including defining the authoritative configuration baseline, routing

proposed deviations through a risk assessment and approval workflow, and maintaining a register of approved exceptions, is an organizational governance activity that must be defined and operated by the organization outside of Avi.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.6.1

> Prior to a change that deviates from the existing baseline configuration associated with baseline items in Parts 1.1.1, 1.1.2, and 1.1.5, and when the method to do so is available to the Responsible Entity from the software source: 1.6.1. Verify the identity of the software source; and

SCF Controls: CFG-02.9

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms for tailoring baseline controls to specific operational requirements, business functions, threat profiles, and environmental conditions.

VCF includes a Security Baseline that builds on top of the platform and addresses frequently requested compliance standards, regulations, and frameworks. This security baseline can be used to evaluate both default and non-default configurations and to assist organizations in securing information systems in a compliance context. The security baseline is designed and validated to allow security configurations to be tailored without impacting VCF's ability to meet its design objectives. Organizations can select from the benchmarks and regulatory frameworks available under VCF based on their specific needs. For environments with specific regulatory requirements, Broadcom also provides DISA Security Technical Implementation Guides (STIGs), which contain detailed instructions on how to secure and configure operating systems, applications, and network devices. DISA Security Requirements Guides (SRGs) outline security requirements for specific technology platforms, providing additional tailoring guidance for regulated environments.

VCF Operations provides a policy framework with built-in inheritance and override capabilities that directly supports baseline tailoring. Baseline policies ship as starting points for creating new policies, and all settings from a base policy are inherited as default settings in a new policy. The policy workspace allows administrators to select base policies and override settings across multiple dimensions, including metrics and properties, alerts and symptoms, capacity, compliance, workload automation, and groups and objects. Each policy can inherit settings from other policies, and administrators can customize and override analysis settings, alert definitions, and symptom definitions for specific object types. Override policies can be selected to overwrite specific settings in the base policy according to service level agreement requirements, and additional policy settings can be applied to specific object types. Custom policies can be created from default or predefined policies and scoped to a specific environment, allowing organizations to maintain a standard baseline while applying targeted adjustments for different workload types or business functions.

VCF Operations also supports custom compliance benchmarks that monitor the alert definitions and policies selected during benchmark creation, allowing organizations to define compliance criteria tailored to their specific mission or business requirements. The VCF 9 Security Baseline is a consolidated out-of-the-box benchmark available in VCF Operations for evaluating environment security and compliance. A compliance threshold can be configured in the Compliance workspace when creating operational policies, giving administrators control over acceptable deviation from baseline settings. Organizations can also activate regulatory benchmark compliance packs and enable specific compliance pack policies to assess objects against installed regulatory benchmarks.

VCF Automation provides a separate policy layer where policies are evaluated, ranked, and merged to produce an effective policy. The highest-ranking policy becomes the baseline, the second-level policy is applied on top of it, and subsequent policies are applied in descending rank order. Deployment criteria narrow the scope of policy application so that policies apply only to deployments where the criteria are true, allowing organizations to define policies scoped to specific deployment characteristics. Day 2 action policies can also be narrowed to particular aspects of deployments. This ranked, scoped approach allows organizations to adapt controls for different mission functions or operational conditions without modifying the underlying baseline.

The Consumption layer within VCF, provided through VMware Kubernetes Service (VKS) and the vSphere Supervisor platform, extends baseline tailoring to containerized workloads. Pod Security Admission (PSA) is the primary baseline tailoring mechanism at the Kubernetes layer, defining three cumulative Pod Security Standard profiles that are applied independently

per namespace: Privileged (no restrictions), Baseline (blocks known privilege escalations while maintaining compatibility with standard containerized workloads), and Restricted (adds controls that limit volume types and require security context settings such as dropping all capabilities and running as a non-root user). Each profile can be activated in three independent modes per namespace: enforce (blocks non-conforming pods at admission), warn (issues admission warnings without blocking), and audit (records policy violations in the audit log). These modes can be configured independently per namespace. A common tailoring pattern is to set enforce to Baseline and audit and warn to Restricted, providing a security floor that blocks known privilege escalations while surfacing workloads that would fail a stricter posture without disrupting operations. Administrators apply these settings through namespace labels such as `pod-security.kubernetes.io/enforce: restricted` for namespaces hosting sensitive workloads, or `pod-security.kubernetes.io/enforce: baseline` for namespaces running infrastructure components that require elevated permissions.

VKS ClusterClass configurations support tailoring at cluster provisioning time through the `podSecurityStandard` ClusterClass variable, which sets default PSA enforcement, warn, and audit levels for all namespaces in a cluster. Different cluster classes can be defined with different default security postures, enabling mission-specific or environment-specific cluster configurations. The VCF Services Consumption interface provides VKS Cluster Management Security Policies with built-in templates including a Baseline template, and supports custom templates as well. Administrators can author custom templates in VCF Automation to tune individual security context fields within the pod spec for specialized requirements, and custom policies can be modified or removed as operational needs evolve to keep governance logic aligned with current security requirements.

Kubernetes ValidatingAdmissionPolicy, built on the Common Expression Language (CEL), allows administrators to define custom admission rules that enforce organization-specific requirements beyond the standard PSA profiles. These policies can check field values, labels, annotations, and resource attributes, and bind to specific resource types or namespaces to address requirements specific to a particular mission, regulatory scope, or threat profile. Kustomize overlays provide a declarative configuration management mechanism for applying targeted customizations on top of base Kubernetes resource definitions, maintaining environment-specific adjustments between development, staging, and production environments without modifying base manifests. Security contexts at the pod and container level allow individual workloads to be configured with specific user IDs, dropped capabilities, and read-only root filesystems, providing workload-level tailoring that complements namespace-level PSA controls.

For infrastructure patch management, VCF supports both fixed and dynamic patch baselines. Fixed baselines contain only specifically selected patches, while dynamic baselines update their patch data based on administrator-defined criteria each time new patches are downloaded. Patch baselines can be attached to individual objects or to container objects such as folders, hosts, clusters, and data centers, allowing administrators to tailor patch application scope to match organizational structure and operational requirements. vSphere Lifecycle Manager further classifies baselines as predefined, recommendation, or custom depending on how they are created and managed. Predefined baselines cannot be edited or deleted; administrators can only attach or detach them to inventory objects, which preserves the integrity of vendor-supplied baseline definitions. Custom baselines can be combined with predefined baselines to form baseline groups, which allow administrators to scan and remediate inventory objects against multiple baselines simultaneously. Security administrators can also create user-defined security baselines that define a set of security standards and compare hosts and virtual machines against those baselines to identify and address deviations. Access to baseline creation and management is governed by the VMware vSphere Lifecycle Manager Manage Baseline privilege.

VMware vDefend (Contributes)

VMware vDefend provides mechanisms for tailoring network security baselines to match specific mission functions, operational environments, threat conditions, and business requirements. The Distributed Firewall organizes security policies into pre-defined categories: Infrastructure, Environment, and Application. Hierarchical rule precedence is enforced in that order, from highest to lowest, so that global infrastructure policies take precedence over environment-specific rules, which in turn take precedence over application-tier controls. Enforcement scope can be set at the rule level; when the policy-level Applied-To setting remains at its default of DFW, the system honors the specific applied-to settings for each individual rule, enabling targeting of security controls to particular workloads or segments.

In 9.1, vDefend introduces a persona-based multi-tenant security model that enables role-differentiated baseline tailoring. A Provider Admin manages global resources and high-precedence rules in the /infra space, while a Project Admin orchestrates security within a project. Security profiles are pre-defined and created per Project, with each Security Strategy representing a collection of policies and rules applied at the project level. Project Admins can select a pre-defined high-level security posture that applies Secure by Default principles, reducing the need to manually configure individual firewall rules for each new VPC. The operational scope available to a Project Admin differs significantly depending on whether they are interacting with a shared or dedicated VPC, allowing the platform to adapt to different tenancy and operational environments.

For organizations operating across multiple sites or regions, vDefend supports federated policy management through the Global Manager and Local Manager architecture. Distributed Firewall policies can be scoped to specific regions, with each Local Manager automatically added as a region. Customized regions can be created for selective policy application, establishing a consistent global security baseline while preserving the ability to apply site-specific configuration on top.

The Security Services Platform extends baseline tailoring through its segmentation planning and recommendation capabilities. Microsegmentation proceeds in two phases: application ring-fencing to define cross-application controls, followed by application-tier segmentation to establish controls within individual applications across tiers such as web, application, and database. Workloads are associated to applications and application tiers to implement these controls, and application-level prioritization overrides group-level settings for fine-grained adjustment. When an existing Distributed Firewall rule that contains Layer 7 context profiles is modified, those profiles are retained in the modified rule, preserving application-aware controls through policy updates. The rule analysis dashboard allows administrators to identify and update the anchor rule based on observed anomaly types, adjusting security posture to address specific threat conditions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support customizing database platform controls to meet specific operational and organizational requirements.

The primary tailoring mechanism in DSM is the data service policy. Administrators can create and assign data service policies that define what resources users can consume, what database options are permitted, and what backup schedules apply. Data service policies apply to MySQL, PostgreSQL, and SQL Server databases, allowing administrators to enforce different standards across different teams or workloads. Policies can be assigned to one or more namespaces or namespace labels, enabling administrators to scope controls to specific tenants or deployment contexts. When multiple policies are assigned to a namespace, DSM aggregates them by applying the more restrictive policy, so the most restrictive assigned policy determines the effective baseline.

Within data service policies, administrators control the degree of customization available to end users through three settings: "Allow Custom Database Options" permits users to add any database parameters; "Allow with a List" creates an allowlist of approved parameters users can select from, restricting self-service to options vetted for the environment; and "Disallow Custom Database Options" fully restricts users from adding any database parameters, enforcing a tighter baseline for sensitive namespaces.

Infrastructure policies complement data service policies by creating guardrails on resource consumption. These policies restrict the quality and quantity of compute and storage resources that DSM users can consume from vSphere clusters, enforcing resource boundaries appropriate to each team's operational context. Infrastructure policy bindings are namespace-scoped via the InfrastructurePolicyBinding resource, allowing different namespaces to receive different infrastructure constraints. Infrastructure policies that are actively used by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added.

DSM supports runtime adjustment of database VM resource configuration after initial provisioning, with administrators selecting from predefined VM classes for vCPU and memory combinations. When a new database is created through cloning, restoring from on-demand backups, or establishing a secondary instance, the new database automatically inherits the configured database options and host-based access configuration of the source database, propagating the established baseline to derived databases.

For operational monitoring, DSM allows administrators and users to configure alert threshold values for CPU Health, Data Disk Health, System Disk Health, and Maximum Connections, with separate thresholds for warning and critical conditions. These thresholds can be adjusted to reflect the specific performance expectations and risk tolerance of each deployment.

The baseline tailoring decisions themselves, including determining which control profiles apply to which business functions, assessing threats and vulnerabilities to inform control selection, and documenting tailoring decisions, remain organizational responsibilities that fall outside DSM's scope. DSM provides the technical mechanisms to implement and enforce tailored configurations once those decisions have been made.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that allow its application delivery security baseline to be specialized and customized for specific operational contexts.

At the virtual service level, Avi supports per-virtual-service policy sets that govern traffic handling at Layers 4 and 7. Layer 4 Policy Sets are organized hierarchically within a connection policy, with rules that match on Layer 3 and Layer 4 fields such as client IP address and port. Individual rules within a policy set can be selectively enabled or disabled, allowing operators to apply only the traffic control policies appropriate to a given application or environment. Policy sets are associated with specific virtual services and are configurable through both the Controller UI and CLI, with match conditions including client IP and port defined at rule creation.

The Web Application Firewall (WAF) policy includes Application Rules that provide targeted protection for specific application types and threat profiles. WAF Application Rules can be tuned so that the protections applied reflect the specific risk profile of the application being protected. This allows administrators to build a differentiated security baseline for different application workloads rather than applying a single uniform ruleset across all virtual services.

Application profiles are configurable objects that attach to virtual services and define HTTP processing behavior, including per-profile compression parameters. Avi exposes all advanced configuration settings for editing after a virtual service is created, allowing profiles to be adjusted as operational requirements evolve. Service Engine Group settings can also be customized per requirement when creating a new Service Engine Group, providing control over data-plane behavior for specific workloads or environments.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) deployment can be customized using the AddonConfig resource, a Supervisor namespace-scoped resource that allows modification of configuration parameters such as log level and shard virtual service size to change default behaviors. This enables per-namespace tailoring of load balancing behavior for Kubernetes workloads within VCF.

For user and account security, Avi allows administrators to create custom user account profiles with thresholds for password history and account security policies that differ from the default profile. The Avi Controller also supports granular role-based access controls (RBAC) at the field level, enabling administrators to define roles with write access restricted to specific sub-resources within objects. This supports tailoring administrative permissions to specific mission or operational requirements.

ControlScripts provide a mechanism for automated responses to system events, including altering Avi configuration dynamically based on health scores or triggering actions in external systems such as VMware vCenter. Alert Actions trigger ControlScripts in response to system events, enabling automated remediation actions rather than manual administrator intervention. This supports tailored responses to operational conditions that could affect mission success.

In organization-managed mode within VCF deployments, a provider administrator can adjust the service units limit for each organization, enabling resource allocation to be specialized per organizational unit.

Avi's contribution to this control applies specifically to the application delivery layer. The broader platform baseline management infrastructure, including hypervisor and infrastructure baselines, is owned by VCF, and a complete baseline tailoring program also requires organizational governance processes that determine what tailoring actions are appropriate for each mission or business function.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 1.6.2

> Prior to a change that deviates from the existing baseline configuration associated with baseline items in Parts 1.1.1, 1.1.2, and 1.1.5, and when the method to do so is available to the Responsible Entity from the software source: 1.6.2. Verify the integrity of the software obtained from the software source.

SCF Controls: CFG-02.9

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms for tailoring baseline controls to specific operational requirements, business functions, threat profiles, and environmental conditions.

VCF includes a Security Baseline that builds on top of the platform and addresses frequently requested compliance standards, regulations, and frameworks. This security baseline can be used to evaluate both default and non-default configurations and to assist organizations in securing information systems in a compliance context. The security baseline is designed and validated to allow security configurations to be tailored without impacting VCF's ability to meet its design objectives. Organizations can select from the benchmarks and regulatory frameworks available under VCF based on their specific needs. For environments with specific regulatory requirements, Broadcom also provides DISA Security Technical Implementation Guides (STIGs), which contain detailed instructions on how to secure and configure operating systems, applications, and network devices. DISA Security Requirements Guides (SRGs) outline security requirements for specific technology platforms, providing additional tailoring guidance for regulated environments.

VCF Operations provides a policy framework with built-in inheritance and override capabilities that directly supports baseline tailoring. Baseline policies ship as starting points for creating new policies, and all settings from a base policy are inherited as default settings in a new policy. The policy workspace allows administrators to select base policies and override settings across multiple dimensions, including metrics and properties, alerts and symptoms, capacity, compliance, workload automation, and groups and objects. Each policy can inherit settings from other policies, and administrators can customize and override analysis settings, alert definitions, and symptom definitions for specific object types. Override policies can be selected to overwrite specific settings in the base policy according to service level agreement requirements, and additional policy settings can be applied to specific object types. Custom policies can be created from default or predefined policies and scoped to a specific environment, allowing organizations to maintain a standard baseline while applying targeted adjustments for different workload types or business functions.

VCF Operations also supports custom compliance benchmarks that monitor the alert definitions and policies selected during benchmark creation, allowing organizations to define compliance criteria tailored to their specific mission or business requirements. The VCF 9 Security Baseline is a consolidated out-of-the-box benchmark available in VCF Operations for evaluating environment security and compliance. A compliance threshold can be configured in the Compliance workspace when creating operational policies, giving administrators control over acceptable deviation from baseline settings. Organizations can also activate regulatory benchmark compliance packs and enable specific compliance pack policies to assess objects against installed regulatory benchmarks.

VCF Automation provides a separate policy layer where policies are evaluated, ranked, and merged to produce an effective policy. The highest-ranking policy becomes the baseline, the second-level policy is applied on top of it, and subsequent policies are applied in descending rank order. Deployment criteria narrow the scope of policy application so that policies apply only to deployments where the criteria are true, allowing organizations to define policies scoped to specific deployment characteristics. Day 2 action policies can also be narrowed to particular aspects of deployments. This ranked, scoped approach allows organizations to adapt controls for different mission functions or operational conditions without modifying the underlying baseline.

The Consumption layer within VCF, provided through VMware Kubernetes Service (VKS) and the vSphere Supervisor platform, extends baseline tailoring to containerized workloads. Pod Security Admission (PSA) is the primary baseline tailoring mechanism at the Kubernetes layer, defining three cumulative Pod Security Standard profiles that are applied independently

per namespace: Privileged (no restrictions), Baseline (blocks known privilege escalations while maintaining compatibility with standard containerized workloads), and Restricted (adds controls that limit volume types and require security context settings such as dropping all capabilities and running as a non-root user). Each profile can be activated in three independent modes per namespace: enforce (blocks non-conforming pods at admission), warn (issues admission warnings without blocking), and audit (records policy violations in the audit log). These modes can be configured independently per namespace. A common tailoring pattern is to set enforce to Baseline and audit and warn to Restricted, providing a security floor that blocks known privilege escalations while surfacing workloads that would fail a stricter posture without disrupting operations. Administrators apply these settings through namespace labels such as `pod-security.kubernetes.io/enforce: restricted` for namespaces hosting sensitive workloads, or `pod-security.kubernetes.io/enforce: baseline` for namespaces running infrastructure components that require elevated permissions.

VKS ClusterClass configurations support tailoring at cluster provisioning time through the `podSecurityStandard` ClusterClass variable, which sets default PSA enforcement, warn, and audit levels for all namespaces in a cluster. Different cluster classes can be defined with different default security postures, enabling mission-specific or environment-specific cluster configurations. The VCF Services Consumption interface provides VKS Cluster Management Security Policies with built-in templates including a Baseline template, and supports custom templates as well. Administrators can author custom templates in VCF Automation to tune individual security context fields within the pod spec for specialized requirements, and custom policies can be modified or removed as operational needs evolve to keep governance logic aligned with current security requirements.

Kubernetes ValidatingAdmissionPolicy, built on the Common Expression Language (CEL), allows administrators to define custom admission rules that enforce organization-specific requirements beyond the standard PSA profiles. These policies can check field values, labels, annotations, and resource attributes, and bind to specific resource types or namespaces to address requirements specific to a particular mission, regulatory scope, or threat profile. Kustomize overlays provide a declarative configuration management mechanism for applying targeted customizations on top of base Kubernetes resource definitions, maintaining environment-specific adjustments between development, staging, and production environments without modifying base manifests. Security contexts at the pod and container level allow individual workloads to be configured with specific user IDs, dropped capabilities, and read-only root filesystems, providing workload-level tailoring that complements namespace-level PSA controls.

For infrastructure patch management, VCF supports both fixed and dynamic patch baselines. Fixed baselines contain only specifically selected patches, while dynamic baselines update their patch data based on administrator-defined criteria each time new patches are downloaded. Patch baselines can be attached to individual objects or to container objects such as folders, hosts, clusters, and data centers, allowing administrators to tailor patch application scope to match organizational structure and operational requirements. vSphere Lifecycle Manager further classifies baselines as predefined, recommendation, or custom depending on how they are created and managed. Predefined baselines cannot be edited or deleted; administrators can only attach or detach them to inventory objects, which preserves the integrity of vendor-supplied baseline definitions. Custom baselines can be combined with predefined baselines to form baseline groups, which allow administrators to scan and remediate inventory objects against multiple baselines simultaneously. Security administrators can also create user-defined security baselines that define a set of security standards and compare hosts and virtual machines against those baselines to identify and address deviations. Access to baseline creation and management is governed by the VMware vSphere Lifecycle Manager Manage Baseline privilege.

VMware vDefend (Contributes)

VMware vDefend provides mechanisms for tailoring network security baselines to match specific mission functions, operational environments, threat conditions, and business requirements. The Distributed Firewall organizes security policies into pre-defined categories: Infrastructure, Environment, and Application. Hierarchical rule precedence is enforced in that order, from highest to lowest, so that global infrastructure policies take precedence over environment-specific rules, which in turn take precedence over application-tier controls. Enforcement scope can be set at the rule level; when the policy-level Applied-To setting remains at its default of DFW, the system honors the specific applied-to settings for each individual rule, enabling targeting of security controls to particular workloads or segments.

In 9.1, vDefend introduces a persona-based multi-tenant security model that enables role-differentiated baseline tailoring. A Provider Admin manages global resources and high-precedence rules in the /infra space, while a Project Admin orchestrates security within a project. Security profiles are pre-defined and created per Project, with each Security Strategy representing a collection of policies and rules applied at the project level. Project Admins can select a pre-defined high-level security posture that applies Secure by Default principles, reducing the need to manually configure individual firewall rules for each new VPC. The operational scope available to a Project Admin differs significantly depending on whether they are interacting with a shared or dedicated VPC, allowing the platform to adapt to different tenancy and operational environments.

For organizations operating across multiple sites or regions, vDefend supports federated policy management through the Global Manager and Local Manager architecture. Distributed Firewall policies can be scoped to specific regions, with each Local Manager automatically added as a region. Customized regions can be created for selective policy application, establishing a consistent global security baseline while preserving the ability to apply site-specific configuration on top.

The Security Services Platform extends baseline tailoring through its segmentation planning and recommendation capabilities. Microsegmentation proceeds in two phases: application ring-fencing to define cross-application controls, followed by application-tier segmentation to establish controls within individual applications across tiers such as web, application, and database. Workloads are associated to applications and application tiers to implement these controls, and application-level prioritization overrides group-level settings for fine-grained adjustment. When an existing Distributed Firewall rule that contains Layer 7 context profiles is modified, those profiles are retained in the modified rule, preserving application-aware controls through policy updates. The rule analysis dashboard allows administrators to identify and update the anchor rule based on observed anomaly types, adjusting security posture to address specific threat conditions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support customizing database platform controls to meet specific operational and organizational requirements.

The primary tailoring mechanism in DSM is the data service policy. Administrators can create and assign data service policies that define what resources users can consume, what database options are permitted, and what backup schedules apply. Data service policies apply to MySQL, PostgreSQL, and SQL Server databases, allowing administrators to enforce different standards across different teams or workloads. Policies can be assigned to one or more namespaces or namespace labels, enabling administrators to scope controls to specific tenants or deployment contexts. When multiple policies are assigned to a namespace, DSM aggregates them by applying the more restrictive policy, so the most restrictive assigned policy determines the effective baseline.

Within data service policies, administrators control the degree of customization available to end users through three settings: "Allow Custom Database Options" permits users to add any database parameters; "Allow with a List" creates an allowlist of approved parameters users can select from, restricting self-service to options vetted for the environment; and "Disallow Custom Database Options" fully restricts users from adding any database parameters, enforcing a tighter baseline for sensitive namespaces.

Infrastructure policies complement data service policies by creating guardrails on resource consumption. These policies restrict the quality and quantity of compute and storage resources that DSM users can consume from vSphere clusters, enforcing resource boundaries appropriate to each team's operational context. Infrastructure policy bindings are namespace-scoped via the InfrastructurePolicyBinding resource, allowing different namespaces to receive different infrastructure constraints. Infrastructure policies that are actively used by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added.

DSM supports runtime adjustment of database VM resource configuration after initial provisioning, with administrators selecting from predefined VM classes for vCPU and memory combinations. When a new database is created through cloning, restoring from on-demand backups, or establishing a secondary instance, the new database automatically inherits the configured database options and host-based access configuration of the source database, propagating the established baseline to derived databases.

For operational monitoring, DSM allows administrators and users to configure alert threshold values for CPU Health, Data Disk Health, System Disk Health, and Maximum Connections, with separate thresholds for warning and critical conditions. These thresholds can be adjusted to reflect the specific performance expectations and risk tolerance of each deployment.

The baseline tailoring decisions themselves, including determining which control profiles apply to which business functions, assessing threats and vulnerabilities to inform control selection, and documenting tailoring decisions, remain organizational responsibilities that fall outside DSM's scope. DSM provides the technical mechanisms to implement and enforce tailored configurations once those decisions have been made.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that allow its application delivery security baseline to be specialized and customized for specific operational contexts.

At the virtual service level, Avi supports per-virtual-service policy sets that govern traffic handling at Layers 4 and 7. Layer 4 Policy Sets are organized hierarchically within a connection policy, with rules that match on Layer 3 and Layer 4 fields such as client IP address and port. Individual rules within a policy set can be selectively enabled or disabled, allowing operators to apply only the traffic control policies appropriate to a given application or environment. Policy sets are associated with specific virtual services and are configurable through both the Controller UI and CLI, with match conditions including client IP and port defined at rule creation.

The Web Application Firewall (WAF) policy includes Application Rules that provide targeted protection for specific application types and threat profiles. WAF Application Rules can be tuned so that the protections applied reflect the specific risk profile of the application being protected. This allows administrators to build a differentiated security baseline for different application workloads rather than applying a single uniform ruleset across all virtual services.

Application profiles are configurable objects that attach to virtual services and define HTTP processing behavior, including per-profile compression parameters. Avi exposes all advanced configuration settings for editing after a virtual service is created, allowing profiles to be adjusted as operational requirements evolve. Service Engine Group settings can also be customized per requirement when creating a new Service Engine Group, providing control over data-plane behavior for specific workloads or environments.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) deployment can be customized using the AddonConfig resource, a Supervisor namespace-scoped resource that allows modification of configuration parameters such as log level and shard virtual service size to change default behaviors. This enables per-namespace tailoring of load balancing behavior for Kubernetes workloads within VCF.

For user and account security, Avi allows administrators to create custom user account profiles with thresholds for password history and account security policies that differ from the default profile. The Avi Controller also supports granular role-based access controls (RBAC) at the field level, enabling administrators to define roles with write access restricted to specific sub-resources within objects. This supports tailoring administrative permissions to specific mission or operational requirements.

ControlScripts provide a mechanism for automated responses to system events, including altering Avi configuration dynamically based on health scores or triggering actions in external systems such as VMware vCenter. Alert Actions trigger ControlScripts in response to system events, enabling automated remediation actions rather than manual administrator intervention. This supports tailored responses to operational conditions that could affect mission success.

In organization-managed mode within VCF deployments, a provider administrator can adjust the service units limit for each organization, enabling resource allocation to be specialized per organizational unit.

Avi's contribution to this control applies specifically to the application delivery layer. The broader platform baseline management infrastructure, including hypervisor and infrastructure baselines, is owned by VCF, and a complete baseline tailoring program also requires organizational governance processes that determine what tailoring actions are appropriate for each mission or business function.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-010-4 2.1

> Monitor at least once every 35 calendar days for changes to the baseline configuration (as described in Requirement R1, Part 1.1). Document and investigate detected unauthorized changes.

SCF Controls: CFG-02, CFG-02.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control CIP-010-4 3.1

> At least once every 15 calendar months, conduct a paper or active vulnerability assessment.

SCF Controls: VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-010-4 3.2.1

> Where technically feasible, at least once every 36 calendar months: 3.2.1 Perform an active vulnerability assessment in a test environment, or perform an active vulnerability assessment in a production environment where the test is performed in a manner that minimizes adverse effects, that models the baseline configuration of the BES Cyber System in a production environment; and 3.2.2 Document the results of the testing and, if a test environment was used, the differences between the test environment and the production environment, including a description of the measures used to account for any differences in operation between the test and production environments.

SCF Controls: VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the

management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan

results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-010-4 3.2.2

> Where technically feasible, at least once every 36 calendar months: 3.2.1 Perform an active vulnerability assessment in a test environment, or perform an active vulnerability assessment in a production environment where the test is performed in a manner that minimizes adverse effects, that models the baseline configuration of the BES Cyber System in a production environment; and 3.2.2 Document the results of the testing and, if a test environment was used, the differences between the test environment and the production environment, including a description of the measures used to account for any differences in operation between the test and production environments.

SCF Controls: VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the

management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan

results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-010-4 3.3

> Prior to adding a new applicable Cyber Asset to a production environment, perform an active vulnerability assessment of the new Cyber Asset, except for CIP Exceptional Circumstances and like replacements of the same type of Cyber Asset with a baseline configuration that models an existing baseline configuration of the previous or other existing Cyber Asset.

SCF Controls: VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-010-4 3.4

> Document the results of the assessments conducted according to Parts 3.1, 3.2, and 3.3 and the action plan to remediate or mitigate vulnerabilities identified in the assessments including the planned date of completing the action plan and the execution status of any remediation or mitigation action items.

SCF Controls: VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's inventoryfaultconfig setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-011-3 1.1

> Method(s) to identify BCSI.

SCF Controls: AST-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The `SimpleClient` sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. `ResourceAttribute` elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-011-3 1.2

> Method(s) to protect and securely handle BCSI to mitigate risks of compromising confidentiality.

SCF Controls: AST-01, AST-01.1, DCH-01, END-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security

zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports

additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control CIP-011-3 2.1

> Prior to the release for reuse of applicable Cyber Assets that contain BCSI (except for reuse within other systems identified in the “Applicable Systems” column), the Responsible Entity shall take action to prevent the unauthorized retrieval of BCSI from the Cyber Asset data storage media.

SCF Controls: DCH-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support media sanitization workflows for virtualized infrastructure, though the full control requires organizational procedures for physical media handling, verification, and documentation.

Encryption-based cryptographic erasure

VCF supports encryption of virtual machine disk (VMDK) files, where data in an encrypted VMDK is never written in cleartext to storage or transmitted in cleartext over the network. For storage environments using vSAN data-at-rest encryption or VM Encryption, cryptographic erasure is available as a sanitization method: destroying the encryption keys associated with the storage renders the encrypted data unrecoverable without requiring block-level overwriting. This approach is recognized by industry-standard best practices as an acceptable sanitization technique for encrypted media. Administrators configure VM encryption through VMware vCenter and the key management infrastructure, which supports both KMIP-compatible external Key Management Servers and vSphere Native Key Provider.

The vSphere Web Services API provides `removeKey` and `removeKeys` methods for programmatic removal of cryptographic keys by ID, each with an optional `force` parameter. The `force` option is intended for cases where a key has been compromised or expired, removing it from use across the environment. These API methods support automated key destruction workflows as part of a cryptographic erasure process. On VMware ESX hosts, calling `removeKey` without the `force` option deletes the key from the host's key cache and renders any encrypted virtual machine using that key unusable, because ESX hosts do not track which keys are in use.

The No Cryptography Administrator role separates cryptographic privileges from routine administrative operations. This role includes all Administrator privileges except Cryptographic Operations, and it can be cloned to create custom roles with only specific cryptographic privileges. This separation helps restrict who can modify encryption settings or remove keys during media lifecycle activities.

vSAN disk sanitization features

vSAN includes a disk wipe capability for securely wiping storage devices. Before wiping ineligible disks, administrators must check the partition table and verify the data stored on those disks. When encryption is enabled on an existing vSAN cluster, the “Erase disks before use” option wipes existing data from storage devices as they are brought into encrypted disk groups. Devices added to a vSAN disk group that contain residual data or partition information must be cleaned before they can be claimed, providing a built-in sanitization step during device onboarding. vSAN also supports re-encrypting all data using new keys through a rolling disk reformat, which generates a new Key Encryption Key and new Data Encryption Keys.

ESX host configuration protection

ESX stores its configuration data in encrypted form on boot devices. When a Trusted Platform Module (TPM) 2.0 is available, encryption keys can be persisted in the TPM across reboots using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter. This means host decommissioning can include clearing the TPM to render the stored configuration unrecoverable.

Orphaned disk identification and reclamation

VCF Operations provides capabilities for identifying orphaned virtual disks, defined as VMDKs on datastores that are not connected to any registered virtual machines and have not been modified during a defined period. Administrators can configure a reporting threshold that sets the minimum number of days before unattached VMDKs are flagged as orphaned.

The Reclaim Resources feature allows execution of resource reclamation processes, and administrators should verify the accuracy of reported orphaned disks before performing reclamation. A Reclaimable Orphaned Disks metric displays potential savings from removing orphaned VMDKs across all datastores. Identifying and removing orphaned disks that may contain residual sensitive data is a relevant step in the media sanitization lifecycle.

Datastore removal and virtual disk controls

When a VMFS datastore is destroyed via the RemoveDatastore API, the partitions that compose the VMFS volume are removed and the datastore becomes unavailable to all ESX systems after a rescan. Datastore resignaturing is irreversible because it overwrites the original VMFS UUID. These operations provide mechanisms for decommissioning storage volumes as part of a media reuse or disposal workflow. The delete operation for a VMFS datastore permanently deletes all files associated with virtual machines on the datastore. Before initiating deletion, Storage DRS and Storage I/O Control should be disabled for the datastore to prevent automated storage management processes from interfering with the deletion workflow.

VCF also provides the `isolation.tools.diskWiper.disable` setting, which controls whether guest operating systems can issue virtual disk wiper operations. In hardened environments, this setting is typically configured to restrict disk wiper access, giving administrators centralized control over disk sanitization activities rather than allowing individual virtual machines to initiate wipe operations.

Protecting sensitive data in operational files

Backup files for VCF Operations, VMware vCenter, and NSX are encrypted using AES-256-CBC encryption with SHA256 message digest. After file-based restore operations, administrators are directed to securely delete decrypted backup files and control access to them during the restore process.

Core dumps on vCenter systems are not encrypted and can contain memory contents that include credentials, encryption keys, or other sensitive data. Administrators should consider disabling core dumps on vCenter systems to restrict sensitive information from persisting in diagnostic files. Managing the lifecycle of these operational files is part of a complete media sanitization program.

VCF does not include dedicated media sanitization workflow tools, inventory tracking for media disposal, or chain-of-custody documentation capabilities. These organizational processes, along with physical media destruction procedures and verification of sanitization effectiveness, must be addressed through enterprise asset management and data governance programs outside of VCF.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-011-3 2.2

> Prior to the disposal of applicable Cyber Assets that contain BCSI, the Responsible Entity shall take action to prevent the unauthorized retrieval of BCSI from the Cyber Asset or destroy the data storage media.

SCF Controls: AST-30

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-011-3 R1

> Each Responsible Entity shall implement one or more documented information protection program(s) for BES Cyber System Information (BCSI) pertaining to “Applicable Systems” identified in CIP-011-3 Table R1 – Information Protection Program that collectively includes each of the applicable requirement parts in CIP-011-3 Table R1 – Information Protection Program. [Violation Risk Factor: Medium] [Time Horizon: Operations Planning].

SCF Controls: AST-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-013-2 1.1

> One or more process(es) used in planning for the procurement of BES Cyber Systems and their associated EACMS and PACS to identify and assess cyber security risk(s) to the Bulk Electric System from vendor products or services resulting from: (i) procuring and installing vendor equipment and software; and (ii) transitions from one vendor(s) to another vendor(s).

SCF Controls: RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-013-2 1.2.1

> One or more process(es) used in procuring BES Cyber Systems, and their associated EACMS and PACS, that address the following, as applicable: 1.2.1. Notification by the vendor of vendor-identified incidents related to the products or services provided to the Responsible Entity that pose cyber security risk to the Responsible Entity;

SCF Controls: TPM-05.1, TPM-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-013-2 1.2.2

> One or more process(es) used in procuring BES Cyber Systems, and their associated EACMS and PACS, that address the following, as applicable: 1.2.2. Coordination of responses to vendor-identified incidents related to the products or services provided to the Responsible Entity that pose cyber security risk to the Responsible Entity;

SCF Controls: IRO-10.4, TPM-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-013-2 1.2.3

> One or more process(es) used in procuring BES Cyber Systems, and their associated EACMS and PACS, that address the following, as applicable: 1.2.3. Notification by vendors when remote or onsite access should no longer be granted to vendor representatives;

SCF Controls: IAC-20.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms for revoking logical access authorizations across its component products, though full compliance with this control also requires organizational processes governing when and how revocation occurs.

VCF Automation includes dedicated access token revocation capabilities. Administrators can revoke access tokens for individual users through the Administration access control settings, navigating to a specific user's access control page to view and revoke their active tokens at any time. When a user's access needs to be suspended rather than permanently removed, VCF Automation supports disabling the user account, which blocks access while preserving the account for potential reactivation later. Provider account access can also be revoked and accounts deleted through administrative controls. Deactivating the provider consumption organization feature flag blocks access to that organization through the UI and the Provider Management API without deleting the underlying organization data.

For service accounts, VCF uses API access tokens that rotate after each use. Access tokens have a default lifetime of one hour and are derived from a refresh token that lasts 90 days. The refresh token can be revoked before its expiration and optionally rotated with each access token request, giving administrators control over the window of valid access for automated integrations.

At the VMware vCenter layer, the AuthorizationManager provides programmatic methods for modifying and removing access authorizations. RemoveAuthorizationRole allows deletion of defined roles, and SetEntityPermissions allows administrators to reassign or clear permissions on specific inventory objects. The ResetEntityPermissions method replaces existing permissions with a new set of permissions on vSphere inventory objects, providing a bulk permission replacement capability. AuthorizationManager enforces role-based access control across vSphere components, restricting access to server objects based on the permissions associated with each object. System administrators with the Manage General ACL right in VCF Automation can also create, modify, and remove specific access control lists through the accessControls API, providing another path for revoking granular permissions.

NSX enforces access restrictions on objects owned by principal identities. Users without the Enterprise Administrator role cannot modify or delete protected objects, while Enterprise Administrators retain the ability to modify or delete those objects when access changes are required. This layered ownership model provides a controlled mechanism for adjusting access to network configuration objects.

Because authentication is centralized through VCF SSO, disabling or removing a user's identity source account effectively revokes access across all VCF components simultaneously. When an authentication source needs to be fully decommissioned, deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes all provisioned users and groups associated with it. When resetting VCF SSO to change the identity provider, provisioned users and groups must be removed and then reassigned required service roles in each component. These mechanisms provide broad revocation capabilities for scenarios such as identity provider migrations or environment decommissioning.

For Kubernetes workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, revocation operates at multiple layers of the access model. At the namespace level, permissions control which users can self-provision namespaces through kubectl, with the Administrator role as the default when permissions are unset. Users with the Namespaces.Edit privilege on a user-created Namespace folder can perform create, patch, update, delete, watch, get, and list operations on Kubernetes API resources.

Within VKS clusters, the primary revocation mechanism for user access is deletion of RBAC binding objects. Removing a RoleBinding takes effect immediately for new API requests within the specific namespace; removing a ClusterRoleBinding revokes access across the entire cluster. Because Kubernetes RBAC authorization is evaluated at request time against the current state of the authorization store, there is no delay between removing a binding and its effect on subsequent requests. Administrators should avoid assigning users to the system:masters group, as membership bypasses all RBAC rights checks and cannot be restricted or revoked through standard RBAC mechanisms; access should instead be granted through named roles and bindings that can be individually removed.

Service account access within VKS clusters is revoked by deleting the ServiceAccount object or its associated token Secrets. ServiceAccount tokens can also be explicitly revoked through the Kubernetes API, and a token's validity can optionally be bound to the lifetime of a specific API object, causing it to become invalid automatically when that object is deleted. Short-lived bound tokens issued via the TokenRequest API expire automatically without requiring explicit revocation; however, TokenRequest API tokens are not suited for user authentication because no revocation method exists for them. Kubernetes RBAC should be used to enforce least-privilege access to Secret objects, limiting the data a service account can reach after credentials are injected into containers running in a namespace.

Authentication for Supervisor namespaces integrates with VCF SSO via OIDC. When a user is removed from the identity provider, new authentication requests fail at the VCF SSO layer. OIDC tokens carry a finite lifetime and the API server may cache authentication state, creating a window between identity provider deprovisioning and complete access termination; administrators should account for this in deprovisioning procedures. Minimizing the number of active authentication mechanisms in a cluster further reduces the paths through which a user might retain access after being deprovisioned from the primary identity source.

Within individual virtual machines, VCF SSO user mappings to guest operating system accounts can be removed, revoking VCF SSO-authenticated access to specific guest accounts without affecting the user's broader platform permissions.

For virtual machine access to physical devices, VMware ESX allows administrators to revoke device access by removing the associated virtual device from the VM configuration. This applies to USB, storage, optical disc drives, virtual GPU, and PCI passthrough devices that have been granted to a guest. ESX also allows administrators to deactivate shell access for individual users. When shell access is deactivated for a user with administrative privileges, that user can no longer grant shell access to other users or modify the passwords of users who have shell access.

Role-based access control across vCenter, ESX, NSX, and VCF Operations supports granular permission removal at each layer. When vCenter permissions change, VCF Operations refreshes those permissions at fixed intervals defined in its auth.properties configuration, or users can log out and back in to pick up changes immediately. This cross-component RBAC model, combined with the centralized VCF SSO revocation path, allows administrators to revoke access at multiple levels of granularity depending on the situation.

VMware Private AI Services (PAIS) gates access to its endpoints through OIDC group-based authorization. The Private AI Services configuration includes an `authorizedGroups` setting that names the OIDC groups permitted to reach PAIS in a given organization namespace, with example group names such as `group-for-pais-access-01` and `group-for-pais-access-02`. Removing a user from a configured group in the external OIDC identity provider revokes that user's access at the next authentication or token refresh, because PAIS validates group membership against the groups claim in the access token. The OIDC integration is configured with an issuer URL, the `pais-authentication-id` client ID, and the `openid`, `groups`, and `offline\_access` scopes. PAIS requires the OIDC provider to be registered as a public client application with Authorization Code and Refresh Token grant types, and it supports configurable Extra Audiences and a configurable groups claim name to align with the OIDC provider's token format. Activation requires coordination with the OIDC provider administrator.

PAIS exposes several revocation surfaces for non-interactive access as well. Model endpoints deployed through PAIS use a `harbor-pull-secret-readonly` credential to pull container images from the private Harbor registry, and rotating or deleting this secret revokes the endpoint's ability to pull new images. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and linked data sources and can be revoked individually. Remote Model Context Protocol (MCP) servers connected to PAIS can optionally use static authentication tokens that can be rotated to revoke access.

Passwords entered through the Private AI Services Quickstart, including the private container registry password and proxy password, are saved as VCF Automation secrets, where they can be rotated or deleted.

Platform identity store management and tenant detachment are handled outside PAIS. VCF SSO governs identity for the surrounding VCF platform, and detaching a VMware vCenter from VCF Automation requires verifying that the associated identity provider has been deleted on the vCenter Identity Providers page. PAIS does not manage identities or group membership directly; primary revocation occurs in the organizational OIDC provider and in the VCF identity layer. The control also covers physical access authorization revocation, which is handled outside the platform.

VMware vDefend (Contributes)

VMware vDefend contributes to access authorization revocation through network-level controls that can immediately restrict or terminate connectivity for users and workloads, complementing the identity and credential revocation mechanisms provided by other VCF components.

vDefend (DFW) and Gateway Firewall (GFW) policies can be updated to deny network access to specific workloads, IP addresses, or network segments. Because firewall rules are enforced at the vNIC level (Distributed Firewall) and at tier-0/tier-1 gateways (Gateway Firewall), changes take effect immediately across the fabric without requiring affected workloads to be restarted or reconfigured. Administrators revoking access can add deny rules or remove allow rules to cut off network connectivity for a user, application, or workload. Security Intelligence supports this by allowing administrators to modify allow actions to deny, effectively enforcing microsegmentation as part of the revocation process. Organization Admin ownership of firewall rules restricts project members from accessing rule modifications, adding a governance layer over the revocation mechanism itself.

vDefend Identity Firewall (IDFW) provides identity-based network access control by integrating with Active Directory. IDFW maps users to IP addresses to enable identity-based filtering and access control, and applies security policies to virtual machines based on dynamic name-based criteria combined with Active Directory group membership of logged-in users. When an AD administrator modifies or removes a user's group membership, AD administrators should force a logout so that Identity Firewall rule changes take effect and reflect current group membership. Identity Firewall rules enforce context-aware access control by matching AD group membership to network traffic, including blocking SSH access for specific user groups. In Remote Desktop Session Host (RDSH) environments, administrators create Active Directory security groups to allow or deny users access to application servers based on their assigned role, making revocation as straightforward as modifying the relevant AD group.

Security Services Platform (SSP) supports deletion of remote user and remote user group role assignments when LDAP is configured as an authentication provider, providing a mechanism for revoking management-plane access to vDefend capabilities. SSP implements Role-Based Access Control (RBAC) to limit system access based on user roles so that only authorized users can perform specific actions within the platform, including the License Hub.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the revocation of logical access to database services. The platform exposes user management capabilities through its administrator interface that allow authorized administrators to remove access at multiple levels.

The primary revocation mechanism for local users is account deletion. Deleting a user from DSM revokes their access to the system. The revocation process involves an additional step before deletion: the administrator must first reset the user's password, which immediately blocks continued access, and then delegate management of any databases owned by that user to a different account. This sequenced process is available through the user management interface, where DSM administrators can edit role assignments and namespace access for existing local users, and delete those users entirely. The initial DSM administrator account created during deployment of the Provider Appliance is mandatory and cannot be deleted, which is a constraint on full access revocation at the administrator tier.

For local user accounts, DSM includes a `force_password_change` flag that administrators can configure. This flag can be used as part of an access review workflow to require immediate credential rotation before full account removal, reducing the window of access for a user whose authorization is being revoked.

When DSM is integrated with a directory service via LDAPS, the directory becomes the authoritative source for user identity. Disabling or removing an account in the connected directory restricts access accordingly. Reconfiguring the LDAPS server or group in DSM may also result in loss of access for users not registered with the new configuration. At the individual database level, DSM supports enabling or disabling directory service authentication per database, which allows administrators to restrict authentication for specific databases independently of the global directory configuration.

At the database privilege layer, DSM manages privilege assignments for provisioned databases. For MySQL, DSM revokes create and update privileges on objects in the `mysql.system` schema for database users, establishing a least-privilege baseline. MySQL users created with LDAPS authentication can also be granted specific privileges using the GRANT command to restrict access to designated databases. For SQL Server, DSM assigns the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative rights, and an internal management login (`dsm_mgmt`) restricts users from accessing or modifying system-level objects. These privilege assignments are managed by the platform rather than requiring manual revocation by administrators.

Physical access revocation is outside the scope of DSM, as it is a software platform that operates on top of the vSphere infrastructure layer. Full compliance with this control requires organizational processes for managing the lifecycle of access authorizations, including timely removal of directory accounts when users leave or change roles, and procedural enforcement of the multi-step local user deletion workflow.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports logical access revocation through several mechanisms within its management and data planes.

For local administrator accounts, access can be revoked by deleting the account or removing the user's role assignments through the Avi Controller UI or REST API. The Controller can also be configured to restrict access for any user who does not have a defined role, so that removing a user's role assignment is sufficient to revoke access without deleting the account. The superuser flag on Controller accounts can be disabled to immediately reduce a user's privileges across all tenants and roles. For administrators using password-less SSH-based login, a dedicated REST API endpoint allows targeted deletion of individual SSH public keys, supporting revocation of specific credentials without affecting the account as a whole.

The Avi Controller system administrator can create temporary tokens for users that grant access for a limited duration. These tokens automatically expire at the configured time, revoking access without requiring explicit deletion. This provides a time-bounded access mechanism suitable for temporary or delegated access scenarios.

Granular role-based access control allows app owners to remove specific object labels from a resource, discontinuing access for other users scoped to that object. The Avi License Hub provides an additional administrative path for access revocation: it allows deletion of all current user role assignments to remove an identity source.

When Avi is integrated with an external identity provider via LDAP, SAML, or OAuth/OIDC, access is governed through Auth Mapping Profiles that bind user group memberships to Avi roles and tenants. Revoking access in these configurations requires removing the user from the relevant group in the external directory; the Auth Mapping Profile then rejects their access on the next authentication attempt. Auth Mapping rules can also be updated directly to deny privileges to specific users, preventing them from obtaining any roles or tenants upon login. The Controller Access Policy provides configurable authentication and authorization fields to define and enforce these mappings. Basic Authentication can be deactivated when no longer required, narrowing available authentication pathways.

At the data-plane level, the Controller automatically revokes secure channel credentials for all Service Engines when the Controller cluster enters manual recovery state. This provides a mechanism to invalidate data-plane trust relationships as part of incident response or planned recovery operations.

One architectural consideration applies to client-facing JWT authentication. JWTs used in OAuth/OIDC flows are designed as portable, decoupled identities that cannot be revoked at the authorization server level once issued. Organizations using JWT-based client authentication should configure short token expiry windows to limit exposure from tokens that cannot be individually recalled. Avi provides a configuration API for defining JWT authorization policies under the `ssopolicy:authorization_policy:authz_rules` path, allowing fine-grained control over which tokens can access specific resources.

Physical access revocation is outside Avi's scope; that capability rests with VCF platform controls and organizational physical security processes.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CIP-013-2 1.2.4

> One or more process(es) used in procuring BES Cyber Systems, and their associated EACMS and PACS, that address the following, as applicable: 1.2.4. Disclosure by vendors of known vulnerabilities related to the products or services provided to the Responsible Entity;

SCF Controls: TDA-02.11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-013-2 1.2.5

> One or more process(es) used in procuring BES Cyber Systems, and their associated EACMS and PACS, that address the following, as applicable: 1.2.5. Verification of software integrity and authenticity of all software and patches provided by the vendor for use in the BES Cyber System and their associated EACMS and PACS; and

SCF Controls: TPM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-013-2 1.2.6

> One or more process(es) used in procuring BES Cyber Systems, and their associated EACMS and PACS, that address the following, as applicable: 1.2.6. Coordination of controls for vendor-initiated remote access

SCF Controls: TPM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-013-2 R1

> Each Responsible Entity shall develop one or more documented supply chain cyber security risk management plan(s) for high and medium impact BES Cyber Systems and their associated Electronic Access Control or Monitoring Systems (EACMS) and Physical Access Control Systems (PACS). The plan(s) shall include: [Violation Risk Factor: Medium] [Time Horizon: Operations Planning]

SCF Controls: RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-013-2 R2

> Each Responsible Entity shall implement its supply chain cyber security risk management plan(s) specified in Requirement R1. [Violation Risk Factor: Medium] [Time Horizon: Operations Planning]

SCF Controls: RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CIP-013-2 R3

> Each Responsible Entity shall review and obtain CIP Senior Manager or delegate approval of its supply chain cyber security risk management plan(s) specified in Requirement R1 at least once every 15 calendar months. [Violation Risk Factor: Medium]
[Time Horizon: Operations Planning]

SCF Controls: RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

